



CompTIA

CertyIQ

Premium exam material

Get certification quickly with the CertyIQ Premium exam material.

Everything you need to prepare, learn & pass your certification exam easily. Lifetime free updates

First attempt guaranteed success.

<https://www.CertyIQ.com>

About CertyIQ

We here at CertyIQ eventually got enough of the industry's greedy exam paid for. Our team of IT professionals comes with years of experience in the IT industry Prior to training CertyIQ we worked in test areas where we observed the horrors of the paywall exam preparation system.

The misuse of the preparation system has left our team disillusioned. And for that reason, we decided it was time to make a difference. We had to make In this way, CertyIQ was created to provide quality materials without stealing from everyday people who are trying to make a living.

Doubt Support

We have developed a very scalable solution using which we are able to solve 400+ doubts every single day with an average rating of 4.8 out of 5.

<https://www.certyiq.com>

[Mail us on - certyiqofficial@gmail.com](mailto:certyiqofficial@gmail.com)



Lifetime Free Updates

We provide lifetime free updates to our customers. To make life easier for our valued customers and fulfill their needs



Free Exam PDF

You are sure to pass the exam completely free of charge



Money Back Guarantee

We Provide 100% money back guarantee to our customer in case of any failure

John

October 19, 2022



Thanks you so much for your help. I scored 972 in my exam today. More than 90% were from your PDFs!

Dana

September 04, 2022



Thanks a lot for this updated AZ-900 Q&A. I just passed my exam and got 974, I followed both of your Az-900 videos and the 6 PDF, the PDFs are very much valid, all answers are correct. Could you please create a similar video/PDF for DP900, your content/PDF's is really awesome. The team did a really good job. Thank You 😊.

Ahamed Shibly

2 months ago



Customer support is really fast and helpful, I just finished my exam and this video along with the 6 PDF helped me pass! Definitely recommend getting the PDFs. Thank you!

October 22, 2022



Passed my exam today with 891 marks. Out of 52 questions, 51 were from certyiq PDFs including Contoso case study. Thank You certyiq team!

Henry Rome

2 months ago



These questions are real and 100 % valid. Thank you so much for your efforts, also your 4 PDFs are awesome, I passed the DP900 exam on 1 Sept. With 968 marks. Thanks a lot, buddy!

Esmaria

2 months ago



Simple easy to understand explanations. To anyone out there wanting to write AZ900, I highly recommend 6 PDF's. Thank you so much, appreciate all your hard work in having such great content. Passed my exam Today - 3 September with 942 score.

Google

(Professional Cloud Security Engineer)

Professional Cloud Security Engineer

Total: **326 Questions**

Link: <https://certyiq.com/papers/google/professional-cloud-security-engineer>

Question: 1

Your team needs to make sure that a Compute Engine instance does not have access to the internet or to any Google APIs or services.

Which two settings must remain disabled to meet these requirements? (Choose two.)

- A. Public IP
- B. IP Forwarding
- C. Private Google Access
- D. Static routes
- E. IAM Network User Role

Answer: AC

Explanation:

The correct answer is A and C. To prevent a Compute Engine instance from accessing the internet or Google APIs/services, both a public IP address and Private Google Access must be disabled. A public IP address, assigned directly to the instance, allows it to communicate directly with the internet. Disabling this prevents any outbound connections to external networks. Private Google Access, when enabled, allows instances without public IPs to communicate with Google APIs and services, using a private IP address within the VPC network. By disabling this feature, we block that channel of communication. IP Forwarding (B) enables instances to act as routers, which is irrelevant to internet connectivity for the instance itself. Static routes (D) direct traffic but don't inherently grant internet access. The IAM Network User Role (E) controls who can use the network, not whether the instance has connectivity. Therefore, disabling both public IP addresses and Private Google Access are the two crucial settings to achieve complete network isolation for the Compute Engine instance. This isolates the instance from the internet and Google services, thus fulfilling the stated security requirements.

Relevant links:

Google Cloud VPC Overview: <https://cloud.google.com/vpc/docs/vpc>

Compute Engine Instance IP Addresses: <https://cloud.google.com/compute/docs/ip>

Private Google Access: <https://cloud.google.com/vpc/docs/private-access>

Question: 2

Which two implied firewall rules are defined on a VPC network? (Choose two.)

- A. A rule that allows all outbound connections
- B. A rule that denies all inbound connections
- C. A rule that blocks all inbound port 25 connections
- D. A rule that blocks all outbound connections
- E. A rule that allows all inbound port 80 connections

Answer: AB

Explanation:

The correct answer is A and B. Google Cloud Virtual Private Cloud (VPC) networks have implied firewall rules that govern network traffic when no explicit firewall rules are defined. By default, a VPC network allows all outbound connections. This means virtual machine instances within the network can initiate connections to any destination, both within and outside the network, as long as the target endpoint is reachable. This is a fundamental aspect of a VPC's default behavior. The other implied rule is that all inbound connections are

denied. This security posture ensures that by default, no external source can initiate a connection to instances within the VPC. This design principle adheres to the least privilege principle, limiting exposure. To permit specific inbound connections, explicit firewall rules must be configured, whitelisting desired source IP addresses and protocols. Choices C, D, and E are incorrect. There is no implied rule blocking only port 25 connections (C) or all outbound connections (D). Option E, which suggests all inbound port 80 traffic is allowed, is also wrong as all inbound traffic is blocked by default. Thus, the only default and implied rules are to allow all outbound connections and to block all inbound connections.[Google Cloud VPC Firewall Overview](#)

Question: 3

CertyIQ

A customer needs an alternative to storing their plain text secrets in their source-code management (SCM) system.

How should the customer achieve this using Google Cloud Platform?

- A. Use Cloud Source Repositories, and store secrets in Cloud SQL.
- B. Encrypt the secrets with a Customer-Managed Encryption Key (CMEK), and store them in Cloud Storage.
- C. Run the Cloud Data Loss Prevention API to scan the secrets, and store them in Cloud SQL.
- D. Deploy the SCM to a Compute Engine VM with local SSDs, and enable preemptible VMs.

Answer: B

Explanation:

Option B is the most appropriate solution for securely managing secrets outside of source code. Storing secrets directly in source code, especially plain text, is a significant security risk. Option B leverages two core Google Cloud Platform (GCP) services: Customer-Managed Encryption Keys (CMEK) and Cloud Storage. CMEK allows the customer to control the encryption keys used to protect their data, ensuring that only authorized users can decrypt the secrets. By encrypting the secrets before storing them, the risk of exposure is significantly reduced. Cloud Storage provides a secure and scalable storage solution for the encrypted secrets. This approach adheres to best practices in security by not storing secrets in version control and utilizing encryption at rest. Options A, C, and D are not suitable solutions for secret management. Option A uses Cloud SQL for storing secrets which doesn't offer suitable encryption-at-rest capabilities for secrets. Option C, while using Cloud DLP which can identify secrets, doesn't actually provide a solution for storing them securely. Option D proposes to use local SSDs and preemptible VMs which is both highly unreliable and complex, and therefore unsuitable for production environments. Therefore, option B offers the most secure and practical approach.

Relevant links:

CMEK: <https://cloud.google.com/kms/docs/cmek>

Cloud Storage Security: <https://cloud.google.com/storage/docs/security>

Secret Management Best Practices: <https://cloud.google.com/security/best-practices/secret-management>

Question: 4

CertyIQ

Your team wants to centrally manage GCP IAM permissions from their on-premises Active Directory Service. Your team wants to manage permissions by AD group membership.

What should your team do to meet these requirements?

- A. Set up Cloud Directory Sync to sync groups, and set IAM permissions on the groups.
- B. Set up SAML 2.0 Single Sign-On (SSO), and assign IAM permissions to the groups.
- C. Use the Cloud Identity and Access Management API to create groups and IAM permissions from Active

Directory.

D. Use the Admin SDK to create groups and assign IAM permissions from Active Directory.

Answer: A

Explanation:

The correct answer is A: Set up Cloud Directory Sync to sync groups, and set IAM permissions on the groups. Here's why:

Cloud Directory Sync (formerly known as Google Cloud Directory Sync or GCDS) is specifically designed to synchronize user and group data from on-premises directories, like Active Directory, to Google Cloud Identity. This directly addresses the requirement of centrally managing IAM permissions from Active Directory. By syncing AD groups to Cloud Identity, you can then assign GCP IAM roles directly to those synced groups. This approach allows for centralized management because changes in Active Directory group membership are automatically reflected in Google Cloud, updating access privileges accordingly. SAML 2.0 SSO (option B) focuses on authentication and doesn't manage group synchronization needed for central authorization using AD groups. Using APIs (options C and D) might allow group creation, but it doesn't provide the essential, ongoing synchronization that Cloud Directory Sync offers for consistent permission management. Cloud Directory Sync avoids the need for custom scripting and facilitates a more manageable and automated system. This solution leverages existing directory structure for seamless integration with Google Cloud IAM.

Authoritative links for further research:

Cloud Directory Sync Documentation: <https://support.google.com/a/answer/106368?hl=en>

Managing access using groups: <https://cloud.google.com/iam/docs/manage-access-groups>

Overview of Cloud Identity: <https://cloud.google.com/identity/docs/overview>

Question: 5

CertyIQ

When creating a secure container image, which two items should you incorporate into the build if possible? (Choose two.)

- A. Ensure that the app does not run as PID 1.
- B. Package a single app as a container.
- C. Remove any unnecessary tools not needed by the app.
- D. Use public container images as a base image for the app.
- E. Use many container image layers to hide sensitive information.

Answer: BC

Explanation:

The correct answer is **B and C**. Here's why:

B. Package a single app as a container: This aligns with the principle of microservices and the single responsibility principle in containerization. A single container should ideally host only one application, making it easier to manage, scale, and secure. This reduces the attack surface, as a vulnerability in one service won't automatically compromise others in different containers. This approach also facilitates better resource management and faster deployment cycles.

C. Remove any unnecessary tools not needed by the app: Including extraneous tools increases the image size, adding to the potential attack surface. These unneeded utilities could harbor vulnerabilities or be exploited by malicious actors. Reducing the image to the bare minimum required for the application's operation is crucial for improving the container's security and performance. This principle is known as "least

privilege" applied to container images, where the container is given only the required resources.

Why other options are incorrect:

A. Ensure that the app does not run as PID 1: While container security best practices do suggest avoiding running applications as PID 1, it's not a feature inherent to the image build process. It's a runtime configuration concern handled by the container orchestration system.

D. Use public container images as a base image for the app: Public images can be a good starting point, but using them directly without proper vetting can introduce vulnerabilities into your system. It's better to start from a minimal base image or build one from scratch.

E. Use many container image layers to hide sensitive information: Layers in Docker images aren't designed for security through obscurity. Each layer is accessible and can be inspected. Sensitive information should be handled through secure environment variables or secrets management outside the image itself.

Supporting Links:

Docker Security Best Practices: <https://docs.docker.com/develop/security/>

Google Cloud Security Best Practices for Containers: <https://cloud.google.com/security/best-practices/container-security>

OWASP Container Security Cheat Sheet:
https://cheatsheetseries.owasp.org/cheatsheets/Container_Security_Cheat_Sheet.html

By adhering to these best practices, you create more secure and efficient container images that reduce the risk of vulnerabilities and malicious attacks.

Question: 6

CertyIQ

A customer needs to launch a 3-tier internal web application on Google Cloud Platform (GCP). The customer's internal compliance requirements dictate that end-user access may only be allowed if the traffic seems to originate from a specific known good CIDR. The customer accepts the risk that their application will only have SYN flood DDoS protection. They want to use GCP's native SYN flood protection. Which product should be used to meet these requirements?

- A. Cloud Armor
- B. VPC Firewall Rules
- C. Cloud Identity and Access Management
- D. Cloud CDN

Answer: A

Explanation:

Here's a detailed justification for choosing Cloud Armor over other options, based on the scenario:

The core requirement is to restrict end-user access to a web application based on source IP CIDR ranges while utilizing GCP's native SYN flood protection. Cloud Armor is the most appropriate choice because it's designed for precisely this purpose – implementing web application firewalls (WAF) and advanced security policies at the edge of Google's network. Cloud Armor allows you to define rules based on source IP ranges, ensuring that only traffic originating from authorized networks can reach your application. Furthermore, it provides native SYN flood protection, fulfilling the customer's requirement for this specific DDoS mitigation.

VPC Firewall Rules, while effective for controlling network traffic within a VPC, operate at the network layer (Layer 3/4) and do not provide the same granular filtering capabilities at the application layer (Layer 7) required for web application security. They also don't inherently offer SYN flood protection; while some basic traffic control is possible, it's not the primary focus. Cloud Identity and Access Management (IAM) is focused

on managing user permissions and access to GCP resources, not on filtering network traffic. Cloud CDN is a content delivery network designed to accelerate content delivery to end-users, not for implementing access control lists (ACLs) based on source IPs or providing SYN flood protection for origin servers.

In summary, Cloud Armor is the only option that directly addresses both the source IP restriction and SYN flood protection requirements, making it the optimal choice for this specific scenario. It acts as a perimeter security layer for the web application, enabling the enforcement of detailed access policies.

Authoritative links for further research:

Google Cloud Armor documentation: <https://cloud.google.com/armor/docs>

Google Cloud VPC Firewall rules documentation: <https://cloud.google.com/vpc/docs/firewalls>

Google Cloud IAM documentation: <https://cloud.google.com/iam/docs>

Google Cloud CDN documentation: <https://cloud.google.com/cdn/docs>

Question: 7

CertyIQ

A company is running workloads in a dedicated server room. They must only be accessed from within the private company network. You need to connect to these workloads from Compute Engine instances within a Google Cloud Platform project.

Which two approaches can you take to meet the requirements? (Choose two.)

- A. Configure the project with Cloud VPN.
- B. Configure the project with Shared VPC.
- C. Configure the project with Cloud Interconnect.
- D. Configure the project with VPC peering.
- E. Configure all Compute Engine instances with Private Access.

Answer: AC

Explanation:

Here's a breakdown of why options A and C are the correct approaches, and why the others are not:

Correct Options:

A. Configure the project with Cloud VPN: Cloud VPN creates an encrypted tunnel between your on-premises network and your Google Cloud VPC. This allows Compute Engine instances within your project to securely communicate with resources in your dedicated server room over the internet, but with the traffic being protected. The connection is established through public IP addresses, however the traffic is encapsulated within the IPsec tunnel.

Concept: Site-to-Site VPN, Secure Connectivity

Link: [Cloud VPN Documentation](#)

C. Configure the project with Cloud Interconnect: Cloud Interconnect provides a direct, private connection between your on-premises network and Google Cloud. This offers lower latency, higher bandwidth, and greater reliability compared to Cloud VPN. It's a dedicated physical connection. With Cloud Interconnect, Compute Engine instances can connect to your server room without traversing the public internet, maintaining network isolation and enhanced performance.

Concept: Dedicated Private Connectivity, Network Performance

Link: [Cloud Interconnect Documentation](#)

Incorrect Options:

B. Configure the project with Shared VPC: Shared VPC allows multiple projects to access resources in a common VPC network within an organization. While it can manage internal network access, it does not extend connectivity to an external on-premises server room. Shared VPC is for projects within the same Google Cloud organization.

D. Configure the project with VPC peering: VPC peering connects two VPC networks within Google Cloud. It does not establish connections with an on-premises server room or external networks. It is designed for internal communications between VPC networks within Google.

E. Configure all Compute Engine instances with Private Access: Private Access, which can either be Private Google Access or Private Service Access, enables instances without external IP addresses to reach Google APIs and services. It does not provide connectivity to private on-premises networks. It primarily handles connectivity to Google's internal services.

Justification Summary: The requirement is to connect Compute Engine instances in a Google Cloud project to a dedicated server room on a private network. Both Cloud VPN and Cloud Interconnect offer ways to bridge the on-premises network and Google's cloud. Cloud VPN uses an encrypted internet tunnel while Cloud Interconnect provides a dedicated private physical connection. Both fulfill the requirement to access the private network without the need to expose workloads to the public internet directly. The remaining options don't address connecting to an on-premises network.

Question: 8

CertyIQ

A customer implements Cloud Identity-Aware Proxy for their ERP system hosted on Compute Engine. Their security team wants to add a security layer so that the ERP systems only accept traffic from Cloud Identity-Aware Proxy. What should the customer do to meet these requirements?

- A. Make sure that the ERP system can validate the JWT assertion in the HTTP requests.
- B. Make sure that the ERP system can validate the identity headers in the HTTP requests.
- C. Make sure that the ERP system can validate the x-forwarded-for headers in the HTTP requests.
- D. Make sure that the ERP system can validate the user's unique identifier headers in the HTTP requests.

Answer: A

Explanation:

The correct answer is A because Cloud Identity-Aware Proxy (IAP) secures applications by verifying user identity before granting access. IAP works by issuing JSON Web Tokens (JWTs), which are digitally signed security tokens, to authorized users. These JWTs are then included in the HTTP requests sent to the backend application. To ensure that only traffic originating from IAP is accepted, the ERP system must validate these JWTs. This validation confirms that the request comes from a user authenticated by IAP. Option B is incorrect because while IAP does add headers, relying solely on those identity headers is less secure than validating the JWT. Option C is incorrect as x-forwarded-for headers can be easily spoofed, making them unreliable for security purposes. Option D is incorrect because while IAP can provide unique user identifiers, validating the entire JWT is more robust. JWT validation ensures the request hasn't been tampered with and originated from IAP. This establishes a secure and trusted path for accessing the ERP system. The process generally involves retrieving the public key of the IAP issuer from Google's public key service and using it to verify the signature and claims within the JWT. This approach effectively limits access to authenticated users via IAP.

Relevant Documentation:

Cloud IAP Overview: <https://cloud.google.com/iap/docs/concepts-overview>

Verifying Identity: <https://cloud.google.com/iap/docs/verify-howto>

Question: 9

A company has been running their application on Compute Engine. A bug in the application allowed a malicious user to repeatedly execute a script that results in the Compute Engine instance crashing. Although the bug has been fixed, you want to get notified in case this hack re-occurs. What should you do?

- A. Create an Alerting Policy in Stackdriver using a Process Health condition, checking that the number of executions of the script remains below the desired threshold. Enable notifications.
- B. Create an Alerting Policy in Stackdriver using the CPU usage metric. Set the threshold to 80% to be notified when the CPU usage goes above this 80%.
- C. Log every execution of the script to Stackdriver Logging. Create a User-defined metric in Stackdriver Logging on the logs, and create a Stackdriver Dashboard displaying the metric.
- D. Log every execution of the script to Stackdriver Logging. Configure BigQuery as a log sink, and create a BigQuery scheduled query to count the number of executions in a specific timeframe.

Answer: A**Explanation:**

The correct answer is **A**. Here's why:

Option A directly addresses the problem by monitoring the specific event – the execution of the problematic script. Using Stackdriver's (now Cloud Monitoring) Process Health condition allows you to track the number of times the script runs, setting a threshold that, when exceeded, triggers an alert. This approach provides precise notification of the reoccurrence of the previously exploited vulnerability. It proactively alerts you if the script's usage spikes, even if overall system metrics like CPU usage aren't excessively high. This is crucial because the script's effect is a specific issue separate from general system load. Notifications are the key to timely intervention.

Option B, monitoring CPU usage, is a more general system health check. While a crashing instance might cause high CPU usage, it's not a specific indicator of this particular exploit reoccurring. High CPU can occur for many reasons.

Option C, logging script executions and creating a user-defined metric for a dashboard, is valuable for analysis but isn't ideal for proactive alerting. You'd need to constantly watch the dashboard which isn't efficient or scalable for incident response.

Option D, logging to BigQuery and running scheduled queries, is similarly focused on analysis. It doesn't provide immediate alerts and has the disadvantage of processing delays which might mean critical time is lost before action is taken.

In summary, proactive, immediate alerts upon script re-execution are essential. Stackdriver's process health condition is perfect for this specific use case.

Authoritative Links:

Cloud Monitoring Alerting: <https://cloud.google.com/monitoring/alerts>

Cloud Monitoring Process Health Checks: <https://cloud.google.com/monitoring/process-health>

General Monitoring Concepts: <https://cloud.google.com/solutions/monitoring-observability>

Question: 10

Your team needs to obtain a unified log view of all development cloud projects in your SIEM. The development projects are under the NONPROD organization folder with the test and pre-production projects. The development projects share the ABC-BILLING billing account with the rest of the organization. Which logging export strategy should you use to meet the requirements?

- A. 1. Export logs to a Cloud Pub/Sub topic with folders/NONPROD parent and includeChildren property set to True in a dedicated SIEM project. 2. Subscribe SIEM to the topic.
- B. 1. Create a Cloud Storage sink with billingAccounts/ABC-BILLING parent and includeChildren property set to False in a dedicated SIEM project. 2. Process Cloud Storage objects in SIEM.
- C. 1. Export logs in each dev project to a Cloud Pub/Sub topic in a dedicated SIEM project. 2. Subscribe SIEM to the topic.
- D. 1. Create a Cloud Storage sink with a publicly shared Cloud Storage bucket in each project. 2. Process Cloud Storage objects in SIEM.

Answer: C

Explanation:

The correct answer is **C**. Here's why:

Option C proposes exporting logs from each individual development project to a central Cloud Pub/Sub topic within a dedicated SIEM project. This approach aligns perfectly with the requirement of obtaining a unified log view of only the development projects. By exporting logs from each project separately, you are able to maintain a focused scope on just the development logs, avoiding the inclusion of test and pre-production logs. Using Cloud Pub/Sub provides a scalable and reliable method for streaming logs to the SIEM for real-time analysis.

Option A, while seemingly encompassing, aims for a broader scope by using the NONPROD folder as a sink source and including all child projects. This would inadvertently pull in logs from both the development, test, and pre-production environments, which contradicts the stated requirements. Option B is not recommended due to limitations on Cloud Storage log sinks and cost. Option D is not a best practice due to security concerns. Furthermore, using Cloud Storage is not designed for real time ingestion, as it requires an intermediary process to export logs into the SIEM tool.

Here's a further breakdown:

Granular Control: Option C offers the most granular control. Exporting logs from individual projects means you get exactly what you need – development logs only.

Real-Time Analysis: Pub/Sub provides a real-time stream of logs, crucial for timely threat detection in a SIEM.

Avoids Over-Collection: Option C ensures you're not pulling in unnecessary logs (test/pre-production), reducing noise and potential costs.

Scalability and Reliability: Cloud Pub/Sub is designed for scalability and reliability, making it a good fit for streaming logs to a SIEM.

Authoritative Links:

Cloud Logging exports overview: <https://cloud.google.com/logging/docs/export>

Cloud Pub/Sub: <https://cloud.google.com/pubsub>

Best practices for logging in GCP: <https://cloud.google.com/architecture/best-practices-for-logging>

In summary, Option C offers the most accurate and effective solution by targeting only the necessary logs and delivering them efficiently to the SIEM for analysis.

A customer needs to prevent attackers from hijacking their domain/IP and redirecting users to a malicious site through a man-in-the-middle attack.

Which solution should this customer use?

- A. VPC Flow Logs
- B. Cloud Armor
- C. DNS Security Extensions
- D. Cloud Identity-Aware Proxy

Answer: C

Explanation:

The correct answer is **C. DNS Security Extensions (DNSSEC)**.

DNSSEC is designed to protect against DNS spoofing and manipulation, which are the core mechanisms used in man-in-the-middle attacks targeting domain name resolution. It works by digitally signing DNS records, allowing clients to verify the authenticity and integrity of the data they receive from DNS servers. This prevents attackers from intercepting DNS queries and returning false IP addresses, which would redirect users to malicious sites.

Let's explore why the other options are not suitable:

A. VPC Flow Logs: These logs record network traffic within a Virtual Private Cloud (VPC). While valuable for security monitoring, they don't actively prevent attacks like DNS hijacking. They are a diagnostic tool.

B. Cloud Armor: Cloud Armor provides web application firewall (WAF) and DDoS protection. While it can prevent other types of attacks on web applications, it doesn't directly address DNS manipulation. It operates on higher network layers (L7) while DNS operates on the application layer (L3/L4).

D. Cloud Identity-Aware Proxy (IAP): IAP controls access to applications and resources based on user identity and context. It helps with authorization and authentication, not DNS security. It's more about controlling access than preventing DNS-related attacks.

Therefore, only DNSSEC provides the necessary cryptographic validation to secure the DNS resolution process. By ensuring that clients receive legitimate responses from DNS servers, DNSSEC effectively mitigates the risk of man-in-the-middle attacks that rely on DNS hijacking.

Authoritative Links:

Google Cloud Documentation on DNSSEC: <https://cloud.google.com/dns/docs/dnssec>

ICANN on DNSSEC: <https://www.icann.org/resources/pages/dnssec-what-is-it-2019-03-21-en>

Wikipedia on DNSSEC: https://en.wikipedia.org/wiki/Domain_Name_System_Security_Extensions

Question: 12

CertyIQ

A customer deploys an application to App Engine and needs to check for Open Web Application Security Project (OWASP) vulnerabilities.

Which service should be used to accomplish this?

- A. Cloud Armor
- B. Google Cloud Audit Logs
- C. Web Security Scanner
- D. Anomaly Detection

Answer: C

Explanation:

The correct answer is **C. Web Security Scanner**.

Web Security Scanner is specifically designed to identify OWASP Top 10 vulnerabilities and other common web application security flaws. It crawls your application, analyzing its components for weaknesses like SQL injection, cross-site scripting (XSS), and broken authentication, aligning directly with the stated need to check for OWASP vulnerabilities.

Cloud Armor (A) is primarily a web application firewall (WAF) used to protect applications against external threats by implementing security policies and access controls. While it provides security features, it does not actively scan for OWASP vulnerabilities in the application's code or configuration like Web Security Scanner. Google Cloud Audit Logs (B) records administrative actions and access to Google Cloud resources. It's crucial for tracking events and maintaining a security audit trail, but doesn't perform vulnerability scans. Anomaly Detection (D) focuses on identifying deviations from normal patterns of behavior. It's helpful in detecting unusual activities but not suited for checking for specific web application security vulnerabilities.

Therefore, for a customer deploying an application on App Engine and needing to identify OWASP vulnerabilities, Web Security Scanner offers the necessary active vulnerability scanning functionality. It's a purpose-built solution for this scenario, providing reports on identified vulnerabilities and guidance for remediation.

For further research, refer to the official Google Cloud documentation:

Web Security Scanner: <https://cloud.google.com/web-security-scanner/docs>

OWASP Top 10: <https://owasp.org/Top10/>

Question: 13

CertyIQ

A customer's data science group wants to use Google Cloud Platform (GCP) for their analytics workloads. Company policy dictates that all data must be company-owned and all user authentications must go through their own Security Assertion Markup Language (SAML) 2.0 Identity Provider (IdP). The Infrastructure Operations Systems Engineer was trying to set up Cloud Identity for the customer and realized that their domain was already being used by G Suite. How should you best advise the Systems Engineer to proceed with the least disruption?

- A. Contact Google Support and initiate the Domain Contestation Process to use the domain name in your new Cloud Identity domain.
- B. Register a new domain name, and use that for the new Cloud Identity domain.
- C. Ask Google to provision the data science manager's account as a Super Administrator in the existing domain.
- D. Ask customer's management to discover any other uses of Google managed services, and work with the existing Super Administrator.

Answer: D

Explanation:

The correct answer is **D. Ask customer's management to discover any other uses of Google managed services, and work with the existing Super Administrator**.

Here's why:

The core issue is that the customer's domain is already claimed by a G Suite organization. Cloud Identity cannot be set up using the same domain without conflicting with the existing G Suite configuration. Attempting to take over the domain (options A and B) is disruptive and could break existing services. Option C is risky as it gives a manager, rather than a person with expertise, too much power over the entire

organization. Option D, however, addresses the problem directly. It acknowledges that another entity is using the domain and advocates for collaboration. By having management identify all other Google service usage, it allows for informed decisions to be made, including which approach will have the least disruption. It may be possible to add Cloud Identity to the existing domain as a sub-domain or to migrate data later. This approach also respects established processes, and is consistent with governance principles.

Therefore, working with the existing Super Administrator to understand the current usage will allow for a more informed decision on the next steps with minimal disruption.

Authoritative Links:

Google Cloud Identity Documentation: <https://cloud.google.com/identity/docs/> - Provides a comprehensive overview of Cloud Identity.

Google Workspace Admin Help: <https://support.google.com/a/?hl=en#topic=7570606> - Contains resources about domain management and organization structures in Google.

Cloud Identity and Google Workspace interoperability: <https://support.google.com/a/answer/7372233?hl=en> -Explains the connection between both offerings.

Question: 14

CertyIQ

A business unit at a multinational corporation signs up for GCP and starts moving workloads into GCP. The business unit creates a Cloud Identity domain with an organizational resource that has hundreds of projects. Your team becomes aware of this and wants to take over managing permissions and auditing the domain resources.

Which type of access should your team grant to meet this requirement?

- A. Organization Administrator
- B. Security Reviewer
- C. Organization Role Administrator
- D. Organization Policy Administrator

Answer: A

Explanation:

The correct answer is **A. Organization Administrator**.

Here's why:

An Organization Administrator role grants the broadest level of control and access to an entire Google Cloud organization. This includes managing all resources within the organization, including projects, folders, and the organization itself. This role allows your team to effectively take over the management of permissions and auditing, as they require full control.

Option B, Security Reviewer, only provides read-only access for security-related information. This doesn't allow for modification of permissions or any management activities, thus not meeting the requirement. Option C, Organization Role Administrator, only provides the ability to manage organization-level IAM roles but not the other organization resources, and Option D, Organization Policy Administrator, allows management of policies but not other resources and user permissions.

The team needs the ability to set permissions, manage resources, and enforce policies to take over complete management and audit responsibilities, which is only provided by the Organization Administrator role. This aligns with the scenario where a team needs to regain control over a domain with hundreds of projects created by another entity. This is a powerful role and should be granted with appropriate care.

Authoritative Links:

IAM roles: <https://cloud.google.com/iam/docs/understanding-roles>

Organization Administrator role: <https://cloud.google.com/resource-manager/docs/access-control-org#org-admin>

Predefined IAM roles: <https://cloud.google.com/iam/docs/predefined-roles>

Question: 15

CertyIQ

An application running on a Compute Engine instance needs to read data from a Cloud Storage bucket. Your team does not allow Cloud Storage buckets to be globally readable and wants to ensure the principle of least privilege. Which option meets the requirement of your team?

- A. Create a Cloud Storage ACL that allows read-only access from the Compute Engine instance's IP address and allows the application to read from the bucket without credentials.
- B. Use a service account with read-only access to the Cloud Storage bucket, and store the credentials to the service account in the config of the application on the Compute Engine instance.
- C. Use a service account with read-only access to the Cloud Storage bucket to retrieve the credentials from the instance metadata.
- D. Encrypt the data in the Cloud Storage bucket using Cloud KMS, and allow the application to decrypt the data with the KMS key.

Answer: C

Explanation:

Option C, utilizing a service account with read-only access to the Cloud Storage bucket and retrieving credentials from instance metadata, is the most secure and compliant approach. Instance metadata provides temporary, automatically rotated credentials to the Compute Engine instance, eliminating the need to store sensitive keys directly within the application configuration (as suggested in option B). This mitigates the risk of compromised credentials if the application is ever exposed or if the configuration file is leaked. Option A, relying on IP address-based ACLs, is fragile and does not scale well, as IP addresses can change and do not represent a strong authentication mechanism. Option D, while a good practice, addresses data encryption and doesn't inherently manage the authentication and authorization needed for the application to access Cloud Storage. By granting the service account read-only access, the principle of least privilege is respected, as the application only receives the minimum permissions necessary to perform its task. The service account, associated with the Compute Engine instance, implicitly establishes the identity, enabling Cloud Storage to control access. This method leverages the secure infrastructure provided by Google Cloud Platform.

Google Cloud IAM: Information about Identity and Access Management (IAM) including service accounts. **Compute Engine Service Accounts:** Details on utilizing service accounts with Compute Engine. **Cloud Storage IAM:** Information about using IAM to control access to Cloud Storage resources. **Instance Metadata:** Documentation on accessing instance metadata for secrets management.

Question: 16

CertyIQ

An organization's typical network and security review consists of analyzing application transit routes, request handling, and firewall rules. They want to enable their developer teams to deploy new applications without the overhead of this full review.

How should you advise this organization?

- A. Use Forseti with Firewall filters to catch any unwanted configurations in production.
- B. Mandate use of infrastructure as code and provide static analysis in the CI/CD pipelines to enforce policies.
- C. Route all VPC traffic through customer-managed routers to detect malicious patterns in production.
- D. All production applications will run on-premises. Allow developers free rein in GCP as their dev and QA

platforms.

Answer: B

Explanation:

The most suitable approach for enabling developers to deploy applications without the overhead of full network and security reviews while maintaining security is option B: Mandating Infrastructure as Code (IaC) and integrating static analysis into CI/CD pipelines. This approach shifts security left, incorporating it earlier in the development lifecycle. IaC, using tools like Terraform or Cloud Deployment Manager, allows infrastructure to be defined and managed as code, ensuring consistency and repeatability. By enforcing policies through static analysis during the CI/CD process, you can automatically identify security misconfigurations and vulnerabilities before they reach production. This includes checks for overly permissive firewall rules, insecure network configurations, and other potential security risks. This prevents issues by design and reduces the risk of manual errors, which are common in traditional review processes. Forseti (option A) is valuable for auditing and monitoring but isn't preventative like static analysis in CI/CD. Routing all VPC traffic through customer-managed routers (option C) adds unnecessary complexity and overhead without addressing the core issue of proactive security. Option D, restricting production to on-premises, limits the benefits of cloud and doesn't align with the question's goal of enabling developers in GCP.

Authoritative Links:

Infrastructure as Code: <https://martinfowler.com/bliki/InfrastructureAsCode.html>

CI/CD Pipelines: <https://cloud.google.com/devops/ci-cd/>

Shift Left Security: <https://www.veracode.com/blog/security/shift-left-security-what-it-and-why-its-so-important>

Static Analysis: https://owasp.org/www-community/OWASP_Source_Code_Analysis_Tools

Question: 17

CertyIQ

An employer wants to track how bonus compensations have changed over time to identify employee outliers and correct earning disparities. This task must be performed without exposing the sensitive compensation data for any individual and must be reversible to identify the outlier.

Which Cloud Data Loss Prevention API technique should you use to accomplish this?

- A. Generalization
- B. Redaction
- C. CryptoHashConfig
- D. CryptoReplaceFfxFpeConfig

Answer: D

Explanation:

The correct answer is **D. CryptoReplaceFfxFpeConfig**. Here's why:

The employer needs to transform sensitive compensation data to track trends and identify outliers without exposing individual earnings. Importantly, this transformation needs to be reversible to pinpoint the specific outliers and address earning disparities.

A. Generalization: While generalization can mask data, it does so by broadening categories (e.g., salary ranges), making it impossible to reverse the transformation to identify an exact individual's earnings, which makes it unsuitable for outlier identification as required here.

B. Redaction: Redaction removes or masks data entirely (e.g., replacing values with asterisks). This would be

useless for the purpose stated because it destroys the original information and cannot be reversed.

C. CryptoHashConfig: Hashing creates a one-way function; the original value cannot be retrieved from the hash. Therefore, while it anonymizes data, it is not reversible, rendering it unusable for the task that requires recovering original values for outlier identification.

D. CryptoReplaceFfxFpeConfig: This method utilizes format-preserving encryption (FPE), specifically the FFX (prefix-free Feistel network) algorithm. FPE transforms data while maintaining the original format (e.g., a number remains a number with the same number of digits). Crucially, it uses a key, enabling the transformation to be reversed and the original data to be recovered with the same key. This is perfect for the scenario because it anonymizes the data for analysis while allowing for decryption and outlier identification.

Therefore, CryptoReplaceFfxFpeConfig is the only technique that fulfills the requirements of data transformation for analysis and reversibility for outlier identification, while also protecting the sensitive nature of the data.

Further Research:

Google Cloud DLP Documentation on De-identification Methods:

<https://cloud.google.com/dlp/docs/transformations-deid>

Format-Preserving Encryption (FPE) Overview: https://en.wikipedia.org/wiki/Format-preserving_encryption

FFX Algorithm: <https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-38g.pdf>

Question: 18

CertyIQ

An organization adopts Google Cloud Platform (GCP) for application hosting services and needs guidance on setting up password requirements for their Cloud Identity account. The organization has a password policy requirement that corporate employee passwords must have a minimum number of characters.

Which Cloud Identity password guidelines can the organization use to inform their new requirements?

- A. Set the minimum length for passwords to be 8 characters.
- B. Set the minimum length for passwords to be 10 characters.
- C. Set the minimum length for passwords to be 12 characters.
- D. Set the minimum length for passwords to be 6 characters.

Answer: A

Explanation:

The correct answer is **A. Set the minimum length for passwords to be 8 characters.**

Cloud Identity, Google's identity and access management service, allows administrators to enforce password policies for user accounts. While best practices often recommend stronger passwords, Cloud Identity imposes a minimum password length requirement to ensure a basic level of security. The absolute minimum password length supported by Cloud Identity is indeed 8 characters. Options B and C, suggesting 10 and 12 characters respectively, are stronger recommendations, but they are not the minimal standard. Option D, offering 6 characters, falls below the supported minimum and would not be a viable choice for establishing password requirements within Cloud Identity. While administrators can configure longer minimum lengths through the Google Admin console, the default and lowest allowed length is 8. Thus, informing the organization that 8 characters is the minimal standard is a correct statement based on Cloud Identity's restrictions. This baseline ensures all users create passwords that meet a fundamental security threshold, while allowing organizations to increase this minimum for enhanced protection.

Here are relevant links for further research:

Question: 19

CertyIQ

You need to follow Google-recommended practices to leverage envelope encryption and encrypt data at the application layer.
What should you do?

- A. Generate a data encryption key (DEK) locally to encrypt the data, and generate a new key encryption key (KEK) in Cloud KMS to encrypt the DEK. Store both the encrypted data and the encrypted DEK.
- B. Generate a data encryption key (DEK) locally to encrypt the data, and generate a new key encryption key (KEK) in Cloud KMS to encrypt the DEK. Store both the encrypted data and the KEK.
- C. Generate a new data encryption key (DEK) in Cloud KMS to encrypt the data, and generate a key encryption key (KEK) locally to encrypt the key. Store both the encrypted data and the encrypted DEK.
- D. Generate a new data encryption key (DEK) in Cloud KMS to encrypt the data, and generate a key encryption key (KEK) locally to encrypt the key. Store both the encrypted data and the KEK.

Answer: A

Explanation:

The correct answer is A because it accurately describes the recommended practice for envelope encryption using Google Cloud KMS (Key Management Service). Envelope encryption involves encrypting data with a locally generated Data Encryption Key (DEK), and then encrypting the DEK itself with a Key Encryption Key (KEK) managed by a centralized service like Cloud KMS. This approach offers a balance between performance and security. DEKs are used for high-speed data encryption/decryption, while KEKs managed by Cloud KMS provide robust key management and access control. The process begins by creating a DEK locally where the application is processing the data. Then the data is encrypted using that DEK. The DEK is then encrypted using a KEK managed by Cloud KMS. Critically, the encrypted DEK and the encrypted data are stored; the original DEK is never stored. This ensures that if the stored data is compromised, it cannot be decrypted without access to the KEK in Cloud KMS. Option B is incorrect because storing the KEK directly instead of the encrypted DEK defeats the purpose of envelope encryption, potentially exposing the key. Options C and D are incorrect because they involve using Cloud KMS to generate the DEK, which is not how envelope encryption is typically implemented and introduces a performance penalty for every data encryption/decryption operation. Moreover, they propose generating KEKs locally which is not recommended from a security and management standpoint.

For more information about envelope encryption and best practices with Cloud KMS, refer to the following Google Cloud documentation:

Cloud KMS documentation on envelope encryption: <https://cloud.google.com/kms/docs/envelope-encryption>
Best practices for using Cloud KMS: <https://cloud.google.com/kms/docs/best-practices>

Question: 20

CertyIQ

How should a customer reliably deliver Stackdriver logs from GCP to their on-premises SIEM system?

- A. Send all logs to the SIEM system via an existing protocol such as syslog.
- B. Configure every project to export all their logs to a common BigQuery DataSet, which will be queried by the SIEM system.
- C. Configure Organizational Log Sinks to export logs to a Cloud Pub/Sub Topic, which will be sent to the SIEM via Dataflow.

D. Build a connector for the SIEM to query for all logs in real time from the GCP RESTful JSON APIs.

Answer: C

Explanation:

The correct answer is C. Here's why: Option C proposes using **Organizational Log Sinks** to export logs to a **Cloud Pub/Sub Topic**, which are then processed and forwarded to the on-premises SIEM using **Dataflow**. This approach offers a scalable, reliable, and managed solution for log delivery. Organizational log sinks centrally manage log exports at the organization level, ensuring that all relevant projects contribute to the stream. Cloud Pub/Sub provides a durable and reliable messaging queue, decoupling the log generation from the SIEM system. Dataflow is a fully managed, serverless data processing service that can efficiently read from Pub/Sub and transform data for the SIEM, often leveraging batching and backoff mechanisms for better performance and reliability. In contrast, option A using syslog directly lacks scalability and management controls for large GCP environments. Option B involves BigQuery, which is great for analysis but not optimized for near real-time SIEM ingestion. Option D, querying via the APIs, is highly inefficient and rate-limited, making it unsuitable for reliable large-scale log delivery. Option C leverages managed services that promote a more sustainable, maintainable and robust architecture for sending logs to a SIEM system.

Authoritative Links:

Cloud Logging Sinks: https://cloud.google.com/logging/docs/export/configure_export_v2

Cloud Pub/Sub: <https://cloud.google.com/pubsub/docs>

Cloud Dataflow: <https://cloud.google.com/dataflow/docs>

Question: 21

CertyIQ

In order to meet PCI DSS requirements, a customer wants to ensure that all outbound traffic is authorized. Which two cloud offerings meet this requirement without additional compensating controls? (Choose two.)

- A. App Engine
- B. Cloud Functions
- C. Compute Engine
- D. Google Kubernetes Engine
- E. Cloud Storage

Answer: CD

Explanation:

The question focuses on meeting PCI DSS requirements by ensuring authorized outbound traffic. PCI DSS mandates strict controls over network traffic to protect cardholder data. Both Compute Engine (C) and Google Kubernetes Engine (GKE) (D), when properly configured, can meet this requirement without additional compensating controls. Compute Engine allows for the creation of virtual machines with tightly controlled egress traffic through firewall rules and network tags. You define which specific traffic is allowed outbound based on IP addresses, ports and protocols. Similarly, GKE allows granular control of network policies to dictate outbound traffic within the cluster. You can establish Kubernetes Network Policies to restrict outbound connectivity of pods based on namespace, pod labels, and other selectors. App Engine (A) and Cloud Functions (B) are managed platforms with limitations on network configurations. They rely on Google's infrastructure, and achieving granular control over outbound traffic without additional compensating controls, like a VPC connector, isn't feasible. Cloud Storage (E) is a storage service, not related to outbound network traffic control.

Therefore, Compute Engine and GKE offer the most direct and configurable mechanisms for enforcing

outbound traffic authorization through their respective networking capabilities, allowing for compliance with PCI DSS requirements without reliance on additional compensating controls for basic egress. These services provide the necessary fine-grained controls over outbound network traffic that are essential for securing PCI DSS data environments.

[Google Cloud Networking Documentation](#)[Google Kubernetes Engine Network Policies](#)

Question: 22

CertyIQ

A website design company recently migrated all customer sites to App Engine. Some sites are still in progress and should only be visible to customers and company employees from any location. Which solution will restrict access to the in-progress sites?

- A. Upload an .htaccess file containing the customer and employee user accounts to App Engine.
- B. Create an App Engine firewall rule that allows access from the customer and employee networks and denies all other traffic.
- C. Enable Cloud Identity-Aware Proxy (IAP), and allow access to a Google Group that contains the customer and employee user accounts.
- D. Use Cloud VPN to create a VPN connection between the relevant on-premises networks and the company's GCP Virtual Private Cloud (VPC) network.

Answer: C

Explanation:

The correct answer is **C. Enable Cloud Identity-Aware Proxy (IAP), and allow access to a Google Group that contains the customer and employee user accounts.**

Here's why:

Identity-Aware Proxy (IAP): IAP is a Google Cloud service that verifies user identity and context before allowing access to applications. This is precisely what's needed to restrict access based on user roles, regardless of their location. IAP handles authentication and authorization at the application level.

Google Groups for User Management: Using a Google Group allows for easy management of the customer and employee accounts. Adding or removing users from the group dynamically updates access permissions. This is much more flexible and scalable than static lists.

Why other options are incorrect:

A (.htaccess): App Engine does not support .htaccess files in the same way as traditional web servers. It's not a valid mechanism for access control in this context.

B (Firewall Rules): Firewall rules are based on network IP addresses and not user identities. Customers and employees are accessing from various locations, so IP-based rules are not a practical solution. This approach will block or allow at the network level and is not granular enough for user-based access.

D (Cloud VPN): Cloud VPN establishes a secure network connection between on-premises networks and VPC. While secure, it only handles network connectivity and doesn't address user identity. It's also overkill for this scenario, as access is needed from various locations, not just on-prem networks.

Advantages of IAP: IAP provides fine-grained access control, user-based authentication, and integrates seamlessly with Google Cloud services. It aligns with a zero-trust security model, where identity is central to access control.

In conclusion, enabling Cloud IAP and utilizing a Google Group offers the most effective and appropriate solution to restrict access to in-progress websites on App Engine to designated users from any location.

Authoritative Links for further research:

Cloud Identity-Aware Proxy (IAP): <https://cloud.google.com/iap>

Google Groups: <https://support.google.com/groups/?hl=en#topic=9216504>

Question: 23

CertyIQ

When working with agents in a support center via online chat, an organization's customers often share pictures of their documents with personally identifiable information (PII). The organization that owns the support center is concerned that the PII is being stored in their databases as part of the regular chat logs they retain for review by internal or external analysts for customer service trend analysis.

Which Google Cloud solution should the organization use to help resolve this concern for the customer while still maintaining data utility?

- A. Use Cloud Key Management Service (KMS) to encrypt the PII data shared by customers before storing it for analysis.
- B. Use Object Lifecycle Management to make sure that all chat records with PII in them are discarded and not saved for analysis.
- C. Use the image inspection and redaction actions of the DLP API to redact PII from the images before storing them for analysis.
- D. Use the generalization and bucketing actions of the DLP API solution to redact PII from the texts before storing them for analysis.

Answer: C

Explanation:

The correct answer is **C. Use the image inspection and redaction actions of the DLP API to redact PII from the images before storing them for analysis.**

Here's the justification:

The core problem is the presence of PII within images shared during chat sessions, leading to privacy concerns during storage and analysis. Options A, B, and D don't effectively address this specific issue.

Option A (Cloud KMS): While encryption is crucial for data security, it doesn't remove PII from the content itself. Encrypted data can still be decrypted, exposing the original PII during analysis, defeating the purpose of protecting privacy. Encryption protects data in transit and at rest but does not alter the data itself.

Option B (Object Lifecycle Management): Discarding chat records would completely eliminate the data necessary for trend analysis, which contradicts the business requirement. Object lifecycle policies are used for managing the lifecycle of objects stored in Cloud Storage. It's meant for deleting and moving data based on age and storage class not for redaction of specific information.

Option D (DLP API for Text): While DLP API can redact text-based PII, the question explicitly states that the PII is in images of documents. Text-based redaction wouldn't be applicable in this scenario. DLP does have support for text data, and in another context that option may be correct.

Option C (DLP API for Images): This is the most fitting solution. The Data Loss Prevention (DLP) API is designed to identify and redact sensitive information. Crucially, its image inspection capabilities can locate and redact PII within images before storage. This allows the organization to maintain the chat data for analysis, while also removing the sensitive PII in images. This approach fulfills the need for both data utility and data protection.

In summary, DLP's image inspection and redaction capabilities allow the organization to balance their need for analysis with the privacy concerns created by customers sharing images with PII.

Authoritative Links:

Google Cloud DLP API Documentation: <https://cloud.google.com/dlp/docs>

DLP API Concepts: <https://cloud.google.com/dlp/docs/concepts-dlp>

Image Redaction with DLP: <https://cloud.google.com/dlp/docs/inspect-image>

Question: 24

CertyIQ

A company's application is deployed with a user-managed Service Account key. You want to use Google-recommended practices to rotate the key. What should you do?

- A. Open Cloud Shell and run `gcloud iam service-accounts enable-auto-rotate --iam-account=IAM_ACCOUNT`.
- B. Open Cloud Shell and run `gcloud iam service-accounts keys rotate --iam-account=IAM_ACCOUNT --key=NEW_KEY`.
- C. Create a new key, and use the new key in the application. Delete the old key from the Service Account.
- D. Create a new key, and use the new key in the application. Store the old key on the system as a backup key.

Answer: C

Explanation:

The correct answer is C because it aligns with Google's best practices for managing service account keys and ensuring a secure rotation process. Option A is incorrect because the `gcloud iam service-accounts enable-auto-rotate` command does not exist. Automatic key rotation for user-managed keys is not directly supported by a simple command. Option B is incorrect because the command `gcloud iam service-accounts keys rotate` does not directly rotate the key; it generates a new key and leaves the old key. Simply rotating in place leaves a potential security gap if the key were compromised.

Option C provides a sound methodology to perform a manual key rotation. The strategy of creating a new key first allows applications to be updated without downtime or interruption, ensuring continuous service availability. Once all applications have been updated to use the new key, and the system is validated to be operational, the old key can be safely deleted from the service account. This approach minimizes the impact of rotation and avoids unnecessary risk. Storing the old key as a backup (Option D) is generally discouraged because it introduces the risk of accidental misuse and potential security issues, contradicting the principle of least privilege and minimizing attack surface.

The fundamental concept behind this approach is minimizing risk and enabling a controlled transition to a new security credential. Google recommends that service account keys should be rotated regularly as a best practice. This ensures that if a key is compromised, the window of vulnerability is limited.

Supporting Links:

Best practices for using service account keys: <https://cloud.google.com/iam/docs/best-practices-service-accounts>

Managing service account keys: <https://cloud.google.com/iam/docs/service-account-keys>

Key rotation concepts: https://en.wikipedia.org/wiki/Key_rotation

Question: 25

CertyIQ

Your team needs to configure their Google Cloud Platform (GCP) environment so they can centralize the control over networking resources like firewall rules, subnets, and routes. They also have an on-premises environment where resources need access back to the GCP resources through a private VPN connection. The networking resources will need to be controlled by the network security team.

Which type of networking design should your team use to meet these requirements?

- A. Shared VPC Network with a host project and service projects
- B. Grant Compute Admin role to the networking team for each engineering project
- C. VPC peering between all engineering projects using a hub and spoke model
- D. Cloud VPN Gateway between all engineering projects using a hub and spoke model

Answer: A

Explanation:

The correct answer is A: Shared VPC Network with a host project and service projects. This design best addresses the requirements of centralized network control and hybrid connectivity. Shared VPC allows a central host project to manage a network, including firewalls, subnets, and routes, while other service projects utilize resources within that shared network. This allows the network security team to maintain control, as specified. Option B is incorrect because granting the Compute Admin role for each project would distribute control instead of centralizing it. Options C and D are incorrect because VPC peering and Cloud VPN gateways provide connectivity but don't inherently centralize control over networking resources. Shared VPC, conversely, directly fulfills the requirement of centralized control. Furthermore, a shared VPC environment easily supports a VPN connection from the on-premises environment, as it connects to the central host project and allows connectivity to all service projects within the shared network. This setup promotes a consistent and secure networking architecture while offering needed hybrid connectivity.

Supporting Links:

Shared VPC Overview: <https://cloud.google.com/vpc/docs/shared-vpc>

Planning a Shared VPC: <https://cloud.google.com/vpc/docs/shared-vpc-planning>

Hybrid Connectivity with Shared VPC: (This can be inferred but not a direct link. Search Google Cloud documentation for "Cloud VPN with Shared VPC" for more on this).

Question: 26

CertyIQ

An organization is migrating from their current on-premises productivity software systems to G Suite. Some network security controls were in place that were mandated by a regulatory body in their region for their previous on-premises system. The organization's risk team wants to ensure that network security controls are maintained and effective in G Suite. A security architect supporting this migration has been asked to ensure that network security controls are in place as part of the new shared responsibility model between the organization and Google Cloud.

What solution would help meet the requirements?

- A. Ensure that firewall rules are in place to meet the required controls.
- B. Set up Cloud Armor to ensure that network security controls can be managed for G Suite.
- C. Network security is a built-in solution and Google's Cloud responsibility for SaaS products like G Suite.
- D. Set up an array of Virtual Private Cloud (VPC) networks to control network security as mandated by the relevant regulation.

Answer: C

Explanation:

The correct answer is C, "Network security is a built-in solution and Google's Cloud responsibility for SaaS products like G Suite." This is because G Suite, as a Software-as-a-Service (SaaS) offering, operates under a shared responsibility model where Google manages the underlying infrastructure and network security. The organization is responsible for data and user access management, not the underlying network. Options A, B, and D are not applicable to a SaaS model like G Suite. Firewall rules (A) are more relevant to Infrastructure-

as-a-Service (IaaS) and Platform-as-a-Service (PaaS) deployments where the organization manages the infrastructure. Cloud Armor (B) is also a Google Cloud service designed to protect web applications and services, not the underlying network of a SaaS product. VPC networks (D) are typically used for IaaS deployments, where an organization manages virtualized networks. The network security controls for G Suite are inherent in the product design and are handled by Google. The organization should focus on controls like data loss prevention (DLP), user access policies, and activity monitoring within the G Suite application rather than low-level network controls. This ensures compliance without unnecessary and inappropriate configurations within Google's SaaS environment.

Authoritative links:

Google Workspace Shared Responsibility: <https://cloud.google.com/security/shared-responsibility>

Google Workspace Security: <https://workspace.google.com/security/>

Question: 27

CertyIQ

A customer's company has multiple business units. Each business unit operates independently, and each has their own engineering group. Your team wants visibility into all projects created within the company and wants to organize their Google Cloud Platform (GCP) projects based on different business units. Each business unit also requires separate sets of IAM permissions.

Which strategy should you use to meet these needs?

- A. Create an organization node, and assign folders for each business unit.
- B. Establish standalone projects for each business unit, using gmail.com accounts.
- C. Assign GCP resources in a project, with a label identifying which business unit owns the resource.
- D. Assign GCP resources in a VPC for each business unit to separate network access.

Answer: A

Explanation:

Justification for Option A: Create an organization node, and assign folders for each business unit.

Option A is the most suitable approach because it leverages the hierarchical structure of Google Cloud Platform (GCP) organizations, folders, and projects to address the customer's needs for centralized visibility and decentralized management. Creating an organization node establishes a root for the entire company's GCP resources, enabling centralized policies and monitoring. Assigning folders for each business unit provides a logical grouping mechanism, allowing for independent resource management and IAM policies specific to each unit. This structure allows the security team to have the required visibility into all projects created and organized based on the business units. Moreover, IAM permissions can be inherited down the hierarchy, allowing for granular control. The folder structure creates a clear separation of resources and allows each business unit to manage their projects without interfering with others. It promotes scalability, as new business units can easily be added as folders. Resource tagging (option C) and VPC separation (option D) are less ideal as they don't provide the same organizational structure and IAM isolation offered by folders. Option B, using gmail.com accounts, is not recommended for business use due to the lack of central governance and collaboration features inherent in an organization setup.

Authoritative Links:

Resource Hierarchy: <https://cloud.google.com/resource-manager/docs/cloud-platform-resource-hierarchy>

Organizations: <https://cloud.google.com/resource-manager/docs/organizations-overview>

Folders: <https://cloud.google.com/resource-manager/docs/folders-overview>

IAM Roles: <https://cloud.google.com/iam/docs/overview>

Question: 28

A company has redundant mail servers in different Google Cloud Platform regions and wants to route customers to the nearest mail server based on location.
How should the company accomplish this?

- A. Configure TCP Proxy Load Balancing as a global load balancing service listening on port 995.
- B. Create a Network Load Balancer to listen on TCP port 995 with a forwarding rule to forward traffic based on location.
- C. Use Cross-Region Load Balancing with an HTTP(S) load balancer to route traffic to the nearest region.
- D. Use Cloud CDN to route the mail traffic to the closest origin mail server based on client IP address.

Answer: A

Explanation:

The correct answer is A: Configure TCP Proxy Load Balancing as a global load balancing service listening on port 995.

Here's why: TCP Proxy Load Balancing is designed for non-HTTP(S) traffic, which is suitable for mail protocols like POP3 (often using port 995). It operates at Layer 4 (TCP) of the OSI model and can distribute traffic to backend instances based on proximity to the client. This global load balancing service automatically directs users to the closest regional mail server based on their location, minimizing latency and optimizing performance. Options B, C, and D are less suitable for the specific requirements. A Network Load Balancer (B) is regional, not global, and wouldn't inherently provide location-based routing. HTTP(S) load balancing (C) is meant for HTTP(S) traffic and cannot handle mail protocols directly. Cloud CDN (D) is primarily for caching content, not routing TCP-based mail traffic. TCP Proxy Load Balancing offers the required global scope, TCP support, and location-based routing necessary for this scenario. The service operates globally with a single IP address and supports multiple backends across regions, directing traffic to the closest available backend for the best user experience. This choice aligns perfectly with the need to route customers to the nearest mail server based on their geographic location.

Authoritative Links:

Google Cloud Load Balancing Overview: <https://cloud.google.com/load-balancing/docs/load-balancing-overview>

TCP Proxy Load Balancing: <https://cloud.google.com/load-balancing/docs/tcp/>

Question: 29

Your team sets up a Shared VPC Network where project co-vpc-prod is the host project. Your team has configured the firewall rules, subnets, and VPN gateway on the host project. They need to enable Engineering Group A to attach a Compute Engine instance to only the 10.1.1.0/24 subnet.
What should your team grant to Engineering Group A to meet this requirement?

- A. Compute Network User Role at the host project level.
- B. Compute Network User Role at the subnet level.
- C. Compute Shared VPC Admin Role at the host project level.
- D. Compute Shared VPC Admin Role at the service project level.

Answer: B

Explanation:

The correct answer is **B. Compute Network User Role at the subnet level**. Here's a detailed justification:

Shared VPC allows organizations to centralize network resources in a host project and share them with service projects. To enable a service project (in this case, Engineering Group A) to create resources within a Shared VPC, it needs the appropriate permissions. The key is to grant the least privilege necessary.

Option A, "Compute Network User Role at the host project level," would grant broad access to the entire network configuration in the host project, including other subnets, which violates the requirement of accessing only the 10.1.1.0/24 subnet.

Option B, "Compute Network User Role at the subnet level," aligns perfectly with the requirement. Granting the `compute.networkUser` role specifically on the 10.1.1.0/24 subnet allows Engineering Group A to create and manage Compute Engine instances connected to that subnet only. This follows the principle of least privilege by limiting their access.

Option C, "Compute Shared VPC Admin Role at the host project level," grants overly broad administrative permissions over the entire Shared VPC host project, exceeding what Engineering Group A needs.

Option D, "Compute Shared VPC Admin Role at the service project level," is not correct as the service project doesn't need admin rights on its own project to attach to host project resources.

Therefore, granting the `compute.networkUser` role at the subnet level is the most secure and appropriate way to allow Engineering Group A to attach a Compute Engine instance only to the specified subnet, fulfilling the specific requirement.

Authoritative Links:

Shared VPC Overview: <https://cloud.google.com/vpc/docs/shared-vpc>

IAM Roles for Shared VPC: <https://cloud.google.com/vpc/docs/shared-vpc#permissions>

Compute Network User Role: <https://cloud.google.com/iam/docs/understanding-roles#compute.networkUser>

Question: 30

CertyIQ

A company migrated their entire data/center to Google Cloud Platform. It is running thousands of instances across multiple projects managed by different departments. You want to have a historical record of what was running in Google Cloud Platform at any point in time.

What should you do?

- A. Use Resource Manager on the organization level.
- B. Use Forseti Security to automate inventory snapshots.
- C. Use Stackdriver to create a dashboard across all projects.
- D. Use Security Command Center to view all assets across the organization.

Answer: B

Explanation:

Okay, let's analyze why option B, using Forseti Security to automate inventory snapshots, is the correct approach for maintaining a historical record of Google Cloud Platform (GCP) resources.

The core requirement is to track what was running at any point in time, implying the need for a time-series record of resources and their configurations. Forseti Security directly addresses this with its inventory capabilities. It's an open-source tool designed for GCP security and governance, and a key feature is its ability to periodically scan your GCP organization, projects, and assets, creating snapshots of their state. These snapshots include details about resource types, configurations, access control policies, and more, providing a comprehensive picture of your GCP environment.

By scheduling these scans, you effectively build a historical database of your GCP resources. You can then

query this data to understand what resources existed at a specific time, enabling you to track changes over time and even investigate past incidents. Unlike Resource Manager (option A), which focuses on hierarchical organization and access control, or Stackdriver (option C), which is a monitoring and logging tool, Forseti is specifically tailored for this type of inventory and historical tracking. While Security Command Center (option D) offers real-time asset visibility, it isn't designed to archive past configurations for historical analysis in the same way Forseti does.

Forseti's automated nature makes it ideal for large, dynamic GCP environments like the one described in the scenario, where manual tracking would be impractical. Additionally, Forseti integrates well with other GCP security tools, enhancing your overall security posture. In summary, Forseti's inventory snapshots provide the necessary time-series data to meet the stated requirement, distinguishing it as the most suitable solution from the other options.

Authoritative Links for Further Research:

Forseti Security: <https://forsetisecurity.org/>

Forseti Inventory Feature: <https://forsetisecurity.org/docs/concepts/inventory/>

Google Cloud Resource Manager: <https://cloud.google.com/resource-manager/docs>

Google Cloud Operations Suite (formerly Stackdriver): <https://cloud.google.com/stackdriver>

Google Cloud Security Command Center: <https://cloud.google.com/security-command-center>

Question: 31

CertyIQ

An organization is starting to move its infrastructure from its on-premises environment to Google Cloud Platform (GCP). The first step the organization wants to take is to migrate its current data backup and disaster recovery solutions to GCP for later analysis. The organization's production environment will remain on-premises for an indefinite time. The organization wants a scalable and cost-efficient solution. Which GCP solution should the organization use?

- A. BigQuery using a data pipeline job with continuous updates
- B. Cloud Storage using a scheduled task and gsutil
- C. Compute Engine Virtual Machines using Persistent Disk
- D. Cloud Datastore using regularly scheduled batch upload jobs

Answer: B

Explanation:

The correct answer is **B. Cloud Storage using a scheduled task and gsutil**. Here's why:

Cloud Storage is an object storage service ideal for storing backups and disaster recovery data due to its scalability, cost-effectiveness, and durability. The organization's primary need is a place to store backups from their on-premises environment, and Cloud Storage is perfect for this use case. Using gsutil, a command-line tool for Cloud Storage, enables efficient data transfer from the on-premises environment to Google Cloud. A scheduled task can automate the backup process, aligning with the organization's preference for a streamlined and recurring approach. Unlike other options, Cloud Storage doesn't require managing complex infrastructure like virtual machines (Compute Engine) or databases (BigQuery, Cloud Datastore) just to store the data, thus achieving a cost-efficient solution. BigQuery is for data analysis, not primary data storage. Cloud Datastore, a NoSQL database, is not suitable for storing raw backups. Compute Engine requires provisioning and managing VMs and storage, increasing the complexity and cost.

For further research, consider these links:

Google Cloud Storage Documentation: <https://cloud.google.com/storage/docs>

gsutil Documentation: <https://cloud.google.com/storage/docs/gsutil>

Question: 32

You are creating an internal App Engine application that needs to access a user's Google Drive on the user's behalf. Your company does not want to rely on the current user's credentials. It also wants to follow Google-recommended practices.

What should you do?

- A. Create a new Service account, and give all application users the role of Service Account User.
- B. Create a new Service account, and add all application users to a Google Group. Give this group the role of Service Account User.
- C. Use a dedicated G Suite Admin account, and authenticate the application's operations with these G Suite credentials.
- D. Create a new service account, and grant it G Suite domain-wide delegation. Have the application use it to impersonate the user.

Answer: D

Explanation:

The correct answer is **D**, creating a new service account with G Suite domain-wide delegation and impersonating the user. Here's why:

Service Accounts for Application Access: Service accounts are designed for applications needing to access Google Cloud resources, instead of relying on individual user credentials. This is a fundamental security practice in cloud environments. [Google Cloud Service Accounts](#)

Avoiding Shared Credentials: Options A, B, and C are problematic. Option A granting all users the Service Account User role is overly permissive, granting them access beyond their needs. Option B still relies on managing group membership, which is cumbersome. Option C is a critical security risk, as a G Suite Admin account should not be used for application operations due to its broad permissions. Sharing credentials for the Admin user is a bad practice that opens the door for severe security risks.

Domain-Wide Delegation for User Impersonation: Domain-wide delegation allows a service account to act on behalf of any user within the G Suite domain, without requiring their explicit consent each time. This is ideal for scenarios where an application needs to access user-specific data, like a user's Google Drive. [Google Workspace domain-wide delegation](#)

Google Recommended Practice: Google recommends using service accounts with domain-wide delegation for situations where an application needs to act on a user's behalf, aligning with least-privilege principles. This approach provides a balance between access requirements and security.

Least Privilege: Using impersonation through domain-wide delegation ensures that the application only accesses the specific user's resources it needs and avoids the risks of broad access or using shared user accounts. This aligns with the concept of least privilege.

No need for user interaction The impersonation feature also allows for automation without any required user interaction.

In summary, Option D is the best practice approach, following Google's recommendations for securing application access to user data in a G Suite environment. It avoids shared credentials, grants only the necessary permissions, and enables seamless operation without direct user credential handling.

Question: 33

A customer wants to move their sensitive workloads to a Compute Engine-based cluster using Managed Instance Groups (MIGs). The jobs are bursty and must be completed quickly. They have a requirement to be able to control

the key lifecycle.

Which boot disk encryption solution should you use on the cluster to meet this customer's requirements?

- A. Customer-supplied encryption keys (CSEK)
- B. Customer-managed encryption keys (CMEK) using Cloud Key Management Service (KMS)
- C. Encryption by default
- D. Pre-encrypting files before transferring to Google Cloud Platform (GCP) for analysis

Answer: B

Explanation:

The correct answer is B, Customer-managed encryption keys (CMEK) using Cloud Key Management Service (KMS). This choice best addresses the customer's need for both controlling the key lifecycle and ensuring data security for their sensitive workloads on Compute Engine MIGs. CMEK empowers the customer to create, manage, and rotate encryption keys within Cloud KMS, providing granular control over the encryption process. In contrast, Customer-supplied encryption keys (CSEK) require the customer to manage keys outside of Google Cloud, adding operational overhead and complexity. While Encryption by default encrypts data at rest with Google-managed keys, it doesn't fulfill the requirement of customer-controlled key lifecycles. Pre-encrypting files offers encryption during transit but does not address encryption at rest on the Compute Engine instances and managed disks. With CMEK, the customer's encryption keys are used to encrypt the boot disks of the Compute Engine instances within the MIG, and they maintain control over key access policies and rotation schedules. This allows them to adhere to compliance requirements and internal security policies. CMEK integrates seamlessly with other GCP services, simplifying key management and security workflows. The bursty nature of the workloads doesn't inherently dictate the encryption method. Instead, the need to control the key lifecycle drives the decision towards CMEK. In summary, CMEK provides the optimal balance of security and control, fulfilling the specific requirements of the customer in this scenario.<https://cloud.google.com/kms/docs/cmek><https://cloud.google.com/compute/docs/disks/customer-managed-encryption>

Question: 34

CertyIQ

Your company is using Cloud Dataproc for its Spark and Hadoop jobs. You want to be able to create, rotate, and destroy symmetric encryption keys used for the persistent disks used by Cloud Dataproc. Keys can be stored in the cloud.

What should you do?

- A. Use the Cloud Key Management Service to manage the data encryption key (DEK).
- B. Use the Cloud Key Management Service to manage the key encryption key (KEK).
- C. Use customer-supplied encryption keys to manage the data encryption key (DEK).
- D. Use customer-supplied encryption keys to manage the key encryption key (KEK).

Answer: B

Explanation:

The correct answer is **B. Use the Cloud Key Management Service to manage the key encryption key (KEK).** Here's why:

Cloud Dataproc, like many Google Cloud services, uses a two-layered encryption approach for data at rest. Data Encryption Keys (DEKs) are used to encrypt the actual data on persistent disks. These DEKs are themselves encrypted using Key Encryption Keys (KEKs). This separation of concerns provides enhanced security.

The question specifically mentions the need to create, rotate, and destroy encryption keys. Cloud Key Management Service (KMS) is the recommended service for managing cryptographic keys in Google Cloud. It enables secure key generation, storage, usage, and lifecycle management, including rotation and destruction.

When using Cloud KMS, you manage the KEK. Google handles the DEK generation and encryption of the data using the managed KEK. This is the recommended approach because you retain control of the root of trust for the encryption while Google handles the complexity of the data encryption process. You don't directly manage the DEKs in this scenario, hence options A and C are incorrect.

Customer-supplied encryption keys (CSEK), which would be options C & D, involve the user providing the key and handling its storage. While these keys offer full control, they come with the burden of security and key lifecycle management. Using CSEK would also not allow rotation of the keys using Cloud KMS capabilities. Since the scenario specifies key rotation, CSEK is a less desirable method. Given the need for rotation and management within the cloud, using KMS is the best practice here.

Therefore, using Cloud KMS to manage the KEK provides the ability to securely create, rotate, and destroy the keys used for encryption of Dataproc persistent disks. This strikes the balance between security control and operational simplicity.

Authoritative Links:

Google Cloud KMS: <https://cloud.google.com/kms/docs>

Cloud Dataproc Encryption Options: <https://cloud.google.com/dataproc/docs/concepts/configuring-clusters/encryption>

Encryption at Rest Overview: <https://cloud.google.com/security/encryption-at-rest>

Question: 35

CertyIQ

You are a member of the security team at an organization. Your team has a single GCP project with credit card payment processing systems alongside web applications and data processing systems. You want to reduce the scope of systems subject to PCI audit standards.

What should you do?

- A. Use multi-factor authentication for admin access to the web application.
- B. Use only applications certified compliant with PA-DSS.
- C. Move the cardholder data environment into a separate GCP project.
- D. Use VPN for all connections between your office and cloud environments.

Answer: C

Explanation:

The correct answer is **C. Move the cardholder data environment into a separate GCP project**. This is the most effective method for reducing the scope of a PCI audit. PCI DSS standards apply to all systems that store, process, or transmit cardholder data (CHD). By isolating the CHD environment into its own project, the remaining projects, hosting web applications and data processing systems, can be explicitly excluded from the PCI audit scope. This significantly reduces the overhead and cost associated with PCI compliance efforts, as you only need to implement and maintain the required security controls within the dedicated project. This approach aligns with the principle of least privilege and segmentation in security architecture. Creating distinct project boundaries provides a clear separation of environments and allows for the application of specific security policies and access controls tailored to the PCI environment, thereby minimizing the attack surface for CHD. Option A, while good security practice, does not reduce audit scope. Option B focuses on application compliance but doesn't address infrastructure scope. Option D addresses network security but also doesn't reduce audit scope.

Authoritative Links:

PCI DSS Requirements: https://www.pcisecuritystandards.org/document_library (Refer to the latest PCI DSS documentation)

Google Cloud Resource Hierarchy: <https://cloud.google.com/resource-manager/docs/cloud-platform-resource-hierarchy> (Understanding project isolation)

Google Cloud Security Best Practices: <https://cloud.google.com/security/> (General security guidance)

Question: 36

CertyIQ

A retail customer allows users to upload comments and product reviews. The customer needs to make sure the text does not include sensitive data before the comments or reviews are published.

Which Google Cloud Service should be used to achieve this?

- A. Cloud Key Management Service
- B. Cloud Data Loss Prevention API
- C. BigQuery
- D. Web Security Scanner

Answer: B

Explanation:

The correct answer is **B. Cloud Data Loss Prevention API (DLP API)**. This service is specifically designed to inspect and redact sensitive data, such as Personally Identifiable Information (PII), within text and structured data. In the context of the retail customer's requirement, the DLP API can be used to scan user-uploaded comments and reviews for sensitive information like credit card numbers, social security numbers, addresses, or phone numbers. It can then mask, redact, or report this information before the content is published, ensuring compliance with privacy regulations and preventing data leaks. Option A, Cloud Key Management Service, is for managing cryptographic keys, not data inspection. Option C, BigQuery, is a data warehouse for large datasets, not for real-time sensitive data identification and redaction. Option D, Web Security Scanner, is a service for identifying security vulnerabilities in websites, not content inspection for sensitive data. Therefore, the DLP API is the only service among the options that directly addresses the stated requirement of preventing sensitive data from being exposed in user-generated content. The DLP API offers various pre-defined detectors and allows for custom detectors, offering a flexible and effective solution for data protection.

Further Research:

Google Cloud DLP API Documentation: <https://cloud.google.com/dlp/docs>

Overview of Cloud DLP: <https://cloud.google.com/dlp/docs/overview>

Cloud DLP Use Cases: <https://cloud.google.com/dlp/docs/use-cases>

Question: 37

CertyIQ

A company allows every employee to use Google Cloud Platform. Each department has a Google Group, with all department members as group members. If a department member creates a new project, all members of that department should automatically have read-only access to all new project resources. Members of any other department should not have access to the project. You need to configure this behavior.

What should you do to meet these requirements?

- A. Create a Folder per department under the Organization. For each department's Folder, assign the Project Viewer role to the Google Group related to that department.
- B. Create a Folder per department under the Organization. For each department's Folder, assign the Project

Browser role to the Google Group related to that department.

C. Create a Project per department under the Organization. For each department's Project, assign the Project Viewer role to the Google Group related to that department.

D. Create a Project per department under the Organization. For each department's Project, assign the Project Browser role to the Google Group related to that department.

Answer: A

Explanation:

Okay, let's break down why option A is the correct approach for this scenario.

The core requirement is to automatically grant read-only access to new projects created by department members to all members of the same department, while isolating projects from other departments. This calls for a hierarchical structure for resource management and access control. Google Cloud Organizations provide this structure, with Folders and Projects as key components.

Folders are designed to group resources logically, often based on departments or environments. Applying IAM (Identity and Access Management) roles at the folder level propagates those roles to all resources within that folder, including new projects created within it.

Option A proposes creating a Folder for each department. This establishes the necessary hierarchical structure. Then, by assigning the "Project Viewer" role to the department's Google Group at the Folder level, all members of that group automatically get read-only (viewer) access to any project created within that folder. This fulfills the "read-only access to all new project resources" requirement for the relevant department. Other departments, which are in different Folders, are naturally excluded.

Option B uses "Project Browser," which is an older term; "Project Viewer" is the currently recommended role for read-only access. Options C and D focus on creating a Project per department, which does not meet the requirement of providing access to new projects created by the department. A project-based approach would require additional configuration for each new project, thereby not meeting the "automatically" requirement.

In summary, the folder hierarchy with role inheritance via IAM solves the problem in an efficient and scalable way.

For further research on IAM and resource hierarchies, refer to the following links:

Google Cloud Resource Hierarchy: <https://cloud.google.com/resource-manager/docs/cloud-platform-resource-hierarchy>

IAM Roles: <https://cloud.google.com/iam/docs/understanding-roles>

Managing access using folders: <https://cloud.google.com/resource-manager/docs/managing-folders>

IAM Policy Inheritance: <https://cloud.google.com/iam/docs/resource-hierarchy-access-control>

Question: 38

CertyIQ

A customer's internal security team must manage its own encryption keys for encrypting data on Cloud Storage and decides to use customer-supplied encryption keys (CSEK).

How should the team complete this task?

A. Upload the encryption key to a Cloud Storage bucket, and then upload the object to the same bucket.

B. Use the gsutil command line tool to upload the object to Cloud Storage, and specify the location of the encryption key.

C. Generate an encryption key in the Google Cloud Platform Console, and upload an object to Cloud Storage using the specified key.

D. Encrypt the object, then use the gsutil command line tool or the Google Cloud Platform Console to upload the object to Cloud Storage.

Answer: B

Explanation:

The correct answer is B because it accurately reflects the process of using Customer-Supplied Encryption Keys (CSEK) with Google Cloud Storage. CSEK allows customers to manage their own encryption keys instead of relying on Google-managed keys. This approach provides greater control over encryption and aligns with the customer's requirement for internal security team management of keys.

Option B, which involves utilizing the gsutil command-line tool, directly aligns with the best practice for uploading objects with CSEK. The gsutil tool provides command-line options to specify the encryption key during the upload process. This avoids the need to store the encryption key within Google Cloud Storage, which would negate the security benefits of CSEK.

Options A, C, and D are incorrect. Option A suggests storing the key in a Cloud Storage bucket, which exposes the key and defeats the purpose of CSEK. Option C suggests creating a key in GCP console; however, CSEK requires you to create and manage the keys yourself, outside of Google. Option D assumes pre-encryption, which is redundant because CSEK uses server-side encryption with customer-provided keys; it is not client-side encryption. Instead, the CSEK is used during the upload process to encrypt data at rest server-side.

Therefore, gsutil is the standard way to specify the encryption key for CSEK during object uploads to Cloud Storage, making option B the correct method for the customer's security team.

Relevant documentation:

Using customer-supplied encryption keys: <https://cloud.google.com/storage/docs/encryption/customer-supplied-keys>

gsutil cp command: <https://cloud.google.com/storage/docs/gsutil/commands/cp>

Question: 39

CertyIQ

A customer has 300 engineers. The company wants to grant different levels of access and efficiently manage IAM permissions between users in the development and production environment projects. Which two steps should the company take to meet these requirements? (Choose two.)

- A. Create a project with multiple VPC networks for each environment.
- B. Create a folder for each development and production environment.
- C. Create a Google Group for the Engineering team, and assign permissions at the folder level.
- D. Create an Organizational Policy constraint for each folder environment.
- E. Create projects for each environment, and grant IAM rights to each engineering user.

Answer: BC

Explanation:

The correct answer is **BC**. Here's a detailed justification:

Option B (Create a folder for each development and production environment) is crucial for establishing a hierarchical resource structure within Google Cloud. Folders allow for the grouping of projects based on environment (development, production, testing, etc.). This organizational structure simplifies access management, as policies applied at the folder level cascade down to all projects within it, enabling efficient permission inheritance. It also aligns with Google Cloud's best practices for resource organization.

Option C (Create a Google Group for the Engineering team, and assign permissions at the folder level) promotes efficient IAM management. Instead of individually granting permissions to 300 engineers, adding

them to a Google Group allows administrators to assign permissions at the folder level to the group. This simplifies administration as adding or removing engineers from the group automatically updates their permissions. This approach leverages the principle of least privilege by assigning permissions at a higher organizational level, allowing for inheritance.

Why other options are incorrect:

A (Create a project with multiple VPC networks for each environment): While VPC networks are crucial for network isolation, using a single project for all environments creates administrative complexity and makes IAM management harder.

D (Create an Organizational Policy constraint for each folder environment): While organization policies are important, they define broader company-wide controls rather than managing permissions for teams. They work in conjunction with folder-based IAM, but alone are insufficient for the described scenario.

E (Create projects for each environment, and grant IAM rights to each engineering user): Granting individual IAM rights to every user is cumbersome, error-prone, and doesn't scale. This creates a significant management overhead, making it difficult to implement consistent security practices.

In summary: Folders are foundational for resource organization, allowing for logical grouping and policy inheritance. Google Groups, combined with folder-level IAM permissions, enable scalable and manageable access control. This combination ensures efficient administration and alignment with cloud security best practices.

Authoritative Links:

Google Cloud Resource Hierarchy: <https://cloud.google.com/resource-manager/docs/cloud-platform-resource-hierarchy>

IAM overview: <https://cloud.google.com/iam/docs/overview>

Google Groups: <https://support.google.com/groups/answer/2464926?hl=en>

Managing access using folders: <https://cloud.google.com/resource-manager/docs/access-control-folders>

Question: 40

CertyIQ

You want to evaluate your organization's Google Cloud instance for PCI compliance. You need to identify Google's inherent controls.

Which document should you review to find the information?

- A. Google Cloud Platform: Customer Responsibility Matrix
- B. PCI DSS Requirements and Security Assessment Procedures
- C. PCI SSC Cloud Computing Guidelines
- D. Product documentation for Compute Engine

Answer: A

Explanation:

The correct answer is A. Google Cloud Platform: Customer Responsibility Matrix. This document is specifically designed to outline the shared responsibility model between Google and its customers when using Google Cloud services. It details which security controls are managed by Google (inherent controls) and which are the responsibility of the customer. This distinction is crucial for understanding the scope of your PCI compliance efforts. For PCI compliance, you need to know what controls are already in place by Google. Options B, C, and D provide information about PCI standards, cloud guidelines, and specific product documentation, but they don't directly detail Google's inherent security controls related to PCI compliance. Option B outlines the overall requirements for PCI compliance, while option C provides general guidelines for implementing PCI in a cloud environment. Option D focuses on specific technical implementations rather than Google's inherent

shared responsibility. The Customer Responsibility Matrix, therefore, provides the essential clarity on how Google assists in your PCI compliance journey through built-in controls, which is the core of the question.

Further Research:

Google Cloud Shared Responsibility Model: <https://cloud.google.com/security/compliance/shared-responsibility>

Customer Responsibility Matrix: <https://cloud.google.com/security/compliance/customer-responsibility-matrix>

Question: 41

CertyIQ

Your company runs a website that will store PII on Google Cloud Platform. To comply with data privacy regulations, this data can only be stored for a specific amount of time and must be fully deleted after this specific period. Data that has not yet reached the time period should not be deleted. You want to automate the process of complying with this regulation.

What should you do?

- A. Store the data in a single Persistent Disk, and delete the disk at expiration time.
- B. Store the data in a single BigQuery table and set the appropriate table expiration time.
- C. Store the data in a single Cloud Storage bucket and configure the bucket's Time to Live.
- D. Store the data in a single BigTable table and set an expiration time on the column families.

Answer: C

Explanation:

The correct answer is **C. Store the data in a single Cloud Storage bucket and configure the bucket's Time to Live.**

Here's why:

Cloud Storage offers a feature called "Object Lifecycle Management," which allows you to automatically delete objects after a specified period using Time to Live (TTL). This directly addresses the requirement to delete data automatically after a set time. By configuring a bucket's TTL policy, objects stored in that bucket will be automatically deleted after the TTL expires, ensuring data privacy compliance. This is a server-side feature that doesn't require any active management from the user, ensuring data deletion regardless of application behavior.

Option A is incorrect because deleting a Persistent Disk also deletes all the data stored on it, regardless of individual data expiration. This doesn't allow for selective deletion based on the age of the PII and is overly aggressive.

Option B, using BigQuery's table expiration, does offer data deletion, but it operates at a table level. Since the requirement implies granular, object-level control, a BigQuery table isn't the right fit for managing time-sensitive PII.

Option D, using Bigtable column family expiration, doesn't offer individual object time-to-live capabilities and thus isn't a suitable solution. Bigtable column families are meant for storing structured data with flexible schema, not time-based object lifecycle management.

Therefore, Cloud Storage with object lifecycle management and TTL offers the best solution for compliant, automated deletion of PII data after a specific time period. This feature allows granular control over object deletion based on their age.

Authoritative Links:

Question: 42

CertyIQ

A DevOps team will create a new container to run on Google Kubernetes Engine. As the application will be internet-facing, they want to minimize the attack surface of the container. What should they do?

- A. Use Cloud Build to build the container images.
- B. Build small containers using small base images.
- C. Delete non-used versions from Container Registry.
- D. Use a Continuous Delivery tool to deploy the application.

Answer: B

Explanation:

The correct answer is **B. Build small containers using small base images**. This choice directly addresses minimizing the attack surface of a container. Smaller base images, like those based on distroless images or minimal operating systems, contain only the necessary libraries and tools to run the application, reducing the number of potential vulnerabilities a malicious actor could exploit. Including unnecessary packages and utilities in larger base images expands the attack surface. Options A, C, and D are important for security and efficient operations but do not directly reduce the attack surface of the container itself. Cloud Build is for building, Container Registry for storing, and CD tools for deploying, while a lean container image reduces the potential entry points of attack. Using small base images implements the principle of least privilege at the container level, making the container inherently more secure. For further reading on best practices for container security, research "container hardening" and "distroless containers."

[Google Cloud Container Security](#)

[Distroless Images](#)

[Kubernetes Security Best Practices](#)

Question: 43

CertyIQ

While migrating your organization's infrastructure to GCP, a large number of users will need to access GCP Console. The Identity Management team already has a well-established way to manage your users and want to keep using your existing Active Directory or LDAP server along with the existing SSO password. What should you do?

- A. Manually synchronize the data in Google domain with your existing Active Directory or LDAP server.
- B. Use Google Cloud Directory Sync to synchronize the data in Google domain with your existing Active Directory or LDAP server.
- C. Users sign in directly to the GCP Console using the credentials from your on-premises Kerberos compliant identity provider.
- D. Users sign in using OpenID (OIDC) compatible IdP, receive an authentication token, then use that token to log in to the GCP Console.

Answer: B

Explanation:

The correct answer is **B. Use Google Cloud Directory Sync to synchronize the data in Google domain with your existing Active Directory or LDAP server**. Here's why:

Google Cloud Directory Sync (GCDS) is specifically designed to synchronize user and group data between an organization's existing directory service (like Active Directory or LDAP) and Google Workspace (which includes Google Cloud Identity). This aligns perfectly with the scenario where the Identity Management team wants to continue managing users through their established on-premises system while providing access to the GCP Console. GCDS automates the process of creating, updating, and deleting user accounts and groups in Google Workspace based on changes in the source directory. This removes the need for manual synchronization, which would be error-prone and inefficient (eliminating option A).

Option C is incorrect because direct sign-in to the GCP Console using on-premises Kerberos credentials is not a standard or supported authentication method. The GCP Console uses Google's Identity Platform. Option D, while involving a valid authentication flow (OIDC), is not the most straightforward solution for synchronizing existing user directory data, and would require additional configurations not covered by the scenario.

By leveraging GCDS, the organization maintains a consistent identity management system, reduces administrative overhead, and ensures users can access GCP Console using their existing SSO password, effectively extending their existing identity infrastructure to Google Cloud. This ensures a smooth transition to the cloud without significant disruption to the existing identity management practices.

Further Research:

Google Cloud Directory Sync: <https://support.google.com/a/answer/1069302?hl=en>

Google Cloud Identity: <https://cloud.google.com/identity/>

Synchronize users from an LDAP directory or Active Directory using GCDS:

<https://support.google.com/a/answer/1069302#zippy=%2Cset-up-directory-sync-for-your-directory>

Question: 44

CertyIQ

Your company is using GSuite and has developed an application meant for internal usage on Google App Engine. You need to make sure that an external user cannot gain access to the application even when an employee's password has been compromised.

What should you do?

- A. Enforce 2-factor authentication in GSuite for all users.
- B. Configure Cloud Identity-Aware Proxy for the App Engine Application.
- C. Provision user passwords using GSuite Password Sync.
- D. Configure Cloud VPN between your private network and GCP.

Answer: A

Explanation:

The correct answer is **A. Enforce 2-factor authentication in GSuite for all users.**

Here's why:

The core issue is preventing unauthorized access even with compromised credentials. Option A directly addresses this by mandating 2-factor authentication (2FA), now commonly referred to as multi-factor authentication (MFA). MFA requires users to provide a second verification factor in addition to their password, significantly reducing the risk of account compromise even if a password is stolen. This second factor could be a code from a mobile app, a security key, or a SMS verification.

Option B, configuring Cloud Identity-Aware Proxy (IAP), is useful for controlling access based on user identity and context, but it doesn't inherently prevent access if the user's credentials are compromised. IAP primarily manages access after authentication. Option C, provisioning user passwords with G Suite Password Sync, is relevant for syncing passwords between G Suite and on-premise directories, but it does not enhance security

against password compromises. Option D, configuring Cloud VPN, would establish a secure tunnel for network traffic, which is not directly related to preventing unauthorized access due to compromised GSuite passwords.

While IAP (option B) can be layered on top of MFA for further security, MFA (option A) is the foundational step for preventing access with stolen credentials. It ensures a secondary layer of verification is required, thereby mitigating the risk associated with compromised passwords. By enforcing 2FA across all GSuite users, access to sensitive internal applications is protected, even if a user's password is compromised.

Therefore, the most effective method is to enforce 2-factor authentication in GSuite.

Authoritative links for further research:

Google Workspace Admin Help: Turn on 2-Step Verification: <https://support.google.com/a/answer/175197?hl=en>

Google Cloud Documentation: Identity-Aware Proxy Overview: <https://cloud.google.com/iap/docs/concepts-overview>

Question: 45

CertyIQ

A large financial institution is moving its Big Data analytics to Google Cloud Platform. They want to have maximum control over the encryption process of data stored at rest in BigQuery. What technique should the institution use?

- A. Use Cloud Storage as a federated Data Source.
- B. Use a Cloud Hardware Security Module (Cloud HSM).
- C. Customer-managed encryption keys (CMEK).
- D. Customer-supplied encryption keys (CSEK).

Answer: C

Explanation:

The correct answer is C, Customer-managed encryption keys (CMEK). CMEK gives the financial institution the highest level of control over encryption keys used to protect data at rest in BigQuery. With CMEK, the customer manages the keys in Cloud KMS, granting them direct control over key lifecycle, access policies, and usage. This is superior to Google-managed keys because it allows the institution to enforce its own security policies and compliance requirements. Cloud Storage as a federated data source (Option A) only addresses data storage locations, not encryption control in BigQuery. Cloud HSM (Option B) is a hardware solution that can store keys, but CMEK uses those keys for BigQuery encryption. Customer-supplied encryption keys (CSEK) (Option D) would require the customer to supply encryption keys every time data is written, which is highly impractical for BigQuery operations and not recommended. CMEK provides a balance of security and usability, suitable for sensitive financial data needing strong encryption controls. CMEK is ideal for scenarios where compliance regulations demand explicit control of encryption keys.

Authoritative Links:

Google Cloud Documentation on CMEK in BigQuery: <https://cloud.google.com/bigquery/docs/customer-managed-encryption>

Google Cloud Documentation on Cloud KMS: <https://cloud.google.com/kms/docs>

Google Cloud Documentation on CSEK: <https://cloud.google.com/storage/docs/encryption/customer-supplied-keys>

Question: 46

A company is deploying their application on Google Cloud Platform. Company policy requires long-term data to be stored using a solution that can automatically replicate data over at least two geographic places. Which Storage solution are they allowed to use?

- A. Cloud Bigtable
- B. Cloud BigQuery
- C. Compute Engine SSD Disk
- D. Compute Engine Persistent Disk

Answer: B

Explanation:

The correct answer is **B. Cloud BigQuery**. Here's why:

Cloud BigQuery is a fully managed, serverless data warehouse that automatically replicates data across multiple availability zones within a region. Crucially, BigQuery's geo-replication feature allows for the storage and replication of data in two or more geographically distinct places, meeting the requirement of the company policy. This is done to ensure high availability and durability. Data is replicated automatically as data is ingested into the system, making it highly resilient to data loss and regional outages.

Cloud Bigtable (A) is a NoSQL wide-column store that can be replicated but does not offer built in geo-replication as part of its design. It might be achieved with complex custom scripts and is not as straightforward. Compute Engine SSD Disk (C) and Persistent Disk (D) are block storage options tied to specific Compute Engine instances. While they can offer regional redundancy via replication across zones within a region, they do not inherently provide geo-replication to separate geographic locations. Additionally, these options are not designed for long-term data storage in the way that a data warehouse is, and require more administrative overhead.

In summary, BigQuery's inherent multi-region replication capabilities align directly with the company's requirement for long-term storage replicated across at least two geographic places, making it the most suitable solution among the options.

Further research:

[BigQuery Multi-region datasets](#)

[BigQuery Data Storage](#)

[Bigtable replication](#)

[Compute Engine Persistent Disk regions and zones](#)

Question: 47

A large e-retailer is moving to Google Cloud Platform with its ecommerce website. The company wants to ensure payment information is encrypted between the customer's browser and GCP when the customers checkout online. What should they do?

- A. Configure an SSL Certificate on an L7 Load Balancer and require encryption.
- B. Configure an SSL Certificate on a Network TCP Load Balancer and require encryption.
- C. Configure the firewall to allow inbound traffic on port 443, and block all other inbound traffic.
- D. Configure the firewall to allow outbound traffic on port 443, and block all other outbound traffic.

Answer: A

Explanation:

Here's a detailed justification for why option A is the correct answer, along with supporting information and links:

Option A, "Configure an SSL Certificate on an L7 Load Balancer and require encryption," is the correct approach for securing payment information during online checkout. Layer 7 (Application Layer) load balancers, such as Google Cloud's HTTP(S) Load Balancing, are designed to handle HTTP/HTTPS traffic. They can terminate SSL/TLS connections, decrypting the incoming encrypted traffic before forwarding it to the backend servers. This process is crucial because the browser, customer, initiates the encrypted connection on port 443 to protect sensitive information like payment details. By configuring an SSL certificate on the load balancer, you ensure that the connection from the customer's browser is encrypted all the way to the load balancer. The load balancer handles the certificate management, simplifying the process. The "require encryption" part of the answer ensures that only encrypted traffic is accepted. This prevents insecure, unencrypted connections. L7 load balancers also provide features like content-based routing, which is not relevant to this question but further reinforces why it's the correct choice.

Option B, "Configure an SSL Certificate on a Network TCP Load Balancer and require encryption," is incorrect. Network TCP Load Balancers operate at Layer 4 (Transport Layer) of the OSI model and do not terminate SSL/TLS connections. They simply forward traffic based on IP addresses and ports. Therefore, they are unsuitable for encrypting and decrypting HTTPS traffic. While they can forward traffic on port 443, the SSL termination point needs to be an application-aware component, and this is not a TCP Load Balancer.

Option C, "Configure the firewall to allow inbound traffic on port 443, and block all other inbound traffic," is necessary but insufficient. Allowing inbound traffic on port 443 enables HTTPS traffic to reach the load balancer, but it does not handle encryption itself. This is a fundamental step, but not the complete solution.

Option D, "Configure the firewall to allow outbound traffic on port 443, and block all other outbound traffic," is also incorrect. Blocking outbound traffic on port 443 prevents backend services from making secure HTTPS calls, which is not the objective of securing the customer-to-GCP connection for payment information.

In summary, the L7 load balancer with SSL termination is the standard and best practice for securing HTTPS traffic in cloud environments.

Authoritative Links:

Google Cloud Load Balancing: <https://cloud.google.com/load-balancing>

HTTPS Load Balancing: <https://cloud.google.com/load-balancing/docs/https>

SSL/TLS Certificates: <https://cloud.google.com/certificate-manager/docs/overview>

OSI Model: <https://www.cloudflare.com/learning/network-layer/what-is-the-osi-model/>

Question: 48

CertyIQ

Applications often require access to `secrets` - small pieces of sensitive data at build or run time. The administrator managing these secrets on GCP wants to keep a track of `who did what, where, and when?` within their GCP projects.

Which two log streams would provide the information that the administrator is looking for? (Choose two.)

- A. Admin Activity logs
- B. System Event logs
- C. Data Access logs
- D. VPC Flow logs
- E. Agent logs

Answer: AC

Explanation:

The correct answer is **A. Admin Activity logs** and **C. Data Access logs**. Here's why:

Admin Activity logs, also known as audit logs, record administrative actions or API calls that modify the configuration or metadata of resources within your Google Cloud Platform (GCP) project. These logs track activities like creation, deletion, or modification of secrets, along with who performed the action and when. This aligns perfectly with the administrator's requirement to track "who did what, where, and when."

Data Access logs, specifically the "ADMIN_READ" type, capture instances when a user or service account accesses sensitive data, including secrets stored in services like Secret Manager. This log type helps monitor the retrieval or viewing of secrets. By enabling both Admin Activity and Data Access logs, the administrator can effectively track both the management and access of secrets, fulfilling the requirement of identifying "who did what, where, and when" concerning sensitive data.

System Event logs (B) primarily focus on system events, such as virtual machine restarts or hardware failures, which are not directly related to secret management or access. VPC Flow logs (D) track network traffic flows within your VPC, not user interactions or secret accesses. Agent logs (E) are specific to application agents and do not provide consolidated insights into secret management within GCP.

Therefore, for the administrator's needs of monitoring secret management and access, Admin Activity logs and Data Access logs are the appropriate choices.

For further research, consult the following resources:

Google Cloud Logging Overview: <https://cloud.google.com/logging/docs/overview>

Google Cloud Audit Logging: <https://cloud.google.com/logging/docs/audit>

Data Access Audit Logs: <https://cloud.google.com/logging/docs/audit/data-access>

Secret Manager Logging: <https://cloud.google.com/secret-manager/docs/audit-logging>

Question: 49

CertyIQ

You are in charge of migrating a legacy application from your company datacenters to GCP before the current maintenance contract expires. You do not know what ports the application is using and no documentation is available for you to check. You want to complete the migration without putting your environment at risk. What should you do?

- A. Migrate the application into an isolated project using a Lift & Shift approach. Enable all internal TCP traffic using VPC Firewall rules. Use VPC Flow logs to determine what traffic should be allowed for the application to work properly.
- B. Migrate the application into an isolated project using a Lift & Shift approach in a custom network. Disable all traffic within the VPC and look at the Firewall logs to determine what traffic should be allowed for the application to work properly.
- C. Refactor the application into a micro-services architecture in a GKE cluster. Disable all traffic from outside the cluster using Firewall Rules. Use VPC Flow logs to determine what traffic should be allowed for the application to work properly.
- D. Refactor the application into a micro-services architecture hosted in Cloud Functions in an isolated project. Disable all traffic from outside your project using Firewall Rules. Use VPC Flow logs to determine what traffic should be allowed for the application to work properly.

Answer: A

Explanation:

The correct answer is **A**. Here's why:

Option A proposes a practical approach for migrating a legacy application with unknown port requirements, prioritizing security. The "Lift & Shift" approach in an isolated project allows for a controlled environment, preventing unintended exposure of the application to the wider organization. Allowing all internal TCP traffic initially, while not ideal long-term, is a pragmatic step to ensure the application functions immediately after migration. Subsequently, VPC Flow Logs can be used to observe actual traffic patterns, revealing the specific ports in use. This allows for the creation of finely tuned firewall rules that restrict access only to necessary communication pathways. The combination of broad allowance initially followed by precise restriction based on real traffic, minimizes risk and is suitable in situations where legacy app documentation is unavailable.

Options B, C, and D are less suitable:

Option B suggests disabling all traffic which will break the application immediately. While secure, it requires a very granular firewall rule configuration that would need to be guessed, leading to prolonged downtime and debugging time.

Option C, while potentially more secure and scalable long-term, is not appropriate for this scenario given the time constraint (the maintenance contract is expiring) and lack of knowledge about the application's functionality. Refactoring to microservices in GKE is time-consuming.

Option D, similar to C, involves a significant refactoring to a serverless architecture that is not feasible for an immediate migration given the deadlines and lack of documentation.

In summary, Option A's phased approach, using broad initial allowance followed by precise restrictions based on observed traffic patterns, offers the most practical and secure solution for the given scenario, balancing immediate functionality with long-term security.

Supporting Links:

VPC Flow Logs: <https://cloud.google.com/vpc/docs/using-flow-logs>

VPC Firewall Rules: <https://cloud.google.com/vpc/docs/firewalls>

Lift and Shift Migration: <https://cloud.google.com/architecture/migration/lift-and-shift>

Question: 50

CertyIQ

Your company has deployed an application on Compute Engine. The application is accessible by clients on port 587. You need to balance the load between the different instances running the application. The connection should be secured using TLS, and terminated by the Load Balancer. What type of Load Balancing should you use?

- A. Network Load Balancing
- B. HTTP(S) Load Balancing
- C. TCP Proxy Load Balancing
- D. SSL Proxy Load Balancing

Answer: D

Explanation:

Here's a detailed justification for choosing SSL Proxy Load Balancing (Option D) in this scenario:

The key requirements are load balancing a TCP application accessible via port 587 and terminating TLS at the load balancer. This combination dictates the appropriate load balancing solution.

SSL Proxy Load Balancing is specifically designed to handle TLS/SSL connections and decrypt them at the load balancer itself. This means the backend instances running the application receive unencrypted traffic. This aligns perfectly with the requirement for TLS termination.

HTTP(S) Load Balancing (Option B) is designed for HTTP(S) traffic and primarily operates at Layer 7

(application layer). While it can also handle TLS, it expects HTTP(S) protocols. This doesn't fit the requirement as the traffic is not HTTP(S).

Network Load Balancing (Option A) operates at Layer 4 (network layer) and simply forwards traffic based on IP address and port. It does not provide TLS termination or load balancing based on application content. Therefore, it cannot be used in this case because of the need for TLS termination.

TCP Proxy Load Balancing (Option C) is useful for TCP traffic but does not inherently provide TLS termination. Therefore, it will not fulfill the requirement of terminating TLS at the load balancer.

SSL Proxy Load Balancing handles the connection setup, TLS handshake, and decryption. This takes the load off the backend instances and provides a better experience for clients. The traffic between the load balancer and backend instances can be unencrypted, improving backend performance. This separation of concerns is a best practice for application security and performance.

In summary, SSL Proxy Load Balancing is the best fit here as it addresses the specific needs: load balancing TCP traffic on port 587 while terminating TLS at the load balancer.

Supporting Links:

Google Cloud Load Balancing Overview: <https://cloud.google.com/load-balancing/docs/load-balancing-overview>

SSL Proxy Load Balancing: <https://cloud.google.com/load-balancing/docs/ssl>

Choosing a Load Balancer: <https://cloud.google.com/load-balancing/docs/choosing-load-balancer>

Question: 51

CertyIQ

You want to limit the images that can be used as the source for boot disks. These images will be stored in a dedicated project. What should you do?

- A. Use the Organization Policy Service to create a `compute.trustedimageProjects` constraint on the organization level. List the trusted project as the whitelist in an allow operation.
- B. Use the Organization Policy Service to create a `compute.trustedimageProjects` constraint on the organization level. List the trusted projects as the exceptions in a deny operation.
- C. In Resource Manager, edit the project permissions for the trusted project. Add the organization as member with the role: Compute Image User.
- D. In Resource Manager, edit the organization permissions. Add the project ID as member with the role: Compute Image User.

Answer: A

Explanation:

Option A is the correct approach for limiting boot disk images. The `compute.trustedimageProjects` constraint within the Organization Policy Service is designed explicitly for this purpose. By applying this constraint at the organization level, you ensure that the policy applies to all projects within the organization. Setting the allow operation and whitelisting the dedicated project enforces that only images from that specific project can be used for creating boot disks. This creates a centralized and consistent policy across the entire organization, enhancing security and compliance. Options B, C, and D are incorrect. Option B uses a deny operation which, in this case, would block usage of images from every project except the one specified. This isn't the desired outcome, which is to specifically allow from one project. Option C involves granting a compute image user role at the project level to the whole organization, this is too broad and does not restrict other projects from supplying images. Option D attempts to grant the Compute Image User role to a project, which doesn't make sense. Project IDs are not members that can be assigned roles at the organization level.

Authoritative Links:

Organization Policy Service: <https://cloud.google.com/resource-manager/docs/organization-policy/overview>
compute.trustedimageProjects Constraint: <https://cloud.google.com/resource-manager/docs/organization-policy/constraints/compute-constraints#compute.trustedimageprojects>
Understanding Resource Hierarchy: <https://cloud.google.com/resource-manager/docs/cloud-platform-resource-hierarchy>

Question: 52

CertyIQ

Your team needs to prevent users from creating projects in the organization. Only the DevOps team should be allowed to create projects on behalf of the requester.

Which two tasks should your team perform to handle this request? (Choose two.)

- A. Remove all users from the Project Creator role at the organizational level.
- B. Create an Organization Policy constraint, and apply it at the organizational level.
- C. Grant the Project Editor role at the organizational level to a designated group of users.
- D. Add a designated group of users to the Project Creator role at the organizational level.
- E. Grant the billing account creator role to the designated DevOps team.

Answer: AD

Explanation:

Here's a detailed justification for why options A and D are the correct choices, and why the others are incorrect:

Why A and D are correct:

A. Remove all users from the Project Creator role at the organizational level: The core of the requirement is to prevent most users from creating projects. The Project Creator role grants the ability to create new projects within an organization. Removing this role from all users at the organizational level effectively accomplishes this limitation for the general population. <https://cloud.google.com/iam/docs/understanding-roles#project-roles>

D. Add a designated group of users to the Project Creator role at the organizational level: The DevOps team needs the ability to create projects. Granting the Project Creator role specifically to a designated group (in this case, the DevOps team) at the organizational level ensures that only they retain this permission. This directly fulfills the requirement that only the DevOps team should be able to create projects. <https://cloud.google.com/iam/docs/granting-changing-revoking-access>

By implementing both A and D, you achieve the desired outcome: no user can create projects except for the explicitly granted members of the DevOps team. This employs the principle of least privilege, granting only the necessary permissions to the designated team.

Why B and C are incorrect:

B. Create an Organization Policy constraint, and apply it at the organizational level: While organization policies can control many aspects of project creation (like allowed regions or resource types), there isn't a direct policy constraint to completely disable project creation at the organizational level and then delegate to a specific group of users. They control what can be created, not who can create projects. IAM roles are the appropriate mechanism for controlling access and permissions. <https://cloud.google.com/resource-manager/docs/organization-policy/overview>

C. Grant the Project Editor role at the organizational level to a designated group of users: The Project Editor role allows users to modify existing projects, but it does not grant the permission to create new projects.

Therefore, this would not solve the primary requirement of enabling the DevOps team to create projects. This approach would not allow the DevOps team to create the required projects, and the user request would not be met. <https://cloud.google.com/iam/docs/understanding-roles#project-roles>

Why E is not in the answer:

E. Grant the billing account creator role to the designated DevOps team: The billing account creator role provides the permissions to link a project to a billing account, but this is not related to project creation itself. This is an orthogonal concern and is not a part of the immediate goal. This role manages billing responsibilities, not project creation rights. <https://cloud.google.com/billing/docs/how-to/billing-access>

Question: 53

CertyIQ

A customer deployed an application on Compute Engine that takes advantage of the elastic nature of cloud computing.

How can you work with Infrastructure Operations Engineers to best ensure that Windows Compute Engine VMs are up to date with all the latest OS patches?

- A. Build new base images when patches are available, and use a CI/CD pipeline to rebuild VMs, deploying incrementally.
- B. Federate a Domain Controller into Compute Engine, and roll out weekly patches via Group Policy Object.
- C. Use Deployment Manager to provision updated VMs into new serving Instance Groups (IGs).
- D. Reboot all VMs during the weekly maintenance window and allow the StartUp Script to download the latest patches from the internet.

Answer: A

Explanation:

Option A, rebuilding VMs with updated base images via a CI/CD pipeline, is the most robust approach to patching Windows Compute Engine VMs in an elastic environment. This method aligns with the principles of immutable infrastructure, where servers are replaced rather than modified in place, minimizing configuration drift and inconsistencies. By baking in the latest OS patches into the base image, you ensure that each new instance deployed is already secure and up-to-date. A CI/CD pipeline facilitates this process by automating the image building, testing, and deployment, allowing for frequent updates with minimal manual effort. Furthermore, incremental deployments using new instance groups allow you to gradually roll out changes while minimizing service disruption. Option B, while feasible, introduces complexity by relying on domain controllers and group policy within Google Cloud. It also adds overhead, with domain controllers needing to be managed, making it less suitable for highly elastic environments. Option C, using Deployment Manager, is a valid infrastructure-as-code approach, but it does not address the core requirement of frequently updating base images. It also lacks the automated testing aspect inherent to CI/CD. Option D, relying on startup scripts and reboots, is the least reliable and least scalable option. It introduces race conditions, prolongs the startup process, and can lead to inconsistencies in the patch level of VMs. It also doesn't facilitate testing. In summary, the CI/CD approach to rebuild VMs with updated base images aligns with cloud native best practices and offers the most consistent, reliable and scalable method to manage OS patching in an elastic cloud environment.

Authoritative Links:

Immutable Infrastructure: <https://martinfowler.com/bliki/ImmutableServer.html>

Google Cloud CI/CD: <https://cloud.google.com/solutions/devops/devops-continuous-delivery>

Compute Engine Instance Templates: <https://cloud.google.com/compute/docs/instance-templates>

Instance Groups: <https://cloud.google.com/compute/docs/instance-groups>

Question: 54

Your team needs to make sure that their backend database can only be accessed by the frontend application and no other instances on the network.
How should your team design this network?

- A. Create an ingress firewall rule to allow access only from the application to the database using firewall tags.
- B. Create a different subnet for the frontend application and database to ensure network isolation.
- C. Create two VPC networks, and connect the two networks using Cloud VPN gateways to ensure network isolation.
- D. Create two VPC networks, and connect the two networks using VPC peering to ensure network isolation.

Answer: A

Explanation:

The most effective and efficient way to restrict database access to only the frontend application is by using firewall rules with tags, as proposed in option A. This approach leverages Google Cloud's Virtual Private Cloud (VPC) firewall capabilities to control network traffic at the instance level. Assigning a firewall tag to the frontend application instances and the database instances allows the creation of an ingress rule on the database network that permits traffic exclusively from the application's tag. This precisely defines the permitted communication path, denying all other connections.

Option B, using separate subnets, provides a degree of isolation but does not, on its own, prevent unauthorized access. Instances in different subnets within the same VPC can still communicate by default. Firewall rules would still be needed to enforce access control. Options C and D introduce unnecessarily complex network segmentation. Creating separate VPCs and connecting them with Cloud VPN or VPC Peering is more appropriate for establishing connectivity between distinct environments or organizations, not for isolating two services within the same application. It adds administrative overhead and infrastructure complexity that is not necessary for the given requirement. Using tags and firewall rules is the most granular, cost-effective, and manageable way to enforce security requirements within the same VPC.

In summary, option A provides the most direct, efficient, and cost-effective way to fulfill the requirement of allowing only the frontend application to access the database, aligning with the principle of least privilege.

Supporting Documentation:

VPC Firewall rules overview: <https://cloud.google.com/vpc/docs/firewalls>

Using target tags: https://cloud.google.com/vpc/docs/firewalls#target_tags

Network isolation concepts: <https://cloud.google.com/vpc/docs/concepts-networks#isolation>

Question: 55

An organization receives an increasing number of phishing emails.
Which method should be used to protect employee credentials in this situation?

- A. Multifactor Authentication
- B. A strict password policy
- C. Captcha on login pages
- D. Encrypted emails

Answer: A

Explanation:

The most effective method to protect employee credentials against phishing emails is **Multifactor Authentication (MFA)**. Phishing attacks aim to steal usernames and passwords. While strict password policies (Option B) might make passwords harder to guess, they don't prevent successful phishing where users willingly give their credentials. Captchas (Option C) prevent automated bots, not malicious actors who trick users into entering their information. Encrypted emails (Option D) protect the content of messages but don't prevent credential theft if a user enters their details on a fake login page linked from the email. MFA adds an extra layer of security beyond just a password, requiring users to provide a second verification factor, such as a code from an authenticator app, a biometric scan, or a one-time SMS code. Even if a phisher obtains a user's password, they cannot access the account without this second factor. This significantly reduces the risk of account compromise, making MFA a crucial defense mechanism against phishing. Common cloud identity and access management solutions offer robust MFA options.

Authoritative Links:

Google Cloud Documentation on MFA: <https://cloud.google.com/identity/docs/multi-factor-authentication>

NIST Guidelines on MFA: <https://csrc.nist.gov/publications/detail/sp/800-63b/final>

OWASP on Phishing Prevention: <https://owasp.org/www-project-top-ten/> (While not specifically about MFA, it contextualizes phishing threats.)

Question: 56

CertyIQ

A customer is collaborating with another company to build an application on Compute Engine. The customer is building the application tier in their GCP Organization, and the other company is building the storage tier in a different GCP Organization. This is a 3-tier web application. Communication between portions of the application must not traverse the public internet by any means.

Which connectivity option should be implemented?

- A. VPC peering
- B. Cloud VPN
- C. Cloud Interconnect
- D. Shared VPC

Answer: A

Explanation:

The correct answer is **A. VPC peering**. Here's why:

VPC peering enables private communication between two VPC networks, regardless of whether they reside in the same or different Google Cloud organizations. This fulfills the requirement that traffic should not traverse the public internet. VPC peering establishes a direct, private connection between the two VPC networks, allowing resources in each to communicate using internal IP addresses. This connection is highly secure and operates within Google's backbone network.

Options B, C and D, while they establish private connectivity, are less suitable for this specific scenario. Cloud VPN (B) uses encrypted tunnels over the public internet, failing to meet the requirement of avoiding public internet completely. Cloud Interconnect (C) is best for connecting on-premises networks to GCP, and in the given context, there is not an on-premise environment mentioned in the prompt. Shared VPC (D) is used within the same organization to share networks, making it unsuitable since both companies are using different GCP Organizations.

VPC peering is purpose-built for connecting VPC networks across projects and organizations. It's easier to configure than other options and provides a scalable, high-performance link for private network communication. Therefore, for establishing private connectivity between two VPC networks owned by

separate organizations without public internet exposure, VPC peering is the ideal choice for this particular scenario.

For further research, refer to the official Google Cloud documentation on VPC peering:<https://cloud.google.com/vpc/docs/vpc-peering>

Question: 57

CertyIQ

Your team wants to make sure Compute Engine instances running in your production project do not have public IP addresses. The frontend application Compute Engine instances will require public IPs. The product engineers have the Editor role to modify resources. Your team wants to enforce this requirement. How should your team meet these requirements?

- A. Enable Private Access on the VPC network in the production project.
- B. Remove the Editor role and grant the Compute Admin IAM role to the engineers.
- C. Set up an organization policy to only permit public IPs for the front-end Compute Engine instances.
- D. Set up a VPC network with two subnets: one with public IPs and one without public IPs.

Answer: C

Explanation:

The correct answer is **C. Set up an organization policy to only permit public IPs for the front-end Compute Engine instances.**

Here's why:

Organization Policies for Centralized Control: Google Cloud Organization Policies allow administrators to define constraints at the organization, folder, or project level. These policies enforce rules that cannot be easily overridden by users within the defined scope, ensuring consistency and security across your cloud environment. This is crucial for enforcing the requirement that production instances lack public IPs.

Targeted Constraint Application: Organization policies can be granular. We don't want to block all public IPs, only those for non-frontend instances. The `constraints/compute.restrictPublicIP` constraint is ideal here as it allows you to define exceptions for specific resources, like the frontend application instances. You can specify the allowed resources by tagging them and granting them an explicit exception within the policy.

IAM Role Management is Secondary: While controlling IAM roles (like Editor or Compute Admin) is important for managing who can make changes, it doesn't inherently enforce the type of change being made. Removing the Editor role (Option B) and changing it to Compute Admin is a way to restrict modification capability but does not specifically address the public IP issue as described, it could instead, increase the work load of users.

Private Access Doesn't Prevent Public IPs: Enabling Private Access (Option A) allows VMs without public IPs to reach Google APIs and services. However, it doesn't prevent a user with proper permissions from creating a VM with a public IP address.

VPC Subnets Won't Enforce the Policy: Setting up separate subnets (Option D) is a good practice for network segmentation, but it relies on project-level configurations and doesn't enforce the required policy. Users with sufficient privileges can still configure instances in the "private" subnet with a public IP.

In summary: Organization policies provide the necessary centralized enforcement mechanism to restrict public IP usage on production instances, while still allowing the required public IPs for the specified front-end instances. This method is the most secure and efficient way to meet the stated requirements.

Authoritative Links:

Google Cloud Organization Policies: <https://cloud.google.com/resource-manager/docs/organization-policy/overview>

compute.restrictPublicIP Constraint: <https://cloud.google.com/resource-manager/docs/organization-policy/org-policy-constraints#constraints/compute.restrictPublicIp>

Question: 58

CertyIQ

Which two security characteristics are related to the use of VPC peering to connect two VPC networks? (Choose two.)

- A. Central management of routes, firewalls, and VPNs for peered networks
- B. Non-transitive peered networks; where only directly peered networks can communicate
- C. Ability to peer networks that belong to different Google Cloud organizations
- D. Firewall rules that can be created with a tag from one peered network to another peered network
- E. Ability to share specific subnets across peered networks

Answer: BC

Explanation:

Here's a detailed justification for why options B and C are the correct answers regarding security characteristics of VPC peering:

Option B: Non-transitive peered networks is accurate because VPC peering creates a direct connection between two VPC networks. This connection is not transitive; meaning, if VPC A is peered with VPC B and VPC B is peered with VPC C, VPC A and VPC C cannot communicate directly through peering unless they are explicitly peered with each other. This non-transitivity enhances security by limiting the scope of network access, reducing the risk of unintended lateral movement. It enforces a more controlled network topology.

Option C: Ability to peer networks that belong to different Google Cloud organizations is also a core feature of VPC peering. This enables secure cross-organization collaboration, allowing networks within separate Google Cloud organizations to communicate directly without needing to traverse the public internet. This feature is crucial for scenarios like mergers, acquisitions, or partnerships where multiple organizations need to securely connect their cloud infrastructure. However, it requires proper role and permission management to ensure secure peering.

Why other options are incorrect:

Option A: Central management...: VPC peering doesn't provide central management of routes, firewalls, or VPNs across peered networks. Each VPC network retains its own independent routing, firewall, and VPN configurations.

Option D: Firewall rules that can be created with a tag...: While you can use tags within a network for firewall rules, you cannot directly reference tags from one peered network in the firewall rules of another peered network. Firewall rules are applied within the scope of a single VPC network.

Option E: Ability to share specific subnets...: VPC peering connects entire VPC networks and does not involve sharing specific subnets. If you need to share IP ranges across networks, it's handled at the networking configurations and routing level rather than at the peering level directly.

In summary: VPC peering's security model focuses on direct, non-transitive connections between networks. It facilitates secure communication between networks across different organizations while maintaining network isolation.

Authoritative links:

Google Cloud VPC Peering Documentation: <https://cloud.google.com/vpc/docs/vpc-peering>

VPC Network Overview: <https://cloud.google.com/vpc/docs/vpc>

Question: 59

CertyIQ

A patch for a vulnerability has been released, and a DevOps team needs to update their running containers in Google Kubernetes Engine (GKE).

How should the DevOps team accomplish this?

- A. Use Puppet or Chef to push out the patch to the running container.
- B. Verify that auto upgrade is enabled; if so, Google will upgrade the nodes in a GKE cluster.
- C. Update the application code or apply a patch, build a new image, and redeploy it.
- D. Configure containers to automatically upgrade when the base image is available in Container Registry.

Answer: C

Explanation:

The correct approach to patching a running container in Google Kubernetes Engine (GKE) involves rebuilding and redeploying the container image. Option C accurately describes this process. Container images are immutable; they cannot be directly patched while running. Attempting to modify a running container (as suggested in options A and D) goes against this core principle of containerization. Option A, suggesting tools like Puppet or Chef, is more appropriate for configuring the host operating system of the nodes themselves, not the containers. Option B, while auto-upgrade is a beneficial feature for GKE nodes, it doesn't patch the application within the container. Therefore, patching the vulnerability involves updating the application code or applying the patch, then building a new container image. This new image should then be deployed to replace the existing containers in GKE. This strategy ensures the immutability of containers, enables repeatable deployments, and allows for rollbacks if necessary. It also follows standard DevOps practices for containerized applications. For further reading on best practices in container image management, consult the official Google Cloud documentation: <https://cloud.google.com/kubernetes-engine/docs/concepts/container-image> and <https://cloud.google.com/blog/products/containers-kubernetes/kubernetes-best-practices-upgrading-your-application>.

Question: 60

CertyIQ

A company is running their webshop on Google Kubernetes Engine and wants to analyze customer transactions in BigQuery. You need to ensure that no credit card numbers are stored in BigQuery.

What should you do?

- A. Create a BigQuery view with regular expressions matching credit card numbers to query and delete affected rows.
- B. Use the Cloud Data Loss Prevention API to redact related infoTypes before data is ingested into BigQuery.
- C. Leverage Security Command Center to scan for the assets of type Credit Card Number in BigQuery.
- D. Enable Cloud Identity-Aware Proxy to filter out credit card numbers before storing the logs in BigQuery.

Answer: B

Explanation:

Okay, let's break down why option B is the correct solution and why the others are not ideal for preventing

credit card numbers from being stored in BigQuery.

Option B, using the Cloud Data Loss Prevention (DLP) API to redact sensitive data before ingestion, is the most appropriate solution for this scenario. DLP is specifically designed to identify, classify, and mask sensitive information. By integrating DLP into the data pipeline before data is loaded into BigQuery, we ensure that credit card numbers are detected and replaced (e.g., with hash tokens, redaction characters) in real-time before reaching the storage layer. This approach actively prevents sensitive data from being stored in the target database, providing a robust proactive security measure. Data is never exposed within BigQuery, enhancing security.

Option A, creating a BigQuery view with regular expressions, is a reactive, not a proactive, approach. It attempts to mask or delete data after it has been stored, leaving a window of vulnerability where sensitive data is present within BigQuery. While helpful for querying purposes, it does not prevent the sensitive data from landing in BigQuery. Deleting data based on regex does not guarantee complete coverage as credit card patterns can vary. It's also not scalable and will require frequent updates.

Option C, leveraging Security Command Center to scan for credit card numbers, is another reactive approach. Security Command Center is beneficial for post-storage analysis and alerting, but it will flag existing sensitive data already inside the BigQuery tables. It doesn't prevent the sensitive data from being stored initially and only discovers vulnerabilities after they exist. This is suitable for compliance reporting but not a preventive mechanism for this use case.

Option D, enabling Cloud Identity-Aware Proxy (IAP), is designed to control access to applications, not to filter data content. IAP works at the application layer and does not have the necessary content-aware capabilities to parse customer transaction data to identify and mask credit card numbers. It focuses on authentication and authorization but not data sanitization.

Key Takeaway: Prevention is always preferable to detection and remediation when dealing with sensitive data. DLP provides the best preventative method as it acts directly before storage.

Authoritative Links for further Research:

Cloud DLP: <https://cloud.google.com/dlp/docs>

BigQuery: <https://cloud.google.com/bigquery/docs>

Security Command Center: <https://cloud.google.com/security-command-center/docs>

Identity-Aware Proxy: <https://cloud.google.com/iap/docs>

Question: 61

CertyIQ

A customer wants to deploy a large number of 3-tier web applications on Compute Engine. How should the customer ensure authenticated network separation between the different tiers of the application?

- A. Run each tier in its own Project, and segregate using Project labels.
- B. Run each tier with a different Service Account (SA), and use SA-based firewall rules.
- C. Run each tier in its own subnet, and use subnet-based firewall rules.
- D. Run each tier with its own VM tags, and use tag-based firewall rules.

Answer: B

Explanation:

The correct answer is B: Run each tier with a different Service Account (SA), and use SA-based firewall rules. This approach provides the most robust and granular level of authenticated network separation between application tiers. Service Accounts are IAM identities that allow Compute Engine instances to act as that identity, authorizing them for specific actions. By assigning distinct SAs to each tier (e.g., web tier, application

tier, database tier), you establish a clear, auditable identity for each tier. Then, firewall rules can be defined to only allow connections based on the source SA. For example, only instances with the "application tier" SA would be allowed to connect to instances with the "database tier" SA. This method provides authentication, ensuring that only instances acting as the intended tier can communicate. Options C and D rely solely on network locations (subnets) or VM tags which are not a form of authenticated access. Project labels are for organization and billing and don't provide network segmentation capabilities. SA-based firewalls are more dynamic than subnet-based because VM instances can be moved across subnets and maintain their access controls. This approach provides granular control and strong security by enforcing the principle of least privilege, ensuring that only authorized identities can communicate between tiers.

Authoritative Links:

Google Cloud Firewall Rules: <https://cloud.google.com/vpc/docs/firewalls>

Service Accounts: <https://cloud.google.com/iam/docs/service-accounts>

Using Service Accounts with Instances: <https://cloud.google.com/compute/docs/access/service-accounts>

Identity and Access Management (IAM): <https://cloud.google.com/iam/docs>

Question: 62

CertyIQ

A manager wants to start retaining security event logs for 2 years while minimizing costs. You write a filter to select the appropriate log entries. Where should you export the logs?

- A. BigQuery datasets
- B. Cloud Storage buckets
- C. StackDriver logging
- D. Cloud Pub/Sub topics

Answer: B

Explanation:

The correct answer is **B. Cloud Storage buckets**.

Here's why:

The primary requirement is cost-effective long-term storage of security event logs for two years. While BigQuery (A) offers analytical capabilities, it is generally more expensive for simple log retention. Stackdriver Logging (C) is primarily for real-time log viewing and analysis and not designed for cost-effective long-term archival. Cloud Pub/Sub topics (D) are for message streaming and not suitable for storing large amounts of log data.

Cloud Storage buckets are designed for cost-effective, durable object storage and are ideal for long-term log retention. They offer various storage classes (e.g., Standard, Nearline, Coldline, Archive) that can be chosen based on access frequency and cost. Logs can be easily exported to a bucket using Cloud Logging's export feature, and with lifecycle policies, retention periods can be configured according to the manager's two-year requirement. Additionally, storage costs are generally lower than alternatives like BigQuery when data is not actively analyzed. Therefore, Cloud Storage offers the most cost-effective solution for long-term log storage while satisfying the need for a two-year retention period.

For further research:

Cloud Storage: <https://cloud.google.com/storage> - Official documentation on Cloud Storage.

Cloud Logging Exporting Logs: <https://cloud.google.com/logging/docs/export> - Documentation on exporting logs from Cloud Logging.

Question: 63

CertyIQ

For compliance reasons, an organization needs to ensure that in-scope PCI Kubernetes Pods reside on `in-scope` Nodes only. These Nodes can only contain the `in-scope` Pods.

How should the organization achieve this objective?

- A. Add a nodeSelector field to the pod configuration to only use the Nodes labeled inscope: true.
- B. Create a node pool with the label inscope: true and a Pod Security Policy that only allows the Pods to run on Nodes with that label.
- C. Place a taint on the Nodes with the label inscope: true and effect NoSchedule and a toleration to match in the Pod configuration.
- D. Run all in-scope Pods in the namespace in-scope-pci.

Answer: A

Explanation:

The most appropriate solution is **A: Add a nodeSelector field to the pod configuration to only use the Nodes labeled inscope: true**. This approach directly addresses the requirement of placing PCI-compliant pods on designated nodes. nodeSelector is a Kubernetes feature that allows you to constrain which nodes a pod can be scheduled on, based on node labels. By applying inscope: true to the pod specification's nodeSelector, you explicitly instruct Kubernetes to schedule these pods exclusively on nodes also labeled inscope: true. This ensures that sensitive PCI workloads only run on compliant infrastructure.

Option B, using a Pod Security Policy (PSP), is deprecated in Kubernetes v1.21 and removed in v1.25; therefore it is not a viable long-term solution. While PSPs could enforce node affinity, they are no longer recommended. Option C, using taints and tolerations, is generally used for node isolation and preference rather than strict placement. While you could use this approach, nodeSelector offers a more straightforward and idiomatic way to achieve the desired outcome. Option D, running all in-scope Pods in a dedicated namespace, provides logical separation but does not inherently guarantee that pods only run on designated nodes. Namespaces do not have node affinity characteristics. Therefore, while namespacing is a useful practice, it is not sufficient to meet this specific requirement.

In summary, using nodeSelector provides a precise and compliant mechanism for restricting pod placement based on node labels, aligning with the organization's PCI compliance needs.

Authoritative Links:

Kubernetes Documentation on nodeSelector: <https://kubernetes.io/docs/concepts/scheduling-eviction/assign-pod-node/#nodeselector>

Kubernetes Deprecation of Pod Security Policies: <https://kubernetes.io/blog/2021/04/06/pod-security-policy-deprecation-past-present-future/>

Question: 64

CertyIQ

In an effort for your company messaging app to comply with FIPS 140-2, a decision was made to use GCP compute and network services. The messaging app architecture includes a Managed Instance Group (MIG) that controls a cluster of Compute Engine instances. The instances use Local SSDs for data caching and UDP for instance-to-instance communications. The app development team is willing to make any changes necessary to comply with the standard

Which options should you recommend to meet the requirements?

- A. Encrypt all cache storage and VM-to-VM communication using the BoringCrypto module.
- B. Set Disk Encryption on the Instance Template used by the MIG to customer-managed key and use BoringSSL for all data transit between instances.
- C. Change the app instance-to-instance communications from UDP to TCP and enable BoringSSL on clients' TLS connections.
- D. Set Disk Encryption on the Instance Template used by the MIG to Google-managed Key and use BoringSSL library on all instance-to-instance communications.

Answer: A

Explanation:

Okay, let's break down why option A is the best fit for FIPS 140-2 compliance in this scenario.

FIPS 140-2 is a US federal government standard that specifies security requirements for cryptographic modules. This means any cryptographic operations used by the messaging app, including encryption of data at rest (storage) and data in transit (communication), must use FIPS-validated cryptographic modules.

Option A, recommending encryption for all cache storage and VM-to-VM communication using the **BoringCrypto module**, is the correct approach because BoringCrypto is a FIPS 140-2 validated cryptographic library. This ensures that the encryption algorithms and key management processes used comply with the standard. Using a FIPS-validated library is the core requirement for FIPS compliance.

Let's examine why the other options are less suitable:

Option B: While using customer-managed keys for disk encryption is a good security practice, it doesn't guarantee FIPS 140-2 compliance. The disk encryption service itself needs to use a FIPS-validated module for encryption, and customer-managed keys don't influence this. Moreover, BoringSSL is primarily used for TLS/SSL, not general data encryption, as mentioned in the context of data transit between instances.

Option C: Changing from UDP to TCP and enabling BoringSSL on client connections is beneficial for security, but it doesn't address the specific requirement of FIPS 140-2 compliance for all communication within the MIG, as UDP is used for instance-to-instance communications.. It only focuses on client connection.

Option D: Using Google-managed keys for disk encryption is convenient, but similar to Option B, it doesn't ensure the cryptographic module used for encryption is FIPS-validated. While using BoringSSL is useful, It only focuses on instance-to-instance communications and doesn't address data encryption.

In summary, Option A is the most compliant answer because it specifically addresses the requirement of using a FIPS-validated cryptographic module (BoringCrypto) for both data at rest (cache storage) and data in transit (VM-to-VM communication), aligning with the core principles of FIPS 140-2.

Authoritative Links for Further Research:

FIPS 140-2 Standard: <https://csrc.nist.gov/publications/detail/fips/140/2/final> (Official NIST document)

BoringCrypto: <https://boringssl.googlesource.com/boringssl/+HEAD/>

Google Cloud Compliance: <https://cloud.google.com/security/compliance/fips-140-2>

Remember, FIPS compliance is about how cryptography is implemented, not just if it is. Using a FIPS validated module is non-negotiable.

Question: 65

CertyIQ

A customer has an analytics workload running on Compute Engine that should have limited internet access. Your team created an egress firewall rule to deny (priority 1000) all traffic to the internet.

The Compute Engine instances now need to reach out to the public repository to get security updates. What should your team do?

- A. Create an egress firewall rule to allow traffic to the CIDR range of the repository with a priority greater than 1000.
- B. Create an egress firewall rule to allow traffic to the CIDR range of the repository with a priority less than 1000.
- C. Create an egress firewall rule to allow traffic to the hostname of the repository with a priority greater than 1000.
- D. Create an egress firewall rule to allow traffic to the hostname of the repository with a priority less than 1000.

Answer: B

Explanation:

The correct answer is B because firewall rules in Google Cloud Platform (GCP) are evaluated based on priority, with lower numbers having higher precedence. The existing rule denies all egress traffic with a priority of 1000. To allow specific traffic for security updates, a new egress rule must be created that permits traffic to the repository's CIDR range. This new rule must have a lower priority number than the existing block rule (1000) to take effect. This approach ensures that the exception to access the repository is processed first, and then the generic block rule is applied for all other traffic. Options C and D are incorrect because firewall rules use CIDR ranges, not hostnames, for destination specifications, and Option A is incorrect due to the prioritization rule order in GCP firewall. Option B correctly prioritizes the specific allow rule, allowing the needed access, while keeping the broader restriction of internet access in place. This is a fundamental aspect of network security and firewall management, and is a common way to manage exceptions.

Authoritative Links:

VPC firewall rules overview: <https://cloud.google.com/vpc/docs/firewalls>

Firewall rule priorities: <https://cloud.google.com/vpc/docs/firewalls#priority>

Firewall rule components: <https://cloud.google.com/vpc/docs/firewalls#components>

Question: 66

CertyIQ

You want data on Compute Engine disks to be encrypted at rest with keys managed by Cloud Key Management Service (KMS). Cloud Identity and Access Management (IAM) permissions to these keys must be managed in a grouped way because the permissions should be the same for all keys. What should you do?

- A. Create a single KeyRing for all persistent disks and all Keys in this KeyRing. Manage the IAM permissions at the Key level.
- B. Create a single KeyRing for all persistent disks and all Keys in this KeyRing. Manage the IAM permissions at the KeyRing level.
- C. Create a KeyRing per persistent disk, with each KeyRing containing a single Key. Manage the IAM permissions at the Key level.
- D. Create a KeyRing per persistent disk, with each KeyRing containing a single Key. Manage the IAM permissions at the KeyRing level.

Answer: B

Explanation:

Okay, here's a detailed justification for why option B is the correct answer, along with supporting concepts and links:

Option B, "Create a single KeyRing for all persistent disks and all Keys in this KeyRing. Manage the IAM permissions at the KeyRing level," is the most efficient and manageable approach for the scenario. The core requirement is to encrypt Compute Engine disks with Cloud KMS keys while managing IAM permissions consistently for all keys.

Cloud KMS organizes keys within KeyRings. KeyRings serve as logical containers for keys, allowing for easier management and access control. Managing IAM permissions at the KeyRing level provides a mechanism to apply the same permissions to all keys within that KeyRing. This satisfies the requirement of grouped permission management.

Creating a single KeyRing for all disks simplifies the overall architecture. It avoids the complexity of managing numerous KeyRings, one for each disk, which would make permission management cumbersome and error-prone. Managing IAM permissions at the Key level (as in option A and C) would require individual configuration for each key, going against the need for grouped permission management. While options C and D use a 1:1 KeyRing to Key relation, option C manages IAM at the key level again, making it not efficient for grouped management. Option D achieves the grouped access through KeyRing but it introduces unnecessary complexity of having many KeyRings. Therefore, option B offers the best balance of security, manageability, and adherence to the given requirements. It aligns well with the principle of least privilege and streamlined administrative processes in cloud environments.

Authoritative Links:

Cloud KMS Key Hierarchy: https://cloud.google.com/kms/docs/key-concepts#key_hierarchy

Managing access with IAM: <https://cloud.google.com/kms/docs/access-control>

Cloud KMS Best Practices: <https://cloud.google.com/kms/docs/best-practices>

These links offer further insight into Cloud KMS key management and best practices, reinforcing the justification for choosing option B.

Question: 67

CertyIQ

A company is backing up application logs to a Cloud Storage bucket shared with both analysts and the administrator. Analysts should only have access to logs that do not contain any personally identifiable information (PII). Log files containing PII should be stored in another bucket that is only accessible by the administrator. What should you do?

- A. Use Cloud Pub/Sub and Cloud Functions to trigger a Data Loss Prevention scan every time a file is uploaded to the shared bucket. If the scan detects PII, have the function move into a Cloud Storage bucket only accessible by the administrator.
- B. Upload the logs to both the shared bucket and the bucket only accessible by the administrator. Create a job trigger using the Cloud Data Loss Prevention API. Configure the trigger to delete any files from the shared bucket that contain PII.
- C. On the bucket shared with both the analysts and the administrator, configure Object Lifecycle Management to delete objects that contain any PII.
- D. On the bucket shared with both the analysts and the administrator, configure a Cloud Storage Trigger that is only triggered when PII data is uploaded. Use Cloud Functions to capture the trigger and delete such files.

Answer: A

Explanation:

Okay, let's analyze why option A is the correct solution and why the others are not suitable for this scenario.

Option A leverages a powerful combination of serverless technologies to achieve the required data segregation. Cloud Pub/Sub acts as a messaging bus, creating an event-driven architecture. Whenever a log

file is uploaded to the shared bucket, a message is published to a Pub/Sub topic. This triggers a Cloud Function, a serverless piece of code that executes in response to the event. The Cloud Function then utilizes the Data Loss Prevention (DLP) API to scan the uploaded log file. DLP is designed to identify sensitive information like PII within data. Based on the DLP scan results, if PII is detected, the Cloud Function moves the log file to a separate bucket that is only accessible to the administrator. This ensures that analysts only have access to sanitized logs, fulfilling the security requirement. This approach is efficient because it processes files only upon upload.

Option B is flawed because it uploads sensitive information to a bucket intended for analysts, even temporarily. Deleting files afterward is a reactive measure, introducing a window of vulnerability where PII is potentially exposed to unauthorized users.

Option C is incorrect because Object Lifecycle Management (OLM) in Cloud Storage primarily handles time-based actions like deletion or archival, not content-based actions. OLM can't analyze the content of files to determine if it includes PII.

Option D, while attempting to use a Cloud Function, incorrectly attempts to filter based on the upload event itself. It's not feasible to trigger based on the data content during an upload. Moreover, deleting files is again a reactive measure and may create a small window where PII is accessible.

Justification Summary: Option A is the most robust and secure solution. It proactively uses DLP to identify PII and move files to the correct location automatically, ensuring that analysts never gain access to the restricted information. It is based on event-driven processing which is efficient and minimizes vulnerability windows, aligning with best practices for data security.

Authoritative Links:

Cloud Pub/Sub: <https://cloud.google.com/pubsub/docs>

Cloud Functions: <https://cloud.google.com/functions/docs>

Data Loss Prevention (DLP) API: <https://cloud.google.com/dlp/docs>

Cloud Storage Object Lifecycle Management: <https://cloud.google.com/storage/docs/lifecycle>

Question: 68

CertyIQ

A customer terminates an engineer and needs to make sure the engineer's Google account is automatically deprovisioned.

What should the customer do?

- A. Use the Cloud SDK with their directory service to remove their IAM permissions in Cloud Identity.
- B. Use the Cloud SDK with their directory service to provision and deprovision users from Cloud Identity.
- C. Configure Cloud Directory Sync with their directory service to provision and deprovision users from Cloud Identity.
- D. Configure Cloud Directory Sync with their directory service to remove their IAM permissions in Cloud Identity.

Answer: C

Explanation:

The correct answer is C: Configure Cloud Directory Sync with their directory service to provision and deprovision users from Cloud Identity. This is because Cloud Directory Sync is specifically designed to synchronize user and group information between an organization's existing directory service (like Active Directory or LDAP) and Google Cloud Identity. When an engineer's account is terminated in the source directory, Cloud Directory Sync automatically detects this change and deprovisions the corresponding user account in Google Cloud Identity. This includes disabling the user's access to Google Workspace applications,

cloud resources, and Google Cloud Platform (GCP).

Options A, B, and D are incorrect. While the Cloud SDK can be used for managing resources, it's not the ideal solution for automated user provisioning and deprovisioning based on directory changes. Using the SDK directly would require custom scripting and manual management, making it less efficient and prone to errors compared to Cloud Directory Sync. Furthermore, directly removing IAM permissions (as suggested in options A and D) only impacts resource access in GCP; it doesn't fully deprovision a user's account from Google Cloud Identity, which is necessary to fully remove access across the Google ecosystem. Cloud Directory Sync automates the entire process based on the state of the source directory, ensuring a consistent and reliable outcome.

Key concepts here include:

Cloud Identity: Google's identity as a service, providing central user management for Google Workspace and GCP.

Directory Service: A centralized database storing user and group information (e.g., Active Directory).

Cloud Directory Sync: A Google tool synchronizing users and groups between a directory service and Cloud Identity.

IAM (Identity and Access Management): A Google Cloud service for controlling access to resources.

Authoritative Links:

Cloud Directory Sync Overview: <https://support.google.com/a/answer/106368?hl=en>

Cloud Identity Documentation: <https://cloud.google.com/identity/docs>

Question: 69

CertyIQ

An organization is evaluating the use of Google Cloud Platform (GCP) for certain IT workloads. A well-established directory service is used to manage user identities and lifecycle management. This directory service must continue for the organization to use as the 'source of truth' directory for identities.

Which solution meets the organization's requirements?

- A. Google Cloud Directory Sync (GCDS)
- B. Cloud Identity
- C. Security Assertion Markup Language (SAML)
- D. Pub/Sub

Answer: A

Explanation:

The correct answer is **A. Google Cloud Directory Sync (GCDS)**. Here's why:

GCDS is specifically designed to synchronize user and group data from an existing directory service (like Active Directory or LDAP) to Google Cloud's Cloud Identity or Google Workspace. This aligns perfectly with the organization's requirement to maintain their current directory service as the "source of truth." GCDS ensures that changes made in the organization's primary directory are reflected in Google's identity system, ensuring consistency and eliminating the need for duplicate management efforts. It does not attempt to replace the existing system but rather integrates with it, preserving the existing user lifecycle management processes.

Option B, Cloud Identity, is Google's identity-as-a-service platform and can function as a directory itself, but it doesn't inherently synchronize with an external directory. It would be the destination of the sync by GCDS, not the mechanism for it. Option C, SAML, is an authentication protocol, which helps provide single sign-on capabilities, but does not handle directory synchronization. Option D, Pub/Sub, is a messaging service for

asynchronous data exchange and is irrelevant for directory synchronization. Therefore, GCDS is the only option that satisfies the core requirement of synchronizing an existing directory service with Google Cloud.

Authoritative Links:

Google Cloud Directory Sync (GCDS) Documentation: <https://support.google.com/a/answer/106368?hl=en>
Cloud Identity Overview: <https://cloud.google.com/identity>
SAML Overview: <https://cloud.google.com/identity/docs/how-to/saml>
Pub/Sub Documentation: <https://cloud.google.com/pubsub/docs>

Question: 70

CertyIQ

Which international compliance standard provides guidelines for information security controls applicable to the provision and use of cloud services?

- A. ISO 27001
- B. ISO 27002
- C. ISO 27017
- D. ISO 27018

Answer: C

Explanation:

The correct answer is C, ISO 27017. ISO 27017 is an international standard that provides specific guidance on information security controls applicable to cloud services. It's essentially an extension of ISO 27002, focusing on the unique aspects of cloud environments. ISO 27017 addresses areas like shared responsibility in cloud security, virtual environment security, incident response within the cloud, and the management of cloud-specific risks. While ISO 27001 establishes the framework for an Information Security Management System (ISMS), and ISO 27002 provides a general code of practice for information security controls, they lack the cloud-specific focus of ISO 27017. ISO 27018, on the other hand, focuses on the protection of Personally Identifiable Information (PII) in public cloud environments, making it less appropriate for the broader scope of the question. Cloud service providers and users alike can benefit from adopting ISO 27017 to enhance their security posture and address compliance requirements. This standard helps in defining roles and responsibilities within cloud environments, ensuring proper security implementations. It promotes transparency and trust within the cloud ecosystem by establishing a common language for cloud security. It also supports regulatory requirements by providing a framework that aligns with industry best practices. Essentially, ISO 27017 is specifically designed to bridge the gap between general information security controls and the unique challenges of cloud computing.

Authoritative Links:

ISO 27017: <https://www.iso.org/standard/43757.html>
ISO 27001: <https://www.iso.org/isoiec-27001-information-security.html>
ISO 27002: <https://www.iso.org/standard/54534.html>
ISO 27018: <https://www.iso.org/standard/61489.html>

Question: 71

CertyIQ

You will create a new Service Account that should be able to list the Compute Engine instances in the project. You want to follow Google-recommended practices. What should you do?

- A. Create an Instance Template, and allow the Service Account Read Only access for the Compute Engine Access Scope.
- B. Create a custom role with the permission `compute.instances.list` and grant the Service Account this role.
- C. Give the Service Account the role of Compute Viewer, and use the new Service Account for all instances.
- D. Give the Service Account the role of Project Viewer, and use the new Service Account for all instances.

Answer: B

Explanation:

The correct answer is **B. Create a custom role with the permission `compute.instances.list` and grant the Service Account this role.**

This approach adheres to the principle of least privilege, a fundamental security best practice in cloud computing. Instead of granting broad, predefined roles like "Compute Viewer" or "Project Viewer" (options C and D), which encompass numerous permissions the Service Account doesn't need, we create a custom role specifically tailored to its requirement: listing Compute Engine instances. The `compute.instances.list` permission is exactly what's required and nothing more. This minimizes the potential impact if the Service Account's credentials are ever compromised. Option A, utilizing access scopes on an Instance Template, is primarily used for instance access to resources rather than granting an independent Service Account resource access, and also mixes compute access control with service account access control. It also doesn't directly grant the access we are trying to achieve with the service account. Option C (Compute Viewer) grants significantly more permissions, including the ability to view VM details, disks, snapshots, etc. Option D (Project Viewer) is even broader. By creating the custom role, we provide granular access, restricting the Service Account to only the necessary action. This enhances security posture by reducing the attack surface. Google explicitly advocates for using custom roles over pre-defined roles wherever feasible to enforce least privilege. Furthermore, this custom role can be clearly named (e.g., `computeInstanceLister`), making it easy to understand its purpose.

Supporting Links:

Google Cloud IAM Overview: <https://cloud.google.com/iam/docs/overview> - Provides a comprehensive overview of IAM, including roles and permissions.

Understanding Roles: <https://cloud.google.com/iam/docs/understanding-roles> - Details predefined and custom roles, highlighting best practices.

Creating and Managing Custom Roles: <https://cloud.google.com/iam/docs/creating-custom-roles> - Explains how to create custom roles to implement the principle of least privilege.

Compute Engine Permissions: <https://cloud.google.com/compute/docs/access/iam> - Lists the various permissions related to Compute Engine resources.

Question: 72

CertyIQ

In a shared security responsibility model for IaaS, which two layers of the stack does the customer share responsibility for? (Choose two.)

- A. Hardware
- B. Network Security
- C. Storage Encryption
- D. Access Policies
- E. Boot

Answer: BD

Explanation:

Okay, let's break down the shared responsibility model in IaaS, focusing on why network security and access policies are the customer's shared responsibilities.

In IaaS, the cloud provider handles the underlying infrastructure – the hardware, physical data centers, and the basic networking. This includes the physical security of the hardware (option A) and, typically, the physical network infrastructure. However, the customer is responsible for configuring and managing certain aspects that directly impact their resources. Option B, "Network Security," is one such area. While the provider ensures the physical network's integrity, the customer must configure firewalls, virtual networks, subnetting, routing, and other security measures that apply to their virtualized network resources within the cloud environment. These measures are vital for isolating and protecting the customer's specific application environment.

Option D, "Access Policies," is also a shared responsibility because it involves defining and managing who has access to the cloud resources. Cloud providers handle access control to the base infrastructure, but customers are responsible for managing user permissions, roles, groups, and any other forms of access controls for their deployed services and data within the cloud. This includes controlling who can manage virtual machines, access storage buckets, and interact with other cloud resources.

The customer does not share the responsibility for hardware (A), which is managed by the cloud provider. Similarly, storage encryption (C) is a responsibility often shared with the cloud provider, but the customer is generally responsible for enabling and managing the encryption keys. Boot(E) is not part of the shared responsibility.

Therefore, the correct answer is **B. Network Security** and **D. Access Policies** because these two layers specifically require the customer's active management and configuration within the IaaS model, alongside the provider's shared responsibility.

Here are some authoritative links for further reading:

Microsoft Azure Shared Responsibility: <https://learn.microsoft.com/en-us/azure/security/fundamentals/shared-responsibility>

AWS Shared Responsibility Model: <https://aws.amazon.com/compliance/shared-responsibility-model/>

Google Cloud Shared Responsibility: <https://cloud.google.com/security/overview/shared-responsibility>

Question: 73

CertyIQ

An organization is starting to move its infrastructure from its on-premises environment to Google Cloud Platform (GCP). The first step the organization wants to take is to migrate its ongoing data backup and disaster recovery solutions to GCP. The organization's on-premises production environment is going to be the next phase for migration to GCP. Stable networking connectivity between the on-premises environment and GCP is also being implemented.

Which GCP solution should the organization use?

- A. BigQuery using a data pipeline job with continuous updates via Cloud VPN
- B. Cloud Storage using a scheduled task and gsutil via Cloud Interconnect
- C. Compute Engines Virtual Machines using Persistent Disk via Cloud Interconnect
- D. Cloud Datastore using regularly scheduled batch upload jobs via Cloud VPN

Answer: B

Explanation:

Option B, Cloud Storage using a scheduled task and gsutil via Cloud Interconnect, is the most suitable solution for migrating data backups and disaster recovery to GCP initially. Cloud Storage offers a highly

durable and scalable object storage service ideal for storing backup data. gsutil is a command-line tool that facilitates easy data transfer to and from Cloud Storage. Using Cloud Interconnect ensures a stable and dedicated network connection between the on-premises environment and GCP, which is crucial for consistent backup operations and disaster recovery scenarios. This eliminates reliance on potentially less reliable public internet, reducing latency and improving data transfer speeds. Scheduled tasks, such as cron jobs, automate the backup process, promoting consistent and timely backups. Unlike BigQuery (A), which is primarily for data analytics and not for storing raw backups, Cloud Storage is designed for this purpose. Compute Engine VMs (C) would require more complex configurations for managing backup targets. Cloud Datastore (D), being a NoSQL database, isn't optimized for storing large backups either. Cloud Storage's object-based nature is also excellent for long-term retention of backups.

Authoritative links:

Cloud Storage: <https://cloud.google.com/storage>

gsutil: <https://cloud.google.com/storage/docs/gsutil>

Cloud Interconnect: <https://cloud.google.com/interconnect>

Question: 74

CertyIQ

What are the steps to encrypt data using envelope encryption?

A.

- Generate a data encryption key (DEK) locally.
- Use a key encryption key (KEK) to wrap the DEK.
- Encrypt data with the KEK.
- Store the encrypted data and the wrapped KEK.

B.

- Generate a key encryption key (KEK) locally.
- Use the KEK to generate a data encryption key (DEK).
- Encrypt data with the DEK.
- Store the encrypted data and the wrapped DEK.

C.

- Generate a data encryption key (DEK) locally.
- Encrypt data with the DEK.
- Use a key encryption key (KEK) to wrap the DEK.
- Store the encrypted data and the wrapped DEK.

D.

- Generate a key encryption key (KEK) locally.
- Generate a data encryption key (DEK) locally.
- Encrypt data with the KEK.
- Store the encrypted data and the wrapped DEK.

■

Answer: C

Explanation:

Answer is (C).

The process of encrypting data is to generate a DEK locally, encrypt data with the DEK, use a KEK to wrap the DEK, and then store the encrypted data and the wrapped DEK. The KEK never leaves Cloud KMS.

Reference:

<https://cloud.google.com/kms/docs/envelope-encryption>

Question: 75

CertyIQ

A customer wants to make it convenient for their mobile workforce to access a CRM web interface that is hosted on Google Cloud Platform (GCP). The CRM can only be accessed by someone on the corporate network. The customer wants to make it available over the internet. Your team requires an authentication layer in front of the application that supports two-factor authentication. Which GCP product should the customer implement to meet these requirements?

- A. Cloud Identity-Aware Proxy
- B. Cloud Armor
- C. Cloud Endpoints
- D. Cloud VPN

Answer: A

Explanation:

The correct answer is **A. Cloud Identity-Aware Proxy (IAP)**. Here's why:

Cloud IAP is a GCP service designed to control access to web applications and APIs running on Google Cloud, without relying on a traditional VPN. It acts as a central authentication and authorization layer, verifying user identity before granting access. This perfectly matches the requirement for an authentication layer in front of the CRM application.

The customer explicitly needs two-factor authentication. Cloud IAP natively supports this via integration with Google Accounts, enforcing security policies like 2-Step Verification or other multi-factor authentication methods. This ensures that only authorized users with verified identities can reach the CRM system.

Furthermore, IAP simplifies access for remote workers by allowing internet-based access without the need for a VPN to the corporate network. It replaces the need for traditional network-based access control with identity-based access, enhancing the user experience for the mobile workforce.

Here's why other options are not the best fit:

B. Cloud Armor: While Cloud Armor provides web application firewall (WAF) capabilities for protecting applications against attacks, it does not handle authentication or authorization. It focuses on security at the network layer, not user identity.

C. Cloud Endpoints: Cloud Endpoints is a management platform for developing, deploying, and monitoring APIs. It's helpful for exposing APIs, but not the primary solution for user authentication with 2FA on a web application.

D. Cloud VPN: Cloud VPN provides a secure IPsec tunnel between your on-premises network and a Google Cloud VPC. It's suitable for extending networks but does not directly provide user-based access control or authentication features like 2FA.

Therefore, Cloud IAP is the most suitable choice for adding a robust and convenient authentication layer with two-factor authentication for the CRM application, while enabling secure access for the remote workforce over the internet.

Authoritative Links:

Cloud Identity-Aware Proxy Documentation: <https://cloud.google.com/iap/docs>

Cloud Identity-Aware Proxy Overview: <https://cloud.google.com/iap/docs/concepts/overview>

Question: 76

CertyIQ

Your company is storing sensitive data in Cloud Storage. You want a key generated on-premises to be used in the encryption process. What should you do?

- A. Use the Cloud Key Management Service to manage a data encryption key (DEK).
- B. Use the Cloud Key Management Service to manage a key encryption key (KEK).
- C. Use customer-supplied encryption keys to manage the data encryption key (DEK).
- D. Use customer-supplied encryption keys to manage the key encryption key (KEK).

Answer: C

Explanation:

The correct answer is C because it directly addresses the requirement of using an on-premises key for encrypting data in Cloud Storage. Customer-supplied encryption keys (CSEK) allow you to provide your own encryption key, which Google uses to encrypt the data encryption key (DEK) that encrypts the actual data. In this scenario, you generate and manage the key on your premises, maintaining full control and ensuring that Google doesn't have access to your root encryption key. Option D, while using CSEK, incorrectly applies it to the KEK, which is not the data encryption key itself. While KEKs are used in encryption hierarchies, in this context, the customer is directly concerned with the key that encrypts the data at rest. Options A and B are incorrect because they suggest using Cloud KMS keys, which means the key material would be managed within Google's infrastructure, conflicting with the stated requirement of using an on-premises key. With CSEK, the DEK is encrypted with your provided key, and this process takes place server-side, protecting the data at rest on Google's storage infrastructure.

Key concepts to understand:

Data Encryption Key (DEK): A symmetric key used to encrypt the actual data.

Key Encryption Key (KEK): A key used to encrypt the DEK, providing a layer of security by keeping DEKs encrypted at rest.

Customer-Supplied Encryption Keys (CSEK): Allows customers to provide their own keys for encrypting data stored in Google Cloud Storage.

Cloud Key Management Service (KMS): A managed service by Google Cloud for generating, storing, and managing encryption keys.

Authoritative Links:

Google Cloud Storage Customer-Supplied Encryption Keys:

<https://cloud.google.com/storage/docs/encryption/customer-supplied>

Google Cloud Encryption Overview: <https://cloud.google.com/security/encryption/>

Understanding Encryption Keys: <https://cloud.google.com/kms/docs/concepts>

Question: 77

CertyIQ

Last week, a company deployed a new App Engine application that writes logs to BigQuery. No other workloads are running in the project. You need to validate that all data written to BigQuery was done using the App Engine Default Service Account.

What should you do?

- A. 1. Use Cloud Logging and filter on BigQuery Insert Jobs. 2. Click on the email address in line with the App Engine Default Service Account in the authentication field. 3. Click Hide Matching Entries. 4. Make sure the resulting list is empty.
- B. 1. Use Cloud Logging and filter on BigQuery Insert Jobs. 2. Click on the email address in line with the App Engine Default Service Account in the authentication field. 3. Click Show Matching Entries. 4. Make sure the resulting list is empty.
- C. 1. In BigQuery, select the related dataset. 2. Make sure that the App Engine Default Service Account is the only account that can write to the dataset.
- D. 1. Go to the Identity and Access Management (IAM) section of the project. 2. Validate that the App Engine Default Service Account is the only account that has a role that can write to BigQuery.

Answer: A

Explanation:

The correct answer is A. Here's why:

Understanding the Problem: We need to verify that only the App Engine default service account is writing data to the BigQuery dataset. This means we need to examine the logs of write operations (BigQuery Insert Jobs) and confirm that these actions are exclusively attributed to the designated service account.

Why Option A Works:

1. **Cloud Logging for Audit:** Cloud Logging provides a comprehensive audit trail of actions within Google Cloud. By filtering on BigQuery Insert Jobs, we isolate the specific events of interest - data writes to BigQuery.
2. **Identifying the Service Account:** Within the log entries for BigQuery Insert Jobs, the authentication field records the identity of the actor responsible for the operation, often an email address associated with a service account.
3. **Filtering for Exclusivity:** Clicking on the email address of the App Engine Default Service Account within Cloud Logging will filter the logs and show only events associated with that specific identity.
4. **Verification:** If only the App Engine service account wrote to BigQuery, then after filtering and then selecting "Hide Matching Entries", the resulting list should be empty, because the filtering has removed all the writes from the service account, and that should have been all of the writes to the BigQuery dataset. The logic works as "showing only writes for the service account", and if you select "Hide Matching Entries", and the results are empty, then, that proves only the service account wrote to the dataset, therefore answering our question.

Why Other Options are Incorrect:

Option B: "Show Matching Entries" will display log entries that were done by the service account. It will not prove that only the service account has written to BigQuery.

Option C: Checking write permissions on the dataset level is an important access control step but it does not prove that only that service account has written the records that already exist. Permissions can change over time or other service accounts might have had writing permissions in the past and therefore written to the dataset.

Option D: Similar to C, verifying IAM roles confirms authorization, not actual historical usage. It only confirms which service accounts have permissions to write data to BigQuery but it doesn't provide proof of which accounts have actually written data.

Key Concepts:

Cloud Logging: A fully managed service for storing and analyzing logs. <https://cloud.google.com/logging>

BigQuery Insert Jobs: Operations that write data into BigQuery.

<https://cloud.google.com/bigquery/docs/reference/auditlogs/rest/Shared.Types/AuditLogData#BigQueryJobInsert>

Service Accounts: Non-human accounts used by applications and services to access Google Cloud resources.

<https://cloud.google.com/iam/docs/service-accounts>

Least Privilege: The principle of granting only necessary permissions, which is partially addressed in this scenario through verifying the service account writes.

In summary, Option A provides the most accurate and effective approach by directly inspecting the audit logs associated with the BigQuery writes, filtering by the relevant service account, and then showing the inverse to show no logs exists outside of that service account.

Question: 78

Your team wants to limit users with administrative privileges at the organization level. Which two roles should your team restrict? (Choose two.)

- A. Organization Administrator
- B. Super Admin
- C. GKE Cluster Admin
- D. Compute Admin
- E. Organization Role Viewer

Answer: AB

Explanation:

The correct answer is A and B, Organization Administrator and Super Admin. These two roles grant the highest level of administrative control within a Google Cloud organization. An Organization Administrator has broad permissions to manage resources and policies across the entire organization, including the ability to create and manage folders, projects, and other organizational resources. Similarly, a Super Admin, which is specific to Google Workspace, possesses overarching control over the organization's users, settings, and data. Restricting these roles is crucial for limiting the blast radius of any compromised account and adhering to the principle of least privilege. GKE Cluster Admin (C) and Compute Admin (D) have administrative control, but within the scope of specific services (Kubernetes Engine and Compute Engine, respectively) and not at the organization level. Organization Role Viewer (E) does not grant administrative permissions but allows users to only view role assignments. For further information, please refer to Google Cloud's documentation on Identity and Access Management (IAM): <https://cloud.google.com/iam/docs> and Google Workspace's documentation on administrator roles: <https://support.google.com/a/answer/1075115>. Limiting the number of users with Organization Administrator and Super Admin privileges is a fundamental security best practice.

Question: 79

An organization's security and risk management teams are concerned about where their responsibility lies for certain production workloads they are running in Google Cloud and where Google's responsibility lies. They are mostly running workloads using Google Cloud's platform-as-a-Service (PaaS) offerings, including App Engine primarily. Which area in the technology stack should they focus on as their primary responsibility when using App Engine?

- A. Configuring and monitoring VPC Flow Logs
- B. Defending against XSS and SQLi attacks
- C. Managing the latest updates and security patches for the Guest OS
- D. Encrypting all stored data

Answer: B

Explanation:

The correct answer is **B. Defending against XSS and SQLi attacks**. This aligns with the shared responsibility model in cloud computing, particularly when using PaaS offerings like Google App Engine. Google manages the underlying infrastructure, including the operating system (OS), security patches, and data encryption at rest (parts of answers C and D), as part of their service offering. Customers are responsible for securing the applications they build and deploy. XSS and SQL injection (SQLi) are application-level vulnerabilities. Therefore, the primary responsibility of the organization is to implement security practices within the code.

and configuration of their App Engine applications to prevent these attacks. VPC flow logs (A) is more of an infrastructure/network security concern, which Google handles to some extent but can also be customer responsibility, but not the primary one for App Engine.

Here's a breakdown:

Shared Responsibility Model: In PaaS, the cloud provider (Google) manages infrastructure, OS, and platform. The customer manages data, application, identity, and access management.

Application Layer Security: XSS and SQLi are vulnerabilities at the application layer. These vulnerabilities arise from how the application handles user input and interacts with data.

App Engine's Abstraction: App Engine abstracts away the complexities of OS management, patching, and underlying infrastructure.

Customer Responsibility: Organizations must implement input validation, output encoding, parameterized queries, and other security coding practices to prevent XSS and SQLi attacks.

Data at Rest Encryption: Google encrypts data at rest within its infrastructure, which is not the primary area of responsibility for a PaaS consumer.

Relevant Links:

Google Cloud Shared Responsibility: <https://cloud.google.com/security/infrastructure/compliance/shared-responsibility>

OWASP XSS (Cross Site Scripting): <https://owasp.org/www-project-top-ten/>

OWASP SQL Injection: <https://owasp.org/www-project-top-ten/>

Google App Engine Security Overview: <https://cloud.google.com/appengine/docs/standard/python/security>

Question: 80

CertyIQ

An engineering team is launching a web application that will be public on the internet. The web application is hosted in multiple GCP regions and will be directed to the respective backend based on the URL request. Your team wants to avoid exposing the application directly on the internet and wants to deny traffic from a specific list of malicious IP addresses.

Which solution should your team implement to meet these requirements?

- A. Cloud Armor
- B. Network Load Balancing
- C. SSL Proxy Load Balancing
- D. NAT Gateway

Answer: A

Explanation:

Cloud Armor is the correct solution because it's a web application firewall (WAF) service offered by Google Cloud that is specifically designed to protect applications from various threats, including malicious IP addresses. Option A directly addresses the requirements by enabling the team to configure rules to block traffic from a defined list of IP addresses, ensuring that the web application is not exposed to potentially harmful requests. Cloud Armor operates at the edge of Google's network, providing the first line of defense before traffic reaches the application servers. This protects backend infrastructure from direct internet exposure, enhancing security. It also integrates seamlessly with Google Cloud Load Balancing services, which can distribute traffic to multiple regions, making it a comprehensive and suitable choice. Other options, like Network Load Balancing, SSL Proxy Load Balancing, and NAT Gateway, don't provide the IP address filtering or WAF functionalities needed for this situation. Network Load Balancing is designed for distributing TCP, UDP, and ESP traffic across backend instances, and while SSL Proxy Load Balancing manages SSL certificates for web traffic and provides load balancing, neither offers filtering based on IP address or other

common web attack mitigation. NAT Gateway provides network address translation and doesn't have security capabilities relevant to the requirements. Therefore, Cloud Armor is the most effective solution for protecting the public-facing web application from malicious IP addresses and meeting security compliance requirements.

[Authoritative links for further research:]

1. Cloud Armor overview: <https://cloud.google.com/armor/docs/overview>
2. Cloud Armor WAF rules: <https://cloud.google.com/armor/docs/rules-overview>
3. Load Balancing concepts: <https://cloud.google.com/load-balancing/docs/load-balancing-concepts>

Question: 81

CertyIQ

A customer is running an analytics workload on Google Cloud Platform (GCP) where Compute Engine instances are accessing data stored on Cloud Storage.

Your team wants to make sure that this workload will not be able to access, or be accessed from, the internet. Which two strategies should your team use to meet these requirements? (Choose two.)

- A. Configure Private Google Access on the Compute Engine subnet
- B. Avoid assigning public IP addresses to the Compute Engine cluster.
- C. Make sure that the Compute Engine cluster is running on a separate subnet.
- D. Turn off IP forwarding on the Compute Engine instances in the cluster.
- E. Configure a Cloud NAT gateway.

Answer: AB

Explanation:

Here's a breakdown of why options A and B are the correct strategies for isolating the analytics workload from the internet:

Option A: Configure Private Google Access on the Compute Engine subnet is crucial. Private Google Access allows instances without external IP addresses to access Google APIs and services, like Cloud Storage, over Google's internal network. This eliminates the need for traffic to traverse the public internet to reach these services, enhancing security and reducing latency. <https://cloud.google.com/vpc/docs/private-google-access>

Option B: Avoid assigning public IP addresses to the Compute Engine cluster is equally vital. Without public IPs, the Compute Engine instances cannot directly communicate with the internet. This means no inbound or outbound internet traffic is possible unless explicitly routed through a NAT gateway or other similar solution (which is not desired in this scenario). This effectively isolates the workload from external threats. <https://cloud.google.com/vpc/docs/firewalls>

Why other options are not correct:

C. Make sure that the Compute Engine cluster is running on a separate subnet: While subnet segmentation is a good security practice, it doesn't directly prevent internet access. Instances within any subnet can have public IPs and potentially access the internet unless explicitly blocked.

D. Turn off IP forwarding on the Compute Engine instances in the cluster: IP forwarding controls whether an instance can act as a router. It's irrelevant when attempting to control access to/from the internet.

E. Configure a Cloud NAT gateway: Cloud NAT provides outbound internet access to instances without public IPs. This contradicts the requirement to prevent the workload from accessing or being accessed from the internet.

By combining Private Google Access and avoiding public IPs, the workload can operate securely within the

Question: 82

CertyIQ

A customer wants to run a batch processing system on VMs and store the output files in a Cloud Storage bucket. The networking and security teams have decided that no VMs may reach the public internet. How should this be accomplished?

- A. Create a firewall rule to block internet traffic from the VM.
- B. Provision a NAT Gateway to access the Cloud Storage API endpoint.
- C. Enable Private Google Access.
- D. Mount a Cloud Storage bucket as a local filesystem on every VM.

Answer: C

Explanation:

The correct answer is **C. Enable Private Google Access**.

Here's why:

Private Google Access allows Google Cloud resources within a VPC network (like VMs) to access Google APIs and services, such as Cloud Storage, without traversing the public internet. This satisfies the customer's requirement that VMs have no public internet access while still allowing them to write to the Cloud Storage bucket. By enabling Private Google Access, traffic to Cloud Storage is routed through Google's internal network, maintaining isolation and security.

Option A, blocking internet traffic with a firewall rule, would prevent the VMs from reaching the Cloud Storage API endpoint on the public internet. Option B, a NAT Gateway, facilitates internet access, which contradicts the requirement. Option D, mounting the bucket as a local filesystem, is less efficient and doesn't address the networking security concerns. It also lacks scalability for this use-case and wouldn't align with common practices. With Private Google Access, the VMs can communicate with Cloud Storage using private IPs, ensuring a secure and efficient data transfer without exposing the VMs to the public internet. This is the recommended approach for secure and private interaction with Google APIs within a VPC.

Authoritative Links:

Private Google Access: <https://cloud.google.com/vpc/docs/private-google-access>

VPC Network overview: <https://cloud.google.com/vpc/docs/vpc>

Cloud Storage: <https://cloud.google.com/storage/docs>

Question: 83

CertyIQ

As adoption of the Cloud Data Loss Prevention (Cloud DLP) API grows within your company, you need to optimize usage to reduce cost. Cloud DLP target data is stored in Cloud Storage and BigQuery. The location and region are identified as a suffix in the resource name.

Which cost reduction options should you recommend?

- A. Set appropriate rowsLimit value on BigQuery data hosted outside the US and set appropriate bytesLimitPerFile value on multiregional Cloud Storage buckets.
- B. Set appropriate rowsLimit value on BigQuery data hosted outside the US, and minimize transformation units on multiregional Cloud Storage buckets.
- C. Use rowsLimit and bytesLimitPerFile to sample data and use CloudStorageRegexFileSet to limit scans.
- D. Use FindingLimits and TimespanConfig to sample data and minimize transformation units.

Answer: C

Explanation:

The correct answer is **C. Use rowsLimit and bytesLimitPerFile to sample data and use CloudStorageRegexFileSet to limit scans.**

Here's why:

Cloud DLP costs are primarily driven by the amount of data inspected. To optimize costs, you must reduce the volume of data processed. Options A and B incorrectly focus on where the data is located (outside the US), which is not the primary cost factor. While regions can affect overall cost due to network egress, the question is primarily focused on data volumes. Option B mentions "transformation units," which is not a core cost component for Cloud DLP when inspecting BigQuery and Cloud Storage.

Option C directly addresses cost reduction through sampling and limiting scope:

rowsLimit and bytesLimitPerFile: These parameters in Cloud DLP allow you to sample data. rowsLimit limits the number of rows inspected in a BigQuery table, and bytesLimitPerFile restricts the data volume processed from a Cloud Storage file. By sampling, you analyze a representative portion of the data instead of the entire dataset, significantly reducing processing costs.

CloudStorageRegexFileSet: This feature enables you to specify regular expressions to filter which Cloud Storage files are inspected. Limiting scans through regex matching allows targeting only the necessary files, which is crucial for reducing the scope of the scan and subsequently reducing cost.

Option D is not correct because FindingLimits are used to control the quantity of findings returned by DLP, not to control the amount of data scanned and therefore, do not affect the cost. The TimespanConfig is used to define a period of time to inspect and it is not the most cost efficient method of reducing the scope of scanning.

Therefore, sampling with rowsLimit and bytesLimitPerFile, coupled with file filtering through CloudStorageRegexFileSet, provides the most effective way to minimize the data volume scanned by Cloud DLP, resulting in direct cost savings.

Authoritative links for further research:

Cloud DLP Pricing: <https://cloud.google.com/dlp/pricing>

Cloud DLP Concepts: <https://cloud.google.com/dlp/docs/concepts-inspecting-storage>

Cloud DLP API reference: <https://cloud.google.com/dlp/docs/reference/rest/v2/InspectConfig>

Cloud DLP storage configurations: <https://cloud.google.com/dlp/docs/configuring-storage>

Question: 84

CertyIQ

Your team uses a service account to authenticate data transfers from a given Compute Engine virtual machine instance of to a specified Cloud Storage bucket. An engineer accidentally deletes the service account, which breaks application functionality. You want to recover the application as quickly as possible without compromising security.

What should you do?

- A. Temporarily disable authentication on the Cloud Storage bucket.
- B. Use the undelete command to recover the deleted service account.
- C. Create a new service account with the same name as the deleted service account.
- D. Update the permissions of another existing service account and supply those credentials to the applications.

Answer: B

Explanation:

The correct answer is **B. Use the undelete command to recover the deleted service account.** Here's why:

Option B directly addresses the root cause of the problem: the accidental deletion of the service account. Google Cloud allows for the recovery of recently deleted resources, including service accounts, using the undelete command or its equivalent in the Cloud Console. This is the fastest and most secure way to restore functionality. By recovering the original service account, all pre-existing permissions and configurations remain intact.

Option A, disabling authentication on the Cloud Storage bucket, introduces a severe security vulnerability, making the bucket publicly accessible and exposing sensitive data. This is completely unacceptable for security best practices.

Option C, creating a new service account with the same name, will not automatically restore functionality. While the name is the same, it's a completely different identity with different unique IDs and keys. It would require extensive reconfiguration of the Compute Engine instance to use this new account, along with reassigning the required permissions. This process is time-consuming and prone to errors.

Option D, updating another service account's permissions, is also not ideal. It introduces unnecessary permissions changes to an existing service account which is not meant for this function. This could lead to further security risks and complicate access control in the long run.

Therefore, recovering the deleted service account using the undelete function is the most efficient and secure way to restore the application's functionality with minimal disruption and without compromising security principles.

For further information, refer to:

Undeleting a Service Account: <https://cloud.google.com/iam/docs/undeleting-service-accounts>

Service Accounts Overview: <https://cloud.google.com/iam/docs/service-accounts>

Question: 85

CertyIQ

You are the Security Admin in your company. You want to synchronize all security groups that have an email address from your LDAP directory in Cloud IAM.

What should you do?

- A. Configure Google Cloud Directory Sync to sync security groups using LDAP search rules that have user email address as the attribute to facilitate one-way sync.
- B. Configure Google Cloud Directory Sync to sync security groups using LDAP search rules that have user email address as the attribute to facilitate bidirectional sync.
- C. Use a management tool to sync the subset based on the email address attribute. Create a group in the Google domain. A group created in a Google domain will automatically have an explicit Google Cloud Identity and Access Management (IAM) role.
- D. Use a management tool to sync the subset based on group object class attribute. Create a group in the Google domain. A group created in a Google domain will automatically have an explicit Google Cloud Identity and Access Management (IAM) role.

Answer: A

Explanation:

The correct answer is A because Google Cloud Directory Sync (GCDS) is designed to synchronize data from LDAP directories to Google Workspace (which includes Cloud Identity). Specifically, GCDS can be configured

to sync security groups based on LDAP search rules. In this case, the requirement is to synchronize groups that have email addresses associated with users. By setting the search rule to filter based on the email address attribute, GCDS will correctly select the relevant groups. Importantly, GCDS provides a one-way synchronization, meaning changes in the LDAP directory are pushed to Google Workspace, but not vice versa. This is appropriate in this scenario as the LDAP is the source of truth for user and group information. Option B is incorrect because it proposes bidirectional sync, which is not typically desired for security group management where the authoritative source is usually an on-premises LDAP. Options C and D are unsuitable because they don't leverage the built-in synchronization capabilities of GCDS and instead suggest using a generic "management tool," which doesn't align with Google's recommended best practices. Furthermore, simply creating a group in a Google domain does not automatically grant it a direct IAM role (as suggested in C and D). IAM roles are granted explicitly through policies, not through group creation. IAM roles are applied to resources, not groups. GCDS is the appropriate tool for this specific sync requirement.

Authoritative Links:

Google Cloud Directory Sync documentation: <https://support.google.com/a/answer/106368>

GCDS LDAP Search Rules: <https://support.google.com/a/answer/106372>

Google Cloud Identity and Access Management (IAM) Overview:

<https://cloud.google.com/iam/docs/overview>

Question: 86

CertyIQ

You are part of a security team investigating a compromised service account key. You need to audit which new resources were created by the service account.

What should you do?

- A. Query Data Access logs.
- B. Query Admin Activity logs.
- C. Query Access Transparency logs.
- D. Query Stackdriver Monitoring Workspace.

Answer: B

Explanation:

The correct answer is **B. Query Admin Activity logs**.

Here's a detailed justification:

Admin Activity logs in Google Cloud Platform (GCP) record API calls or administrative actions that modify the configuration or metadata of services. When a service account key is compromised and used to create new resources, these actions are captured as administrative events in the Admin Activity logs. These logs record details like who performed the action (in this case, the compromised service account), what action was performed (e.g., creating a resource), and when the action took place.

Data Access logs, option A, focus on user access to data stored within GCP services. They wouldn't typically record resource creation, which is an administrative action. Access Transparency logs, option C, provide visibility into actions taken by Google personnel. These logs are not relevant to activity by a compromised service account. Stackdriver Monitoring Workspace, option D, is a monitoring tool and not a log that tracks administrative actions.

Therefore, for the task of auditing resource creation by a compromised service account, querying Admin Activity logs is the most effective approach as they provide the necessary details of administrative changes performed by that account. This allows security teams to identify the specific resources created and take appropriate remediation steps.

Here are some authoritative links for further research:

Google Cloud Logging documentation on Admin Activity logs: <https://cloud.google.com/logging/docs/audit/>

Google Cloud Logging documentation on Audit Logs: <https://cloud.google.com/logging/docs/audit>

Google Cloud Logging documentation on Understanding Audit Logs:

<https://cloud.google.com/logging/docs/audit/understanding-audit-logs>

Question: 87

CertyIQ

You have an application where the frontend is deployed on a managed instance group in subnet A and the data layer is stored on a mysql Compute Engine virtual machine (VM) in subnet B on the same VPC. Subnet A and Subnet B hold several other Compute Engine VMs. You only want to allow the application frontend to access the data in the application's mysql instance on port 3306.

What should you do?

- A. Configure an ingress firewall rule that allows communication from the src IP range of subnet A to the tag "data-tag" that is applied to the mysql Compute Engine VM on port 3306.
- B. Configure an ingress firewall rule that allows communication from the frontend's unique service account to the unique service account of the mysql Compute Engine VM on port 3306.
- C. Configure a network tag "fe-tag" to be applied to all instances in subnet A and a network tag "data-tag" to be applied to all instances in subnet B. Then configure an egress firewall rule that allows communication from Compute Engine VMs tagged with data-tag to destination Compute Engine VMs tagged fe- tag.
- D. Configure a network tag "fe-tag" to be applied to all instances in subnet A and a network tag "data-tag" to be applied to all instances in subnet B. Then configure an ingress firewall rule that allows communication from Compute Engine VMs tagged with fe-tag to destination Compute Engine VMs tagged with data-tag.

Answer: B

Explanation:

The correct answer is **B**, using service accounts for granular access control. Here's why:

Principle of Least Privilege: Option B adheres to the principle of least privilege by granting access only to the specific resources that require it. It restricts communication to the application frontend's service account and the database instance's service account, instead of broadly allowing communication based on network tags or IP ranges.

Service Account-Based Access: Google Cloud Platform (GCP) service accounts represent identities for non-human resources, like VMs. Using service accounts allows for more granular control compared to relying on IP ranges or network tags. This approach provides a robust, identity-based security posture.

Granular Control: By utilizing service accounts, we can define fine-grained permissions, allowing specific front-end instances to communicate with the specific database instance. This contrasts with solutions relying on network tags that would allow all instances with a tag to communicate with all instances with another tag potentially expanding the attack surface.

Avoiding IP-Based Rules: Using IP ranges (Option A) can lead to maintenance overhead. IP addresses can change, and relying on them may lead to misconfigurations. Additionally, IP-based rules are less secure as they don't consider identities.

Firewall Rule Direction: Option C incorrectly suggests egress firewall rules. Egress rules control outbound traffic from VMs, not inbound. The application frontend is initiating the communication to the database, hence it is ingress traffic from the perspective of the database.

Incorrect Tag Usage in Options C and D: Options C and D use network tags to identify the source and destination VMs. However, these options allow communication from any VM with the "fe-tag" to any VM with

the "data-tag" which is not what the question asks, which is the frontend of the application to only the database, and opens the communication to any VM with those tags.

Security Best Practice: Google Cloud strongly recommends using service accounts to control resource access, as it provides a more secure and maintainable approach. Relying on IP ranges or network tags can lead to complex rules and misconfigurations.

Reduced Attack Surface: Option B minimizes the potential attack surface by limiting communication solely to intended service accounts, enhancing the security posture.

Authoritative Links for Further Research:

Google Cloud IAM Overview: <https://cloud.google.com/iam/docs/overview>

Service Accounts: <https://cloud.google.com/iam/docs/service-accounts>

Firewall Rules Overview: <https://cloud.google.com/vpc/docs/firewalls>

Best Practices for using Service Accounts: <https://cloud.google.com/iam/docs/best-practices-for-using-service-accounts>

Question: 88

CertyIQ

Your company operates an application instance group that is currently deployed behind a Google Cloud load balancer in us-central-1 and is configured to use the Standard Tier network. The infrastructure team wants to expand to a second Google Cloud region, us-east-2. You need to set up a single external IP address to distribute new requests to the instance groups in both regions. What should you do?

- A. Change the load balancer backend configuration to use network endpoint groups instead of instance groups.
- B. Change the load balancer frontend configuration to use the Premium Tier network, and add the new instance group.
- C. Create a new load balancer in us-east-2 using the Standard Tier network, and assign a static external IP address.
- D. Create a Cloud VPN connection between the two regions, and enable Google Private Access.

Answer: B

Explanation:

The correct answer is **B**. To achieve a single external IP address distributing traffic across multiple regions, a global load balancer is required. Standard Tier networking in Google Cloud provides regional resources, meaning the load balancer's IP address and its scope are limited to the us-central-1 region.

Moving to Premium Tier networking enables the use of global load balancing features. Specifically, by selecting Premium Tier, you gain access to a global external HTTP(S) load balancer. This type of load balancer allows you to configure backends (in this case, instance groups) in multiple regions, such as both us-central-1 and us-east-2, and manages request distribution according to configured rules. Option B correctly states changing the front-end configuration to Premium Tier, which is necessary for multi-region load balancing and adding the new instance group in us-east-2.

Option A is incorrect because while network endpoint groups (NEGs) offer flexibility, changing to NEGs alone will not resolve the limitation of Standard Tier networking preventing global traffic distribution. Option C is incorrect because creating a second regional load balancer in us-east-2 would not satisfy the requirement of having a single external IP address; it would create a second point of entry with its own IP address. Option D is incorrect because a Cloud VPN is not necessary for external load balancing. VPNs are used for secure network connectivity, not request distribution for publicly facing applications. Furthermore, Google Private Access is for accessing Google APIs from private networks, not for multi-region load balancing.

Supporting links:

Premium Tier Network: <https://cloud.google.com/network-connectivity/docs/network-tiers/premium-tier>

Global External HTTP(S) Load Balancer: <https://cloud.google.com/load-balancing/docs/https/>

Network Endpoint Groups (NEGs): <https://cloud.google.com/load-balancing/docs/negs>

Question: 89

CertyIQ

You are the security admin of your company. You have 3,000 objects in your Cloud Storage bucket. You do not want to manage access to each object individually. You also do not want the uploader of an object to always have full control of the object. However, you want to use Cloud Audit Logs to manage access to your bucket. What should you do?

- A. Set up an ACL with OWNER permission to a scope of allUsers.
- B. Set up an ACL with READER permission to a scope of allUsers.
- C. Set up a default bucket ACL and manage access for users using IAM.
- D. Set up Uniform bucket-level access on the Cloud Storage bucket and manage access for users using IAM.

Answer: D

Explanation:

The correct answer is **D. Set up Uniform bucket-level access on the Cloud Storage bucket and manage access for users using IAM.**

Here's why:

Uniform bucket-level access is designed to simplify access control for Cloud Storage buckets. It disables the use of Access Control Lists (ACLs) and enforces IAM-based permissions. This addresses the requirement of not managing access on individual objects.

IAM provides a centralized and more manageable approach to access control. You can assign roles to users or groups, granting them specific permissions (e.g., storage.objectAdmin, storage.objectCreator, storage.objectViewer) at the bucket level, eliminating the need to manage per-object ACLs. This fulfills the requirement of avoiding individual object access management and prevents object uploaders from having full control.

Cloud Audit Logs record administrative and data access activity for your Google Cloud resources. While they provide visibility into access attempts, they do not directly manage access, but allow you to analyze access patterns. IAM handles the authorization of access, not the audit logs.

Options A and B using ACLs with allUsers would grant access to anyone which is a huge security risk. Option C is not the best option as you want to centralize your access control.

In summary, by enabling uniform bucket-level access and using IAM, you gain centralized control over your Cloud Storage bucket, ensuring that users only have the necessary permissions and that object access is managed consistently at the bucket level, not individually. This also addresses the requirements of not granting uploaders full control and leverages Cloud Audit logs for monitoring rather than management.

Authoritative Links:

Uniform bucket-level access: <https://cloud.google.com/storage/docs/uniform-bucket-level-access>

IAM for Cloud Storage: <https://cloud.google.com/storage/docs/access-control/iam-permissions>

Cloud Audit Logs: <https://cloud.google.com/logging/docs/audit>

Question: 90

You are the security admin of your company. Your development team creates multiple GCP projects under the "implementation" folder for several dev, staging, and production workloads. You want to prevent data exfiltration by malicious insiders or compromised code by setting up a security perimeter. However, you do not want to restrict communication between the projects.

What should you do?

- A. Use a Shared VPC to enable communication between all projects, and use firewall rules to prevent data exfiltration.
- B. Create access levels in Access Context Manager to prevent data exfiltration, and use a shared VPC for communication between projects.
- C. Use an infrastructure-as-code software tool to set up a single service perimeter and to deploy a Cloud Function that monitors the "implementation" folder via Stackdriver and Cloud Pub/Sub. When the function notices that a new project is added to the folder, it executes Terraform to add the new project to the associated perimeter.
- D. Use an infrastructure-as-code software tool to set up three different service perimeters for dev, staging, and prod and to deploy a Cloud Function that monitors the "implementation" folder via Stackdriver and Cloud Pub/Sub. When the function notices that a new project is added to the folder, it executes Terraform to add the new project to the respective perimeter.

Answer: C

Explanation:

The correct answer is **C**. Here's why:

Service perimeters, as offered by VPC Service Controls (VPC SC), are designed to prevent data exfiltration by restricting access to Google Cloud services from outside the defined perimeter. This aligns directly with the requirement to prevent data loss from malicious insiders or compromised code. Option C leverages a single service perimeter for all projects within the "implementation" folder, fulfilling the need for data exfiltration protection while still allowing unrestricted communication between projects within the perimeter. The infrastructure-as-code (IaC) approach using Terraform ensures consistent and automated deployment of the perimeter, and the Cloud Function automates the inclusion of new projects in the perimeter. This dynamic inclusion eliminates the need for manual updates and ensures new projects are always under the perimeter's protection, thereby improving overall security posture.

Option A is incorrect as Shared VPC and firewall rules primarily manage network traffic, not data exfiltration via service access. Option B is partially correct in its access levels recommendation but Access Context Manager does not provide comprehensive control over data exfiltration similar to VPC Service Controls. It is best used for access control based on attributes like device type or IP, not for perimeter based data exfiltration. Option D while attempting to implement perimeters, uses multiple perimeters, and by doing so it adds unnecessary complexity and goes against the requirement to allow all projects to communicate with each other without restriction. If these were separate perimeters, communication between them would be restricted.

Authoritative links:

VPC Service Controls: <https://cloud.google.com/vpc-service-controls>

Terraform: <https://www.terraform.io/>

Cloud Functions: <https://cloud.google.com/functions>

Stackdriver (now Cloud Logging): <https://cloud.google.com/logging>

Cloud Pub/Sub: <https://cloud.google.com/pubsub>

Access Context Manager: <https://cloud.google.com/access-context-manager>

Shared VPC: <https://cloud.google.com/vpc/docs/shared-vpc>

Question: 91

You need to provide a corporate user account in Google Cloud for each of your developers and operational staff who need direct access to GCP resources.

Corporate policy requires you to maintain the user identity in a third-party identity management provider and leverage single sign-on. You learn that a significant number of users are using their corporate domain email addresses for personal Google accounts, and you need to follow Google recommended practices to convert existing unmanaged users to managed accounts.

Which two actions should you take? (Choose two.)

- A. Use Google Cloud Directory Sync to synchronize your local identity management system to Cloud Identity.
- B. Use the Google Admin console to view which managed users are using a personal account for their recovery email.
- C. Add users to your managed Google account and force users to change the email addresses associated with their personal accounts.
- D. Use the Transfer Tool for Unmanaged Users (TTUU) to find users with conflicting accounts and ask them to transfer their personal Google accounts.
- E. Send an email to all of your employees and ask those users with corporate email addresses for personal Google accounts to delete the personal accounts immediately.

Answer: AD

Explanation:

Here's the justification for choosing options A and D:

Option A: Use Google Cloud Directory Sync to synchronize your local identity management system to Cloud Identity. This is a crucial step in transitioning to a managed identity environment. Google Cloud Directory Sync (GCDS) allows you to automatically synchronize user accounts and groups from your existing third-party identity management system (like Active Directory or another LDAP server) to Google Cloud Identity. This ensures that all corporate users who need access to GCP resources are represented in your managed Google account. By having a centralized source of truth for user identities, you can enforce consistent policies and permissions.<https://support.google.com/cloudidentity/answer/7272480?hl=en>

Option D: Use the Transfer Tool for Unmanaged Users (TTUU) to find users with conflicting accounts and ask them to transfer their personal Google accounts. Since many users have personal Google accounts tied to their corporate email, simply creating new managed accounts for them won't address the underlying issue of account conflict. The Transfer Tool for Unmanaged Users (TTUU) helps identify these conflicting personal accounts. By prompting these users to transfer their data from their personal Google accounts to the newly created managed accounts, the issue of conflicting accounts is resolved. This ensures that the users have access to corporate resources using their corporate credentials, and their personal accounts are not affected by the move.<https://support.google.com/a/answer/6486918?hl=en>

Why other options are not correct:

Option B: While useful, checking for recovery emails won't directly help with transitioning unmanaged accounts.

Option C: Forcing users to change their personal email addresses is not feasible or recommended, and can cause a significant disruption for the users.

Option E: Asking users to delete their accounts will cause data loss and isn't a recommended practice. TTUU allows users to transfer the data instead of delete the account.

By employing GCDS and TTUU, you can efficiently migrate existing corporate users to managed Google accounts while ensuring their data from personal accounts is migrated and maintaining the single-sign-on approach that your organization requires. This approach aligns with Google's best practices for managing identity in a corporate setting.

Question: 92

You are on your company's development team. You noticed that your web application hosted in staging on GKE dynamically includes user data in web pages without first properly validating the inputted data. This could allow an attacker to execute gibberish commands and display arbitrary content in a victim user's browser in a production environment.

How should you prevent and fix this vulnerability?

- A. Use Cloud IAP based on IP address or end-user device attributes to prevent and fix the vulnerability.
- B. Set up an HTTPS load balancer, and then use Cloud Armor for the production environment to prevent the potential XSS attack.
- C. Use Web Security Scanner to validate the usage of an outdated library in the code, and then use a secured version of the included library.
- D. Use Web Security Scanner in staging to simulate an XSS injection attack, and then use a templating system that supports contextual auto-escaping.

Answer: D

Explanation:

The correct answer is **D**. Here's why:

Option D directly addresses the identified XSS (Cross-Site Scripting) vulnerability. Using Web Security Scanner in staging allows you to simulate an XSS attack, confirming the vulnerability's presence. Then, implementing a templating system that supports contextual auto-escaping is a vital preventive measure. This system automatically encodes user input when rendering it into HTML, ensuring that injected script is treated as plain text rather than executable code. This stops an attacker from executing arbitrary code within a user's browser and mitigates the risk.

Option A, Cloud IAP, primarily controls access to your application but does not prevent XSS. It may limit who can interact, but an attacker with valid access could still exploit the vulnerability. Option B, Cloud Armor, can help with some attack vectors like DDoS or SQL injection, but it doesn't fully mitigate XSS attacks that are dynamic in nature. Option C, while finding vulnerable libraries is beneficial, it doesn't directly deal with the specific vulnerability at hand. An updated library won't inherently block XSS, which often arises from how data is used rather than library weaknesses. Therefore, the most effective combination of detection and remediation for XSS is found in Option D.

Authoritative Links:

OWASP (Open Web Application Security Project) on XSS: <https://owasp.org/www-project-top-ten/> -

Specifically, see the section on "Cross-Site Scripting (XSS)"

Google Cloud Documentation on Web Security Scanner: <https://cloud.google.com/security-command-center/docs/concepts-web-security-scanner>

Templating systems and contextual auto-escaping: Search for resources on specific templating systems (e.g., Jinja2, Handlebars) and their security features. For example, Jinja2 auto-escaping:

<https://jinja.palletsprojects.com/en/3.1.x/templates/#escaping>

Question: 93

You are part of a security team that wants to ensure that a Cloud Storage bucket in Project A can only be readable from Project B. You also want to ensure that data in the Cloud Storage bucket cannot be accessed from or copied to Cloud Storage buckets outside the network, even if the user has the correct credentials.

What should you do?

- A. Enable VPC Service Controls, create a perimeter with Project A and B, and include Cloud Storage service.

- B. Enable Domain Restricted Sharing Organization Policy and Bucket Policy Only on the Cloud Storage bucket.
- C. Enable Private Access in Project A and B networks with strict firewall rules to allow communication between the networks.
- D. Enable VPC Peering between Project A and B networks with strict firewall rules to allow communication between the networks.

Answer: A

Explanation:

The correct answer is A because it directly addresses the requirements of restricting access to a Cloud Storage bucket in Project A to only Project B, while also preventing data exfiltration outside the designated network. VPC Service Controls (VPC SC) allows you to establish security perimeters around Google Cloud resources, limiting access based on the request's network origin, not just the user's identity. Option A creates a perimeter encompassing Projects A and B, including Cloud Storage. This ensures that only requests originating from within this perimeter can access the Cloud Storage bucket, effectively preventing access from outside the defined network, even if a user has valid credentials. Option B, using Domain Restricted Sharing, would only restrict sharing based on identity and not network location, failing to prevent exfiltration to storage outside the desired projects. Option C, focusing on Private Access and firewall rules, restricts network traffic between the projects but doesn't prevent access to the storage from outside, assuming valid identities. Option D, utilizing VPC peering and firewalls, establishes connectivity but lacks the perimeter enforcement to block external access entirely. VPC SC, on the other hand, provides this layer of perimeter-based security, fulfilling the requirements of limiting access and preventing data exfiltration. Therefore, VPC SC, with a perimeter including projects A and B and the Cloud Storage service, is the best option.

Authoritative Link: [VPC Service Controls Documentation](#)

Question: 94

CertyIQ

You are responsible for protecting highly sensitive data in BigQuery. Your operations teams need access to this data, but given privacy regulations, you want to ensure that they cannot read the sensitive fields such as email addresses and first names. These specific sensitive fields should only be available on a need-to-know basis to the Human Resources team. What should you do?

- A. Perform data masking with the Cloud Data Loss Prevention API, and store that data in BigQuery for later use.
- B. Perform data redaction with the Cloud Data Loss Prevention API, and store that data in BigQuery for later use.
- C. Perform data inspection with the Cloud Data Loss Prevention API, and store that data in BigQuery for later use.
- D. Perform tokenization for Pseudonymization with the Cloud Data Loss Prevention API, and store that data in BigQuery for later use.

Answer: D

Explanation:

The correct answer is **D. Perform tokenization for Pseudonymization with the Cloud Data Loss Prevention API, and store that data in BigQuery for later use.**

Here's why:

Tokenization for pseudonymization is the ideal method when you need to protect sensitive data while still allowing for data processing and analysis. Tokenization replaces sensitive values (like email addresses and names) with non-sensitive, reversible tokens. This means the operations team can work with the data without accessing the real sensitive information, fulfilling privacy requirements.

Cloud DLP (Data Loss Prevention) API is the perfect tool for performing this kind of transformation. It offers built-in functions for tokenizing, de-identifying, and re-identifying data.

Preservation of data utility: The key advantage of tokenization is that it allows the operations teams to perform joins, aggregations, and other analyses with the tokenized data. They maintain the structure and relationality of the original dataset. If the HR team needs the actual sensitive data, they can use the token mapping managed by DLP to re-identify specific records on a need-to-know basis.

Masking (Option A) replaces sensitive values with fixed characters, like 'X'. This makes the data useless for most analytical purposes as the relationships and utility of the data are destroyed.

Redaction (Option B) simply removes the sensitive information, which is also not ideal when teams need some data processing capabilities. The data is completely removed and is not reversible.

Data inspection (Option C) only detects and reports sensitive data, which doesn't actively address the need to provide accessible but protected information for operations. It's a preliminary step, not a solution for this scenario.

Therefore, tokenization with Cloud DLP provides the required balance between data security and accessibility for different teams. It is the best method for protecting sensitive data and allowing data processing by the operations team while restricting direct access to sensitive fields to the HR team, who can re-identify the values when necessary.

Authoritative links for further research:

Google Cloud DLP documentation: <https://cloud.google.com/dlp/docs>

De-identification methods with DLP: <https://cloud.google.com/dlp/docs/deid-transformations>

Tokenization basics: <https://www.dataversity.net/tokenization-data-security-explained/>

Question: 95

CertyIQ

You are a Security Administrator at your organization. You need to restrict service account creation capability within production environments. You want to accomplish this centrally across the organization. What should you do?

- A. Use Identity and Access Management (IAM) to restrict access of all users and service accounts that have access to the production environment.
- B. Use organization policy constraints/iam.disableServiceAccountKeyCreation boolean to disable the creation of new service accounts.
- C. Use organization policy constraints/iam.disableServiceAccountKeyUpload boolean to disable the creation of new service accounts.
- D. Use organization policy constraints/iam.disableServiceAccountCreation boolean to disable the creation of new service accounts.

Answer: D

Explanation:

The correct answer is **D. Use organization policy constraints/iam.disableServiceAccountCreation boolean to disable the creation of new service accounts.**

Here's why: Organization policies in Google Cloud are designed to provide centralized control and governance across your entire organization. The iam.disableServiceAccountCreation boolean constraint specifically targets the ability to create new service accounts. Setting this constraint at the organizational level will enforce this restriction across all projects and resources within the organization, including production environments. This directly addresses the requirement to centrally restrict service account creation.

Option A, while addressing access control, focuses on managing existing permissions and doesn't prevent the creation of new accounts. Options B and C, iam.disableServiceAccountKeyCreation and

iam.disableServiceAccountKeyUpload, control the creation and uploading of service account keys, respectively. While related to service accounts, they don't prevent their creation, which is the core requirement.

By using the iam.disableServiceAccountCreation constraint, you can effectively prevent the creation of new service accounts, ensuring that production environments adhere to your defined security policy. This policy constraint is inherited down through the resource hierarchy, providing consistent governance. This approach promotes a least privilege principle by restricting the ability to create new service accounts which could potentially be misused, thereby minimizing the attack surface.

Authoritative links:

Google Cloud Organization Policy Constraints: <https://cloud.google.com/resource-manager/docs/organization-policy/org-policy-constraints>

IAM Organization Policy constraints: <https://cloud.google.com/iam/docs/org-policy-constraints>

Organization policies for service accounts: <https://cloud.google.com/iam/docs/organization-policy-service-accounts>

Question: 96

CertyIQ

You are the project owner for a regulated workload that runs in a project you own and manage as an Identity and Access Management (IAM) admin. For an upcoming audit, you need to provide access reviews evidence. Which tool should you use?

- A. Policy Troubleshooter
- B. Policy Analyzer
- C. IAM Recommender
- D. Policy Simulator

Answer: B

Explanation:

The correct answer is **B. Policy Analyzer**. Here's why:

Policy Analyzer is specifically designed to understand and analyze IAM policies within your Google Cloud environment. It provides insights into who has what access and allows you to query policies effectively, making it ideal for producing access review evidence. The need for access reviews implies a requirement to understand the current state of permissions within the project, not to troubleshoot, simulate changes, or receive recommendations for modifications. Policy Analyzer allows you to query the IAM policies based on user or service account to enumerate the effective roles and permissions. Unlike Policy Troubleshooter, which focuses on resolving access issues, Policy Analyzer gives a holistic view of current access rights. IAM Recommender suggests optimal IAM configurations based on usage patterns, not the current state required for evidence. Policy Simulator predicts the effect of hypothetical IAM changes, which is not what is needed for an audit seeking evidence of current access. Therefore, Policy Analyzer is the most suitable tool to provide evidence for an audit needing to understand the existing access within your project. It enables you to efficiently document and demonstrate the current access posture, satisfying the requirements of a security access review.

For further information, please refer to the following official Google Cloud documentation:

Policy Analyzer: <https://cloud.google.com/policy-intelligence/docs/policy-analyzer>

IAM Overview: <https://cloud.google.com/iam/docs/overview>

Question: 97

Your organization has implemented synchronization and SAML federation between Cloud Identity and Microsoft Active Directory. You want to reduce the risk of Google Cloud user accounts being compromised. What should you do?

- A. Create a Cloud Identity password policy with strong password settings, and configure 2-Step Verification with security keys in the Google Admin console.
- B. Create a Cloud Identity password policy with strong password settings, and configure 2-Step Verification with verification codes via text or phone call in the Google Admin console.
- C. Create an Active Directory domain password policy with strong password settings, and configure post-SSO (single sign-on) 2-Step Verification with security keys in the Google Admin console.
- D. Create an Active Directory domain password policy with strong password settings, and configure post-SSO (single sign-on) 2-Step Verification with verification codes via text or phone call in the Google Admin console.

Answer: C

Explanation:

The correct answer is C because it addresses the core security concern in a hybrid identity environment where Google Cloud is federated with Microsoft Active Directory. Since user authentication is primarily managed by Active Directory in this scenario, the primary password policy enforcement should occur there, not in Cloud Identity. This ensures consistency across the organization's authentication.

Implementing a strong password policy in Active Directory, as proposed by options C and D, is crucial for preventing password-based attacks. The added layer of security comes from enabling post-SSO 2-Step Verification (2SV) within the Google environment. Post-SSO 2SV means that users, after authenticating through Active Directory via SAML, will be prompted for a second factor when accessing Google Cloud resources.

Security keys are a highly secure form of 2SV, offering resistance against phishing and other types of attacks, making option C superior to option D. Relying solely on text/phone calls for 2SV (as in option D) is considered less secure than security keys. Options A and B are incorrect as they try to enforce password policies within Google, which, in a federated environment, is not the primary authority for password management. Therefore, C provides a comprehensive approach by controlling the password strength at the source (Active Directory) and adding a second security check via secure 2SV within Google Cloud.

Authoritative Links:

Google Cloud Identity Best Practices: <https://cloud.google.com/identity/docs/best-practices>

SAML Federation and Google Workspace: <https://support.google.com/a/answer/6005949?hl=en>

Google 2-Step Verification: <https://support.google.com/accounts/answer/185839?hl=en>

Active Directory Password Policies: <https://learn.microsoft.com/en-us/windows-server/security/credentials-protection-and-management/password-policy>

Post-SSO 2-Step Verification with Google: <https://support.google.com/a/answer/9177181>

Question: 98

You have been tasked with implementing external web application protection against common web application attacks for a public application on Google Cloud.

You want to validate these policy changes before they are enforced. What service should you use?

- A. Google Cloud Armor's preconfigured rules in preview mode
- B. Prepopulated VPC firewall rules in monitor mode
- C. The inherent protections of Google Front End (GFE)

- D. Cloud Load Balancing firewall rules
- E. VPC Service Controls in dry run mode

Answer: A

Explanation:

The correct answer is **A. Google Cloud Armor's preconfigured rules in preview mode**. Here's why:

Google Cloud Armor is a Web Application Firewall (WAF) service designed to protect web applications from various attacks, including those listed in the OWASP Top 10. It offers preconfigured rules that can be customized to specific application needs. Critically, Cloud Armor allows you to deploy these rules in "preview mode." Preview mode enables you to evaluate the impact of your rules by logging matched requests without actively blocking or mitigating them. This feature is essential for validating policy changes and avoiding unintended disruptions to your application.

VPC firewall rules (options B & D) are network-level firewalls that operate on traffic entering and leaving your VPC, focusing on IP addresses and ports, not application-level attacks. While monitor mode in VPC firewalls can log network traffic, it doesn't provide the granular protection and targeted rule sets offered by a WAF like Cloud Armor. The inherent protections of Google Front End (GFE) (option C) offer basic security, but are not as configurable or provide the same level of detail when needing to validate specific rule behavior before deployment. VPC Service Controls (option E) operate on a different layer, focusing on data exfiltration prevention and aren't meant for web application protection or testing WAF rules. They can't be deployed in a dry-run mode that validates security policy changes.

Therefore, Cloud Armor in preview mode is the precise tool for validating web application protection policies before enforcement, allowing administrators to assess potential impacts before implementing changes.

Supporting Links:

Google Cloud Armor documentation: <https://cloud.google.com/armor/docs>

Preview mode information: <https://cloud.google.com/armor/docs/preview-mode>

WAF concepts: <https://cloud.google.com/security/what-is-a-web-application-firewall>

Question: 99

CertyIQ

You are asked to recommend a solution to store and retrieve sensitive configuration data from an application that runs on Compute Engine. Which option should you recommend?

- A. Cloud Key Management Service
- B. Compute Engine guest attributes
- C. Compute Engine custom metadata
- D. Secret Manager

Answer: D

Explanation:

The correct answer is **D. Secret Manager**. Secret Manager is Google Cloud's dedicated service for securely storing and managing sensitive data like API keys, passwords, and other credentials. It offers features like automatic versioning, access control with IAM, audit logging, and encryption at rest and in transit. This makes it the ideal choice for storing configuration data that needs to be protected. While Cloud Key Management Service (A) is used for managing cryptographic keys, it's not designed for directly storing configuration values. Compute Engine guest attributes (B) and custom metadata (C) are suitable for instance-specific configurations but lack the robust security and access controls required for sensitive data like secrets. They

are also more easily accessible compared to Secret Manager, and storing secrets directly in metadata poses a higher security risk. Therefore, Secret Manager provides the appropriate level of security and features for the task.

For further research:

Secret Manager Documentation: <https://cloud.google.com/secret-manager/docs>

Choosing a configuration storage method: <https://cloud.google.com/architecture/configuration-management#choose-configuration-storage>

Secret Management Best Practices: <https://cloud.google.com/security/best-practices/secrets-management>

Question: 100

CertyIQ

You need to implement an encryption at-rest strategy that reduces key management complexity for non-sensitive data and protects sensitive data while providing the flexibility of controlling the key residency and rotation schedule. FIPS 140-2 L1 compliance is required for all data types. What should you do?

- A. Encrypt non-sensitive data and sensitive data with Cloud External Key Manager.
- B. Encrypt non-sensitive data and sensitive data with Cloud Key Management Service
- C. Encrypt non-sensitive data with Google default encryption, and encrypt sensitive data with Cloud External Key Manager.
- D. Encrypt non-sensitive data with Google default encryption, and encrypt sensitive data with Cloud Key Management Service.

Answer: D

Explanation:

Here's a detailed justification for why option D is the correct approach:

Option D best addresses the multi-faceted requirements of the scenario by leveraging the strengths of both Google-managed encryption and Cloud KMS. The prompt requires a strategy for both non-sensitive and sensitive data, with different key management needs. Specifically, non-sensitive data should minimize key management complexity while sensitive data requires greater control, including key residency and rotation. FIPS 140-2 L1 compliance is also mandatory across all data.

Google's default encryption provides automatic encryption at rest using Google-managed keys, minimizing management overhead for non-sensitive data. This meets the requirement of reducing key management complexity and is FIPS 140-2 L1 compliant.

Cloud Key Management Service (KMS) allows you to create, manage, and rotate encryption keys with complete control. This addresses the need for controlled key residency and rotation schedules for sensitive data. Furthermore, Cloud KMS provides FIPS 140-2 Level 1 compliant keys.

Options A and C are incorrect because they propose the use of Cloud External Key Manager (EKM) for non-sensitive data, which introduces unnecessary complexity and cost. EKM is designed for scenarios where keys need to be managed entirely outside of Google Cloud. Option B is incorrect as it misses the opportunity to simplify the management of encryption keys for non-sensitive data. Using Cloud KMS for both data types would add unnecessary administrative overhead and key rotation complexities when Google default keys would meet the requirements of non-sensitive data. Option D is the most cost-effective and efficient solution while fulfilling all stated requirements. It uses simple default encryption for the non-critical data and provides high level management and control for sensitive data.

Authoritative Links:

Google Cloud KMS: <https://cloud.google.com/kms/>

Google Cloud Default Encryption: <https://cloud.google.com/security/encryption-at-rest>

FIPS 140-2 Compliance: <https://cloud.google.com/security/compliance/fips-140-2>

Cloud External Key Manager: <https://cloud.google.com/kms/docs/ekm>

Question: 101

CertyIQ

Your company wants to determine what products they can build to help customers improve their credit scores depending on their age range. To achieve this, you need to join user information in the company's banking app with customers' credit score data received from a third party. While using this raw data will allow you to complete this task, it exposes sensitive data, which could be propagated into new systems.

This risk needs to be addressed using de-identification and tokenization with Cloud Data Loss Prevention while maintaining the referential integrity across the database. Which cryptographic token format should you use to meet these requirements?

- A. Deterministic encryption
- B. Secure, key-based hashes
- C. Format-preserving encryption
- D. Cryptographic hashing

Answer: A

Explanation:

The correct answer is **A. Deterministic encryption**. Here's why:

Deterministic encryption is crucial in this scenario because it allows for consistent tokenization of the same data values. This means that the same user ID, for example, will always result in the same tokenized value. This is essential for maintaining referential integrity across the database, enabling joins between the user information and credit score data while using the tokenized values. The requirement of joining user information and credit scores hinges on the predictability of this tokenization, a feature that deterministic encryption provides. Secure, key-based hashes (B) are one-way functions, and thus not reversible or deterministic for comparison. Format-preserving encryption (C), while useful in certain scenarios, isn't specifically designed for ensuring consistent token values across datasets and maintaining referential integrity for database joins; it would require a lookup to restore the original values to identify matches. Cryptographic hashing (D), like option B, does not produce deterministic, reversible values for comparisons. The need for de-identification and tokenization in the context of sensitive data handling points directly to the use of encryption, as per the best practices for secure data processing. Deterministic encryption allows the joining of records, while still protecting the sensitive user identifiers. It enables analysis to be performed on the data while reducing exposure of sensitive user data.

For further research on deterministic encryption and its applications, consider exploring these resources:

Cloud Data Loss Prevention (DLP) documentation: <https://cloud.google.com/dlp/docs>

Cryptographic tokenization techniques: Search online for resources explaining deterministic encryption and its differences from other methods like hashing. Look for resources focusing on tokenization for referential integrity.

NIST guidelines on data de-identification: Look for NIST publications discussing data anonymization/pseudonymization techniques, as these provide detailed explanations and requirements.

Question: 102

CertyIQ

An office manager at your small startup company is responsible for matching payments to invoices and creating billing alerts. For compliance reasons, the office manager is only permitted to have the Identity and Access Management (IAM) permissions necessary for these tasks. Which two IAM roles should the office manager have?

(Choose two.)

- A. Organization Administrator
- B. Project Creator
- C. Billing Account Viewer
- D. Billing Account Costs Manager
- E. Billing Account User

Answer: CD

Explanation:

The correct IAM roles for the office manager are **Billing Account Viewer** (C) and **Billing Account Costs Manager** (D). These roles grant the necessary permissions for managing billing information without providing excessive access. The manager needs to view billing account details to match payments to invoices, which is facilitated by the Billing Account Viewer role. This role provides read-only access to billing account information. To create billing alerts, the manager requires permission to manage cost data. This is specifically granted by the Billing Account Costs Manager role, which allows for setting up budgets and alerts based on spending. The Organization Administrator role (A) grants broad administrative control at the organization level, which is not needed for the described tasks and violates the principle of least privilege. The Project Creator role (B) grants permission to create new projects, which is irrelevant to billing management. The Billing Account User role (E), while related to billing, doesn't encompass cost management functionalities which are necessary for setting up alerts. Therefore, option C and D are the least privileged roles that satisfy the stated requirements.

Relevant Documentation:

Predefined Roles for Cloud Billing: <https://cloud.google.com/billing/docs/how-to/billing-access> - This official Google Cloud document provides detailed information about billing access control and the various predefined roles.

IAM Roles: <https://cloud.google.com/iam/docs/understanding-roles> - This link provides general information about IAM roles and how they work in Google Cloud.

Question: 103

CertyIQ

You are designing a new governance model for your organization's secrets that are stored in Secret Manager. Currently, secrets for Production and Non-Production applications are stored and accessed using service accounts. Your proposed solution must:

- Provide granular access to secrets
- Give you control over the rotation schedules for the encryption keys that wrap your secrets
- Maintain environment separation
- Provide ease of management

Which approach should you take?

- A. 1. Use separate Google Cloud projects to store Production and Non-Production secrets. 2. Enforce access control to secrets using project-level identity and Access Management (IAM) bindings. 3. Use customer-managed encryption keys to encrypt secrets.
- B. 1. Use a single Google Cloud project to store both Production and Non-Production secrets. 2. Enforce access control to secrets using secret-level Identity and Access Management (IAM) bindings. 3. Use Google-managed encryption keys to encrypt secrets.
- C. 1. Use separate Google Cloud projects to store Production and Non-Production secrets. 2. Enforce access control to secrets using secret-level Identity and Access Management (IAM) bindings. 3. Use Google-managed encryption keys to encrypt secrets.
- D. 1. Use a single Google Cloud project to store both Production and Non-Production secrets. 2. Enforce access control to secrets using project-level Identity and Access Management (IAM) bindings. 3. Use customer-managed encryption keys to encrypt secrets.

Answer: A

Explanation:

Option A is the correct approach because it best addresses the requirements of granular access, encryption key control, environment separation, and ease of management. Storing Production and Non-Production secrets in separate Google Cloud projects ensures strong environment isolation, a core security practice. Project-level IAM bindings provide a good balance of access control granularity, allowing you to manage access at the project level without the complexity of managing individual secret permissions. Using customer-managed encryption keys (CMEK) grants you full control over the encryption key lifecycle, including rotation schedules, which meets the key management requirement. This approach avoids the complexities of secret-level IAM bindings while still providing a secure and maintainable system. Option B fails to provide environment separation, using Google-managed keys doesn't provide control over rotation schedule. Option C fails in the ease of management, Secret-level access control can become unwieldy. Option D violates the environment separation, project level access control will be too broad, and having a single project can lead to accidental cross-environment contamination.

Authoritative Links for further research:

Secret Manager Overview: <https://cloud.google.com/secret-manager/docs/overview>

IAM for Secret Manager: <https://cloud.google.com/secret-manager/docs/access-control>

Customer-Managed Encryption Keys (CMEK) in Secret Manager:

<https://cloud.google.com/kms/docs/cmek/secret-manager>

Best Practices for Organizing Resources: <https://cloud.google.com/resource-manager/docs/creating-managing-projects>

IAM concepts: <https://cloud.google.com/iam/docs/overview>

Question: 104

CertyIQ

You are a security engineer at a finance company. Your organization plans to store data on Google Cloud, but your leadership team is worried about the security of their highly sensitive data. Specifically, your company is concerned about internal Google employees' ability to access your company's data on Google Cloud. What solution should you propose?

- A. Use customer-managed encryption keys.
- B. Use Google's Identity and Access Management (IAM) service to manage access controls on Google Cloud.
- C. Enable Admin activity logs to monitor access to resources.
- D. Enable Access Transparency logs with Access Approval requests for Google employees.

Answer: D

Explanation:

The correct answer is **D. Enable Access Transparency logs with Access Approval requests for Google employees**. This solution directly addresses the concern about Google employees accessing highly sensitive data. Access Transparency provides near real-time logs whenever Google personnel access customer content, offering visibility into these actions. Access Approval further enhances security by requiring explicit approval from the customer before Google support personnel can access customer data. This provides a crucial layer of control and accountability, mitigating the risk of unauthorized internal access. Option A, customer-managed encryption keys, primarily protects against external threats and ensures data confidentiality but doesn't restrict Google internal access. IAM, option B, manages access within the customer's own organization, not Google employees. While option C, admin activity logs, monitors customer-initiated actions, it won't capture Google employee access. Therefore, Access Transparency with Access Approval is the most effective solution to address the specific concern regarding Google employee access.

Supporting Links:

Access Transparency: <https://cloud.google.com/access-transparency>

Access Approval: <https://cloud.google.com/access-approval>

Customer-Managed Encryption Keys: <https://cloud.google.com/kms/docs/cmek>

Identity and Access Management (IAM): <https://cloud.google.com/iam>

Admin Activity Logs: <https://cloud.google.com/logging/docs/audit>

Question: 105

CertyIQ

You want to use the gcloud command-line tool to authenticate using a third-party single sign-on (SSO) SAML identity provider. Which options are necessary to ensure that authentication is supported by the third-party identity provider (IdP)? (Choose two.)

- A. SSO SAML as a third-party IdP
- B. Identity Platform
- C. OpenID Connect
- D. Identity-Aware Proxy
- E. Cloud Identity

Answer: AC

Explanation:

The correct options are **A and C**. Here's why:

A. SSO SAML as a third-party IdP: The question explicitly states the need for third-party SSO SAML authentication. SAML (Security Assertion Markup Language) is an XML-based standard for exchanging authentication and authorization data between an identity provider (IdP) and a service provider. In this scenario, the gcloud tool acts as the service provider, and the user's organization's SSO system, which uses SAML, is the IdP. To use this system, the gcloud tool must be configured to communicate and validate SAML assertions coming from this third-party IdP. This is the fundamental requirement in the scenario.

C. OpenID Connect: OpenID Connect (OIDC) is another authentication protocol built on top of OAuth 2.0. While the question mentions SAML, it does not preclude OIDC being a potential solution. The gcloud command line tool can indeed support OIDC authentication. The use of the term "third party" does not imply that only SAML is valid here, there is no restriction. If the third-party IdP supports OIDC, the gcloud tool can be configured to leverage this protocol as well. This is important because OIDC is often more common than SAML in modern identity systems.

Why other options are incorrect:

B. Identity Platform: Google Identity Platform is a managed service providing user management and authentication. It's not necessary when integrating with an existing external IdP. Identity Platform is better suited for applications that directly manage user identities.

D. Identity-Aware Proxy: Identity-Aware Proxy (IAP) is a service for controlling access to web applications hosted on Google Cloud. While important for security, IAP doesn't handle the initial user authentication process with a third-party IdP. It operates post-authentication and is separate from the gcloud authentication flow.

E. Cloud Identity: Cloud Identity is Google's Identity-as-a-Service (IDaaS) offering. Similar to Identity Platform, Cloud Identity manages user identities within a Google ecosystem. It's not directly relevant when authenticating via an external, non-Google SAML or OIDC IdP with the gcloud tool.

Authoritative Links for further research:

SAML: https://en.wikipedia.org/wiki/Security_Assertion_Markup_Language
OpenID Connect: <https://openid.net/connect/>
gcloud auth: <https://cloud.google.com/sdk/gcloud/reference/auth>
Google Identity Platform: <https://cloud.google.com/identity-platform>
Google Identity Aware Proxy: <https://cloud.google.com/iap/>
Google Cloud Identity: <https://cloud.google.com/identity>

Question: 106

CertyIQ

You work for a large organization where each business unit has thousands of users. You need to delegate management of access control permissions to each business unit. You have the following requirements:

- Each business unit manages access controls for their own projects.

Each business unit manages access control permissions at scale.

- Business units cannot access other business units' projects.
- Users lose their access if they move to a different business unit or leave the company.
- Users and access control permissions are managed by the on-premises directory service.

What should you do? (Choose two.)

- A. Use VPC Service Controls to create perimeters around each business unit's project.
- B. Organize projects in folders, and assign permissions to Google groups at the folder level.
- C. Group business units based on Organization Units (OUs) and manage permissions based on OUs
- D. Create a project naming convention, and use Google's IAM Conditions to manage access based on the prefix of project names.
- E. Use Google Cloud Directory Sync to synchronize users and group memberships in Cloud Identity.

Answer: BE

Explanation:

B. Organize projects in folders, and assign permissions to Google groups at the folder level. E. Use Google Cloud Directory Sync to synchronize users and group memberships in Cloud Identity.

Question: 107

CertyIQ

Your organization recently deployed a new application on Google Kubernetes Engine. You need to deploy a solution to protect the application. The solution has the following requirements:

- Scans must run at least once per week
- Must be able to detect cross-site scripting vulnerabilities
- Must be able to authenticate using Google accounts

Which solution should you use?

- A. Google Cloud Armor
- B. Web Security Scanner
- C. Security Health Analytics
- D. Container Threat Detection

Answer: B

Explanation:

The correct answer is **B. Web Security Scanner**.

Here's a justification:

Web Security Scanner is specifically designed to identify vulnerabilities in web applications. It can detect common issues like cross-site scripting (XSS), SQL injection, and outdated libraries, directly addressing one of the requirements. It performs automated scans, which can be scheduled to run at least once per week, satisfying another criterion. Web Security Scanner is built to integrate with Google Cloud's infrastructure and is capable of authenticating using Google accounts, aligning with the stated authentication requirement.

Google Cloud Armor (A) focuses on protecting against distributed denial-of-service (DDoS) attacks and other network-layer threats, not application-specific vulnerabilities like XSS. Security Health Analytics (C) provides insights into security misconfigurations in Google Cloud resources, not web application vulnerabilities. Container Threat Detection (D) focuses on threats within containers, not web application layer vulnerabilities. Therefore, Web Security Scanner is the only service that fulfills all the specified requirements, making it the most appropriate choice for this scenario.

Authoritative Links for further research:

Web Security Scanner Documentation: <https://cloud.google.com/web-security-scanner/docs>

Google Cloud Armor Documentation: <https://cloud.google.com/armor/docs>

Security Health Analytics Documentation: <https://cloud.google.com/security-command-center/docs/how-to-use-security-health-analytics>

Container Threat Detection Documentation: <https://cloud.google.com/container-threat-detection/docs>

Question: 108

CertyIQ

An organization is moving applications to Google Cloud while maintaining a few mission-critical applications on-premises. The organization must transfer the data at a bandwidth of at least 50 Gbps. What should they use to ensure secure continued connectivity between sites?

- A. Dedicated Interconnect
- B. Cloud Router
- C. Cloud VPN
- D. Partner Interconnect

Answer: A

Explanation:

The correct answer is **A. Dedicated Interconnect**. Here's why:

Dedicated Interconnect provides a direct physical connection between an organization's on-premises network and Google's network. This option offers high-bandwidth, low-latency connectivity crucial for transferring large datasets at 50 Gbps or more. It bypasses the public internet, enhancing security and reliability.

Cloud Router (B) is a fully distributed and managed service that provides dynamic routing using BGP over Cloud VPN or interconnect links, but it doesn't provide the actual physical connectivity. It works in conjunction with Dedicated Interconnect or Partner Interconnect. Cloud VPN (C) establishes secure IPsec tunnels over the public internet. While it offers security, it's limited in bandwidth and is not suitable for transferring data at the required 50 Gbps. Partner Interconnect (D) is another option for interconnectivity, but it relies on a third-party service provider. While capable of high bandwidths, it is not the direct connection that Dedicated Interconnect offers. The specific requirement for 50 Gbps minimum transfer rate makes Dedicated Interconnect the most suitable choice.

Therefore, to meet the organization's requirements for high bandwidth and secure connectivity for the movement of applications and data, Dedicated Interconnect is the optimal solution.

Authoritative Links:

Question: 109

CertyIQ

Your organization has had a few recent DDoS attacks. You need to authenticate responses to domain name lookups. Which Google Cloud service should you use?

- A. Cloud DNS with DNSSEC
- B. Cloud NAT
- C. HTTP(S) Load Balancing
- D. Google Cloud Armor

Answer: A

Explanation:

The correct answer is **A. Cloud DNS with DNSSEC**.

Here's why: DNSSEC (Domain Name System Security Extensions) is a suite of security extensions to DNS that adds cryptographic signatures to DNS data. This allows resolvers to verify the authenticity of DNS responses, ensuring that the information hasn't been tampered with during transit. In the context of DDoS attacks, particularly those that target DNS infrastructure, DNSSEC plays a crucial role. Malicious actors can sometimes attempt to redirect DNS queries to their own servers, causing users to be routed to malicious sites (DNS spoofing). DNSSEC effectively mitigates this threat by ensuring DNS responses are validated through cryptographic signatures.

Cloud DNS with DNSSEC enables you to protect your domain name lookups by providing a trusted chain of authentication that reaches all the way to the authoritative name servers for your domain, preventing man-in-the-middle attacks and reducing the risk of your users being misdirected.

Let's briefly examine why other options aren't suitable:

Cloud NAT: Cloud NAT (Network Address Translation) enables virtual machine instances without external IP addresses to access the internet but doesn't secure DNS responses, focusing on network traffic.

HTTP(S) Load Balancing: HTTP(S) Load Balancing distributes HTTP(S) traffic across multiple backend instances. It is relevant for distributing traffic across servers, not for securing DNS lookups.

Google Cloud Armor: Google Cloud Armor provides web application firewall (WAF) capabilities and protection against layer 7 DDoS attacks, operating at the application level, not the DNS level.

Therefore, the appropriate solution for authenticating DNS responses and mitigating the impact of DNS-related attacks is to use **Cloud DNS with DNSSEC**.

Authoritative Links:

[Cloud DNS Overview](#)

[DNSSEC Overview](#)

[Understanding DNSSEC](#)

Question: 110

CertyIQ

Your Security team believes that a former employee of your company gained unauthorized access to Google Cloud resources some time in the past 2 months by using a service account key. You need to confirm the unauthorized access and determine the user activity. What should you do?

- A. Use Security Health Analytics to determine user activity.
- B. Use the Cloud Monitoring console to filter audit logs by user.
- C. Use the Cloud Data Loss Prevention API to query logs in Cloud Storage.
- D. Use the Logs Explorer to search for user activity.

Answer: D

Explanation:

Okay, let's break down why option D is the correct approach. The core issue is identifying unauthorized access using a service account key within a past timeframe. This requires examining audit logs, not analyzing security vulnerabilities or monitoring performance metrics.

Option D, using the Logs Explorer, is the most appropriate because it's Google Cloud's primary tool for searching and analyzing audit logs. These logs capture a comprehensive record of API calls made to Google Cloud resources, including those made by service accounts. Crucially, Logs Explorer allows filtering by various attributes, such as time range (the past two months), principal (the potentially compromised service account), and resource (specific Google Cloud resources). This granularity is necessary to pinpoint the suspected unauthorized access.

Options A, B, and C are not suitable for this specific scenario. Security Health Analytics (A) focuses on identifying security vulnerabilities in configurations and isn't designed to trace specific user activity from logs. Cloud Monitoring (B) is primarily used for performance monitoring and alerting. While it can surface some log-based metrics, it doesn't provide the detailed log exploration capabilities needed here. The Cloud Data Loss Prevention API (C) is centered around data discovery and classification for sensitive information; it isn't the right tool for analyzing general access logs.

The Logs Explorer allows searching for "protoPayload.authenticationInfo.principalEmail" to identify actions taken by service accounts. It is the correct tool for investigating past user activity with a specific service account key.

In essence, Logs Explorer offers the precise filtering and search capabilities required to correlate potential unauthorized activity with a potentially compromised service account key, making it the most effective choice.

Authoritative Links:

Cloud Logging Overview: <https://cloud.google.com/logging/docs/overview>

Logs Explorer: <https://cloud.google.com/logging/docs/logs-explorer>

Understanding Audit Logs: <https://cloud.google.com/logging/docs/audit>

Question: 111

CertyIQ

Your company requires the security and network engineering teams to identify all network anomalies within and across VPCs, internal traffic from VMs to VMs, traffic between end locations on the internet and VMs, and traffic between VMs to Google Cloud services in production. Which method should you use?

- A. Define an organization policy constraint.
- B. Configure packet mirroring policies.
- C. Enable VPC Flow Logs on the subnet.
- D. Monitor and analyze Cloud Audit Logs.

Answer: B

Explanation:

The correct answer is **B. Configure packet mirroring policies**. Here's why:

Packet mirroring allows you to copy network traffic from virtual machine instances and forward it to a designated collector for analysis. This capability is crucial for identifying network anomalies because it provides a deep inspection of the actual packets transmitted. Packet mirroring can capture traffic within and across VPCs, including VM-to-VM communication, traffic between VMs and the internet, and even communication between VMs and Google Cloud services, as specified in the scenario. This provides the comprehensive visibility needed for the security and network teams.

VPC Flow Logs (C) only record metadata about network flows (source/destination IPs, ports, protocol), not the actual packet content. While useful for traffic analysis, flow logs lack the detailed payload information needed for deep anomaly detection, making it insufficient to identify complex attacks or behavioral anomalies in packet contents. They can be used for trend and volume analysis but not for analysis of an individual transmission.

Organization policy constraints (A) restrict configurations and actions. They are important for enforcing security standards but do not provide monitoring or traffic analysis capabilities, which are required to identify network anomalies.

Cloud Audit Logs (D) record API activity within the Google Cloud environment, not network traffic data. These are helpful for tracking user actions and administrative changes but do not offer insight into the actual network communications, which are necessary for finding anomalies.

Therefore, packet mirroring, with its ability to capture the actual packet data and send it to a collector, provides the most comprehensive method for meeting the company's requirement of identifying network anomalies across all specified traffic types.

Authoritative Links:

Google Cloud Packet Mirroring: <https://cloud.google.com/vpc/docs/packet-mirroring>

Google Cloud VPC Flow Logs: <https://cloud.google.com/vpc/docs/using-flow-logs>

Google Cloud Organization Policy Constraints: <https://cloud.google.com/resource-manager/docs/organization-policy/overview>

Google Cloud Audit Logs: <https://cloud.google.com/logging/docs/audit/>

Question: 112

CertyIQ

Your company has been creating users manually in Cloud Identity to provide access to Google Cloud resources. Due to continued growth of the environment, you want to authorize the Google Cloud Directory Sync (GCDS) instance and integrate it with your on-premises LDAP server to onboard hundreds of users. You are required to:

- Replicate user and group lifecycle changes from the on-premises LDAP server in Cloud Identity.
- Disable any manually created users in Cloud Identity.

You have already configured the LDAP search attributes to include the users and security groups in scope for Google Cloud. What should you do next to complete this solution?

- A. 1. Configure the option to suspend domain users not found in LDAP. 2. Set up a recurring GCDS task.
- B. 1. Configure the option to delete domain users not found in LDAP. 2. Run GCDS after user and group lifecycle changes.
- C. 1. Configure the LDAP search attributes to exclude manually created Cloud Identity users not found in LDAP. 2. Set up a recurring GCDS task.
- D. 1. Configure the LDAP search attributes to exclude manually created Cloud Identity users not found in LDAP. 2. Run GCDS after user and group lifecycle changes.

Answer: A

Explanation:

The correct answer is **A**. Here's the detailed justification:

The primary goal is to transition from manual Cloud Identity user management to automated synchronization with an on-premises LDAP server using Google Cloud Directory Sync (GCDS), while also handling existing manually created users. Option A addresses both aspects.

Step 1: Configure the option to suspend domain users not found in LDAP. This is crucial for deactivating manually created users that are not present in the LDAP directory. GCDS, when configured with this option, will identify users present in Cloud Identity but absent from the synced LDAP directory and automatically suspend them, effectively disabling their access to Google Cloud resources. This ensures that only users managed by the LDAP directory have active accounts, adhering to the requirement to disable manual users.

Step 2: Set up a recurring GCDS task. This step establishes continuous synchronization between the on-premises LDAP server and Cloud Identity. With a recurring task, any lifecycle changes (creations, modifications, deletions) made in the LDAP server will be automatically reflected in Cloud Identity. This fulfills the requirement to replicate user and group lifecycle changes, ensuring ongoing user management consistency.

Option B is incorrect because deleting Cloud Identity users directly, rather than suspending them, would likely cause data loss and is generally not recommended during an initial sync. Options C and D are incorrect because attempting to filter users via LDAP search attributes after the fact does not address the issue of manually created users. The key is to take active action through GCDS to manage these existing users which can be achieved by suspending them.

Relevant Cloud Computing Concepts:

Cloud Identity: Google's Identity as a Service (IDaaS) solution, providing centralized user and group management for Google Cloud and other applications.

Google Cloud Directory Sync (GCDS): A tool that synchronizes data from your on-premises directory to Cloud Identity.

LDAP (Lightweight Directory Access Protocol): A protocol used to access and manage directory information.

User Lifecycle Management: The process of creating, modifying, and deleting user accounts throughout their time in an organization.

Authoritative Links for Further Research:

[About GCDS - Google Workspace Admin Help](#)

[Synchronize users and groups with Google Cloud Directory Sync - Google Workspace Admin Help](#)

[Manage your Cloud Identity users - Google Cloud](#)

In conclusion, option A is the only viable approach to correctly and effectively synchronize your on-premises LDAP server with Cloud Identity while addressing the legacy manual users. It leverages GCDS's functionality to manage the existing users through suspension, and then establishes continuous syncing for long-term management.

Question: 113

CertyIQ

You are troubleshooting access denied errors between Compute Engine instances connected to a Shared VPC and BigQuery datasets. The datasets reside in a project protected by a VPC Service Controls perimeter. What should you do?

- A. Add the host project containing the Shared VPC to the service perimeter.
- B. Add the service project where the Compute Engine instances reside to the service perimeter.
- C. Create a service perimeter between the service project where the Compute Engine instances reside and the host project that contains the Shared VPC.

D. Create a perimeter bridge between the service project where the Compute Engine instances reside and the perimeter that contains the protected BigQuery datasets.

Answer: A

Explanation:

The correct answer is A. Adding the host project containing the Shared VPC to the service perimeter is the necessary step to resolve the access denied errors. VPC Service Controls (VPC SC) perimeters define a security boundary around Google Cloud resources, allowing or denying access based on the project's membership in the perimeter. In a Shared VPC setup, resources in service projects utilize the network in the host project. For resources within a service project to access resources protected by a VPC SC perimeter, the network's host project must be included within the perimeter. Therefore, the access originates not from the individual service projects but from the host project's network. Option B is incorrect because the compute instances reside within the service project, which isn't relevant to the perimeter's network access control, and option C is irrelevant to VPC SC perimeters which are project-level constructs and don't bridge projects. Option D is incorrect because perimeter bridges facilitate access between different perimeters, not within a perimeter. Adding the host project ensures that Compute Engine instances connected to that host's Shared VPC are recognized as originating from a trusted network within the perimeter, thus allowing access to BigQuery datasets. Failing to include the host project within the VPC SC perimeter would lead to continued access denial errors, regardless of any service project membership within the perimeter.

Supporting Documentation:

VPC Service Controls Documentation: <https://cloud.google.com/vpc-service-controls/docs>

Shared VPC and VPC SC: https://cloud.google.com/vpc/docs/shared-vpc#vpc_service_controls

Question: 114

CertyIQ

You recently joined the networking team supporting your company's Google Cloud implementation. You are tasked with familiarizing yourself with the firewall rules configuration and providing recommendations based on your networking and Google Cloud experience. What product should you recommend to detect firewall rules that are overlapped by attributes from other firewall rules with higher or equal priority?

- A. Security Command Center
- B. Firewall Rules Logging
- C. VPC Flow Logs
- D. Firewall Insights

Answer: D

Explanation:

The correct answer is **D. Firewall Insights**. Firewall Insights is a feature within Google Cloud's Network Intelligence Center specifically designed to analyze and provide visibility into firewall rule configurations. A key function of Firewall Insights is to detect and highlight situations where firewall rules overlap, meaning their attributes such as source, destination, protocol, and port ranges, might conflict with other rules of equal or higher priority. This overlap can lead to unexpected network behavior and security vulnerabilities. Firewall Insights identifies these anomalies and provides actionable recommendations, such as removing shadowed rules or modifying the priority of the rules to ensure the intended network security policy is correctly enforced. This capability is critical for maintaining a clean, efficient, and secure firewall configuration.

While Security Command Center (A) provides a broader view of security risks and vulnerabilities across your Google Cloud environment, and can be used to surface firewall misconfigurations, it does not offer the granular analysis of rule overlaps that Firewall Insights provides. Firewall Rules Logging (B) captures logs of

traffic allowed or denied by the rules, but it doesn't analyze rule overlaps itself. Similarly, VPC Flow Logs (C) records network traffic information flowing within your VPC networks and doesn't directly help in resolving overlapping rules.

Therefore, Firewall Insights's dedicated focus on firewall rule analysis and conflict detection makes it the most appropriate tool for the stated task.

Authoritative Links:

Firewall Insights Overview: <https://cloud.google.com/network-intelligence-center/docs/firewall-insights/overview>

Using Firewall Insights: <https://cloud.google.com/network-intelligence-center/docs/firewall-insights/use-insights>

Question: 115

CertyIQ

The security operations team needs access to the security-related logs for all projects in their organization. They have the following requirements:

- Follow the least privilege model by having only view access to logs.
- Have access to Admin Activity logs.
- Have access to Data Access logs.
- Have access to Access Transparency logs.

Which Identity and Access Management (IAM) role should the security operations team be granted?

- A. roles/logging.privateLogViewer
- B. roles/logging.admin
- C. roles/viewer
- D. roles/logging.viewer

Answer: A

Explanation:

The correct answer is **A. roles/logging.privateLogViewer**. Here's why:

The security operations team requires read-only access to several types of logs: Admin Activity, Data Access, and Access Transparency. These logs, while crucial for security monitoring, often contain sensitive information. The roles/logging.privateLogViewer role is specifically designed to grant read-only access to these sensitive log types. Crucially, it aligns with the principle of least privilege by providing no modification or deletion capabilities.

roles/logging.admin (option B) is far too permissive, granting full control over logs, including writing and deletion – which is not required and violates the least privilege principle. roles/viewer (option C) provides broad read access across resources, but not the focused permissions necessary for viewing private logs like Data Access and Access Transparency. Finally, roles/logging.viewer (option D) provides general logging access, but lacks the capability to view the Data Access or Access Transparency Logs, making it insufficient for the team's needs.

roles/logging.privateLogViewer ensures the team can perform their monitoring tasks while minimizing the risk of accidental or malicious modification. This role is specifically tailored for security teams that need to analyze audit data within log entries without altering those records.

Further Research:

Google Cloud IAM Roles for Logging: <https://cloud.google.com/iam/docs/understanding-roles#logging-roles>

Principle of Least Privilege: https://en.wikipedia.org/wiki/Principle_of_least_privilege

Question: 116

CertyIQ

You are exporting application logs to Cloud Storage. You encounter an error message that the log sinks don't support uniform bucket-level access policies. How should you resolve this error?

- A. Change the access control model for the bucket
- B. Update your sink with the correct bucket destination.
- C. Add the roles/logging.logWriter Identity and Access Management (IAM) role to the bucket for the log sink identity.
- D. Add the roles/logging.bucketWriter Identity and Access Management (IAM) role to the bucket for the log sink identity.

Answer: A

Explanation:

The error message "log sinks don't support uniform bucket-level access policies" indicates an incompatibility between the chosen bucket access control configuration and the log sink's requirements. Uniform bucket-level access (UBLA) enforces a single, consistent access policy at the bucket level, ignoring object-level ACLs. Log sinks, by design, often require granular permissions to write log data to specific locations within the bucket. UBLA restricts this granularity. Therefore, to resolve this, you must switch the bucket from using UBLA to using a more traditional access control model like ACLs or IAM policies that allow object-level permissions.

Option A, "Change the access control model for the bucket," is the correct solution. This means disabling UBLA on the Cloud Storage bucket, allowing for the traditional access model using IAM roles and permissions. Options B, C, and D do not address the core issue of incompatibility with UBLA. Updating the sink destination (B) won't solve the UBLA conflict. Adding roles/logging.logWriter (C) or roles/logging.bucketWriter (D) to the log sink's IAM role is necessary for writing to the bucket in general, but they don't bypass the UBLA limitation. The root of the issue is the restrictive nature of UBLA and the log sinks dependency on more flexible access control. Choosing option A, which disables UBLA, restores the granular access control model needed for the log sink to operate correctly.

Authoritative Links for Further Research:

Uniform bucket-level access: <https://cloud.google.com/storage/docs/uniform-bucket-level-access>

Cloud Logging Sink Permissions:

https://cloud.google.com/logging/docs/export/configure_export_v2#permissions

Cloud Storage Access Control: <https://cloud.google.com/storage/docs/access-control/>

Question: 117

CertyIQ

You plan to deploy your cloud infrastructure using a CI/CD cluster hosted on Compute Engine. You want to minimize the risk of its credentials being stolen by a third party. What should you do?

- A. Create a dedicated Cloud Identity user account for the cluster. Use a strong self-hosted vault solution to store the user's temporary credentials.
- B. Create a dedicated Cloud Identity user account for the cluster. Enable the constraints/iam.disableServiceAccountCreation organization policy at the project level.
- C. Create a custom service account for the cluster. Enable the constraints/iam.disableServiceAccountKeyCreation organization policy at the project level

D. Create a custom service account for the cluster. Enable the constraints/iam.allowServiceAccountCredentialLifetimeExtension organization policy at the project level.

Answer: C

Explanation:

The correct answer is C. Here's why:

Option C recommends creating a custom service account for the CI/CD cluster. Service accounts are best practice for applications running within Google Cloud, as they provide a non-human identity with specific permissions, adhering to the principle of least privilege. This is better than using a user account.

Further, Option C advises enabling the constraints/iam.disableServiceAccountKeyCreation organization policy. This policy prevents the creation of new long-lived service account keys. Long-lived keys, if compromised, pose a significant security risk. By disabling their creation, you're forcing applications (in this case, your CI/CD cluster) to rely on short-lived credentials obtained from the instance's metadata server, drastically reducing the impact of key compromise. This approach is preferred to managing and securing keys directly.

Option A is incorrect because while it uses a dedicated Cloud Identity user, using a user account for a cluster is inappropriate and storing temporary credentials in a self-hosted vault creates a complex management overhead with potential security issues if the vault itself is compromised.

Option B is not ideal. While it uses a dedicated Cloud Identity user, enabling constraints/iam.disableServiceAccountCreation would prevent you from creating the necessary service account for the cluster. You do need service accounts to use resources, you don't want to stop them from being created.

Option D is incorrect as constraints/iam.allowServiceAccountCredentialLifetimeExtension would actually extend credential lifetimes, increasing the risk of compromise, not mitigating it. It also does not address the underlying need to use short-lived credentials.

In summary, option C promotes secure practices by using a service account (not user account) and enforcing the use of short-lived credentials via the organization policy, mitigating risks associated with long-lived keys.

Authoritative Links:

Service Accounts: <https://cloud.google.com/iam/docs/service-accounts>

Organization Policies: <https://cloud.google.com/resource-manager/docs/organization-policy/overview>
constraints/iam.disableServiceAccountKeyCreation policy: <https://cloud.google.com/resource-manager/docs/organization-policy/policies/iam-disableServiceAccountKeyCreation>

Metadata Server: <https://cloud.google.com/compute/docs/instances/access-create-metadata>

Question: 118

CertyIQ

You need to set up two network segments: one with an untrusted subnet and the other with a trusted subnet. You want to configure a virtual appliance such as a next-generation firewall (NGFW) to inspect all traffic between the two network segments. How should you design the network to inspect the traffic?

- A. 1. Set up one VPC with two subnets: one trusted and the other untrusted. 2. Configure a custom route for all traffic (0.0.0.0/0) pointed to the virtual appliance.
- B. 1. Set up one VPC with two subnets: one trusted and the other untrusted. 2. Configure a custom route for all RFC1918 subnets pointed to the virtual appliance.
- C. 1. Set up two VPC networks: one trusted and the other untrusted, and peer them together. 2. Configure a custom route on each network pointed to the virtual appliance.
- D. 1. Set up two VPC networks: one trusted and the other untrusted. 2. Configure a virtual appliance using

multiple network interfaces, with each interface connected to one of the VPC networks.

Answer: D

Explanation:

The correct answer is **D**. Here's why:

Option D proposes creating two separate VPC networks, one for the trusted subnet and another for the untrusted subnet. This isolation is crucial for security best practices. By deploying a virtual appliance (like an NGFW) with multiple network interfaces — one connected to each VPC network — the appliance acts as a gateway and enforces security policies between the two segments. Traffic originating from the untrusted subnet must pass through the NGFW to reach the trusted subnet, and vice-versa. This architecture provides a choke point for inspection, allowing the NGFW to analyze and potentially block malicious traffic.

Option A is incorrect because using a single VPC with subnets for both trusted and untrusted environments doesn't offer adequate security separation. Routing all traffic through a virtual appliance in this setup is complex and could inadvertently expose traffic if configurations are not precise.

Option B is also incorrect for similar reasons as Option A; using custom routes for RFC1918 subnets in the same VPC is insufficient to create network segmentation and also doesn't solve the traffic isolation problem.

Option C is incorrect because peering VPCs can expose traffic, and it would not enforce proper isolation as the virtual appliance would also need to be in one of the networks. Therefore it would create unnecessary complexity and overhead.

The architecture in Option D aligns with a hub-and-spoke model, where the NGFW acts as the hub for network traffic between the untrusted and trusted spokes. It leverages the power of network isolation provided by different VPCs while allowing for robust inspection of all communication between them. This design provides an effective and secure way to inspect traffic, and it aligns with zero-trust network principles.

Authoritative Links:

Google Cloud VPC Networking Overview: <https://cloud.google.com/vpc/docs/vpc>

Google Cloud Virtual Appliance Options: <https://cloud.google.com/vpc/docs/firewall-policies/overview> and <https://cloud.google.com/network-connectivity/docs/network-connectivity-center/concepts/network-connectivity-center-overview>

Hub and Spoke Network Design in GCP: <https://cloud.google.com/architecture/networking/hub-spoke>

Question: 119

CertyIQ

You are a member of your company's security team. You have been asked to reduce your Linux bastion host external attack surface by removing all public IP addresses. Site Reliability Engineers (SREs) require access to the bastion host from public locations so they can access the internal VPC while off-site. How should you enable this access?

- A. Implement Cloud VPN for the region where the bastion host lives.
- B. Implement OS Login with 2-step verification for the bastion host.
- C. Implement Identity-Aware Proxy TCP forwarding for the bastion host.
- D. Implement Google Cloud Armor in front of the bastion host.

Answer: C

Explanation:

The correct answer is **C. Implement Identity-Aware Proxy (IAP) TCP forwarding for the bastion host**. Here's

why:

IAP enables secure access to applications and resources running on Google Cloud Platform (GCP) without requiring a public IP address. IAP leverages Google's identity and access management (IAM) framework, ensuring only authorized users can reach the bastion host. When an SRE attempts to connect, IAP authenticates them via their Google account, and enforces any configured access policies. The "TCP forwarding" capability of IAP specifically allows for tunneling SSH connections to the bastion host, which is essential for the SREs to perform their duties. Cloud VPN (A) would establish a site-to-site VPN connection which isn't feasible for SREs working from various public locations. OS Login with 2-step verification (B) enhances the security of individual user accounts but does not address the issue of removing the public IP address. Google Cloud Armor (D) is designed for defending against web-based attacks, not SSH-based traffic which is required for this scenario. IAP thus offers granular access control and eliminates the need for a publicly reachable IP for the bastion host, significantly reducing the attack surface.

Further Research:

[Identity-Aware Proxy Overview](#)

[IAP for TCP forwarding](#)

[Bastion Hosts](#)

Question: 120

CertyIQ

You need to enable VPC Service Controls and allow changes to perimeters in existing environments without preventing access to resources. Which VPC Service Controls mode should you use?

- A. Cloud Run
- B. Native
- C. Enforced
- D. Dry run

Answer: D

Explanation:

The correct answer is **D. Dry run**. VPC Service Controls' dry run mode is specifically designed for situations where you need to observe the impact of perimeter configurations before enforcing them, allowing for risk mitigation and smoother transitions. This mode logs actions that would violate a defined perimeter without actually blocking those actions. This is crucial when dealing with existing environments because it prevents disruption to existing workflows and resource access. By using dry run, you can identify potential issues, unexpected access restrictions, or necessary exceptions before enforcing the perimeter, which could otherwise cause significant downtime or user experience problems. Once you understand the impact and have appropriately adjusted your policies, you can then transition to an enforced mode. Other options like 'Cloud Run' and 'Native' do not represent actual VPC Service Controls modes, and 'Enforced' mode would prevent access which is opposite of the user's need. Dry run allows for safe experimentation before implementing a full security policy by creating logs for evaluation, aiding in creating more refined perimeters for effective security control.

Authoritative Links:

Google Cloud Documentation on VPC Service Controls Dry Run Mode: <https://cloud.google.com/vpc-service-controls/docs/dry-run>

VPC Service Controls Overview: <https://cloud.google.com/vpc-service-controls/docs/overview>

Question: 121

You manage your organization's Security Operations Center (SOC). You currently monitor and detect network traffic anomalies in your Google Cloud VPCs based on packet header information. However, you want the capability to explore network flows and their payload to aid investigations. Which Google Cloud product should you use?

- A. Marketplace IDS
- B. VPC Flow Logs
- C. VPC Service Controls logs
- D. Packet Mirroring
- E. Google Cloud Armor Deep Packet Inspection

Answer: D

Explanation:

The correct answer is **D. Packet Mirroring**. Here's why:

Packet Mirroring is a Google Cloud feature that duplicates network traffic from specified virtual machine instances (VMs) and forwards it to a designated collector destination. This capability is crucial for in-depth analysis because it allows security teams to capture not only header information (as with VPC Flow Logs), but also the full content (payload) of network packets.

Option A, Marketplace IDS, offers pre-configured third-party intrusion detection systems but doesn't natively provide the base packet capture functionality. Option B, VPC Flow Logs, only captures metadata about network flows (source/destination IPs, ports, etc.) and does not include payload data. Option C, VPC Service Controls logs, focuses on access control and service perimeter configurations, not network packet capture. Option E, Google Cloud Armor Deep Packet Inspection (DPI), focuses on inspecting web traffic at the edge for security threats and is not intended for internal VPC traffic analysis.

Packet Mirroring, in contrast, allows SOC teams to examine the complete packet data, enabling them to identify malware, exfiltration attempts, and other threats that would not be visible with header information alone. This is essential for advanced security investigations. By sending mirrored traffic to a tool like a network intrusion detection system (NIDS) or security analytics platform, security professionals can conduct deeper forensic analysis.

Therefore, Packet Mirroring is the best choice to achieve the requirement of exploring network flows and their payload for investigations.

Authoritative Links:

Google Cloud Packet Mirroring Documentation: <https://cloud.google.com/vpc/docs/packet-mirroring>
Overview of VPC Flow Logs: <https://cloud.google.com/vpc/docs/using-flow-logs>

Question: 122

Your organization acquired a new workload. The Web and Application (App) servers will be running on Compute Engine in a newly created custom VPC. You are responsible for configuring a secure network communication solution that meets the following requirements:

- Only allows communication between the Web and App tiers.
- Enforces consistent network security when autoscaling the Web and App tiers.
- Prevents Compute Engine Instance Admins from altering network traffic.

What should you do?

- A. 1. Configure all running Web and App servers with respective network tags. 2. Create an allow VPC firewall rule that specifies the target/source with respective network tags.

- B. 1. Configure all running Web and App servers with respective service accounts. 2. Create an allow VPC firewall rule that specifies the target/source with respective service accounts.
- C. 1. Re-deploy the Web and App servers with instance templates configured with respective network tags. 2. Create an allow VPC firewall rule that specifies the target/source with respective network tags.
- D. 1. Re-deploy the Web and App servers with instance templates configured with respective service accounts. 2. Create an allow VPC firewall rule that specifies the target/source with respective service accounts.

Answer: D

Explanation:

The correct answer is **D**. Here's why:

Option D leverages service accounts and instance templates to achieve secure, consistent, and tamper-proof network communication between the Web and App tiers. Service accounts provide an identity to the Compute Engine instances, which the firewall rules can utilize for authorization. By associating the correct service account with instances in each tier and using them in the firewall rules, we create a policy that ensures that only VMs belonging to the Web tier can communicate with those in the App tier, and vice-versa, while preventing unauthorized traffic.

Instance templates ensure that every new instance, created by autoscaling or other means, will have the proper service account configuration. This establishes consistency across the infrastructure and removes the need for manual tag configuration. Because service accounts can't be modified by Instance Admin users, we've effectively ensured that these firewall rules will be enforced.

Options A and C use tags, which can be easily modified or removed by users with compute instance admin privileges, making them unsuitable for a security-sensitive environment. While option B uses service accounts, it still recommends changing them in the running VMs directly which is undesirable. Option D is the most secure, scalable, and auditable solution.

Here are some links for further reading:

Service Accounts: <https://cloud.google.com/iam/docs/service-accounts>

Instance Templates: <https://cloud.google.com/compute/docs/instance-templates>

VPC Firewall Rules: <https://cloud.google.com/vpc/docs/firewalls>

In summary, Option D effectively isolates communication, ensures consistency, and maintains the security of the networking infrastructure.

Question: 123

CertyIQ

You need to connect your organization's on-premises network with an existing Google Cloud environment that includes one Shared VPC with two subnets named Production and Non-Production. You are required to:

- Use a private transport link.
- Configure access to Google Cloud APIs through private API endpoints originating from on-premises environments.
- Ensure that Google Cloud APIs are only consumed via VPC Service Controls.

What should you do?

- A. 1. Set up a Cloud VPN link between the on-premises environment and Google Cloud. 2. Configure private access using the restricted.googleapis.com domains in on-premises DNS configurations.
- B. 1. Set up a Partner Interconnect link between the on-premises environment and Google Cloud. 2. Configure private access using the private.googleapis.com domains in on-premises DNS configurations.
- C. 1. Set up a Direct Peering link between the on-premises environment and Google Cloud. 2. Configure private access for both VPC subnets.

D. 1. Set up a Dedicated Interconnect link between the on-premises environment and Google Cloud. 2. Configure private access using the restricted.googleapis.com domains in on-premises DNS configurations.

Answer: D

Explanation:

Here's a detailed justification for why option D is the correct solution:

The problem requires a private transport link, private access to Google Cloud APIs from on-premises, and consumption of those APIs through VPC Service Controls. Let's break down why each part of option D addresses these needs:

1. **Dedicated Interconnect:** This option establishes a dedicated, physical connection between your on-premises network and Google Cloud. This satisfies the "private transport link" requirement. Dedicated Interconnect offers high bandwidth and low latency, which is ideal for enterprise environments needing reliable and secure connectivity. It bypasses the public internet, ensuring traffic privacy and security.
2. **restricted.googleapis.com:** Configuring on-premises DNS to resolve API calls to this domain directs traffic to Google's private API endpoints, which are accessible only within your VPC or through private connectivity. This satisfies the requirement for private API access from on-premises. Furthermore, using restricted.googleapis.com enforces VPC Service Controls. APIs can only be accessed via network paths that are part of a service perimeter, and it does not enable access to public Google API endpoints.

Options A, B, and C are less suitable:

Option A (Cloud VPN): While Cloud VPN provides a private connection, it's not as robust or high-bandwidth as Dedicated Interconnect. The security isn't as robust and latency can be more of an issue.

Option B (Partner Interconnect): Partner Interconnect is a valid option but introduces another service provider as a middleman and it requires a third party vendor. Dedicated Interconnect gives a more direct connection between your organization and Google. It also uses private.googleapis.com which is more permissive than restricted.googleapis.com.

Option C (Direct Peering): Direct Peering establishes a direct connection but it does not provide private access to Google Cloud APIs and does not enforce VPC Service Controls.

In summary, Dedicated Interconnect provides the necessary private, high-performance connection while using restricted.googleapis.com for secure and private API access with VPC Service Controls enforcement, making option D the correct choice.

Authoritative Links:

Dedicated Interconnect: <https://cloud.google.com/network-connectivity/docs/interconnect/concepts/dedicated-interconnect>

Private Google Access: <https://cloud.google.com/vpc/docs/private-access-options>

VPC Service Controls: <https://cloud.google.com/vpc-service-controls/docs/overview>

Restricted Google APIs: <https://cloud.google.com/vpc/docs/configure-private-google-access#restricted-google-apis>

Question: 124

CertyIQ

You are working with protected health information (PHI) for an electronic health record system. The privacy officer is concerned that sensitive data is stored in the analytics system. You are tasked with anonymizing the sensitive

data in a way that is not reversible. Also, the anonymized data should not preserve the character set and length. Which Google Cloud solution should you use?

- A. Cloud Data Loss Prevention with deterministic encryption using AES-SIV
- B. Cloud Data Loss Prevention with format-preserving encryption
- C. Cloud Data Loss Prevention with cryptographic hashing
- D. Cloud Data Loss Prevention with Cloud Key Management Service wrapped cryptographic keys

Answer: C

Explanation:

The correct answer is **C. Cloud Data Loss Prevention (DLP) with cryptographic hashing**. Here's why:

The requirement is to anonymize PHI irreversibly while not preserving the character set or length. Cryptographic hashing fulfills this. Hashing transforms data into a fixed-size string (a hash) using a one-way function, making it computationally infeasible to revert back to the original data. This irreversibility is crucial for protecting sensitive information while allowing for analysis of trends in anonymized datasets.

Options A and B are unsuitable. Deterministic encryption (A) produces the same ciphertext for the same plaintext, which, although encrypted, is reversible given the key. Format-preserving encryption (B) maintains the original format and length of the data, contradicting the requirement. Option D, using KMS wrapped cryptographic keys, doesn't specify the actual transformation applied; keys are used to manage access to data rather than anonymize it.

DLP's hashing transformation method is designed precisely for this purpose. It can identify sensitive fields like PHI and apply cryptographic hashing to them, producing anonymized data ready for analytics. The output will be completely different from the original PHI, meeting the requirements of irreversibility, non-preservation of character set and length.

For further research on DLP's transformation methods and cryptographic hashing, refer to the official Google Cloud documentation:

Cloud DLP Documentation: <https://cloud.google.com/dlp/docs>

Cloud DLP Transformation Methods: <https://cloud.google.com/dlp/docs/transformations>

Cryptography: <https://cloud.google.com/security/encryption>

Question: 125

CertyIQ

You are setting up a CI/CD pipeline to deploy containerized applications to your production clusters on Google Kubernetes Engine (GKE). You need to prevent containers with known vulnerabilities from being deployed. You have the following requirements for your solution:

Must be cloud-native -

-
- ⇒ Must be cost-efficient
- ⇒ Minimize operational overhead

How should you accomplish this? (Choose two.)

- A. Create a Cloud Build pipeline that will monitor changes to your container templates in a Cloud Source Repositories repository. Add a step to analyze Container Analysis results before allowing the build to continue.
- B. Use a Cloud Function triggered by log events in Google Cloud's operations suite to automatically scan your container images in Container Registry.
- C. Use a cron job on a Compute Engine instance to scan your existing repositories for known vulnerabilities and raise an alert if a non-compliant container image is found.
- D. Deploy Jenkins on GKE and configure a CI/CD pipeline to deploy your containers to Container Registry. Add a step to validate your container images before deploying your container to the cluster.

E. In your CI/CD pipeline, add an attestation on your container image when no vulnerabilities have been found. Use a Binary Authorization policy to block deployments of containers with no attestation in your cluster.

Answer: AE

Explanation:

Reference:

<https://cloud.google.com/architecture/prep-kubernetes-engine-for-prod>

"target="_blank" style="word-break: break-all;">

Team	IAM Role	Project	Permissions
Developers	roles/container.developer	dev	Can create Kubernetes resources for the existing clusters within the project, and is not allowed to create or delete clusters.
Operations	roles/container.admin	prod	Full administrative access to the clusters and Kubernetes resources running within the project.
Security	roles/container.viewer roles/compute.securityAdmin	prod	Create, modify, and delete firewall rules and SSL certificates as well as view resources that were created within each cluster including the logs of the running pods.
Network	roles/compute.networkAdmin	prod	Create, modify, and delete networking resources, except for firewall rules and SSL certificates.

Question: 126

CertyIQ

Which type of load balancer should you use to maintain client IP by default while using the standard network tier?

- A. SSL Proxy
- B. TCP Proxy
- C. Internal TCP/UDP
- D. TCP/UDP Network

Answer: D

Explanation:

The correct answer is D, TCP/UDP Network Load Balancer. This type of load balancer is designed to operate at the network layer (Layer 4) and directly forwards client connection packets to backend instances. Critically, it preserves the original client IP address by default, as it doesn't act as a proxy in the same way as other load balancers. TCP/UDP Network Load Balancers, when used with the standard network tier, do not perform Network Address Translation (NAT) on the client IP, ensuring that the backend servers receive the actual source IP address. This preservation is fundamental for applications requiring accurate client identification for security, logging, or other session management purposes. SSL Proxy and TCP Proxy Load Balancers, in contrast, function at higher layers (Layer 7) and terminate connections, meaning they act as proxies. This termination process alters the source IP address visible to the backend servers, typically replacing it with the load balancer's IP. While these load balancers can provide features like SSL/TLS offloading and content-based routing, they generally require extra configuration (like using the PROXY protocol) to pass on the client's original IP. Internal TCP/UDP Load Balancers, while also functioning at Layer 4, are designed for internal traffic within a virtual private cloud (VPC), and are not the best option for the external-facing request.

Key Concepts:

Network Layer (Layer 4): Operates with packets and TCP/UDP connections, focusing on routing and forwarding.

Application Layer (Layer 7): Handles application-specific data and protocols, like HTTP or SSL/TLS.

Proxy: A server that acts as an intermediary between clients and other servers, potentially modifying the data in transit.

Network Address Translation (NAT): A process of modifying IP addresses in packet headers.

Standard Network Tier: Google Cloud's network tier offering that provides standard performance and capabilities.

Authoritative Links:

Google Cloud Load Balancing Overview: <https://cloud.google.com/load-balancing/docs/load-balancing-overview>

Network Load Balancing: <https://cloud.google.com/load-balancing/docs/network>

Choosing a Load Balancer: <https://cloud.google.com/load-balancing/docs/choosing-load-balancer>

Question: 127

CertyIQ

You want to prevent users from accidentally deleting a Shared VPC host project. Which organization-level policy constraint should you enable?

- A. `compute.restrictSharedVpcHostProjects`
- B. `compute.restrictXpnProjectLienRemoval`
- C. `compute.restrictSharedVpcSubnetworks`
- D. `compute.sharedReservationsOwnerProjects`

Answer: B

Explanation:

The correct answer is **B. `compute.restrictXpnProjectLienRemoval`**. Here's why:

Organization policies in Google Cloud Platform (GCP) provide centralized control over your cloud resources. The goal is to prevent accidental or unauthorized actions. The scenario requires a safeguard against deleting a Shared VPC host project. Shared VPC host projects are critical as they provide the network infrastructure for other projects.

Option B, `compute.restrictXpnProjectLienRemoval`, directly addresses this. A lien is a mechanism in GCP that prevents the deletion of a resource if certain conditions are met. By applying this organization policy, you restrict the ability to remove the lien on a Shared VPC host project. This ensures that the project cannot be deleted unless the lien is explicitly removed through a permissible operation, typically involving organization-level administrative privileges. In essence, this policy creates an explicit protection.

Option A, `compute.restrictSharedVpcHostProjects`, prevents new projects from being configured as Shared VPC host projects, but it won't protect existing ones from deletion. Option C, `compute.restrictSharedVpcSubnetworks`, limits the creation or modification of subnets in a shared VPC, and is not related to protecting host projects. Option D, `compute.sharedReservationsOwnerProjects` controls which projects can use shared reservations; it is also irrelevant to the deletion protection of host projects.

Therefore, `compute.restrictXpnProjectLienRemoval` is the only policy that addresses the stated concern by directly inhibiting the deletion of a Shared VPC host project through the lien mechanism. It's a crucial security measure for maintaining a stable network configuration.

For further research, consult the following authoritative links:

Google Cloud Organization Policy Constraints: <https://cloud.google.com/resource-manager/docs/organization-policy/org-policy-constraints>

Shared VPC: <https://cloud.google.com/vpc/docs/shared-vpc>

Liens: <https://cloud.google.com/resource-manager/docs/project-deletion-prevention>

Question: 128

CertyIQ

Users are reporting an outage on your public-facing application that is hosted on Compute Engine. You suspect that a recent change to your firewall rules is responsible. You need to test whether your firewall rules are working properly. What should you do?

- A. Enable Firewall Rules Logging on the latest rules that were changed. Use Logs Explorer to analyze whether the rules are working correctly.
- B. Connect to a bastion host in your VPC. Use a network traffic analyzer to determine at which point your requests are being blocked.
- C. In a pre-production environment, disable all firewall rules individually to determine which one is blocking user traffic.
- D. Enable VPC Flow Logs in your VPC. Use Logs Explorer to analyze whether the rules are working correctly.

Answer: A

Explanation:

Option A is the correct approach to diagnose firewall issues. Firewall Rules Logging allows you to record whether a firewall rule was applied to a specific connection attempt. This is crucial for understanding which rule is potentially blocking traffic. By enabling logging on the recently modified rules, you can use Google Cloud's Logs Explorer to analyze these logs, observe which rules are being hit, and determine if the desired traffic is being blocked. Analyzing these logs directly points to the source of the problem, making it efficient for troubleshooting.

Option B, while useful for general network troubleshooting, is less efficient for firewall analysis. It provides a view of the network traffic at a specific point but doesn't directly indicate if and which firewall rules are affecting it.

Option C is risky and inefficient. Disabling firewall rules in a pre-production environment can be disruptive and is not the recommended practice for isolating the issue. It is also cumbersome to individually disable rules to test their functionality.

Option D provides VPC Flow Logs, which record network traffic flow within your VPC, showing source and destination IPs, ports, and protocols. However, these logs don't directly identify which firewall rule, if any, was applied to allow or deny that traffic. Therefore, VPC Flow logs are not ideal for this specific firewall rule diagnosis.

In summary, Firewall Rules Logging, combined with Logs Explorer, offers a direct, efficient, and safe method for analyzing and understanding how your firewall rules are working, enabling you to quickly pinpoint the root cause of the traffic outage. This approach is aligned with security best practices and promotes fast problem resolution.

Authoritative Links:

Firewall Rules Logging: <https://cloud.google.com/vpc/docs/firewall-rules-logging>

Logs Explorer: <https://cloud.google.com/logging/docs/view/logs-explorer>

Question: 129

You are a security administrator at your company. Per Google-recommended best practices, you implemented the domain restricted sharing organization policy to allow only required domains to access your projects. An engineering team is now reporting that users at an external partner outside your organization domain cannot be granted access to the resources in a project. How should you make an exception for your partner's domain while following the stated best practices?

- A. Turn off the domain restriction sharing organization policy. Set the policy value to "Allow All."
- B. Turn off the domain restricted sharing organization policy. Provide the external partners with the required permissions using Google's Identity and Access Management (IAM) service.
- C. Turn off the domain restricted sharing organization policy. Add each partner's Google Workspace customer ID to a Google group, add the Google group as an exception under the organization policy, and then turn the policy back on.
- D. Turn off the domain restricted sharing organization policy. Set the policy value to "Custom." Add each external partner's Cloud Identity or Google Workspace customer ID as an exception under the organization policy, and then turn the policy back on.

Answer: D

Explanation:

The correct answer is **D**. Here's a detailed justification:

The problem states that a domain restriction organization policy is preventing external partners from accessing project resources. The best practice approach is to maintain the organization policy while making specific exceptions, not disabling it completely. Options A and B suggest disabling the policy, which undermines security. Option C suggests using a Google Group, which is not the correct way to manage exceptions in the domain restriction policy.

Option D provides the correct approach. The "Custom" setting in the domain-restricted sharing organization policy allows for specifying exceptions. This involves adding the external partner's Cloud Identity or Google Workspace customer ID to the policy's exception list. Cloud Identity and Google Workspace customer IDs are unique identifiers for organizations that use Google's services, which is essential for accurately identifying and granting exceptions. After adding the exceptions, re-enabling the policy maintains its protection while enabling access for the specified partners, aligning with secure best practices. This approach allows for granular control and reduces the attack surface area, adhering to the principle of least privilege.

By adding customer IDs directly to the exception list, access is precisely granted to those organizations that require it, as opposed to opening up access indiscriminately. This aligns with the principle of defense in depth, providing an added layer of security over relying on IAM permissions alone. This allows the policy to be re-enabled, ensuring that the primary purpose of domain restrictions is still met for all other users in the organization.

Supporting Links:

Organization policy constraints: <https://cloud.google.com/resource-manager/docs/organization-policy/org-policy-constraints>

Domain restricted sharing: <https://cloud.google.com/resource-manager/docs/organization-policy/restricting-domains>

Understanding Google Workspace customer ID: <https://support.google.com/a/answer/100457?hl=en>

Question: 130

You plan to use a Google Cloud Armor policy to prevent common attacks such as cross-site scripting (XSS) and SQL injection (SQLi) from reaching your web application's backend. What are two requirements for using Google

Cloud Armor security policies? (Choose two.)

- A. The load balancer must be an external SSL proxy load balancer.
- B. Google Cloud Armor Policy rules can only match on Layer 7 (L7) attributes.
- C. The load balancer must use the Premium Network Service Tier.
- D. The backend service's load balancing scheme must be EXTERNAL.
- E. The load balancer must be an external HTTP(S) load balancer.

Answer: DE

Explanation:

Let's analyze why options D and E are the correct requirements for using Google Cloud Armor security policies. Google Cloud Armor is a Web Application Firewall (WAF) service, and its purpose is to protect web applications by filtering malicious traffic. It integrates directly with Google Cloud Load Balancers. Crucially, Cloud Armor policies are designed to be attached to external HTTP(S) load balancers, which expose web applications to the internet. Therefore, option E, stating "The load balancer must be an external HTTP(S) load balancer," is correct. This is because Cloud Armor operates on incoming HTTP/HTTPS requests before they reach your backend. The load balancing scheme also needs to be EXTERNAL so that Cloud Armor can intercept and filter the traffic before routing it to the actual backend service. Therefore, option D, stating "The backend service's load balancing scheme must be EXTERNAL," is also correct. Internal load balancers are not directly exposed to the internet and are therefore not the intended target for Cloud Armor policies. Option A is incorrect because Cloud Armor policies are not limited to SSL proxy load balancers and work with both HTTP and HTTPS traffic on external load balancers. Option B is incorrect; While it is true that Cloud Armor rules often focus on L7 attributes like request headers and URLs, it's also capable of matching on L3/L4 attributes like source IP address which also impact a load balancer's ingress traffic. Option C is also incorrect as the network tier of the load balancer is irrelevant for using Cloud Armor, both the Premium and Standard Network Service Tiers are supported. Hence, the correct requirements are that the load balancer must be an external HTTP(S) load balancer and that the backend service's load balancing scheme must be EXTERNAL.

Authoritative Links:

Google Cloud Armor Overview: <https://cloud.google.com/armor/docs/overview>

Load Balancer Types: <https://cloud.google.com/load-balancing/docs/load-balancing-overview>

Question: 131

CertyIQ

You perform a security assessment on a customer architecture and discover that multiple VMs have public IP addresses. After providing a recommendation to remove the public IP addresses, you are told those VMs need to communicate to external sites as part of the customer's typical operations. What should you recommend to reduce the need for public IP addresses in your customer's VMs?

- A. Google Cloud Armor
- B. Cloud NAT
- C. Cloud Router
- D. Cloud VPN

Answer: B

Explanation:

The correct answer is **B. Cloud NAT**.

Here's why:

The scenario requires VMs without public IP addresses to still communicate with external sites. This need arises after a security assessment revealed the presence of public IPs, a risk to be mitigated. Cloud NAT (Network Address Translation) directly addresses this by allowing VMs within a private network to initiate outbound connections to the internet through a shared, single public IP address (or a pool of public IP addresses) provided by the Cloud NAT gateway. This effectively hides the individual private IP addresses of the VMs from the internet, enhancing security.

Google Cloud Armor (A) is a web application firewall focused on protecting applications from attacks at the edge, not for enabling outbound connectivity for private VMs. Cloud Router (C) manages dynamic routing between networks and is not related to internet access for VMs. Cloud VPN (D) is for secure, encrypted connections between networks and isn't for general internet access. Therefore, it is the wrong choice.

Cloud NAT removes the need for individual VMs to have public IP addresses while still providing the necessary internet access for business purposes. By using Cloud NAT, the customer's security posture is significantly improved by removing the direct internet exposure of the VMs. Cloud NAT enhances network security while simplifying network configurations, especially when you have many VMs to manage.

Further research can be done using these links:

Cloud NAT Documentation: <https://cloud.google.com/nat/docs>

Google Cloud Network Security Overview: <https://cloud.google.com/security/products/network>

Question: 132

CertyIQ

You are tasked with exporting and auditing security logs for login activity events for Google Cloud console and API calls that modify configurations to Google

Cloud resources. Your export must meet the following requirements:

- ⇒ Export related logs for all projects in the Google Cloud organization.
- ⇒ Export logs in near real-time to an external SIEM.

What should you do? (Choose two.)

- A. Create a Log Sink at the organization level with a Pub/Sub destination.
- B. Create a Log Sink at the organization level with the includeChildren parameter, and set the destination to a Pub/Sub topic.
- C. Enable Data Access audit logs at the organization level to apply to all projects.
- D. Enable Google Workspace audit logs to be shared with Google Cloud in the Admin Console.
- E. Ensure that the SIEM processes the AuthenticationInfo field in the audit log entry to gather identity information.

Answer: BD

Explanation:

Here's a detailed justification for choosing options B and D as the correct answers:

Option B Justification: Creating a log sink at the organization level is essential to capture logs from all projects within the organization. The includeChildren parameter ensures that logs from all child projects are included in the export. A Pub/Sub topic is a suitable destination for near real-time log streaming to an external SIEM because it provides a durable, scalable, and reliable message bus. This approach satisfies the requirement of capturing logs for all projects and delivering them in near real-time. **(Authoritative Link: https://cloud.google.com/logging/docs/export/configure_org_level_sinks)**

Option D Justification: Google Workspace audit logs specifically capture login activity to the Google Cloud console (and other Google Workspace applications), a critical part of the defined requirement. These logs aren't part of standard Google Cloud logging. Sharing these logs with Google Cloud via the Admin Console is

a necessary step to integrate this data with Google Cloud log exports. This step ensures that login activity from the Google Workspace side, which are Google Cloud console logons, is captured and exported to the SIEM for auditing. (Authoritative Link: <https://support.google.com/a/answer/7027795?hl=en>)

Why other options are incorrect:

Option A: While creating a log sink at the organization level is correct, it doesn't explicitly mention the inclusion of child projects. Without includeChildren, logs from child projects will not be captured.

Option C: Data Access audit logs are important, but they do not cover login activity to the Google Cloud console; they primarily record access to data stored in GCP services.

Option E: The SIEM must be properly configured; however, it's a downstream concern not a solution to fulfill the initial export requirement in Google Cloud.

Question: 133

CertyIQ

Your company's Chief Information Security Officer (CISO) creates a requirement that business data must be stored in specific locations due to regulatory requirements that affect the company's global expansion plans. After working on the details to implement this requirement, you determine the following:

- The services in scope are included in the Google Cloud Data Residency Terms.
- The business data remains within specific locations under the same organization.
- The folder structure can contain multiple data residency locations.

You plan to use the Resource Location Restriction organization policy constraint. At which level in the resource hierarchy should you set the constraint?

- A. Folder
- B. Resource
- C. Project
- D. Organization

Answer: C

Explanation:

The correct answer is **A. Folder**. Here's why:

The scenario requires enforcing data residency compliance at specific locations within Google Cloud, using the Resource Location Restriction organization policy. This policy dictates where resources can be created based on their geographic location. While projects hold resources, setting the policy at the project level would require repetitive configurations for every new project that should adhere to a specific location. Resources themselves don't provide a higher level to set a broad policy. The organization level is too broad, encompassing the entire company, which contradicts the need for specific residency locations based on the folder structure.

Folders in Google Cloud allow for logical grouping of projects and other folders within the organization. They provide an intermediate level in the resource hierarchy where you can apply organization policies, which then cascade down to the projects within the folder, making it an ideal level to enforce policies related to data residency based on the folder structure. This approach avoids repeating policy configuration for each project and allows you to group together those that share the same residency requirement. The goal here is to align the location restriction with the folder hierarchy so that the right restrictions apply to the right groups of projects based on their business needs and the overall folder structure. Therefore, applying the Resource Location Restriction policy at the folder level allows for granular control, flexibility, and centralized policy management based on location requirements as defined by folders.

Further research:

Google Cloud Resource Hierarchy: <https://cloud.google.com/resource-manager/docs/cloud-platform-resource-hierarchy>

Organization Policies: <https://cloud.google.com/resource-manager/docs/organization-policy/overview>

Resource Location Restriction Constraint: <https://cloud.google.com/resource-manager/docs/organization-policy/constraints/gcp.resourceLocations>

Question: 134

CertyIQ

You need to set up a Cloud interconnect connection between your company's on-premises data center and VPC host network. You want to make sure that on-premises applications can only access Google APIs over the Cloud Interconnect and not through the public internet. You are required to only use APIs that are supported by VPC Service Controls to mitigate against exfiltration risk to non-supported APIs. How should you configure the network?

- A. Enable Private Google Access on the regional subnets and global dynamic routing mode.
- B. Set up a Private Service Connect endpoint IP address with the API bundle of "all-apis", which is advertised as a route over the Cloud interconnect connection.
- C. Use private.googleapis.com to access Google APIs using a set of IP addresses only routable from within Google Cloud, which are advertised as routes over the connection.
- D. Use restricted.googleapis.com to access Google APIs using a set of IP addresses only routable from within Google Cloud, which are advertised as routes over the Cloud Interconnect connection.

Answer: D

Explanation:

Option D, utilizing restricted.googleapis.com, is the correct approach for secure access to supported Google APIs over Cloud Interconnect while mitigating exfiltration risks. Here's a breakdown:

Restricted.googleapis.com: This special domain resolves to a set of IP addresses that are routable only within Google's network, making them inaccessible from the public internet. This forces traffic to Google APIs to traverse the Cloud Interconnect connection.

VPC Service Controls Compatibility: restricted.googleapis.com ensures that only APIs that are supported by VPC Service Controls are accessed. This aligns with the requirement to limit access to protect against exfiltration via non-supported APIs.

Route Advertisement: By advertising the specific IP address range associated with restricted.googleapis.com over the Cloud Interconnect connection, your on-premises systems are directed through the secure, private path to Google APIs.

Public Internet Avoidance: The combination of restricted.googleapis.com and the private route advertisement effectively prevents on-premises applications from reaching Google APIs via the public internet, adhering to the security requirement.

Private Google Access (Option A): While Private Google Access allows VMs in a VPC to access Google APIs, it doesn't inherently control where the traffic originates from (i.e., it can still come from the public internet if the VM has an external IP). Also, this method doesn't directly address on-premises connectivity and doesn't ensure VPC Service Controls compliance by itself.

Private Service Connect (Option B): Private Service Connect is designed for accessing services hosted in a different VPC, not accessing Google APIs from an on-premises environment. It would involve setting up a Google Cloud Service, which is beyond the needs of simply accessing google API endpoints over a cloud interconnect link.

private.googleapis.com (Option C): This option is used for private access from within the Google Cloud network, not for on-premises access through a Cloud Interconnect and is not compatible with VPC SC either.

In summary, restricted.googleapis.com, with routes advertised over Cloud Interconnect, provides a secure and VPC Service Controls compliant way for on-premises applications to interact with Google APIs.

Authoritative Links:

Restricted Google APIs: <https://cloud.google.com/vpc-service-controls/docs/supported-apis#restricted-apis>

Private Google Access: <https://cloud.google.com/vpc/docs/private-access-options#private-google-access>

Private Service Connect: <https://cloud.google.com/vpc/docs/private-service-connect>

Question: 135

CertyIQ

You need to implement an encryption-at-rest strategy that protects sensitive data and reduces key management complexity for non-sensitive data. Your solution has the following requirements:

- Schedule key rotation for sensitive data.
- Control which region the encryption keys for sensitive data are stored in.
- Minimize the latency to access encryption keys for both sensitive and non-sensitive data.

What should you do?

- A. Encrypt non-sensitive data and sensitive data with Cloud External Key Manager.
- B. Encrypt non-sensitive data and sensitive data with Cloud Key Management Service.
- C. Encrypt non-sensitive data with Google default encryption, and encrypt sensitive data with Cloud External Key Manager.
- D. Encrypt non-sensitive data with Google default encryption, and encrypt sensitive data with Cloud Key Management Service.

Answer: D

Explanation:

Here's a detailed justification for why option D is the correct answer:

Option D best addresses the requirements of the scenario. It proposes using Google default encryption for non-sensitive data and Cloud Key Management Service (KMS) for sensitive data. This approach is optimal because:

1. **Reduced Key Management Complexity for Non-Sensitive Data:** Google default encryption is fully managed by Google, which means you don't need to worry about key generation, rotation, or storage. This simplifies the management of encryption for non-sensitive data, which is a core requirement.
2. **Control Over Key Rotation & Region for Sensitive Data:** Cloud KMS allows you to schedule automatic key rotations, meeting the requirement for scheduled rotation of sensitive data keys. Additionally, you have explicit control over the geographic location where keys are stored, fulfilling the need to control the region where encryption keys reside for sensitive data.
3. **Minimized Latency for Both Data Types:** Google's default encryption is designed for speed and efficiency. Cloud KMS stores keys in close proximity to the resources that are using them, minimizing latency for both sensitive data encrypted with KMS keys, and non-sensitive data utilizing Google's managed encryption.
4. **Cost-Effective:** Default encryption comes at no extra cost, reducing the price of encrypting the data that doesn't need complex key management. Cloud KMS only comes at a cost when used explicitly.

Options A and C suggest using Cloud External Key Manager (EKM), which is designed for situations where you need to control the physical keys outside of Google's infrastructure. While EKM meets requirements for key location control and key rotation, it's more complex and likely to introduce higher latency than using Cloud KMS directly.

Option B proposes encrypting everything with Cloud KMS, which would meet requirements, but it would be more costly and provide more complex management for non-sensitive data, against the needs outlined in the

problem statement.

In summary, option D strikes the right balance between security, operational efficiency, key management complexity, and cost-effectiveness, making it the ideal solution for the given requirements.

Authoritative Links for further research:

Google Cloud Default Encryption: <https://cloud.google.com/security/encryption/default-encryption>

Cloud Key Management Service (KMS): <https://cloud.google.com/kms/docs>

Cloud External Key Manager (EKM): <https://cloud.google.com/kms/docs/ekm>

Question: 136

CertyIQ

Your security team uses encryption keys to ensure confidentiality of user data. You want to establish a process to reduce the impact of a potentially compromised symmetric encryption key in Cloud Key Management Service (Cloud KMS).

Which steps should your team take before an incident occurs? (Choose two.)

- A. Disable and revoke access to compromised keys.
- B. Enable automatic key version rotation on a regular schedule.
- C. Manually rotate key versions on an ad hoc schedule.
- D. Limit the number of messages encrypted with each key version.
- E. Disable the Cloud KMS API.

Answer: BD

Explanation:

Here's a breakdown of why options B and D are the correct choices for mitigating the impact of a compromised symmetric key in Cloud KMS, along with a detailed explanation:

Option B: Enable automatic key version rotation on a regular schedule.

Key rotation is a fundamental security practice. Automatically rotating key versions regularly minimizes the window of opportunity for a compromised key to be exploited. By periodically generating new key versions, you ensure that even if an older key is compromised, it can only decrypt data encrypted with that specific version, limiting the scope of potential damage. Cloud KMS allows you to configure automatic key rotation policies, automating this crucial process. This prevents human error and ensures keys are updated frequently.

Option D: Limit the number of messages encrypted with each key version.

Limiting the number of messages encrypted with a single key version reduces the attack surface associated with that key. Even if a key is compromised, the attacker's ability to decrypt data is limited to the data encrypted by that particular version and under a prescribed threshold. This practice, often referred to as key diversification, is a defense-in-depth measure. It helps to isolate potential breaches by restricting the amount of data that can be exposed if a key becomes compromised. Limiting the scope of a compromised key reduces the blast radius of any attack.

Why other options are incorrect:

Option A: Disable and revoke access to compromised keys. While crucial as an incident response action, this isn't something to do before an incident. It's a reactive measure, not a preventative one. Revoking access is what you do after you discover a compromise, not before.

Option C: Manually rotate key versions on an ad hoc schedule. Manual rotation is error-prone and doesn't ensure consistent key updates. Automating this process is preferable. Ad hoc rotations are unreliable and may lead to delays which increase vulnerability windows.

Option E: Disable the Cloud KMS API. This action would completely halt all encrypted data access, which is not a suitable proactive measure. It's equivalent to shutting down the business.

In summary, proactive security involves minimizing the risk of a compromised key before an incident occurs. This is achieved by regularly rotating key versions (Option B) and limiting the amount of data encrypted by a single key version (Option D).

Authoritative Links:

Google Cloud KMS Documentation on Key Rotation: <https://cloud.google.com/kms/docs/key-rotation>

Google Cloud Security Best Practices: <https://cloud.google.com/security/best-practices>

OWASP Key Management Cheat Sheet:

https://cheatsheetseries.owasp.org/cheatsheets/Key_Management_Cheat_Sheet.html

Question: 137

CertyIQ

Your company's chief information security officer (CISO) is requiring business data to be stored in specific locations due to regulatory requirements that affect the company's global expansion plans. After working on a plan to implement this requirement, you determine the following:

- The services in scope are included in the Google Cloud data residency requirements.
- The business data remains within specific locations under the same organization.
- The folder structure can contain multiple data residency locations.
- The projects are aligned to specific locations.

You plan to use the Resource Location Restriction organization policy constraint with very granular control. At which level in the hierarchy should you set the constraint?

- A. Organization
- B. Resource
- C. Project
- D. Folder

Answer: C

Explanation:

The correct answer is **C. Project**. Here's why:

The scenario describes a need for granular control over data residency, where different projects must reside in specific geographical locations. Google Cloud's Resource Location Restriction organization policy constraint allows you to define permitted locations for resources within your organization's hierarchy. While the constraint can be applied at various levels, the specific need for location alignment with projects mandates setting it at the **project level**.

Applying the constraint at the **organization level (A)** would be too broad, forcing all resources across the entire organization to reside in a single set of locations, which contradicts the requirement for multiple data residency locations. Applying it at the **resource level (B)** is infeasible, as the constraint is designed to govern resource creation, not individual resource location after creation. The scenario states that **projects are aligned to specific locations**. Therefore, a policy to govern this should be applied at the level of the project itself. Setting it at the **folder level (D)** might seem plausible due to the folder structure containing multiple data residency locations, but this is insufficient if granular control at project level is required. The location of a folder, where a project exists, doesn't dictate where the resources created inside the project should reside.

By applying the constraint at the project level, you can enforce the location requirement for all resources created within that specific project, allowing you to meet regulatory demands while maintaining flexibility in how data is handled across different projects within the organization. This method allows for consistent and controlled data residency while allowing your multiple data residency locations to be managed without

constraints from higher levels in the organization.

Relevant Link for further research:

Resource Location Restriction: <https://cloud.google.com/resource-manager/docs/organization-policy/restricting-resource-locations>

Question: 138

CertyIQ

A database administrator notices malicious activities within their Cloud SQL instance. The database administrator wants to monitor the API calls that read the configuration or metadata of resources. Which logs should the database administrator review?

- A. Admin Activity
- B. System Event
- C. Access Transparency
- D. Data Access

Answer: D

Explanation:

The correct answer is **D. Data Access logs**. Data Access logs record API calls that read or modify user-provided data within Google Cloud resources. In this scenario, the database administrator is concerned about activities that read the configuration or metadata of Cloud SQL instances. While Admin Activity logs capture administrative actions on resources (like creating or deleting), and System Event logs record events related to Google infrastructure, Data Access logs specifically track operations that access data, including configuration and metadata. This is crucial for identifying potentially malicious activities that might be trying to understand the database's structure or settings for malicious purposes. Access Transparency logs provide insights into Google Cloud administrators' actions on customer data, which is not the concern here. Since the focus is on reading configuration and metadata (which is considered data about data), Data Access logs are the most appropriate source for monitoring these specific API calls. Data access logs are configurable and allow users to specifically monitor read operations related to data resources.

Relevant Links for Further Research:

Google Cloud Logging Documentation on Data Access Logs:

<https://cloud.google.com/logging/docs/audit/data-access>

Google Cloud Logging Documentation on Audit Logs: <https://cloud.google.com/logging/docs/audit>

Understanding Audit Logs in Google Cloud: <https://cloud.google.com/blog/products/management-tools/understanding-cloud-audit-logs-google-cloud>

Question: 139

CertyIQ

You are backing up application logs to a shared Cloud Storage bucket that is accessible to both the administrator and analysts. Analysts should not have access to logs that contain any personally identifiable information (PII). Log files containing PII should be stored in another bucket that is only accessible to the administrator. What should you do?

- A. Upload the logs to both the shared bucket and the bucket with PII that is only accessible to the administrator. Use the Cloud Data Loss Prevention API to create a job trigger. Configure the trigger to delete any files that contain PII from the shared bucket.
- B. On the shared bucket, configure Object Lifecycle Management to delete objects that contain PII.
- C. On the shared bucket, configure a Cloud Storage trigger that is only triggered when PII is uploaded. Use

Cloud Functions to capture the trigger and delete the files that contain PII.

D. Use Pub/Sub and Cloud Functions to trigger a Cloud Data Loss Prevention scan every time a file is uploaded to the administrator's bucket. If the scan does not detect PII, have the function move the objects into the shared Cloud Storage bucket.

Answer: D

Explanation:

Option D is the most secure and efficient approach for separating PII logs from shared access. First, the logs containing potential PII are directed to a restricted bucket accessible only to the administrator. This aligns with the principle of least privilege and prevents unauthorized access to sensitive data. Second, Pub/Sub enables an event-driven architecture, triggering a Cloud Function whenever a new log is uploaded to the administrator's bucket. This ensures timely processing and avoids constant polling of the bucket. Third, the Cloud Function leverages the Cloud Data Loss Prevention (DLP) API to thoroughly scan the uploaded logs for PII. This crucial step confirms whether a log file contains sensitive information or not. Finally, the function only moves non-PII logs into the shared bucket, ensuring that PII remains within the controlled, administrator-only environment. This workflow guarantees that analysts are only granted access to sanitized, PII-free logs. Conversely, options A, B, and C present vulnerabilities: Option A could lead to data leakage if the deletion process fails. Option B's Lifecycle Management tool is not sophisticated enough for fine-grained content analysis for PII detection and is usually used for time-based actions. Option C, using triggers for PII, is overly complex, error-prone, and can result in race conditions. Therefore, Option D provides a reliable, secure, and scalable solution by utilizing Pub/Sub for event handling, DLP API for PII detection, and Cloud Functions for task automation.

Authoritative Links for further research:

Cloud Data Loss Prevention (DLP) API: <https://cloud.google.com/dlp/docs>

Cloud Functions: <https://cloud.google.com/functions/docs>

Pub/Sub: <https://cloud.google.com/pubsub/docs>

Cloud Storage: <https://cloud.google.com/storage/docs>

Principle of Least Privilege: <https://cloud.google.com/blog/topics/developers-practitioners/understanding-principle-least-privilege>

Question: 140

CertyIQ

You work for an organization in a regulated industry that has strict data protection requirements. The organization backs up their data in the cloud. To comply with data privacy regulations, this data can only be stored for a specific length of time and must be deleted after this specific period.

You want to automate the compliance with this regulation while minimizing storage costs. What should you do?

- A. Store the data in a persistent disk, and delete the disk at expiration time.
- B. Store the data in a Cloud Bigtable table, and set an expiration time on the column families.
- C. Store the data in a BigQuery table, and set the table's expiration time.
- D. Store the data in a Cloud Storage bucket, and configure the bucket's Object Lifecycle Management feature.

Answer: D

Explanation:

Option D, storing data in a Cloud Storage bucket and using Object Lifecycle Management (OLM), is the optimal solution for automating data deletion based on a specific timeframe while minimizing storage costs. OLM allows you to define rules that automatically transition or delete objects based on criteria like age. This directly addresses the requirement of deleting data after a defined period for compliance. Using OLM avoids manual intervention and ensures consistent policy enforcement. Cloud Storage offers cost-effective storage

options, especially for archival data, and OLM's lifecycle transitions can further optimize costs by moving data to cooler storage classes as it ages. Options A, B, and C are less suited. Persistent disks (A) are typically used for virtual machine storage and aren't the best for bulk data backup. Deleting the entire disk is also not granular enough and would be disruptive. Bigtable (B) column family expiration does not offer the fine-grained time-based deletion at the object level that is required and would not be as suitable for backup data. BigQuery (C) table expiration would remove the entire table, losing granularity. The data might need to be retained for a short period before being completely removed. Therefore, Cloud Storage with OLM is the most efficient and appropriate solution for this specific requirement.

Authoritative Links:

Cloud Storage Object Lifecycle Management: <https://cloud.google.com/storage/docs/lifecycle>

Cloud Storage Storage Classes: <https://cloud.google.com/storage/docs/storage-classes>

Question: 141

CertyIQ

You have been tasked with configuring Security Command Center for your organization's Google Cloud environment. Your security team needs to receive alerts of potential crypto mining in the organization's compute environment and alerts for common Google Cloud misconfigurations that impact security. Which Security Command Center features should you use to configure these alerts? (Choose two.)

- A. Event Threat Detection
- B. Container Threat Detection
- C. Security Health Analytics
- D. Cloud Data Loss Prevention
- E. Google Cloud Armor

Answer: AC

Explanation:

The correct answer is **A. Event Threat Detection** and **C. Security Health Analytics**.

Here's the justification:

Event Threat Detection (A) is designed to identify threats within your Google Cloud environment by analyzing audit logs and other activity data. This includes identifying anomalous behavior such as patterns indicative of crypto mining activities. It uses machine learning and threat intelligence to detect suspicious events, making it suitable for uncovering potential crypto mining attempts in compute instances.

Security Health Analytics (C) focuses on identifying misconfigurations in your Google Cloud resources that could lead to security vulnerabilities. This feature employs a set of built-in detectors that check for compliance with security best practices. It can flag common Google Cloud misconfigurations that impact security, providing insights and remediation steps to improve the overall security posture.

Option B, **Container Threat Detection**, focuses specifically on threats within Kubernetes Engine and is less applicable to general compute environment crypto mining. **Cloud Data Loss Prevention (D)** is for detecting and preventing the loss of sensitive data, which is unrelated to the question's requirements. Finally, **Google Cloud Armor (E)** protects web applications and services from denial-of-service (DoS) and other attacks, which doesn't address the detection of either crypto-mining or general misconfigurations.

Therefore, the combination of Event Threat Detection and Security Health Analytics provides the necessary capabilities to detect crypto mining activities and identify security-related misconfigurations as requested.

Authoritative Links:

Event Threat Detection: <https://cloud.google.com/security-command-center/docs/concepts-event-threat-detection>

Security Health Analytics: <https://cloud.google.com/security-command-center/docs/concepts-security-health-analytics>

Security Command Center Overview: <https://cloud.google.com/security-command-center/docs/overview>

Question: 142

CertyIQ

You have noticed an increased number of phishing attacks across your enterprise user accounts. You want to implement the Google 2-Step Verification (2SV) option that uses a cryptographic signature to authenticate a user and verify the URL of the login page. Which Google 2SV option should you use?

- A. Titan Security Keys
- B. Google prompt
- C. Google Authenticator app
- D. Cloud HSM keys

Answer: A

Explanation:

The correct answer is A, Titan Security Keys, because they provide the most robust protection against phishing attacks by utilizing a cryptographic signature to authenticate users and verify the login page URL. This is achieved through the FIDO2 standard, a modern authentication standard that uses public-key cryptography. When a user attempts to log in, the Titan Security Key generates a unique signature specific to the website and the user. This process ensures that the user is interacting with the genuine Google login page and not a phishing site. Options B and C, Google prompt and the Google Authenticator app respectively, use time-based one-time passwords (TOTP) which, while providing an added layer of security, are susceptible to phishing attacks if the user is tricked into entering the code on a malicious site. Option D, Cloud HSM keys, are primarily used for server-side encryption and not for user authentication.

Titan Security Keys offer the highest level of assurance against phishing due to their use of the FIDO2 protocol, requiring physical presence for authentication. This makes it exceedingly difficult for attackers to compromise user accounts even if they obtain the user's username and password. The cryptographic signature generated by the key only works on the genuine Google domain, preventing the reuse of stolen credentials or session hijacking. By verifying the URL, the key also ensures that the user is not on a fake login page designed to capture their credentials. Using a security key like Titan shifts the authentication burden to a physical, tamper-resistant device, dramatically increasing the security of user login processes. Therefore, for enhanced protection against phishing attacks, Titan Security Keys are the most effective choice among the listed 2SV options.

Further research can be done on the following links:

Google Cloud Security: <https://cloud.google.com/security>

Titan Security Keys: <https://cloud.google.com/titan-security-keys>

FIDO2 standard: <https://fidoalliance.org/fido2/>

Google 2-Step Verification: <https://support.google.com/accounts/answer/185839?hl=en>

Question: 143

CertyIQ

Your organization hosts a financial services application running on Compute Engine instances for a third-party company. The third-party company's servers that will consume the application also run on Compute Engine in a separate Google Cloud organization. You need to configure a secure network connection between the Compute

Engine instances. You have the following requirements:

- The network connection must be encrypted.
- The communication between servers must be over private IP addresses.

What should you do?

- A. Configure a Cloud VPN connection between your organization's VPC network and the third party's that is controlled by VPC firewall rules.
- B. Configure a VPC peering connection between your organization's VPC network and the third party's that is controlled by VPC firewall rules.
- C. Configure a VPC Service Controls perimeter around your Compute Engine instances, and provide access to the third party via an access level.
- D. Configure an Apigee proxy that exposes your Compute Engine-hosted application as an API, and is encrypted with TLS which allows access only to the third party.

Answer: B

Explanation:

The correct answer is B, configuring a VPC peering connection. VPC peering enables private IP address communication between two VPC networks, even those belonging to different Google Cloud organizations. This directly fulfills the requirement for communication using private IPs, avoiding exposure to the public internet. Furthermore, traffic between peered networks remains within Google's network backbone, inherently providing encryption, thus satisfying the encryption requirement. VPC firewalls in each network control access, ensuring only authorized traffic passes between the peered networks.

Option A, Cloud VPN, while providing encryption, uses public IPs for VPN gateway endpoints, failing the private IP requirement. Option C, VPC Service Controls, focuses on data exfiltration and doesn't directly establish network connectivity. Option D, Apigee, creates an API, which is unnecessary when direct server-to-server communication is needed, and introduces complexity. VPC peering is the most straightforward and resource-efficient method to achieve secure private network connectivity between VPC networks in different organizations.

Authoritative Links:

VPC Peering: <https://cloud.google.com/vpc/docs/vpc-peering>

VPC Firewalls: <https://cloud.google.com/vpc/docs/firewalls>

Comparing Network Connectivity Options: <https://cloud.google.com/vpc/docs/choose-network-connectivity>

Question: 144

CertyIQ

Your company's new CEO recently sold two of the company's divisions. Your Director asks you to help migrate the Google Cloud projects associated with those divisions to a new organization node. Which preparation steps are necessary before this migration occurs? (Choose two.)

- A. Remove all project-level custom Identity and Access Management (IAM) roles.
- B. Disallow inheritance of organization policies.
- C. Identify inherited Identity and Access Management (IAM) roles on projects to be migrated.
- D. Create a new folder for all projects to be migrated.
- E. Remove the specific migration projects from any VPC Service Controls perimeters and bridges.

Answer: CE

Explanation:

The correct preparation steps for migrating Google Cloud projects to a new organization node are **C: Identify inherited Identity and Access Management (IAM) roles on projects to be migrated** and **E: Remove the**

specific migration projects from any VPC Service Controls perimeters and bridges.

Justification:

C - Identify Inherited IAM Roles: Before migrating, it is crucial to understand the IAM landscape. Projects often inherit IAM roles from the organization node and/or folders. Failure to identify these inherited roles can result in unexpected permission changes post-migration. You need to document them to reapply them in the new organization if desired or adjust as needed. This ensures a smooth transition with minimal disruption to access management.

E - Remove from VPC Service Controls: VPC Service Controls establish security perimeters around Google Cloud resources to mitigate data exfiltration risks. Projects being moved might be part of such perimeters or bridges. If you migrate the projects before removing them from the perimeters, the migration will fail since you are essentially trying to take the project outside of the defined secure boundary. Therefore, you must remove these projects from any relevant perimeters and bridges to allow successful migration. The perimeters are defined within an organization, so moving to a new organization requires removal and likely re-establishment in the new organization.

Why other options are incorrect:

A - Remove all project-level custom IAM roles: While reviewing custom roles is good practice, removing them isn't mandatory for migration. They will still be valid in the new organization, albeit not inherited if not specified at the new organization node. Custom roles can always be recreated if needed.

B - Disallow inheritance of organization policies: Organization policies are inherited by default. The migration process automatically handles applying organization policies on a move. Disallowing inheritance is not necessary and could create new management complexities.

D - Create a new folder for all projects to be migrated: While organizing projects into folders is good practice, it is not a mandatory step for migration. You can organize projects into the appropriate folder structure before, during or after the migration.

Authoritative Links:

Migrating Projects: <https://cloud.google.com/resource-manager/docs/project-migration>

IAM roles: <https://cloud.google.com/iam/docs/understanding-roles>

VPC Service Controls: <https://cloud.google.com/vpc-service-controls/docs/overview>

In summary, understanding inherited IAM roles and ensuring projects are not constrained by VPC Service Control perimeters are critical prerequisites for a successful Google Cloud project migration between organization nodes.

Question: 145

CertyIQ

You are a consultant for an organization that is considering migrating their data from its private cloud to Google Cloud. The organization's compliance team is not familiar with Google Cloud and needs guidance on how compliance requirements will be met on Google Cloud. One specific compliance requirement is for customer data at rest to reside within specific geographic boundaries. Which option should you recommend for the organization to meet their data residency requirements on Google Cloud?

- A. Organization Policy Service constraints
- B. Shielded VM instances
- C. Access control lists
- D. Geolocation access controls
- E. Google Cloud Armor

Answer: A

Explanation:

The correct answer is **A. Organization Policy Service constraints**. Here's why:

Organization Policy Service allows administrators to define and enforce policies at the organization, folder, or project level. These policies can include constraints that dictate where Google Cloud resources, including data storage, can be located. Specifically, the "constraints/gcp.resourceLocations" constraint can be configured to restrict the creation of resources to specific regions or multi-regions, thereby enforcing data residency requirements. This ensures that data at rest remains within designated geographic boundaries, fulfilling the organization's compliance needs. Shielded VMs (B) focus on ensuring the integrity and security of virtual machines, not data residency. Access Control Lists (C) control access permissions to resources but don't determine their location. Geolocation access controls (D) are related to network traffic filtering and are not designed for data residency at rest. Google Cloud Armor (E) focuses on web application protection and is unrelated to data residency. Therefore, Organization Policy Service constraints is the most suitable option for establishing and enforcing the desired geographic boundary for data at rest.

Further Research:

Google Cloud Organization Policy Service: <https://cloud.google.com/resource-manager/docs/organization-policy/overview>

Resource Location Constraints: https://cloud.google.com/resource-manager/docs/organization-policy/constraints-list#constraint_gcp.resourceLocations

Question: 146

CertyIQ

Your security team wants to reduce the risk of user-managed keys being mismanaged and compromised. To achieve this, you need to prevent developers from creating user-managed service account keys for projects in their organization. How should you enforce this?

- A. Configure Secret Manager to manage service account keys.
- B. Enable an organization policy to disable service accounts from being created.
- C. Enable an organization policy to prevent service account keys from being created.
- D. Remove the iam.serviceAccounts.getAccessToken permission from users.

Answer: C

Explanation:

The correct answer is **C. Enable an organization policy to prevent service account keys from being created**.

Here's why:

The goal is to prevent developers from creating user-managed service account keys, which are a known security risk. Option C directly addresses this by utilizing Google Cloud's Organization Policy service. Organization Policies allow administrators to enforce restrictions at the organization, folder, or project level. Specifically, there's a constraint designed to prohibit the creation of service account keys. This constraint, often referred to as constraints/iam.disableServiceAccountKeyCreation, allows for a centralized and consistent way to enforce this security control across the entire organization.

Option A, using Secret Manager for key management, doesn't prevent the initial creation of the problematic user-managed keys. It only manages keys after they exist. Option B, disabling service account creation, is far too restrictive and would severely hinder development. Option D, removing the iam.serviceAccounts.getAccessToken permission, would only limit the use of existing keys, not their creation.

By leveraging the organization policy, you maintain the flexibility of using service accounts while mitigating the risk of mishandled keys.

Here are some authoritative links for further research:

Organization Policy Service: <https://cloud.google.com/resource-manager/docs/organization-policy/overview>

Constraints for Organization Policy: <https://cloud.google.com/resource-manager/docs/organization-policy/constraints-list> (Specifically look for iam.disableServiceAccountKeyCreation)

Service Account Security Best Practices: <https://cloud.google.com/iam/docs/service-account-best-practices>

Question: 147

CertyIQ

You are responsible for managing your company's identities in Google Cloud. Your company enforces 2-Step Verification (2SV) for all users. You need to reset a user's access, but the user lost their second factor for 2SV. You want to minimize risk. What should you do?

- A. On the Google Admin console, select the appropriate user account, and generate a backup code to allow the user to sign in. Ask the user to update their second factor.
- B. On the Google Admin console, temporarily disable the 2SV requirements for all users. Ask the user to log in and add their new second factor to their account. Re-enable the 2SV requirement for all users.
- C. On the Google Admin console, select the appropriate user account, and temporarily disable 2SV for this account. Ask the user to update their second factor, and then re-enable 2SV for this account.
- D. On the Google Admin console, use a super administrator account to reset the user account's credentials. Ask the user to update their credentials after their first login.

Answer: A

Explanation:

The correct answer is A because it offers the most secure and least disruptive approach to restoring a user's access when their second factor is lost. Generating a backup code provides a temporary alternative authentication method, allowing the user to regain access without compromising the overall 2SV policy. This method avoids weakening the security posture for all users. Option B is problematic because disabling 2SV globally introduces a significant security risk by temporarily exposing all accounts. Option C, while more targeted than B, also weakens security, even if temporarily, by disabling 2SV for a specific user. Moreover, requiring them to re-enable it carries the risk that they might forget, inadvertently leaving their account less secure. Option D is less secure because resetting credentials for a user could be risky if the new credentials are compromised. Generating a backup code is a standard Google Workspace feature designed for such situations. It adheres to the principle of least privilege, granting only necessary access for the specific user and purpose, without disrupting the existing security framework for other users.

Here are some authoritative links to support the reasoning:

Google Workspace Admin Help - Generate backup codes: <https://support.google.com/a/answer/185834?hl=en>

Google Workspace Admin Help - 2-Step Verification (for Admins):
<https://support.google.com/a/answer/175197?hl=en>

Principle of Least Privilege: https://en.wikipedia.org/wiki/Principle_of_least_privilege

Question: 148

CertyIQ

Which Google Cloud service should you use to enforce access control policies for applications and resources?

- A. Identity-Aware Proxy

- B. Cloud NAT
- C. Google Cloud Armor
- D. Shielded VMs

Answer: A

Explanation:

Identity-Aware Proxy (IAP) is the correct Google Cloud service for enforcing access control policies for applications and resources. IAP acts as a central access control layer, verifying user identity and context before granting access to applications and resources hosted on Google Cloud. It leverages Google's identity platform to ensure only authorized users, with the correct context (like device security status), can reach protected resources. This context-aware approach offers a significant security advantage over traditional perimeter-based security, allowing granular access control. Unlike Cloud NAT, which provides network address translation, or Google Cloud Armor, focused on web application protection, IAP specifically addresses the challenge of identity-based access control. Shielded VMs, on the other hand, offer a secure virtual machine environment but do not handle application access authorization policies. IAP can integrate with various authentication and authorization mechanisms, such as Google Accounts and custom IAM policies, enabling fine-grained controls. Its ease of use and central management features streamline access control for organizations, reducing complexity and enhancing overall security posture.

For further reading and authoritative information, refer to:

Google Cloud Identity-Aware Proxy (IAP) Documentation: <https://cloud.google.com/iap/docs>

Google Cloud IAM Overview: <https://cloud.google.com/iam/docs/overview>

Question: 149

CertyIQ

You want to update your existing VPC Service Controls perimeter with a new access level. You need to avoid breaking the existing perimeter with this change, and ensure the least disruptions to users while minimizing overhead. What should you do?

- A. Create an exact replica of your existing perimeter. Add your new access level to the replica. Update the original perimeter after the access level has been vetted.
- B. Update your perimeter with a new access level that never matches. Update the new access level to match your desired state one condition at a time to avoid being overly permissive.
- C. Enable the dry run mode on your perimeter. Add your new access level to the perimeter configuration. Update the perimeter configuration after the access level has been vetted.
- D. Enable the dry run mode on your perimeter. Add your new access level to the perimeter dry run configuration. Update the perimeter configuration after the access level has been vetted.

Answer: D

Explanation:

The correct answer is **D**. VPC Service Controls perimeters offer a "dry run" mode specifically designed for making changes without immediate enforcement. This mode allows you to simulate the impact of a new access level before it's actively applied, mitigating the risk of accidentally disrupting existing workflows or blocking legitimate access.

Option A, creating a replica, introduces unnecessary overhead and complexity. While it achieves the goal of preventing immediate disruption, it involves duplicating resources and requires additional management. Option B, introducing a non-matching access level initially, is not the intended use of access levels and creates a confusing, error-prone process. It would be more complex to update conditions one by one to avoid being overly permissive, than to test in dry-run mode. Option C is incorrect because dry run mode applies to

the perimeter itself, not changes to individual rulesets within a perimeter; dry run is not a generic property that can be "enabled" as suggested in C.

Option D is the ideal approach because it leverages the intended functionality of dry run mode. By adding the new access level to the **dry run** configuration, you can monitor its potential impact through logging and metrics. This allows you to thoroughly vet the access level against real-world traffic without impacting production. Once the access level is validated and confirmed to behave as expected, you can then finalize the update by moving the dry-run changes to the live configuration and removing them from dry-run configuration. This is the least disruptive and most efficient way to implement a new access level in an existing VPC Service Controls perimeter.

Supporting links:

VPC Service Controls Overview: <https://cloud.google.com/vpc-service-controls/docs/overview>

Using VPC Service Controls Dry Run: <https://cloud.google.com/vpc-service-controls/docs/dry-run>

VPC Service Controls Access Levels: <https://cloud.google.com/vpc-service-controls/docs/access-levels>

Question: 150

CertyIQ

Your organization's Google Cloud VMs are deployed via an instance template that configures them with a public IP address in order to host web services for external users. The VMs reside in a service project that is attached to a host (VPC) project containing one custom Shared VPC for the VMs. You have been asked to reduce the exposure of the VMs to the internet while continuing to service external users. You have already recreated the instance template without a public IP address configuration to launch the managed instance group (MIG). What should you do?

- A. Deploy a Cloud NAT Gateway in the service project for the MIG.
- B. Deploy a Cloud NAT Gateway in the host (VPC) project for the MIG.
- C. Deploy an external HTTP(S) load balancer in the service project with the MIG as a backend.
- D. Deploy an external HTTP(S) load balancer in the host (VPC) project with the MIG as a backend.

Answer: C

Explanation:

The correct answer is **C. Deploy an external HTTP(S) load balancer in the service project with the MIG as a backend**. Here's why:

The goal is to remove public IP addresses from the VMs while still allowing external users to access their web services. Simply removing the public IPs renders the VMs unreachable directly from the internet. Cloud NAT (options A and B) allows VMs without public IPs to initiate outbound connections, but it doesn't enable inbound connections from the internet, which is what's needed for web services.

An external HTTP(S) load balancer, on the other hand, is specifically designed for this purpose. It acts as a single point of contact for external traffic, distributing requests to backend VMs. Option C, placing the load balancer in the service project, is correct because the managed instance group (MIG) and its VMs reside in this project. The load balancer should be in the same project as the resources it is managing, this simplifies management and follows best practice for network isolation. The load balancer is the resource that is publicly accessible, the backend VMs remain hidden behind the load balancer and therefore not directly exposed to the internet.

Option D, placing the load balancer in the host (VPC) project, would be incorrect because while technically possible, it adds unnecessary complexity. It would require configuring cross-project network connectivity. The service project is the appropriate project since it contains the MIG. Therefore, option C is the most efficient and straightforward way to accomplish the desired outcome.

Here are some relevant resources:

Google Cloud Load Balancing Overview: <https://cloud.google.com/load-balancing/docs/load-balancing-overview>

External HTTP(S) Load Balancer: <https://cloud.google.com/load-balancing/docs/https/>

Managed Instance Groups (MIGs): <https://cloud.google.com/compute/docs/instance-groups>

Shared VPC: <https://cloud.google.com/vpc/docs/shared-vpc>

Question: 151

CertyIQ

Your privacy team uses crypto-shredding (deleting encryption keys) as a strategy to delete personally identifiable information (PII). You need to implement this practice on Google Cloud while still utilizing the majority of the platform's services and minimizing operational overhead. What should you do?

- A. Use client-side encryption before sending data to Google Cloud, and delete encryption keys on-premises.
- B. Use Cloud External Key Manager to delete specific encryption keys.
- C. Use customer-managed encryption keys to delete specific encryption keys.
- D. Use Google default encryption to delete specific encryption keys.

Answer: C

Explanation:

Here's a detailed justification for why option C, "Use customer-managed encryption keys to delete specific encryption keys," is the correct approach for implementing crypto-shredding on Google Cloud while minimizing operational overhead:

Crypto-shredding relies on rendering data unrecoverable by deleting the encryption keys used to protect it. Options A, B, and D all have drawbacks in this context. Option A, while achieving crypto-shredding, significantly increases operational complexity by requiring client-side encryption before data enters Google Cloud. This adds overhead for key management, encryption/decryption logic, and can hinder the seamless use of many Google Cloud services. Option B, Cloud External Key Manager (EKM), is designed for scenarios where keys are managed entirely outside of Google Cloud, and while it can achieve crypto-shredding via disabling or deleting keys, it might also introduce additional operational overhead and not fully integrate with all Google Cloud services. Option D, relying on Google's default encryption, does not provide the control required for effective crypto-shredding as the user does not manage the encryption keys directly.

Option C, using Customer-Managed Encryption Keys (CMEK), directly addresses the requirements. CMEK allows users to control and manage the encryption keys used to protect data within Google Cloud services. By using CMEK, your privacy team retains control of keys, facilitating crypto-shredding through key deletion when PII removal is necessary. This approach leverages Google Cloud's infrastructure while fulfilling privacy requirements with minimal operational overhead. Furthermore, CMEK is well-integrated with most Google Cloud services, making it easy to apply across various services and resources, without forcing client-side encryption or managing keys externally. This allows Google Cloud services to handle the encryption process.

In short, CMEK provides the ideal balance of control, integration, and operational efficiency for implementing crypto-shredding on Google Cloud.

Authoritative Links:

Google Cloud CMEK Documentation: <https://cloud.google.com/kms/docs/cmek>

Google Cloud EKM Documentation: <https://cloud.google.com/kms/docs/ekm>

Understanding Encryption at Rest in Google Cloud: <https://cloud.google.com/security/encryption-at-rest>

Question: 152

You need to centralize your team's logs for production projects. You want your team to be able to search and analyze the logs using Logs Explorer. What should you do?

- A. Enable Cloud Monitoring workspace, and add the production projects to be monitored.
- B. Use Logs Explorer at the organization level and filter for production project logs.
- C. Create an aggregate org sink at the parent folder of the production projects, and set the destination to a Cloud Storage bucket.
- D. Create an aggregate org sink at the parent folder of the production projects, and set the destination to a logs bucket.

Answer: D

Explanation:

The correct answer is **D: Create an aggregate org sink at the parent folder of the production projects, and set the destination to a logs bucket**. This approach effectively centralizes logs from multiple production projects into a single, accessible location for analysis with Logs Explorer.

Here's why:

Organization-Level Aggregation: Creating an aggregate sink at the parent folder captures logs from all projects within that folder hierarchy. This eliminates the need to configure sinks individually for each project.

Log Bucket Destination: A logs bucket, specifically designed for storing log data, is the ideal destination for centralized logging. Logs Explorer is specifically built to interact with these buckets, enabling efficient searching and analysis of log data.

Logs Explorer Compatibility: Logs Explorer is the primary tool for querying and analyzing logs within Google Cloud. Directing logs to a compatible log bucket ensures these tools can process the data correctly.

Avoidance of Other Options:

Option A (Cloud Monitoring workspace): While Cloud Monitoring collects metrics and some logs, it's not the primary tool for detailed log analysis.

Option B (Logs Explorer at org level filtering): While Logs Explorer can access logs across the organization, it doesn't provide a central repository for easy querying. Logs are stored per project initially, making filtering difficult for long-term analysis.

Option C (Cloud Storage bucket): While a Cloud Storage bucket can store logs, it lacks the indexing and structure of a log bucket, making it less efficient and harder to analyze with Logs Explorer.

Efficiency and Scalability: The aggregate sink approach is efficient for collecting logs from multiple projects into one accessible location. This allows scaling log management as you add or remove production projects from the folder.

Centralized Management: All log data is collected in a centralized, structured manner, which simplifies security monitoring and log analysis.

In summary, creating an aggregate organizational sink with a logs bucket as the destination provides the most efficient and manageable solution for centralizing production project logs for analysis with Logs Explorer. This method ensures proper indexing, querying capabilities, and ease of management.

Relevant Google Cloud Documentation:

Cloud Logging overview: <https://cloud.google.com/logging/docs/overview>

Routing logs to supported destinations: <https://cloud.google.com/logging/docs/routing/overview>

Question: 153

You need to use Cloud External Key Manager to create an encryption key to encrypt specific BigQuery data at rest in Google Cloud. Which steps should you do first?

- A. 1. Create or use an existing key with a unique uniform resource identifier (URI) in your Google Cloud project. 2. Grant your Google Cloud project access to a supported external key management partner system.
- B. 1. Create or use an existing key with a unique uniform resource identifier (URI) in Cloud Key Management Service (Cloud KMS). 2. In Cloud KMS, grant your Google Cloud project access to use the key.
- C. 1. Create or use an existing key with a unique uniform resource identifier (URI) in a supported external key management partner system. 2. In the external key management partner system, grant access for this key to use your Google Cloud project.
- D. 1. Create an external key with a unique uniform resource identifier (URI) in Cloud Key Management Service (Cloud KMS). 2. In Cloud KMS, grant your Google Cloud project access to use the key.

Answer: C

Explanation:

The correct answer is **C**. Here's why:

Cloud External Key Manager (EKM) is designed to allow you to manage encryption keys outside of Google Cloud, using a supported external key management partner. Before you can use an external key with BigQuery, the key needs to exist within the external partner's system. Option C accurately reflects this initial step: first, create or identify the key within the external key management system, ensuring it has a unique URI. Next, you must grant your Google Cloud project permission to access and use this specific key from the external provider's system. This process is crucial for establishing the trust and authorization required for EKM to function correctly. Options A and B focus on creating keys within Google Cloud, which is not the correct approach for Cloud EKM. Option D mixes both, first mentioning external keys within Cloud KMS, which is conceptually incorrect. The core principle of Cloud EKM is that the key material itself resides outside of Google Cloud, managed by a third-party system. Only by first configuring the external key and granting Google Cloud access to it can you then proceed to apply it to encrypt BigQuery data.

Key Concepts:

Cloud External Key Manager (EKM): A Google Cloud service that lets you use encryption keys that are managed and stored externally by a third-party provider.

External Key Management Partner: A third-party system that provides key management services, integrating with Google Cloud EKM.

Uniform Resource Identifier (URI): A unique identifier for a resource, including the key in this case, which the EKM system will use to locate the external key.

Access Control: The mechanism by which the external key management system permits Google Cloud to use a particular key.

Authoritative Links:

Cloud EKM Overview: <https://cloud.google.com/kms/docs/ekm/overview>

Using External Keys: <https://cloud.google.com/kms/docs/ekm/using-external-keys>

Question: 154

Your company's cloud security policy dictates that VM instances should not have an external IP address. You need to identify the Google Cloud service that will allow VM instances without external IP addresses to connect to the internet to update the VMs. Which service should you use?

- A. Identity Aware-Proxy
- B. Cloud NAT
- C. TCP/UDP Load Balancing
- D. Cloud DNS

Answer: B

Explanation:

The correct answer is **B. Cloud NAT**. Cloud NAT (Network Address Translation) is a managed service provided by Google Cloud that enables virtual machine (VM) instances within a Virtual Private Cloud (VPC) network to access the internet without having external IP addresses assigned to them. This aligns directly with the security policy requirement of not exposing VMs directly to the public internet. Cloud NAT allows private instances to make outbound connections to the internet, for example, to download package updates, by translating their private internal IP addresses to public IP addresses managed by the NAT service. This translation happens via a Cloud Router instance. Identity-Aware Proxy (IAP) primarily focuses on controlling access to applications and resources by verifying user identity, not providing general internet connectivity. TCP/UDP Load Balancing is for distributing traffic to multiple instances for high availability and scalability, it doesn't provide a means to connect private VMs to the internet. Cloud DNS is a DNS service; it translates domain names to IP addresses and does not enable internet connectivity for private instances. Only Cloud NAT addresses the specific need of providing internet access for VMs with no external IP addresses, making it the ideal solution for the given scenario.

Further research:

Cloud NAT: <https://cloud.google.com/nat/docs>

Cloud Router: <https://cloud.google.com/router/docs>

Identity Aware Proxy: <https://cloud.google.com/iap/docs>

TCP/UDP Load Balancing: <https://cloud.google.com/load-balancing/docs/tcp>

Cloud DNS: <https://cloud.google.com/dns/docs>

Question: 155

CertyIQ

You want to make sure that your organization's Cloud Storage buckets cannot have data publicly available to the internet. You want to enforce this across all Cloud Storage buckets. What should you do?

- A. Remove Owner roles from end users, and configure Cloud Data Loss Prevention.
- B. Remove Owner roles from end users, and enforce domain restricted sharing in an organization policy.
- C. Configure uniform bucket-level access, and enforce domain restricted sharing in an organization policy.
- D. Remove *.setIamPolicy permissions from all roles, and enforce domain restricted sharing in an organization policy.

Answer: C

Explanation:

The correct answer is **C. Configure uniform bucket-level access, and enforce domain-restricted sharing in an organization policy**. Here's why:

Uniform Bucket-Level Access: This feature ensures that access control is managed exclusively at the bucket

level and not at the object level. This simplifies permissions management, reduces the risk of object-level access misconfigurations, and makes it easier to enforce a consistent access policy across all objects in the bucket.

Domain-Restricted Sharing Organization Policy: This policy restricts the sharing of resources within your organization to only users within your Google Workspace or Cloud Identity domain. This prevents accidental or intentional sharing of bucket data with external accounts, ensuring that resources remain private to your organization.

Combined Approach: Uniform bucket-level access coupled with the domain-restricted sharing organization policy effectively addresses the requirement of preventing public internet access. The uniform access ensures that all permissions are applied consistently at the bucket level, while the domain restriction adds an extra layer of security by limiting sharing to authorized users within your organization only.

Why Other Options are Incorrect:

Option A: While removing owner roles reduces privilege, Cloud Data Loss Prevention (DLP) is primarily designed to detect and prevent sensitive data from leaving a defined boundary, not primarily for preventing public access to buckets. It is not the best tool for preventing public access.

Option B: Removing owner roles limits privilege, but it does not address the core issue of preventing external sharing. Domain-restricted sharing alone isn't sufficient as it doesn't stop bucket level grants to public accounts

Option D: Removing *.setIamPolicy permissions hinders general administration of IAM permissions and will break the ability to manage buckets. Domain-restricted sharing alone doesn't prevent public anonymous access. This approach would be too drastic and prevent normal operations.

In summary, uniform bucket-level access combined with domain-restricted sharing through an organization policy provides a robust and scalable solution for preventing unintended public access to Cloud Storage data. It enforces consistent permissions and limits sharing to trusted users within the organization's domain.

Authoritative Links:

Uniform bucket-level access: <https://cloud.google.com/storage/docs/uniform-bucket-level-access>

Organization policies for Cloud Storage: <https://cloud.google.com/storage/docs/organization-policy>

Domain Restricted Sharing: https://cloud.google.com/resource-manager/docs/organization-policy/org-policy-constraints#constraints_for_gcp_services

Question: 156

CertyIQ

Your company plans to move most of its IT infrastructure to Google Cloud. They want to leverage their existing on-premises Active Directory as an identity provider for Google Cloud. Which two steps should you take to integrate the company's on-premises Active Directory with Google Cloud and configure access management? (Choose two.)

- A. Use Identity Platform to provision users and groups to Google Cloud.
- B. Use Cloud Identity SAML integration to provision users and groups to Google Cloud.
- C. Install Google Cloud Directory Sync and connect it to Active Directory and Cloud Identity.
- D. Create Identity and Access Management (IAM) roles with permissions corresponding to each Active Directory group.
- E. Create Identity and Access Management (IAM) groups with permissions corresponding to each Active Directory group.

Answer: CE

Explanation:

The correct answer is C and E. To integrate an on-premises Active Directory with Google Cloud, we need a mechanism to synchronize user and group identities. Google Cloud Directory Sync (GCDS) is specifically

designed for this purpose (option C). It acts as a bridge, taking user and group information from Active Directory and replicating it in Cloud Identity. This allows Google Cloud to recognize the existing user identities from on-premises.

Once these identities are available in Cloud Identity, we manage access using IAM. However, directly mapping Active Directory groups to IAM roles (option D) isn't the recommended approach. Instead, we create IAM groups (option E) that align with the access permissions needed within Google Cloud. These IAM groups are then granted appropriate IAM roles. This approach allows for granular control and aligns with the principle of least privilege, avoiding assigning unnecessary permissions. Option A, Identity Platform, is more for customer-facing applications rather than employee authentication with Active Directory. Option B, using Cloud Identity SAML directly, is not the primary approach to provision users from Active Directory in bulk. It is mostly used with single-sign on with external IDP solutions. Therefore, the combination of GCDS (C) for synchronization and IAM groups (E) for access management is the optimal solution for this scenario.

Authoritative links for further research:

Google Cloud Directory Sync (GCDS): <https://support.google.com/a/answer/106368?hl=en>

Cloud Identity: <https://cloud.google.com/identity>

Identity and Access Management (IAM): <https://cloud.google.com/iam>

IAM Groups: <https://cloud.google.com/iam/docs/groups>

Question: 157

CertyIQ

You are in charge of creating a new Google Cloud organization for your company. Which two actions should you take when creating the super administrator accounts? (Choose two.)

- A. Create an access level in the Google Admin console to prevent super admin from logging in to Google Cloud.
- B. Disable any Identity and Access Management (IAM) roles for super admin at the organization level in the Google Cloud Console.
- C. Use a physical token to secure the super admin credentials with multi-factor authentication (MFA).
- D. Use a private connection to create the super admin accounts to avoid sending your credentials over the Internet.
- E. Provide non-privileged identities to the super admin users for their day-to-day activities.

Answer: CE

Explanation:

The correct actions for creating super administrator accounts are C and E. Option C, using a physical token for multi-factor authentication (MFA), significantly enhances the security of these highly privileged accounts. MFA, especially using a physical token, makes it much harder for attackers to gain unauthorized access even if they obtain the password. This aligns with best practices for securing administrative accounts, as detailed in Google Cloud's security documentation. Option E, providing non-privileged identities for day-to-day activities, adheres to the principle of least privilege. Super admin accounts should only be used for administrative tasks; for daily tasks, regular accounts with limited privileges should be used. This minimizes the risk of accidental or malicious misuse of highly sensitive permissions. Options A, B, and D are incorrect. Access levels (A) do not prevent login; they manage access based on contextual attributes, and preventing login defeats the purpose of having a super admin. Disabling IAM roles (B) prevents admins from performing their duties. Using private connections (D) is generally not required as Google uses HTTPS encryption for all connections.

Authoritative Links:

Google Cloud Identity and Access Management (IAM) Best Practices:

<https://cloud.google.com/iam/docs/best-practices>

Google Workspace Admin Security: <https://support.google.com/a/answer/1075080?hl=en>

Multi-Factor Authentication (MFA) on Google Cloud: <https://cloud.google.com/security/multifactor-authentication>

Principle of Least Privilege: https://en.wikipedia.org/wiki/Principle_of_least_privilege

Question: 158

CertyIQ

You are deploying a web application hosted on Compute Engine. A business requirement mandates that application logs are preserved for 12 years and data is kept within European boundaries. You want to implement a storage solution that minimizes overhead and is cost-effective. What should you do?

- A. Create a Cloud Storage bucket to store your logs in the EUROPE-WEST1 region. Modify your application code to ship logs directly to your bucket for increased efficiency.
- B. Configure your Compute Engine instances to use the Google Cloud's operations suite Cloud Logging agent to send application logs to a custom log bucket in the EUROPE-WEST1 region with a custom retention of 12 years.
- C. Use a Pub/Sub topic to forward your application logs to a Cloud Storage bucket in the EUROPE-WEST1 region.
- D. Configure a custom retention policy of 12 years on your Google Cloud's operations suite log bucket in the EUROPE-WEST1 region.

Answer: B

Explanation:

Option B is the correct solution because it directly addresses all requirements efficiently. Utilizing the Cloud Logging agent on Compute Engine instances provides a managed and streamlined method to collect logs. Routing these logs to a custom log bucket within the EUROPE-WEST1 region ensures compliance with the data residency requirement. Furthermore, configuring a custom retention period of 12 years on this log bucket fulfills the long-term preservation mandate. This approach minimizes overhead by leveraging Google Cloud's built-in logging infrastructure, eliminating the need for custom coding or complex routing configurations. This is also cost-effective as Cloud Logging is designed for log management. Options A, C, and D are less suitable. Option A requires application code changes, adds overhead, and does not leverage the native logging agent. Option C introduces an unnecessary Pub/Sub component, adding complexity and potential cost. Option D fails to capture logs if they are not routed to Cloud Logging and does not address the log ingestion side.

Here are some helpful links for further research:

Cloud Logging Agent: <https://cloud.google.com/logging/docs/agent/installation>

Cloud Logging Custom Buckets: <https://cloud.google.com/logging/docs/routing/overview#custom-storage>

Cloud Logging Retention Policy: <https://cloud.google.com/logging/docs/storage/logs-storage-retention>

Choosing log storage options: <https://cloud.google.com/logging/docs/storage>

Question: 159

CertyIQ

You discovered that sensitive personally identifiable information (PII) is being ingested to your Google Cloud environment in the daily ETL process from an on-premises environment to your BigQuery datasets. You need to redact this data to obfuscate the PII, but need to re-identify it for data analytics purposes. Which components should you use in your solution? (Choose two.)

- A. Secret Manager
- B. Cloud Key Management Service
- C. Cloud Data Loss Prevention with cryptographic hashing
- D. Cloud Data Loss Prevention with automatic text redaction

Answer: BE

Explanation:

The correct answer is **B. Cloud Key Management Service** and **E. Cloud Data Loss Prevention with deterministic encryption using AES-SIV**. Here's the justification:

The primary requirement is to redact PII while retaining the ability to re-identify it for analytics. This necessitates a reversible transformation, not simple obfuscation or deletion.

Cloud Key Management Service (KMS) is crucial for managing the cryptographic keys required for deterministic encryption. It provides a secure way to store and control access to these sensitive keys, ensuring only authorized services can encrypt and decrypt data.

Cloud Data Loss Prevention (DLP) offers deterministic encryption using AES-SIV. Deterministic encryption is the key here, because it will always produce the same encrypted output given the same input and key, allowing for data matching and re-identification. DLP can identify the PII within the data stream, then apply the chosen deterministic encryption method before loading the data to BigQuery. Redacting via hashing (option C) or automatic text redaction (option D) would not enable re-identification since they are either irreversible or remove the data. Secret Manager (option A), while helpful for managing secrets, doesn't directly contribute to data transformation or encryption, hence it's not a primary component of the solution.

Therefore, using KMS for key management and DLP with deterministic encryption via AES-SIV allows for secure, reversible PII transformation. This meets the requirements of both redaction and the ability to re-identify the data for analysis.

Further research:

Google Cloud KMS: <https://cloud.google.com/kms/docs>

Cloud DLP: <https://cloud.google.com/dlp/docs>

Deterministic Encryption in DLP: <https://cloud.google.com/dlp/docs/transformations-deterministic-encryption>

AES-SIV: <https://en.wikipedia.org/wiki/AES-SIV>

Question: 160

CertyIQ

You are working with a client that is concerned about control of their encryption keys for sensitive data. The client does not want to store encryption keys at rest in the same cloud service provider (CSP) as the data that the keys are encrypting. Which Google Cloud encryption solutions should you recommend to this client? (Choose two.)

- A. Customer-supplied encryption keys.
- B. Google default encryption
- C. Secret Manager
- D. Cloud External Key Manager
- E. Customer-managed encryption keys

Answer: AD

Explanation:

Okay, let's break down why options A (Customer-supplied encryption keys - CSEK) and D (Cloud External Key Manager - Cloud EKM) are the correct choices for a client seeking to control their encryption keys and avoid

storing them with the data in the same CSP.

Customer-Supplied Encryption Keys (CSEK): CSEK allows the customer to generate, manage, and provide their own encryption keys for use by Google Cloud services. Google does not store these keys; the customer is solely responsible for key storage and management. This directly addresses the client's concern about CSP control over their keys, as the keys never reside with Google. Each data encryption operation requires the customer to provide the key, strengthening control but introducing operational overhead.

<https://cloud.google.com/kms/docs/customer-supplied-encryption>

Cloud External Key Manager (Cloud EKM): Cloud EKM allows customers to store their keys in an external key management system, often on-premises or within a different cloud provider. When Google Cloud services need to encrypt or decrypt data, they reach out to this external system for the key, rather than managing them internally. This ensures that keys are entirely out of Google's reach while still being usable within Google's environment. This solution perfectly matches the client's desire to store keys outside the CSP storing the data. <https://cloud.google.com/kms/docs/ekm>

Why the other options are incorrect:

B. Google default encryption: This option utilizes Google-managed encryption keys, which are stored within Google's infrastructure. This contradicts the client's requirement of keeping keys out of the same CSP as their data.

C. Secret Manager: This is a service for storing secrets such as API keys and passwords. While it can store encryption keys, the keys are still stored within Google Cloud, failing to meet the client's requirements for external key storage.

E. Customer-managed encryption keys (CMEK): While CMEK does allow more customer control than Google default encryption, the keys are still managed and stored within Google Cloud's Key Management Service (KMS). This does not fulfill the requirement to store keys outside of Google's environment.

Therefore, CSEK and Cloud EKM directly address the client's needs for external key management, providing a significantly higher level of control and security over their encryption keys. These solutions enable the client to maintain complete control over their keys' lifecycle while utilizing Google Cloud's services.

Question: 161

CertyIQ

You are implementing data protection by design and in accordance with GDPR requirements. As part of design reviews, you are told that you need to manage the encryption key for a solution that includes workloads for Compute Engine, Google Kubernetes Engine, Cloud Storage, BigQuery, and Pub/Sub. Which option should you choose for this implementation?

- A. Cloud External Key Manager
- B. Customer-managed encryption keys
- C. Customer-supplied encryption keys
- D. Google default encryption

Answer: A

Explanation:

The correct answer is A, Cloud External Key Manager (Cloud EKM). Here's why:

The scenario demands managing encryption keys for various Google Cloud services (Compute Engine, GKE, Cloud Storage, BigQuery, and Pub/Sub) while adhering to GDPR's data protection principles. This indicates a need for tight control and potentially external key management for compliance reasons.

Cloud EKM allows you to store and manage your encryption keys in a third-party key management system

outside of Google's infrastructure. This provides the highest level of control and separation of duties for key management. Crucially, it aligns with the "by design" aspect of the prompt, meaning we are building for enhanced security. This approach addresses GDPR requirements because the encryption keys are under your direct control, not Google's. This satisfies the requirement of more stringent key management policies.

Customer-managed encryption keys (CMEK), while granting more control than Google's default encryption, still store the keys within Google's Cloud KMS. This is less suitable when external control is explicitly needed for compliance. Customer-supplied encryption keys (CSEK) require you to upload the encryption key each time, making it cumbersome for various services. Google default encryption does not align with key management requirements.

Therefore, Cloud EKM is the best solution as it gives total control of key lifecycle and the key material outside Google's system, addressing the compliance and 'by design' requirements of the scenario.

Authoritative Links:

Google Cloud EKM Documentation: <https://cloud.google.com/kms/docs/ekm>

GDPR and Encryption: <https://gdpr.eu/encryption/>

Google Cloud KMS: <https://cloud.google.com/kms>

Question: 162

CertyIQ

Which Identity-Aware Proxy role should you grant to an Identity and Access Management (IAM) user to access HTTPS resources?

- A. Security Reviewer
- B. IAP-Secured Tunnel User
- C. IAP-Secured Web App User
- D. Service Broker Operator

Answer: C

Explanation:

The correct role for granting an IAM user access to HTTPS resources protected by Identity-Aware Proxy (IAP) is **C. IAP-Secured Web App User**. IAP functions as an access control layer, verifying a user's identity and context before allowing them to reach applications. The IAP-Secured Web App User role is specifically designed to grant users permission to access web applications secured by IAP via HTTPS. This role does not provide any administrative privileges over IAP itself; it focuses solely on allowing access to the protected resources. In contrast, Security Reviewer is a broader role concerned with auditing and reviewing security configurations, and IAP-Secured Tunnel User is applicable for accessing resources using IAP-managed tunnels, not HTTPS web applications. Service Broker Operator is unrelated to IAP, focusing instead on brokering services within a cloud environment. Thus, IAP-Secured Web App User is the most precise and appropriate role for accessing IAP-protected HTTPS resources. Using least privilege principles, granting this specific role ensures users have the necessary access without being granted unnecessary permissions.

Further Research:

1. **Google Cloud Identity-Aware Proxy (IAP) Documentation:** <https://cloud.google.com/iap/docs/> - Provides comprehensive details about IAP, its capabilities, and usage.
2. **IAM Roles for IAP:** <https://cloud.google.com/iap/docs/manage-access> - Explains the various IAM roles associated with IAP and their functionalities.
3. **IAM Least Privilege Principle:** <https://cloud.google.com/iam/docs/using-iam-securely> - Covers best practices for granting access using IAM and emphasizing the principle of least privilege.

Question: 163

You need to audit the network segmentation for your Google Cloud footprint. You currently operate Production and Non-Production infrastructure-as-a-service (IaaS) environments. All your VM instances are deployed without any service account customization. After observing the traffic in your custom network, you notice that all instances can communicate freely despite tag-based VPC firewall rules in place to segment traffic properly with a priority of 1000. What are the most likely reasons for this behavior?

- A. All VM instances are missing the respective network tags.
- B. All VM instances are residing in the same network subnet.
- C. All VM instances are configured with the same network route.
- D. A VPC firewall rule is allowing traffic between source/targets based on the same service account with priority 999.
- E. A VPC firewall rule is allowing traffic between source/targets based on the same service account with priority 1001.

Answer: AD

Explanation:

Okay, let's break down why options A and D are the most likely reasons for the observed network behavior, and why the other options are less likely.

Reasoning for Option A (Missing Network Tags):

VPC firewall rules in Google Cloud can target specific instances using network tags. If the VM instances are missing the tags specified in the firewall rules, those rules will not apply to them. Consequently, the firewall will effectively ignore them, leading to unrestricted traffic flow. Without appropriate tags, the firewall cannot differentiate between instances intended for different segments, and thus all traffic would be allowed by the implicit allow egress and implied deny ingress rules.

Reasoning for Option D (Conflicting Firewall Rule with Higher Priority):

VPC firewall rules operate on a priority basis. Lower numerical priority takes precedence. The problem states that there are tag-based rules with priority 1000. If another rule, possibly a higher priority rule (e.g., with priority 999), that is based on the default service account of the instances exists that allows all traffic, it would override the tag-based rules. Since all VMs are using the default service account, it could be that this rule is allowing all traffic regardless of source or destination, thus bypassing segmentation.

Why other options are less likely:

Option B (Same subnet): While instances in the same subnet can communicate by default, firewall rules should still apply and restrict that communication based on the rules in place. Subnet itself is not a factor here.

Option C (Same Network Route): Default routes allow instances to communicate inside VPC, it does not mean all instances can bypass firewall rules. Network routes direct traffic after firewall rules are evaluated.

Option E (Conflicting Firewall Rule with Lower Priority): A rule with a priority of 1001 would not override a rule with a priority of 1000. Lower number implies a higher priority.

Justification Summary:

The most likely explanations are either the missing tags which would result in ignoring of segmentation rules, or the presence of a conflicting allow rule with a higher priority that matches all instances and effectively bypasses the intended segmentation. The other options are related to basic networking which will not directly affect firewall rules application.

Authoritative Links for Further Research:

VPC Firewall Rules Overview: <https://cloud.google.com/vpc/docs/firewalls>

Firewall Rule Priorities: <https://cloud.google.com/vpc/docs/firewalls#priority>

Firewall Rule Targeting: <https://cloud.google.com/vpc/docs/firewalls#targeting>

Network Tags: <https://cloud.google.com/vpc/docs/add-remove-network-tags>

Service Accounts: <https://cloud.google.com/iam/docs/service-accounts>

Question: 164

CertyIQ

You are creating a new infrastructure CI/CD pipeline to deploy hundreds of ephemeral projects in your Google Cloud organization to enable your users to interact with Google Cloud. You want to restrict the use of the default networks in your organization while following Google-recommended best practices. What should you do?

- A. Enable the `constraints/compute.skipDefaultNetworkCreation` organization policy constraint at the organization level.
- B. Create a cron job to trigger a daily Cloud Function to automatically delete all default networks for each project.
- C. Grant your users the IAM Owner role at the organization level. Create a VPC Service Controls perimeter around the project that restricts the `compute.googleapis.com` API.
- D. Only allow your users to use your CI/CD pipeline with a predefined set of infrastructure templates they can deploy to skip the creation of the default networks.

Answer: A

Explanation:

Option A is the correct choice because it directly addresses the requirement to restrict the use of default networks organization-wide, following Google's best practices. The `constraints/compute.skipDefaultNetworkCreation` organization policy constraint, when enabled at the organization level, prevents the automatic creation of default networks in new projects within that organization. This proactively enforces the desired behavior, eliminating the need for manual deletion or reliance on user discipline. Option B, while technically achievable, is reactive and introduces operational overhead with a cron job and Cloud Function. It doesn't prevent the initial creation of default networks. Option C grants overly broad permissions (IAM Owner) and uses VPC Service Controls inappropriately. VPC Service Controls primarily protect data egress, not prevent network creation. Also, restricting the `compute.googleapis.com` API would hinder many valid compute operations. Option D relies on the CI/CD pipeline and user discipline, which can be bypassed. Enforcing through organization policy is more robust. Organization policies are the recommended method to control resource creation and configurations at a higher level. <https://cloud.google.com/resource-manager/docs/organization-policy/org-policy-constraints> <https://cloud.google.com/vpc/docs/best-practices> Using the organization policy ensures consistency across all projects, reduces the potential for misconfiguration, and aligns with the principle of least privilege. The other methods are either less effective or introduce unnecessary complexity and security risks.

Question: 165

CertyIQ

You are a security administrator at your company and are responsible for managing access controls (identification, authentication, and authorization) on Google Cloud. Which Google-recommended best practices should you follow when configuring authentication and authorization? (Choose two.)

- A. Use Google default encryption.
- B. Manually add users to Google Cloud.

- C. Provision users with basic roles using Google's Identity and Access Management (IAM) service.
- D. Use SSO/SAML integration with Cloud Identity for user authentication and user lifecycle management.
- E. Provide granular access with predefined roles.

Answer: DE

Explanation:

The correct answers are D and E. Option D, using SSO/SAML integration with Cloud Identity, is a best practice because it centralizes user authentication and lifecycle management. This approach enhances security by reducing the reliance on individual Google Cloud accounts and their associated passwords, which can be vulnerable. It also streamlines user onboarding and offboarding, improving efficiency. Cloud Identity serves as the identity provider, allowing federated authentication from an existing corporate identity system, which is a standard security practice. Option E, providing granular access with predefined roles, is also crucial. Applying the principle of least privilege, granting users only the permissions needed to perform their tasks minimizes the potential damage from compromised accounts or internal threats. Predefined roles in IAM are carefully crafted collections of permissions tailored to specific duties, making it easier to assign appropriate access levels. This is significantly better than assigning broad, powerful roles. Options A, B, and C are not best practices. Default encryption (A) is a baseline, not a best practice for access controls. Manual user addition (B) is cumbersome and error-prone, hindering security. Provisioning users with basic roles alone (C) may not provide the granularity needed.

Authoritative Links:

Google Cloud Identity Documentation: <https://cloud.google.com/identity>

Google Cloud IAM Documentation: <https://cloud.google.com/iam/docs>

Principle of Least Privilege: https://en.wikipedia.org/wiki/Principle_of_least_privilege

Question: 166

CertyIQ

You have been tasked with inspecting IP packet data for invalid or malicious content. What should you do?

- A. Use Packet Mirroring to mirror traffic to and from particular VM instances. Perform inspection using security software that analyzes the mirrored traffic.
- B. Enable VPC Flow Logs for all subnets in the VPC. Perform inspection on the Flow Logs data using Cloud Logging.
- C. Configure the Fluentd agent on each VM Instance within the VPC. Perform inspection on the log data using Cloud Logging.
- D. Configure Google Cloud Armor access logs to perform inspection on the log data.

Answer: A

Explanation:

Option A, utilizing Packet Mirroring, is the most appropriate solution for inspecting IP packet data for invalid or malicious content. Packet Mirroring allows you to copy network traffic from specific VM instances and forward it to an inspection appliance or tool. This provides a direct, real-time view of the actual packets being transmitted, which is crucial for deep packet inspection (DPI) and threat detection. Security software analyzing the mirrored traffic can perform signature-based analysis, anomaly detection, and other advanced checks to identify malicious content.

Options B, C, and D, while valuable for other purposes, are not well-suited for the task at hand. VPC Flow Logs (Option B) record metadata about network flows, such as source and destination IPs, ports, and protocols. They do not capture the actual packet payload, which is necessary for content inspection. Therefore, relying

solely on Flow Logs would be insufficient for detecting malicious code within the packets themselves.

Option C, using Fluentd, focuses on application and system logs, not network traffic data. While log analysis is important for security, it doesn't provide the level of detail required to inspect raw packet content. Similarly, Google Cloud Armor access logs (Option D) provide insights into requests coming through Cloud Armor, primarily focusing on HTTP(S) traffic, not the entire IP packet data. These logs are not suitable for in-depth inspection of network traffic within the VPC.

Therefore, Packet Mirroring offers the capability to capture the full packet data necessary to examine for malicious or invalid content in real-time. This makes it a superior choice for this specific security task.

Authoritative Links for Further Research:

Google Cloud Packet Mirroring: <https://cloud.google.com/vpc/docs/packet-mirroring>

VPC Flow Logs: <https://cloud.google.com/vpc/docs/using-flow-logs>

Google Cloud Logging: <https://cloud.google.com/logging>

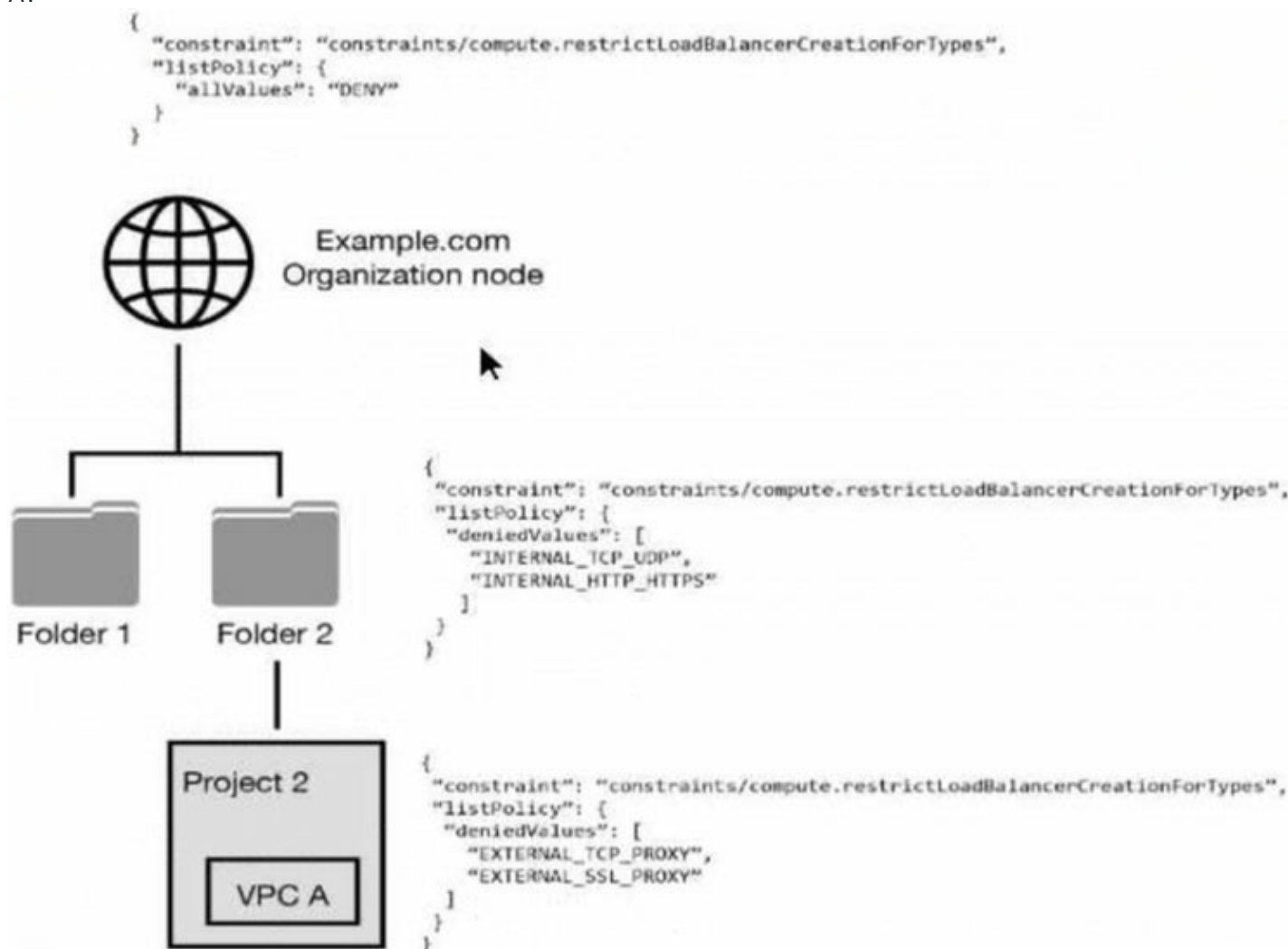
Google Cloud Armor Logging: <https://cloud.google.com/armor/docs/access-logging>

Question: 167

CertyIQ

You have the following resource hierarchy. There is an organization policy at each node in the hierarchy as shown. Which load balancer types are denied in VPC

A?



- A. All load balancer types are denied in accordance with the global node's policy.
- B. INTERNAL_TCP_UDP, INTERNAL_HTTP_HTTPS is denied in accordance with the folder's policy.
- C. EXTERNAL_TCP_PROXY, EXTERNAL_SSL_PROXY are denied in accordance with the project's policy.

D. EXTERNAL_TCP_PROXY, EXTERNAL_SSL_PROXY, INTERNAL_TCP_UDP, and INTERNAL_HTTP_HTTPS are denied in accordance with the folder and project's policies.

Answer: A

Explanation:

It's A. the good answer is A as indicated here : <https://cloud.google.com/load-balancing/docs/org-policy-constraints#gcloud>

Question: 168

CertyIQ

Your security team wants to implement a defense-in-depth approach to protect sensitive data stored in a Cloud Storage bucket. Your team has the following requirements:

- The Cloud Storage bucket in Project A can only be readable from Project B.
- The Cloud Storage bucket in Project A cannot be accessed from outside the network.
- Data in the Cloud Storage bucket cannot be copied to an external Cloud Storage bucket.

What should the security team do?

- A. Enable domain restricted sharing in an organization policy, and enable uniform bucket-level access on the Cloud Storage bucket.
- B. Enable VPC Service Controls, create a perimeter around Projects A and B, and include the Cloud Storage API in the Service Perimeter configuration.
- C. Enable Private Access in both Project A and B's networks with strict firewall rules that allow communication between the networks.
- D. Enable VPC Peering between Project A and B's networks with strict firewall rules that allow communication between the networks.

Answer: B

Explanation:

The correct answer is **B. Enable VPC Service Controls, create a perimeter around Projects A and B, and include the Cloud Storage API in the Service Perimeter configuration.**

Here's the justification:

VPC Service Controls (VPC SC) is the ideal solution for implementing a defense-in-depth approach with the given requirements. VPC SC allows you to define a security perimeter around your Google Cloud resources, restricting access based on identity and network context. By creating a perimeter that includes Projects A and B and the Cloud Storage API, we achieve several objectives. First, it limits access to the Cloud Storage bucket in Project A only from within the perimeter, effectively restricting external network access. Second, defining the Cloud Storage API within the perimeter ensures that resources outside the perimeter cannot copy data from the protected bucket. Furthermore, VPC SC supports cross-project access within the defined perimeter, enabling Project B to read the data while still preventing unauthorized access from Project A's networks to outside locations. This directly addresses the restriction of bucket readability to only Project B. Options A, C and D fail on one or more of the core requirements: Domain restricted sharing, option A, only controls access based on identity and doesn't prevent external access. Private access in option C and Peering in option D establish connectivity between projects, but do not control data exfiltration or enforce the network based access.

Authoritative Links:

VPC Service Controls Overview: <https://cloud.google.com/vpc-service-controls/docs/overview>

VPC Service Controls Concepts: <https://cloud.google.com/vpc-service-controls/docs/concepts-vpc-sc>

VPC Service Controls Service Perimeters: <https://cloud.google.com/vpc-service-controls/docs/service->

Question: 169

CertyIQ

You need to create a VPC that enables your security team to control network resources such as firewall rules. How should you configure the network to allow for separation of duties for network resources?

- A. Set up multiple VPC networks, and set up multi-NIC virtual appliances to connect the networks.
- B. Set up VPC Network Peering, and allow developers to peer their network with a Shared VPC.
- C. Set up a VPC in a project. Assign the Compute Network Admin role to the security team, and assign the Compute Admin role to the developers.
- D. Set up a Shared VPC where the security team manages the firewall rules, and share the network with developers via service projects.

Answer: D**Explanation:**

The correct answer is **D. Set up a Shared VPC where the security team manages the firewall rules, and share the network with developers via service projects.** Here's why:

Shared VPC allows for centralized network resource management, which directly addresses the need for the security team to control firewall rules and other network aspects. This approach enables a separation of duties: the security team, as the host project administrator, maintains control over the shared network and its security policies, while developers, in their respective service projects, can utilize the network resources without managing the underlying network configurations. Option A introduces unnecessary complexity with multi-NIC virtual appliances, making management cumbersome. Option B, while enabling connectivity, doesn't centralize control, undermining the need for security team oversight. Option C incorrectly assumes that Compute Network Admin role is sufficient for security control; the service project admins would still need compute network admin to create their subnets. Furthermore it also allows developers to manage the network using their own project which is not centralized control. Shared VPC is designed for this scenario, explicitly enabling centralized network control with granular access delegation. The security team manages the host project, configuring firewalls, and subnets. Developers can only launch compute resources within these pre-defined network settings, preventing accidental or malicious security misconfigurations. This ensures a clear division of responsibilities and strengthens overall network security posture.

Relevant links for further research:

Shared VPC Overview: <https://cloud.google.com/vpc/docs/shared-vpc>

Shared VPC Concepts: <https://cloud.google.com/vpc/docs/shared-vpc#concepts>

Roles and Permissions: <https://cloud.google.com/vpc/docs/shared-vpc#roles-and-permissions>

Question: 170

CertyIQ

You are onboarding new users into Cloud Identity and discover that some users have created consumer user accounts using the corporate domain name. How should you manage these consumer user accounts with Cloud Identity?

- A. Use Google Cloud Directory Sync to convert the unmanaged user accounts.
- B. Create a new managed user account for each consumer user account.
- C. Use the transfer tool for unmanaged user accounts.
- D. Configure single sign-on using a customer's third-party provider.

Answer: C

Explanation:

The correct answer is **C. Use the transfer tool for unmanaged user accounts**. Here's why:

When users create Google accounts (consumer accounts) using a corporate domain name, they essentially create "unmanaged" accounts outside the control of the organization's Cloud Identity service. These accounts pose a security risk and management challenge. Google provides a specific tool for addressing this: the Unmanaged User Account Transfer tool.

This tool allows administrators to claim and manage these consumer accounts by transferring them into the organization's Cloud Identity environment. It avoids the need to create completely new accounts (Option B), which would disrupt the user's existing access to personal data and services tied to their current account. Option A, Google Cloud Directory Sync, is used for syncing users from an existing directory (like Active Directory) to Cloud Identity, not for transferring unmanaged consumer accounts. While single sign-on (Option D) is a valid security measure, it doesn't directly address the issue of unmanaged accounts.

The transfer process effectively converts the unmanaged accounts into managed Google accounts associated with your organization. This allows the administrator to enforce security policies, manage access, and gain visibility into user activity. The transfer process also lets the user retain their existing Google data.

Therefore, the transfer tool is the most efficient and appropriate method for managing consumer user accounts using the corporate domain name within Cloud Identity.

Further research:

Transfer unmanaged users: <https://support.google.com/a/answer/6297507>

Manage unmanaged accounts: <https://support.google.com/a/answer/11406138>

Cloud Identity features: <https://cloud.google.com/identity/docs/overview>

Question: 171

CertyIQ

You have created an OS image that is hardened per your organization's security standards and is being stored in a project managed by the security team. As a Google Cloud administrator, you need to make sure all VMs in your Google Cloud organization can only use that specific OS image while minimizing operational overhead. What should you do? (Choose two.)

- A. Grant users the compute.imageUser role in their own projects.
- B. Grant users the compute.imageUser role in the OS image project.
- C. Store the image in every project that is spun up in your organization.
- D. Set up an image access organization policy constraint, and list the security team managed project in the project's allow list.
- E. Remove VM instance creation permission from users of the projects, and only allow you and your team to create VM instances.

Answer: BD

Explanation:

The correct answer is **B** and **D**.

B. Grant users the compute.imageUser role in the OS image project. This is necessary because users need permission to utilize the custom OS image stored in the security team's project. The compute.imageUser role grants them the ability to access and use that specific image when creating new VMs, but does not grant permission to modify or delete the image itself. Without this role, they would not be able to select and launch

VMs using the hardened image.

D. Set up an image access organization policy constraint, and list the security team managed project in the project's allow list. This is crucial for enforcing the use of the hardened image across the entire Google Cloud organization. An organization policy allows administrators to define rules at the organizational level that govern the usage of Google Cloud resources. The `compute.allowedImageProjects` constraint, specifically, allows for defining an allow list of projects whose images can be used for VM creation. By including the security team's project in this allow list, only images from that project (which contains the hardened image) are permitted for VM instantiation, effectively preventing the use of other unapproved images. This approach minimizes operational overhead by ensuring consistent policy enforcement without requiring repeated configuration in individual projects.

Options A, C and E, while potentially valid in certain circumstances, are not ideal for the described scenario. **A** is incorrect as it would unnecessarily grant users permissions within their projects which are not needed to fulfill the requirement and could introduce security risks. **C** requires significant overhead to store images in every project and maintain their consistency and is not scalable. **E** would limit the autonomy of project teams by centralizing VM creation, creating a bottleneck for developers and hindering development velocity.

These options ensure the organization's security posture is maintained, only allowing for hardened OS images to be used for VM creation while also ensuring minimal administrative overhead for the organization.

Authoritative Links:

Granting the `compute.imageUser` role: <https://cloud.google.com/compute/docs/access/iam>

Organization policies and `compute.allowedImageProjects` constraint: <https://cloud.google.com/resource-manager/docs/organization-policy/org-policy-constraints/list-constraints>

Using Organization Policies: <https://cloud.google.com/resource-manager/docs/organization-policy/overview>

Question: 172

CertyIQ

You're developing the incident response plan for your company. You need to define the access strategy that your DevOps team will use when reviewing and investigating a deployment issue in your Google Cloud environment. There are two main requirements:

- Least-privilege access must be enforced at all times.
- The DevOps team must be able to access the required resources only during the deployment issue.

How should you grant access while following Google-recommended best practices?

- A. Assign the Project Viewer Identity and Access Management (IAM) role to the DevOps team.
- B. Create a custom IAM role with limited list/view permissions, and assign it to the DevOps team.
- C. Create a service account, and grant it the Project Owner IAM role. Give the Service Account User Role on this service account to the DevOps team.
- D. Create a service account, and grant it limited list/view permissions. Give the Service Account User Role on this service account to the DevOps team.

Answer: B

Explanation:

The correct answer is **B**. Here's a detailed justification:

Option **B** aligns with the principle of least privilege, a cornerstone of cloud security. By creating a custom IAM role with only the necessary list/view permissions, you restrict the DevOps team's access to precisely what they need for incident investigation. This minimizes the potential impact of compromised credentials or accidental misuse. This directly addresses the requirement of least-privilege access at all times.

Options A and C are incorrect. Assigning Project Viewer (A) grants too much access, potentially revealing

sensitive information beyond what's needed for troubleshooting. Similarly, granting a service account the Project Owner role (C) provides excessive power, violating the principle of least privilege. Also, giving the DevOps team the ability to assume the service account identity does not fulfil the "during the deployment issue" requirement.

Option D, while using a service account with limited permissions, still doesn't fully address the temporal aspect of the requirement. It doesn't inherently restrict access to the duration of the deployment issue. Further steps like conditional role bindings are needed for this approach to fully work.

Using a custom IAM role, as in option B, allows for granular control over permissions. The custom role can be applied to the DevOps team only during the incident investigation. This can be achieved through various mechanisms, including temporary role grants, or by leveraging context aware access. This fulfills the "only during the deployment issue" requirement. This temporary access can be revoked when the incident is resolved.

Creating custom roles allows you to grant exactly the permissions required by the DevOps team at the time of investigation, promoting a strong security posture by limiting access. The use of custom roles is a Google-recommended best practice for managing access to resources.

Supporting Concepts:

Least Privilege: Granting only the minimum permissions necessary to perform a task.

IAM (Identity and Access Management): A core service for controlling access to Google Cloud resources.

Custom IAM Roles: Allow for fine-grained control over permissions, tailoring them to specific needs.

Service Accounts: Non-human identities used by applications or services to interact with Google Cloud resources. While useful in some cases, they're not the most appropriate for temporary human access.

Authoritative Links:

IAM best practices: <https://cloud.google.com/iam/docs/best-practices>

Creating and managing custom roles: <https://cloud.google.com/iam/docs/creating-custom-roles>

Understanding IAM Roles: <https://cloud.google.com/iam/docs/understanding-roles>

Question: 173

CertyIQ

You are working with a client who plans to migrate their data to Google Cloud. You are responsible for recommending an encryption service to manage their encrypted keys. You have the following requirements:

- The master key must be rotated at least once every 45 days.
- The solution that stores the master key must be FIPS 140-2 Level 3 validated.
- The master key must be stored in multiple regions within the US for redundancy.

Which solution meets these requirements?

- A. Customer-managed encryption keys with Cloud Key Management Service
- B. Customer-managed encryption keys with Cloud HSM
- C. Customer-supplied encryption keys
- D. Google-managed encryption keys

Answer: B

Explanation:

The correct answer is **B. Customer-managed encryption keys with Cloud HSM**. Let's break down why:

Cloud HSM (Hardware Security Module) is a managed service that offers FIPS 140-2 Level 3 validated hardware for storing cryptographic keys. This directly addresses the requirement for FIPS 140-2 Level 3 validation. Cloud HSM allows for customer-managed keys, giving the client complete control over their key

lifecycle, including rotation.

Customer-managed encryption keys with Cloud Key Management Service (KMS) (Option A) provides the ability to manage encryption keys and provides FIPS 140-2 Level 3 validated service, but the key material itself is not always stored in a FIPS 140-2 Level 3 validated module. This is critical as the question specifically requires the storage of the master key to be in FIPS 140-2 Level 3 hardware. Also, KMS manages keys in regions and not multiple regions within US for the same key.

Customer-supplied encryption keys (CSEK) (Option C) involve the client generating and managing keys outside of Google Cloud. While this gives full control, it adds management burden, and doesn't fulfill the requirement for a managed solution and multi-region storage. Furthermore, this solution does not allow Google to manage the keys.

Google-managed encryption keys (GMEK) (Option D) are fully managed by Google. The customer has no access to or control over the key lifecycle, which contradicts the requirement for customer-managed keys and key rotation every 45 days.

Cloud HSM also allows for creating keys in multiple regions to satisfy the redundancy requirement. The flexibility of Cloud HSM in customer-managed rotation enables the 45-day rotation policy, while Google-managed or customer-supplied keys do not allow for these granular control and storage requirements.

Therefore, Cloud HSM is the only service that meets all three requirements: FIPS 140-2 Level 3 validated storage of the master key, client-controlled key rotation at least every 45 days, and key storage in multiple US regions for redundancy.

Further research:

Google Cloud HSM: <https://cloud.google.com/hsm>

FIPS 140-2: <https://csrc.nist.gov/projects/cryptographic-module-validation-program/standards>

Cloud KMS: <https://cloud.google.com/kms>

Question: 174

CertyIQ

You manage your organization's Security Operations Center (SOC). You currently monitor and detect network traffic anomalies in your VPCs based on network logs. However, you want to explore your environment using network payloads and headers. Which Google Cloud product should you use?

- A. Cloud IDS
- B. VPC Service Controls logs
- C. VPC Flow Logs
- D. Google Cloud Armor
- E. Packet Mirroring

Answer: E

Explanation:

Packet Mirroring is the correct choice because it provides the ability to copy network traffic payloads and headers from specified virtual machines or subnets. This captured traffic can then be sent to a designated collector, like a security appliance, for deep packet inspection and analysis. This capability fulfills the requirement of exploring the environment with network payloads and headers, which goes beyond the capabilities of the other options. Cloud IDS focuses on intrusion detection using threat intelligence, not payload capture. VPC Service Controls logs detail access to services, not packet content. VPC Flow Logs record metadata about network connections, not the actual packets. Google Cloud Armor is designed for web application security and DDoS protection, not capturing general network traffic for analysis. Therefore,

Packet Mirroring is the only service explicitly designed for capturing and analyzing packet payloads and headers.

<https://cloud.google.com/vpc/docs/packet-mirroring><https://cloud.google.com/network-intelligence-center/docs/packet-mirroring>

Question: 175

CertyIQ

You are consulting with a client that requires end-to-end encryption of application data (including data in transit, data in use, and data at rest) within Google Cloud.

Which options should you utilize to accomplish this? (Choose two.)

- A. External Key Manager
- B. Customer-supplied encryption keys
- C. Hardware Security Module
- D. Confidential Computing and Istio
- E. Client-side encryption

Answer: DE

Explanation:

Okay, let's break down why options D and E are the correct choices for achieving end-to-end encryption on Google Cloud, and why the others are not suitable.

D. Confidential Computing and Istio: Confidential Computing provides encryption in use. This technology leverages hardware-based techniques to encrypt data while it's being processed within virtual machines. Istio, a service mesh, allows for the enforcement of mutual TLS (mTLS) encryption between microservices. Combined, they encrypt data in use (confidential computing) and data in transit within the application's network (Istio with mTLS).

E. Client-side encryption: Client-side encryption ensures data is encrypted before it even reaches Google Cloud. The application encrypts the data on the client-side, and it remains encrypted while being transferred and stored in the cloud. This protects the data at rest, in transit to Google Cloud, and in transit within Google Cloud storage.

Why other options are incorrect:

A. External Key Manager: While an external key manager enhances key management control, it doesn't inherently provide end-to-end encryption. It addresses the where of key storage and access control rather than the process of encryption.

B. Customer-supplied encryption keys: Similar to the External Key Manager, customer-supplied encryption keys offer you control over the encryption keys but don't by themselves implement the end to end encryption, particularly in-use.

C. Hardware Security Module: HSMs provide secure storage of encryption keys. They primarily deal with secure key management not end to end encryption of data in use.

Therefore, the combination of Confidential Computing, Istio with mTLS, and Client-side encryption provides a comprehensive solution for securing data in transit, in use, and at rest on Google Cloud, thus providing a true end-to-end protection.

Authoritative Links for Further Research:

Google Cloud Confidential Computing: <https://cloud.google.com/confidential-computing>

Istio Security: <https://istio.io/latest/docs/concepts/security/>

Google Cloud Encryption Options: <https://cloud.google.com/security/encryption>

Client-Side Encryption: <https://cloud.google.com/kms/docs/client-side-encryption>

Question: 176

CertyIQ

You need to enforce a security policy in your Google Cloud organization that prevents users from exposing objects in their buckets externally. There are currently no buckets in your organization. Which solution should you implement proactively to achieve this goal with the least operational overhead?

- A. Create an hourly cron job to run a Cloud Function that finds public buckets and makes them private.
- B. Enable the constraints/storage.publicAccessPrevention constraint at the organization level.
- C. Enable the constraints/storage.uniformBucketLevelAccess constraint at the organization level.
- D. Create a VPC Service Controls perimeter that protects the storage.googleapis.com service in your projects that contains buckets. Add any new project that contains a bucket to the perimeter.

Answer: B

Explanation:

The best solution is **B. Enable the constraints/storage.publicAccessPrevention constraint at the organization level.** This constraint directly addresses the requirement by preventing the creation of publicly accessible buckets and objects within the entire organization. It acts as a proactive safeguard, blocking configurations that would lead to public exposure from the outset. This approach is efficient and requires minimal ongoing maintenance because the enforcement is baked into the organizational policy. Option A, while functional, involves reactive remediation and relies on continuous execution of a function, leading to greater operational overhead. Option C, while enhancing access control, doesn't specifically prevent public access. Option D creates a perimeter but requires ongoing perimeter management for each new project, which isn't the least operationally overhead. The publicAccessPrevention constraint offers the most direct, proactive, and low-overhead way to block public access by design, thus making option B the optimal choice.

Here are the relevant links for further reading:

Organization policy constraints: <https://cloud.google.com/resource-manager/docs/organization-policy/understanding-constraints>

storage.publicAccessPrevention constraint: https://cloud.google.com/resource-manager/docs/organization-policy/org-policy-constraints/constraints-storage#constraint_storage.publicaccessprevention

Cloud Storage uniform bucket-level access: <https://cloud.google.com/storage/docs/uniform-bucket-level-access>

VPC Service Controls: <https://cloud.google.com/vpc-service-controls/docs/overview>

Question: 177

CertyIQ

Your company requires the security and network engineering teams to identify all network anomalies and be able to capture payloads within VPCs. Which method should you use?

- A. Define an organization policy constraint.
- B. Configure packet mirroring policies.
- C. Enable VPC Flow Logs on the subnet.
- D. Monitor and analyze Cloud Audit Logs.

Answer: B

Explanation:

The correct answer is **B. Configure packet mirroring policies**. Here's why:

Packet mirroring provides a mechanism to copy network traffic from specified virtual machine instances (VMs) within a Virtual Private Cloud (VPC) to a destination for analysis. This allows security and network engineering teams to examine the actual network packets (payloads), enabling them to identify anomalies and inspect communication patterns. This is a key functionality for deep network analysis and security monitoring.

Option A, defining an organization policy constraint, primarily governs settings at the organizational level and cannot directly capture packet payloads. It is used for broader security configurations. Option C, enabling VPC Flow Logs, records network traffic metadata (source/destination IP addresses, ports, protocol), which is useful for understanding traffic patterns but does not capture the actual packet data. Option D, monitoring and analyzing Cloud Audit Logs, captures API calls made to Google Cloud services, providing valuable insights into resource configuration changes but not network traffic content.

Packet mirroring, unlike flow logs, captures the complete packet, enabling not just anomaly detection but also payload analysis, which might include examining the data being exchanged. It allows for tools such as intrusion detection systems (IDS) or packet analyzers to deeply inspect network data, a critical requirement for this scenario. The ability to mirror traffic to a dedicated virtual appliance for analysis allows specialized security tooling to be brought to bear.

Therefore, because the requirement includes both anomaly detection and payload capture, packet mirroring is the most suitable method. It provides the level of network visibility needed for detailed security analysis.

For further research, consult the official Google Cloud documentation:

Packet Mirroring Overview: <https://cloud.google.com/vpc/docs/packet-mirroring>

VPC Flow Logs: <https://cloud.google.com/vpc/docs/using-flow-logs>

Organization Policy: <https://cloud.google.com/resource-manager/docs/organization-policy/overview>

Cloud Audit Logs: <https://cloud.google.com/logging/docs/audit>

Question: 178

CertyIQ

An organization wants to track how bonus compensations have changed over time to identify employee outliers and correct earning disparities. This task must be performed without exposing the sensitive compensation data for any individual and must be reversible to identify the outlier.

Which Cloud Data Loss Prevention API technique should you use?

- A. Cryptographic hashing
- B. Redaction
- C. Format-preserving encryption
- D. Generalization

Answer: C

Explanation:

The correct answer is **C. Format-preserving encryption**. Here's why:

Format-preserving encryption (FPE) is the ideal choice because it allows for the sensitive compensation data to be transformed while maintaining its original format (e.g., numeric values remain numeric), which is crucial for analysis and tracking. FPE allows reversible transformations, meaning the original sensitive data can be recovered when needed for outlier identification, fulfilling the reversibility requirement. This technique

satisfies the need to protect individual data while allowing aggregate analysis.

Why other options are not suitable:

A. Cryptographic Hashing: Hashing is a one-way function; it's not reversible. While it protects data, the original values cannot be retrieved for outlier identification and detailed analysis, which is a crucial part of the use case.

B. Redaction: Redaction permanently removes or masks sensitive data, making it impossible to analyze trends or identify outliers using the actual original values. Redaction does not support reversibility.

D. Generalization: Generalization replaces specific data with broader categories, which would make it difficult to do specific financial analysis of compensation changes. It also does not support the needed reversibility.

FPE offers a balance between data protection and data utility by enabling privacy-preserving analysis. It enables data teams to use transformed data for identifying patterns and anomalies while ensuring access to raw sensitive data is limited. This also enables the correction of disparities by pinpointing specific employee compensation when needed.

Authoritative Links for Further Research:

Google Cloud Data Loss Prevention (DLP): <https://cloud.google.com/dlp/docs>

Format-Preserving Encryption on Wikipedia: https://en.wikipedia.org/wiki/Format-preserving_encryption

NIST Special Publication 800-38G: Recommendation for Block Cipher Modes of Operation: Methods for Format-Preserving Encryption <https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-38g.pdf>

These resources offer in-depth knowledge about DLP techniques and format-preserving encryption, validating the justification for option C as the correct choice.

Question: 179

CertyIQ

You need to set up a Cloud Interconnect connection between your company's on-premises data center and VPC host network. You want to make sure that on-premises applications can only access Google APIs over the Cloud Interconnect and not through the public internet. You are required to only use APIs that are supported by VPC Service Controls to mitigate against exfiltration risk to non-supported APIs. How should you configure the network?

A.Enable Private Google Access on the regional subnets and global dynamic routing mode.

B.Create a CNAME to map *.googleapis.com to restricted.googleapis.com, and create A records for restricted.googleapis.com mapped to 199.36.153.8/30.

C.Use private.googleapis.com to access Google APIs using a set of IP addresses only routable from within Google Cloud, which are advertised as routes over the connection.

D.Use restricted.googleapis.com to access Google APIs using a set of IP addresses only routable from within Google Cloud, which are advertised as routes over the Cloud Interconnect connection.

Answer: D

Explanation:

Here's a breakdown of why option D is the correct solution, along with explanations and supporting links:

Justification for Option D: Using restricted.googleapis.com

Option D correctly utilizes restricted.googleapis.com to achieve the desired outcome. This specialized domain name is crucial for accessing Google APIs within a VPC Service Controls perimeter. By using this domain, requests are routed to a set of restricted IP addresses that are only reachable from within Google's network,

specifically through a Cloud Interconnect or Cloud VPN connection. These routes are advertised to the on-premises environment over the dedicated interconnect, ensuring on-premises applications utilize the private connection rather than the public internet to access supported Google APIs. The restriction also ensures that API traffic is confined within the boundaries of the VPC Service Controls policy, mitigating data exfiltration to non-supported APIs.

Why other options are incorrect:

Option A: While Private Google Access enables VMs to access Google APIs without public IPs, it doesn't force on-premises traffic through the Cloud Interconnect or restrict API access to only VPC Service Controls-supported services. This also does not offer restricted routing needed.

Option B: Redirecting *.googleapis.com using a CNAME and hardcoding IP addresses is fragile and not recommended. Google's IP ranges can change, breaking connectivity. Furthermore, this doesn't restrict API access or ensure proper routing through the Cloud Interconnect. The standard googleapis.com endpoint will not use the VPC Service Controls restricted access by default.

Option C: private.googleapis.com is used for Private Google Access within Google Cloud VMs, not for on-premises access over Cloud Interconnect. While it's a private access solution, it's not meant for the on-prem scenario described. It would not have the needed restricted routing.

Key Cloud Concepts:

Cloud Interconnect: Establishes a direct, private connection between an on-premises network and Google Cloud.

VPC Service Controls: Enables you to define security perimeters around your Google Cloud resources, limiting access and data exfiltration risks.

Restricted Google APIs: A set of APIs accessible only within a VPC Service Controls perimeter, enhancing security. restricted.googleapis.com is designed to access these.

Private Google Access: Allows Google Cloud VMs to access Google APIs privately, but it does not apply to the on-prem requirements.

Authoritative Links for Further Research:

VPC Service Controls: <https://cloud.google.com/vpc-service-controls/docs>

Accessing Google APIs over Interconnect and VPN: <https://cloud.google.com/vpc/docs/configure-private-google-access#on-premises-access>

Using Restricted VIP: <https://cloud.google.com/vpc-service-controls/docs/restricted-vip>

In summary, restricted.googleapis.com, combined with routes advertised over Cloud Interconnect, is the only option that satisfies all the requirements of accessing Google APIs privately from on-premises, ensuring only VPC Service Controls-supported APIs are accessed, and routing through the private interconnect connection.

Question: 180

CertyIQ

Your organization develops software involved in many open source projects and is concerned about software supply chain threats. You need to deliver provenance for the build to demonstrate the software is untampered.

What should you do?

- A.1. Hire an external auditor to review and provide provenance.
2. Define the scope and conditions.
3. Get support from the Security department or representative.
4. Publish the attestation to your public web page.

- B.1. Review the software process.
2. Generate private and public key pairs and use Pretty Good Privacy (PGP) protocols to sign the output software artifacts together with a file containing the address of your enterprise and point of contact.

3. Publish the PGP signed attestation to your public web page.

C.1. Publish the software code on GitHub as open source.

2. Establish a bug bounty program, and encourage the open source community to review, report, and fix the vulnerabilities.

D.1. Generate Supply Chain Levels for Software Artifacts (SLSA) level 3 assurance by using Cloud Build.

2. View the build provenance in the Security insights side panel within the Google Cloud console.

Answer: D

Explanation:

Option D is the correct approach to establish software provenance and address supply chain security concerns. Supply Chain Levels for Software Artifacts (SLSA) is a security framework designed to ensure the integrity of software throughout its lifecycle. Achieving SLSA Level 3 with Cloud Build provides verifiable build provenance. Cloud Build automatically generates metadata about the build process, including the source code, build steps, and dependencies. This metadata acts as a tamper-proof record of the build, making it difficult for malicious actors to inject harmful code. This provenance data is accessible through Google Cloud's Security Insights, allowing you to readily verify the integrity of software artifacts. Options A, B, and C are not comprehensive solutions for robust provenance. Hiring an external auditor (A) could provide an opinion but lacks continuous, automated verification. PGP signing (B) offers some level of artifact integrity but does not provide detailed provenance about the build process. While publishing code on GitHub and having a bug bounty program (C) can improve security, it doesn't generate verifiable provenance documentation. SLSA Level 3 with Cloud Build is directly aligned with establishing clear and verifiable software provenance. It provides a traceable, automated, and continuous method for demonstrating software integrity.

Authoritative Links:

SLSA Framework: <https://slsa.dev/>

Cloud Build Provenance: <https://cloud.google.com/build/docs/securing-builds/build-provenance>

Security Insights: <https://cloud.google.com/security-command-center/docs/how-to-view-insights>

Question: 181

CertyIQ

Your organization operates Virtual Machines (VMs) with only private IPs in the Virtual Private Cloud (VPC) with internet access through Cloud NAT. Everyday, you must patch all VMs with critical OS updates and provide summary reports.

What should you do?

A. Validate that the egress firewall rules allow any outgoing traffic. Log in to each VM and execute OS specific update commands. Configure the Cloud Scheduler job to update with critical patches daily for daily updates.

B. Copy the latest patches to the Cloud Storage bucket. Log in to each VM, download the patches from the bucket, and install them.

C. Assign public IPs to VMs. Validate that the egress firewall rules allow any outgoing traffic. Log in to each VM, and configure a daily cron job to enable for OS updates at night during low activity periods.

D. Ensure that VM Manager is installed and running on the VMs. In the OS patch management service, configure the patch jobs to update with critical patches daily.

Answer: D

Explanation:

The correct answer is **D. Ensure that VM Manager is installed and running on the VMs. In the OS patch management service, configure the patch jobs to update with critical patches daily.** This solution leverages Google Cloud's VM Manager, a fully managed service designed for OS management, including patching.

Option A is inadequate because manually logging into each VM for updates is not scalable, maintainable, or efficient, especially in an environment with multiple VMs. It also lacks a central reporting mechanism.

Option B requires the extra step of manual patch distribution via Cloud Storage, adding unnecessary complexity and operational overhead. Again, this doesn't provide central visibility or reporting.

Option C suggests assigning public IPs which is a security risk and unnecessary because Cloud NAT is in place for internet access. Using cron jobs per VM lacks the central control of a managed patch service.

VM Manager, however, addresses all requirements. It allows for automated patching based on various criteria (like critical patches), works with private IPs in conjunction with Cloud NAT, and provides centralized reporting. VM Manager agents residing on VMs execute the patching as per policy set in OS patch management service, ensuring consistent updates across all applicable VMs. This aligns perfectly with the stated need for daily critical OS updates and summary reports. This makes answer D the most suitable for efficient and compliant patching.

Authoritative Links:

VM Manager Overview: <https://cloud.google.com/vm-manager/docs/overview>

OS Patch Management: <https://cloud.google.com/vm-manager/docs/os-patch-management/overview>

Cloud NAT: <https://cloud.google.com/nat/docs/overview>

Question: 182

CertyIQ

For compliance reporting purposes, the internal audit department needs you to provide the list of virtual machines (VMs) that have critical operating system (OS) security updates available, but not installed. You must provide this list every six months, and you want to perform this task quickly.

What should you do?

- A.Run a Security Command Center security scan on all VMs to extract a list of VMs with critical OS vulnerabilities every six months.
- B.Run a gcloud CLI command from the Command Line Interface (CLI) to extract the VM's OS version information every six months.
- C.Ensure that the Cloud Logging agent is installed on all VMs, and extract the OS last update log date every six months.
- D.Ensure the OS Config agent is installed on all VMs and extract the patch status dashboard every six months.

Answer: D

Explanation:

The most efficient and accurate method for identifying VMs with critical OS updates available but not installed is to leverage the OS Config service and its associated agents. Option D is correct because the OS Config agent, when installed on VMs, continuously assesses the patch status of the operating system and reports this information to Google Cloud. The "patch status dashboard" within OS Config provides a centralized view of this data, clearly outlining which VMs have pending critical updates. This eliminates the need for manual scans or log analysis, streamlining the reporting process and ensuring data is consistently available.

Running a Security Command Center scan (Option A) could identify vulnerabilities, but it may not specifically pinpoint pending OS updates requiring installation. Security Command Center focuses on identifying security risks, not granular patch management. Using gcloud CLI to extract OS versions (Option B) is insufficient; it doesn't provide information on available or pending updates. Similarly, analyzing Cloud Logging (Option C) for update logs could be unreliable and require significant parsing and manipulation to extract the desired information, making it a less efficient and potentially less accurate approach. OS Config provides a specific

solution for patch management and its dashboard directly addresses the compliance requirement by offering real-time information about pending updates in a structured format. The six-month interval is easily accommodated by regularly consulting the dashboard.<https://cloud.google.com/compute/docs/osconfig/https://cloud.google.com/os-config/docs/patch-status-overview>

Question: 183

CertyIQ

Your company conducts clinical trials and needs to analyze the results of a recent study that are stored in BigQuery. The interval when the medicine was taken contains start and stop dates. The interval data is critical to the analysis, but specific dates may identify a particular batch and introduce bias. You need to obfuscate the start and end dates for each row and preserve the interval data.

What should you do?

- A. Use date shifting with the context set to the unique ID of the test subject.
- B. Extract the date using TimePartConfig from each date field and append a random month and year.
- C. Use bucketing to shift values to a predetermined date based on the initial value.
- D. Use the FFX mode of format preserving encryption (FPE) and maintain data consistency.

Answer: A

Explanation:

The correct answer is **A. Use date shifting with the context set to the unique ID of the test subject.**

Here's the justification:

Date shifting is a data transformation technique where dates are modified by adding or subtracting a fixed or variable amount of time. Crucially, with a consistent shift within a subject's records, you preserve the intervals between dates while changing the actual calendar values, thus preventing identification of specific dates that might reveal batch information.

Setting the context to the unique ID of the test subject ensures that each subject's dates are shifted uniquely, maintaining internal consistency within a subject's data, while making it impossible to map back to the original date through an offset. If all shifts were the same, patterns would persist, undermining the obfuscation.

Option B, extracting the date using TimePartConfig and appending random month/year, while removing the day part is not suitable as it completely eliminates the temporal context of the data. It also doesn't preserve the interval, which was a crucial element of the question.

Option C, using bucketing, would group dates into wider ranges, losing the fine-grained temporal information needed for interval analysis. This would cause data loss and inaccurate interpretation.

Option D, using Format Preserving Encryption (FPE) in FFX mode, is more suitable for string or numeric data where encryption and decryption needs to be format-preserving. While FPE could be used on dates if properly formatted, it does not address the requirement of maintaining consistency of interval data across all records relating to a single subject while also obfuscating the actual dates. FPE would also add computational overhead. Date shifting is a lighter, faster, and more direct solution for this particular problem.

Therefore, date shifting using a unique subject ID for context is the most appropriate solution to satisfy all requirements: obfuscate dates, preserve interval information, and maintain internal data consistency. It efficiently addresses the core need for privacy preservation while enabling required analysis.

Relevant links for further research:

Google Cloud Data Loss Prevention (DLP): <https://cloud.google.com/dlp/docs> (While not explicitly describing date shifting in this context, it details data masking techniques that are related).

BigQuery functions for dates: https://cloud.google.com/bigquery/docs/reference/standard-sql/date_functions (Useful for understanding various functions that could be used within date shifting, including adding/subtracting intervals).

Question: 184

CertyIQ

You have a highly sensitive BigQuery workload that contains personally identifiable information (PII) that you want to ensure is not accessible from the internet. To prevent data exfiltration, only requests from authorized IP addresses are allowed to query your BigQuery tables.

What should you do?

- A. Use service perimeter and create an access level based on the authorized source IP address as the condition.
- B. Use Google Cloud Armor security policies defining an allowlist of authorized IP addresses at the global HTTPS load balancer.
- C. Use the Restrict Resource Service Usage organization policy constraint along with Cloud Data Loss Prevention (DLP).
- D. Use the Restrict allowed Google Cloud APIs and services organization policy constraint along with Cloud Data Loss Prevention (DLP).

Answer: A

Explanation:

The correct answer is **A. Use service perimeter and create an access level based on the authorized source IP address as the condition.**

Here's why:

Service perimeters, part of Google Cloud's Virtual Private Cloud (VPC) Service Controls, are designed to establish security boundaries around Google Cloud resources, including BigQuery. They allow you to control access based on various attributes like source IP address, identity, and device posture. Creating an access level within the service perimeter with an authorized IP address condition ensures that only requests originating from those specified IPs can access the protected BigQuery data. This directly addresses the requirement of preventing internet access and data exfiltration from unauthorized locations.

Option B, using Cloud Armor, is designed to protect web applications at the global load balancer level, focusing on Layer 7 (HTTP/HTTPS) traffic. While it can filter based on IP addresses, it doesn't restrict access to BigQuery data itself. Cloud Armor is not the right mechanism for protecting data within BigQuery in this scenario.

Options C and D involve Organization Policy Constraints and Cloud DLP. While these tools are valuable, they are not the primary method for restricting access by source IP to BigQuery. Organization policy constraints primarily focus on enforcing global settings, while Cloud DLP helps identify and redact sensitive data, not control source access to resources. They don't directly fulfill the requirement to limit data access based on IP address, unlike service perimeters.

In summary, service perimeters with IP-based access levels provide granular control at the data layer, precisely meeting the security requirements of the scenario.

Authoritative Links for further research:

VPC Service Controls: <https://cloud.google.com/vpc-service-controls>

Access levels: <https://cloud.google.com/access-context-manager/docs/access-levels>

Service perimeters: <https://cloud.google.com/vpc-service-controls/docs/service-perimeters>

Google Cloud Armor: <https://cloud.google.com/armor>

Organization Policy Constraints: <https://cloud.google.com/resource-manager/docs/organization-policy/understanding-constraints>

Cloud Data Loss Prevention (DLP): <https://cloud.google.com/dlp>

Question: 185

CertyIQ

Your organization is moving virtual machines (VMs) to Google Cloud. You must ensure that operating system images that are used across your projects are trusted and meet your security requirements.

What should you do?

- A. Implement an organization policy to enforce that boot disks can only be created from images that come from the trusted image project.
- B. Implement an organization policy constraint that enables the Shielded VM service on all projects to enforce the trusted image repository usage.
- C. Create a Cloud Function that is automatically triggered when a new virtual machine is created from the trusted image repository. Verify that the image is not deprecated.
- D. Automate a security scanner that verifies that no common vulnerabilities and exposures (CVEs) are present in your trusted image repository.

Answer: A

Explanation:

The correct answer is **A. Implement an organization policy to enforce that boot disks can only be created from images that come from the trusted image project.**

Here's the justification:

Organization policies in Google Cloud allow administrators to centrally control resources and configurations across the entire organization. By using a constraint, such as `compute.restrictGuestOSFeatures`, on the `constraints/compute.allowedImageProjects` organization policy, you can restrict where virtual machine (VM) boot disks can be sourced. This enables you to mandate that all VMs in your organization must use images originating from your dedicated, trusted image project. This effectively enforces the usage of trusted, pre-approved operating system images, helping maintain consistent security posture. Option B is incorrect because Shielded VMs enhance the security posture of VMs but do not directly control the source of boot images. Option C is inefficient since it adds complexity using Cloud Functions for enforcement instead of using a central policy. Option D is important for ongoing security hygiene, but it is a vulnerability scanning solution and does not directly enforce the usage of specific trusted images at the time of VM creation. The organization policy provides the most direct, effective, and centralized way to meet the requirements of using trusted OS images, thereby strengthening the overall security of VMs deployed in your Google Cloud environment.

Further Research:

Organization Policies: <https://cloud.google.com/resource-manager/docs/organization-policy/overview>

constraints/compute.allowedImageProjects: <https://cloud.google.com/resource-manager/docs/organization-policy/understanding-constraints#compute>

Custom Images: <https://cloud.google.com/compute/docs/images/create-custom>

Question: 186

CertyIQ

You have stored company approved compute images in a single Google Cloud project that is used as an image repository. This project is protected with VPC Service Controls and exists in the perimeter along with other projects in your organization. This lets other projects deploy images from the image repository project. A team requires deploying a third-party disk image that is stored in an external Google Cloud organization. You need to grant read access to the disk image so that it can be deployed into the perimeter.

What should you do?

- A. Allow the external project by using the organizational policy, constraints/compute.trustedImageProjects.
- B.1. Update the perimeter.
2. Configure the egressTo field to include the external Google Cloud project number as an allowed resource and the serviceName to compute.googleapis.com.
3. Configure the egressFrom field to set identityType to ANY_IDENTITY.
- C.1. Update the perimeter.
2. Configure the ingressFrom field to set identityType to ANY_IDENTITY.
3. Configure the ingressTo field to include the external Google Cloud project number as an allowed resource and the serviceName to compute.googleapis.com.
- D.1. Update the perimeter.
2. Configure the egressTo field to set identityType to ANY_IDENTITY.
3. Configure the egressFrom field to include the external Google Cloud project number as an allowed resource and the serviceName to compute.googleapis.com.

Answer: B

Explanation:

The correct answer is **B**. This scenario involves accessing resources (disk images) from outside a VPC Service Controls perimeter and bringing them inside. VPC Service Controls uses ingress and egress rules to define the direction of data flow and the permissible resources. Since the goal is to read the external image into the perimeter, we need to configure egress rules, specifically the egressTo field, to permit this flow of data.

Option B correctly outlines this process. Step 1 initiates the perimeter update. Step 2, by configuring egressTo with the external project number and compute.googleapis.com, grants access for compute services within the perimeter to interact with resources in the external project. Crucially, egressTo governs outgoing data flow – in this context, the perimeter pulling the image. Step 3, setting egressFrom's identityType to ANY_IDENTITY, means that any identity within the perimeter can initiate this request for external data. This doesn't compromise security because access is still limited to the specified external project and service in the egressTo field.

Option A attempts to use organizational policy constraints, which would restrict the use of trusted images to only those on the list, but not allow external images to enter. Options C and D both misapply the concept of ingress and egress. Ingress rules control incoming data to a perimeter, but in this case, we are initiating a request from inside the perimeter and pulling in an image. Option D mixes the egressFrom and egressTo configurations, attempting to specify an external resource as a source rather than a destination. This is incorrect since the request originates within the perimeter.

Therefore, only option B provides the necessary egress configuration for accessing a Google Compute Engine image from outside the VPC Service Controls perimeter.

Supporting Links:

VPC Service Controls documentation: <https://cloud.google.com/vpc-service-controls/docs>

Egress rules: <https://cloud.google.com/vpc-service-controls/docs/egress-rules>

Identity type: <https://cloud.google.com/vpc-service-controls/docs/identity-types>

A service account key has been publicly exposed on multiple public code repositories. After reviewing the logs, you notice that the keys were used to generate short-lived credentials. You need to immediately remove access with the service account.

What should you do?

- A. Delete the compromised service account.
- B. Disable the compromised service account key.
- C. Wait until the service account credentials expire automatically.
- D. Rotate the compromised service account key.

Answer: A

Explanation:

The correct answer is **A. Delete the compromised service account**. Here's why:

While disabling the compromised key (option B) or rotating it (option D) are valid security responses, they don't immediately prevent further unauthorized access. Since the keys were exposed and used to generate short-lived credentials, an attacker could still generate new credentials if the service account remains active. Waiting for the credentials to expire (option C) is also insufficient due to the persistent risk.

Deleting the entire service account is the most decisive action. It immediately renders all associated keys, existing and potential short-lived credentials, invalid, effectively blocking all further unauthorized attempts. This is a crucial step when dealing with exposed credentials, particularly those being actively used. It's a scorched-earth approach ensuring immediate and complete mitigation of the compromised identity's access. While this might require reconfiguring applications that relied on the account, it prioritizes security and eliminates the risk of further exploitation. Subsequently, you would create a new service account and carefully manage the new credentials, using methods such as workload identity federation for improved security.

Refer to Google Cloud documentation for best practices on handling compromised credentials, service account security, and secure credential management for more insights.

Relevant links:

[Google Cloud Documentation on Service Accounts](#): To understand the concept and usage of service accounts.

[Google Cloud Documentation on Managing Service Account Keys](#): To learn about key rotation and security best practices.

[Google Cloud Documentation on workload identity federation](#): For information on alternative methods to manage authentication for better security.

Question: 188

CertyIQ

A company is using Google Kubernetes Engine (GKE) with container images of a mission-critical application. The company wants to scan the images for known security issues and securely share the report with the security team without exposing them outside Google Cloud.

What should you do?

- A.1. Enable Container Threat Detection in the Security Command Center Premium tier.
- 2. Upgrade all clusters that are not on a supported version of GKE to the latest possible GKE version.
- 3. View and share the results from the Security Command Center.
- B.1. Use an open source tool in Cloud Build to scan the images.
- 2. Upload reports to publicly accessible buckets in Cloud Storage by using gsutil.
- 3. Share the scan report link with your security department.
- C.1. Enable vulnerability scanning in the Artifact Registry settings.

2. Use Cloud Build to build the images.
3. Push the images to the Artifact Registry for automatic scanning.
4. View the reports in the Artifact Registry.

- D.1. Get a GitHub subscription.
2. Build the images in Cloud Build and store them in GitHub for automatic scanning.
3. Download the report from GitHub and share with the Security Team.

Answer: C

Explanation:

The correct answer is C because it utilizes Google Cloud's native services for vulnerability scanning and reporting, keeping the entire process within the Google Cloud environment. Option C leverages Artifact Registry's integrated vulnerability scanning feature, which automatically analyzes container images pushed to the registry for known vulnerabilities. This eliminates the need for external tools or services. Cloud Build is used to create the images, ensuring a secure build process. After the images are pushed to Artifact Registry, the vulnerability scan is triggered automatically. The results are available directly within the Artifact Registry interface, allowing secure access for the security team. This approach aligns with the principle of least privilege by not making reports publicly accessible and reduces the complexity of managing external tools. Options A, B and D are incorrect. Option A suggests using Container Threat Detection, which is geared towards runtime security and not image vulnerability scanning, and the option contains an unnecessary step of upgrading the cluster. Option B involves publicly accessible storage and is not secure. Option D involves using a third party like Github which is not optimal for cloud security.

Key Concepts:

Artifact Registry: A fully managed container registry service on Google Cloud that offers built-in vulnerability scanning.

Vulnerability Scanning: The process of identifying security weaknesses in software and systems.

Cloud Build: A Google Cloud service that allows for building and testing software in a serverless environment.

Principle of Least Privilege: Granting users or services only the necessary permissions to perform their tasks.

Authoritative Links:

[Artifact Registry Vulnerability Scanning](#): Google Cloud documentation on vulnerability scanning in Artifact Registry.

[Cloud Build](#): Google Cloud documentation on Cloud Build.

[Google Cloud Security](#): Overview of Google Cloud's security solutions.

Question: 189

CertyIQ

Your application is deployed as a highly available, cross-region solution behind a global external HTTP(S) load balancer. You notice significant spikes in traffic from multiple IP addresses, but it is unknown whether the IPs are malicious. You are concerned about your application's availability. You want to limit traffic from these clients over a specified time interval.

What should you do?

- A. Configure a throttle action by using Google Cloud Armor to limit the number of requests per client over a specified time interval.
- B. Configure a rate_based_ban action by using Google Cloud Armor and set the ban_duration_sec parameter to the specified time interval.
- C. Configure a firewall rule in your VPC to throttle traffic from the identified IP addresses.
- D. Configure a deny action by using Google Cloud Armor to deny the clients that issued too many requests over the specified time interval.

Answer: A

Explanation:

The correct answer is A. Google Cloud Armor is designed to protect applications from various threats, including denial-of-service attacks and application-layer attacks. Its security policies allow for sophisticated traffic control, including rate limiting. Option A directly addresses the requirement of limiting traffic from clients exceeding a threshold over a specified time interval using a "throttle" action. This prevents the application from being overwhelmed by excessive requests, thus protecting its availability. The "throttle" action temporarily delays requests, unlike outright denial, which is better suited when malicious traffic is definitively identified.

Option B, using `rate_based_ban`, is not the best fit since a ban is more drastic and it involves potentially blocking legitimate traffic for a fixed period. While useful in some situations, a temporary throttle is more appropriate when the nature of the traffic is still unclear. Option C, using a VPC firewall, would not be a suitable solution as it cannot provide rate-limiting capabilities. It works at a lower layer of the OSI model than what is required for application-level traffic control. Option D, using the "deny" action, would immediately block the traffic, which might not be desirable in the given scenario since the nature of the traffic is unclear and throttling is preferred.

Therefore, Google Cloud Armor's throttle action provides the most precise mechanism for managing potential threats by limiting traffic without completely blocking it while maintaining availability.

Relevant Documentation:

Google Cloud Armor Overview: <https://cloud.google.com/armor/docs/overview>

Google Cloud Armor rate limiting: <https://cloud.google.com/armor/docs/rate-limiting-overview>

Google Cloud Armor Security Policies: <https://cloud.google.com/armor/docs/security-policy-concepts>

Question: 190

CertyIQ

Your organization is using Active Directory and wants to configure Security Assertion Markup Language (SAML). You must set up and enforce single sign-on (SSO) for all users.

What should you do?

- A.1. Create a new SAML profile.
- 2. Populate the sign-in and sign-out page URLs.
- 3. Upload the X.509 certificate.
- 4. Configure Entity ID and ACS URL in your IdP.
- B.1. Configure prerequisites for OpenID Connect (OIDC) in your Active Directory (AD) tenant.
- 2. Verify the AD domain.
- 3. Decide which users should use SAML.
- 4. Assign the pre-configured profile to the select organizational units (OUs) and groups.
- C.1. Create a new SAML profile.
- 2. Upload the X.509 certificate.
- 3. Enable the change password URL.
- 4. Configure Entity ID and ACS URL in your IdP.
- D.1. Manage SAML profile assignments.
- 2. Enable OpenID Connect (OIDC) in your Active Directory (AD) tenant.
- 3. Verify the domain.

Answer: A

Explanation:

The correct answer is A because it outlines the necessary steps for configuring SAML-based SSO with Active

Directory. SAML (Security Assertion Markup Language) is a standard XML-based framework for exchanging authentication and authorization data between security domains. Option A correctly starts by creating a new SAML profile, which holds the configuration for the SSO connection. Subsequently, populating the sign-in and sign-out page URLs directs users to the appropriate endpoints during the authentication process. Uploading the X.509 certificate ensures secure communication by verifying the identity of the identity provider (IdP) and the service provider (SP). Finally, configuring the Entity ID and Assertion Consumer Service (ACS) URL in the IdP establishes a trust relationship, enabling successful SAML exchanges.

Option B is incorrect as it focuses on OpenID Connect (OIDC), which is a different authentication protocol and doesn't directly address the problem of configuring SAML. Option C includes the "enable the change password URL", which is not a core step in SAML setup, and the other steps are not in the correct sequence. Option D incorrectly places "manage SAML profile assignments" as the first step before a SAML profile is even created, and also incorrectly suggests enabling OIDC for the given scenario. SAML is the appropriate protocol for establishing SSO with Active Directory.

For further research on SAML, consider the following authoritative links:

OASIS SAML Standard: https://www.oasis-open.org/committees/tc_home.php?wg_abbrev=security

Microsoft's Documentation on SAML and Active Directory: <https://learn.microsoft.com/en-us/entra/identity/hybrid/connect/how-to-connect-fed-saml-idp>

Cloudflare's Understanding SAML: <https://www.cloudflare.com/learning/access-management/what-is-saml/>

Question: 191

CertyIQ

Employees at your company use their personal computers to access your organization's Google Cloud console. You need to ensure that users can only access the Google Cloud console from their corporate-issued devices and verify that they have a valid enterprise certificate.

What should you do?

- A. Implement an Access Policy in BeyondCorp Enterprise to verify the device certificate. Create an access binding with the access policy just created.
- B. Implement a VPC firewall policy. Activate packet inspection and create an allow rule to validate and verify the device certificate.
- C. Implement an organization policy to verify the certificate from the access context.
- D. Implement an Identity and Access Management (IAM) conditional policy to verify the device certificate.

Answer: A

Explanation:

The correct answer is A. Here's why:

BeyondCorp Enterprise, Google's zero-trust security model, is designed to grant access based on user and device context, not solely network location. Implementing an Access Policy within BeyondCorp Enterprise allows you to define specific criteria that devices must meet before gaining access to resources. One such criterion is the presence of a valid client certificate. By setting up an access policy, you can enforce device posture checks, verifying that the certificate used by the device matches your enterprise-issued certificate authority. This ensures only devices with trusted certificates can access the Google Cloud console.

The next step, creating an access binding with the access policy, ties the access control policy to your Google Cloud resources. This binding dictates that only devices that fulfill the conditions in the access policy (specifically having a valid enterprise certificate) will be granted access to the Google Cloud console.

Option B is incorrect because a VPC firewall policy operates at the network layer and is not suitable for

verifying device certificates. Option C is incorrect because Organization policies cannot directly verify certificates in the context of access requests. Option D is incorrect as IAM conditional policies, while providing access control, lack the specific capability to examine and validate client-side certificates in the way BeyondCorp Enterprise does. BeyondCorp Enterprise's access policies are specifically designed for this use case of verifying devices beyond just network or IP based rules.

Therefore, the only solution that directly addresses the requirement to verify enterprise device certificates is implementing an Access Policy in BeyondCorp Enterprise coupled with an access binding. This provides the necessary zero trust mechanism needed to protect access to sensitive cloud resources.

Further Research:

[BeyondCorp Enterprise](#): Google Cloud's official page on BeyondCorp Enterprise.

[Access Context Manager Overview](#): Google's documentation on Access Context Manager, which is the underlying service for access policies in BeyondCorp Enterprise.

[BeyondCorp Zero Trust Access](#): Google's broader documentation on zero trust security.

Question: 192

CertyIQ

Your organization is rolling out a new continuous integration and delivery (CI/CD) process to deploy infrastructure and applications in Google Cloud. Many teams will use their own instances of the CI/CD workflow. It will run on Google Kubernetes Engine (GKE). The CI/CD pipelines must be designed to securely access Google Cloud APIs.

What should you do?

- A.1. Create two service accounts, one for the infrastructure and one for the application deployment.
- 2. Use workload identities to let the pods run the two pipelines and authenticate with the service accounts.
- 3. Run the infrastructure and application pipelines in separate namespaces.
- B.1. Create a dedicated service account for the CI/CD pipelines.
- 2. Run the deployment pipelines in a dedicated nodes pool in the GKE cluster.
- 3. Use the service account that you created as identity for the nodes in the pool to authenticate to the Google Cloud APIs.
- C.1. Create individual service accounts for each deployment pipeline.
- 2. Add an identifier for the pipeline in the service account naming convention.
- 3. Ensure each pipeline runs on dedicated pods.
- 4. Use workload identity to map a deployment pipeline pod with a service account.
- D.1. Create service accounts for each deployment pipeline.
- 2. Generate private keys for the service accounts.
- 3. Securely store the private keys as Kubernetes secrets accessible only by the pods that run the specific deploy pipeline.

Answer: A

Explanation:

The best approach is **A**. Here's why:

Workload Identity is the recommended way for applications running on GKE to securely access Google Cloud APIs. It eliminates the need to store and manage service account keys, mitigating the risk of credential exposure. Option A leverages this best practice.

Separation of Concerns: By using two service accounts – one for infrastructure and one for application deployment – you adhere to the principle of least privilege. This limits the potential impact of a compromised service account, as each only has the necessary permissions for its specific task.

Namespaces for Isolation: Running infrastructure and application pipelines in separate namespaces provides logical isolation and helps prevent accidental or malicious interactions between them. This is good practice

for managing the security and scope within a shared cluster.

Option B is flawed: Using the node pool's service account for pipelines is highly discouraged, as it grants broad permissions to all pods running in that pool. This creates a larger attack surface and violates the principle of least privilege.

Option C is too granular: While individual service accounts are a good practice, requiring dedicated pods for every pipeline adds unnecessary overhead and complexity. Workload identity allows you to map service accounts to pods directly, simplifying the configuration.

Option D is insecure: Managing service account private keys as Kubernetes secrets is a very risky approach. Secrets can be accidentally exposed or compromised, leading to a major security breach.

Option A represents a balance between security, manageability, and best practices. By implementing workload identity, separating concerns through service accounts, and utilizing namespaces, this strategy provides a secure foundation for the CI/CD pipelines.

Authoritative Links for further research:

[Workload Identity](#)

[Principle of Least Privilege](#)

[Kubernetes Namespaces](#)

Question: 193

CertyIQ

Your organization's Customers must scan and upload the contract and their driver license into a web portal in Cloud Storage. You must remove all personally identifiable information (PII) from files that are older than 12 months. Also, you must archive the anonymized files for retention purposes.

What should you do?

- A. Set a time to live (TTL) of 12 months for the files in the Cloud Storage bucket that removes PII and moves the files to the archive storage class.
- B. Create a Cloud Data Loss Prevention (DLP) inspection job that de-identifies PII in files created more than 12 months ago and archives them to another Cloud Storage bucket. Delete the original files.
- C. Configure the Autoclass feature of the Cloud Storage bucket to de-identify PII. Archive the files that are older than 12 months. Delete the original files.
- D. Schedule a Cloud Key Management Service (KMS) rotation period of 12 months for the encryption keys of the Cloud Storage files containing PII to de-identify them. Delete the original keys.

Answer: B

Explanation:

Option B is the correct solution because it directly addresses all requirements: removing PII from files older than 12 months, archiving the anonymized files, and handling the original files appropriately. Cloud Data Loss Prevention (DLP) is designed for inspecting and transforming sensitive data, making it ideal for identifying and de-identifying PII. An inspection job can be configured to target files based on their creation date (older than 12 months). Once the PII is removed, the anonymized files can be moved to an archive storage bucket, meeting the retention requirement. After the anonymization and archiving are successful, the original, potentially sensitive files can be deleted.

Options A, C, and D are not suitable. Option A's TTL feature is primarily for deletion, not for PII removal. Option C's Autoclass feature manages storage class transitions based on access patterns, not PII inspection or removal. Option D's KMS rotation does not de-identify data; instead, it manages encryption keys, which wouldn't achieve the required outcome. Also rotating keys would render encrypted data unreadable if original

keys are not maintained.

Therefore, option B utilizes the appropriate service (Cloud DLP) and provides the necessary mechanisms to fulfill all aspects of the requirements, specifically the de-identification and archiving process.

Further research on Cloud DLP:

[Google Cloud DLP Documentation](#)

[Cloud DLP Concepts](#)

[Cloud Storage documentation](#)

Question: 194

CertyIQ

You plan to synchronize identities to Cloud Identity from a third-party identity provider (IdP). You discovered that some employees used their corporate email address to set up consumer accounts to access Google services. You need to ensure that the organization has control over the configuration, security, and lifecycle of these consumer accounts.

What should you do? (Choose two.)

- A. Mandate that those corporate employees delete their unmanaged consumer accounts.
- B. Reconcile accounts that exist in Cloud Identity but not in the third-party IdP.
- C. Evict the unmanaged consumer accounts in the third-party IdP before you sync identities.
- D. Use Google Cloud Directory Sync (GCDS) to migrate the unmanaged consumer accounts' emails as user aliases.
- E. Use the transfer tool to invite those corporate employees to transfer their unmanaged consumer accounts to the corporate domain.

Answer: B

Explanation:

Okay, let's break down why options B and E are the correct choices for managing existing consumer accounts with corporate email addresses when integrating with a third-party IdP, and why the other options are not suitable.

Why B and E are Correct:

Option B: Reconcile accounts that exist in Cloud Identity but not in the third-party IdP. This is crucial because after you begin identity synchronization, you'll likely have users already present in Cloud Identity as "unmanaged consumer accounts" (using their corporate emails). These users, while they can use Google services, don't fall under your organization's control. Reconciling means identifying these existing accounts, matching them to their corresponding entries in your third-party IdP when synchronization is performed, and moving them under your organization's managed umbrella. This reconciliation enables proper control and security enforcement over these accounts by linking them to the managed corporate identities.

Option E: Use the transfer tool to invite those corporate employees to transfer their unmanaged consumer accounts to the corporate domain. This leverages Google's account transfer tool. This tool allows users to convert their unmanaged consumer accounts into managed accounts under the organization's domain. Upon accepting the invitation and completing the transfer, the user's account is now managed by the organization and linked to the corporate identity, enabling policies, security controls, and proper lifecycle management. This approach maintains user data and avoids data loss/disruption compared to deletion. This is crucial for continuity and prevents the loss of personal data associated with the consumer accounts.

Why other options are incorrect:

Option A: Mandate that those corporate employees delete their unmanaged consumer accounts. While it seems like a straightforward fix, deleting those consumer accounts would lead to data loss and disruption for those employees. They might have valuable documents, emails, and settings tied to those accounts, and losing them would cause considerable problems. Furthermore, it is administratively difficult and requires end user action which is not desirable.

Option C: Evict the unmanaged consumer accounts in the third-party IdP before you sync identities. Since the unmanaged accounts are Google consumer accounts, they don't exist in a third-party IdP. This action is therefore not possible in this context. The identities do exist in Google's platform already.

Option D: Use Google Cloud Directory Sync (GCDS) to migrate the unmanaged consumer accounts' emails as user aliases. GCDS is used to sync your directory structure from your on-premises directory to Google Workspace. It cannot be used to migrate existing user email accounts into managed accounts and not the right tool for this issue.

Key Concepts:

Unmanaged Consumer Accounts: These are Google accounts created by individual users, typically using personal email addresses, but can also use corporate emails. They are not controlled by a Google Workspace organization.

Cloud Identity: Google's Identity as a Service (IDaaS) that allows you to manage user identities and access to Google Cloud and other services.

Third-Party Identity Provider (IdP): A system (e.g., Active Directory, Okta) that stores and manages user identities, used for federated authentication.

Account Reconciliation: The process of identifying and merging or linking existing user accounts to ensure consistency and proper management.

Account Transfer Tool: Google's tool designed to move existing consumer accounts into a managed domain, preserving user data.

Authoritative Links:

[Google Workspace: Manage unmanaged accounts](#)

[Google Workspace: Transfer unmanaged user accounts](#)

[Cloud Identity: Identity synchronization](#)

Question: 195

CertyIQ

You are auditing all your Google Cloud resources in the production project. You want to identify all principals who can change firewall rules.

What should you do?

- A. Use Policy Analyzer to query the permissions `compute.firewalls.get` or `compute.firewalls.list`.
- B. Use Firewall Insights to understand your firewall rules usage patterns.
- C. Reference the Security Health Analytics – Firewall Vulnerability Findings in the Security Command Center.
- D. Use Policy Analyzer to query the permissions `compute.firewalls.create` or `compute.firewalls.update` or `compute.firewalls.delete`.

Answer: D

Explanation:

The correct answer is **D. Use Policy Analyzer to query the permissions `compute.firewalls.create` or `compute.firewalls.update` or `compute.firewalls.delete`.**

Here's why:

Policy Analyzer is a powerful tool within Google Cloud that allows you to understand who has what access to your resources based on IAM policies. To identify who can change firewall rules, we need to look for permissions that grant the ability to modify them, not just view or list them.

Options A, B and C are incorrect:

Option A focuses on `compute.firewalls.get` and `compute.firewalls.list`, these permissions allow a principal to view or retrieve information about existing firewall rules. They do not grant the ability to modify the rules.

Option B directs you to Firewall Insights, which is focused on understanding firewall usage patterns and effectiveness. It does not provide information about which principals have the permissions to change firewall rules.

Option C references Security Health Analytics within Security Command Center, which flags potential vulnerabilities related to firewall configurations but doesn't identify which principals have the permission to modify these rules.

Option D is correct because:

The permissions `compute.firewalls.create`, `compute.firewalls.update`, and `compute.firewalls.delete` directly grant the ability to create new firewall rules, modify existing ones, or delete them entirely. These are the key actions that enable changes to firewall configurations. By using Policy Analyzer to query for these specific permissions, you can effectively determine which principals have the authority to alter your project's firewall rules. Policy analyzer helps you understand which principals (users, service accounts) have these permissions applied at the project level, folder level, or even organization level. This allows for comprehensive auditing.

For further research, you can refer to the following Google Cloud documentation:

Policy Analyzer: <https://cloud.google.com/policy-analyzer/docs/overview>

IAM Permissions for Compute Engine: <https://cloud.google.com/compute/docs/access/iam>

Understanding IAM: <https://cloud.google.com/iam/docs/overview>

Question: 196

CertyIQ

Your organization previously stored files in Cloud Storage by using Google Managed Encryption Keys (GMEK), but has recently updated the internal policy to require Customer Managed Encryption Keys (CMEK). You need to re-encrypt the files quickly and efficiently with minimal cost.

What should you do?

- A.Reupload the files to the same Cloud Storage bucket specifying a key file by using gsutil.
- B.Encrypt the files locally, and then use gsutil to upload the files to a new bucket.
- C.Copy the files to a new bucket with CMEK enabled in a secondary region.
- D.Change the encryption type on the bucket to CMEK, and rewrite the objects.

Answer: D

Explanation:

Option D, "Change the encryption type on the bucket to CMEK, and rewrite the objects," is the most efficient and cost-effective approach for transitioning from Google Managed Encryption Keys (GMEK) to Customer Managed Encryption Keys (CMEK) in Google Cloud Storage. This method avoids the significant time and cost associated with re-uploading or copying large volumes of data. By changing the bucket's default encryption to CMEK and then triggering a rewrite of the objects, Google Cloud Storage handles the re-encryption process in the background. This is done server-side, minimizing data transfer overhead and processing on client machines. It leverages Google's infrastructure, allowing for a rapid transition compared to the other options.

Re-uploading (Option A) involves unnecessary egress and ingress traffic. Encrypting locally and uploading (Option B) introduces client-side processing overhead and is more time-consuming. Copying to a new bucket (Option C) incurs storage costs for the new bucket and the time for the transfer. Rewriting in place, however, only updates the encryption metadata and content without data transfer outside Google Cloud Storage. This process efficiently manages the required changes with minimal overhead.

Reference Link:<https://cloud.google.com/storage/docs/encryption/customer-managed-keys><https://cloud.google.com/storage/docs/using-customer-managed-encryption-keys><https://cloud.google.com/storage/docs/encryption/default-keys>

Question: 197

CertyIQ

You run applications on Cloud Run. You already enabled container analysis for vulnerability scanning. However, you are concerned about the lack of control on the applications that are deployed. You must ensure that only trusted container images are deployed on Cloud Run.

What should you do? (Choose two.)

- A.Enable Binary Authorization on the existing Cloud Run service.
- B.Set the organization policy constraint constraints/run.allowedBinaryAuthorizationPolicies to the list or allowed Binary Authorization policy names.
- C.Enable Binary Authorization on the existing Kubernetes cluster.
- D.Use Cloud Run breakglass to deploy an image that meets the Binary Authorization policy by default.
- E.Set the organization policy constraint constraints/compute.trustedImageProjects to the list of projects that contain the trusted container images.

Answer: AB

Explanation:

The question addresses securing Cloud Run deployments by ensuring only trusted container images are used. Option A, enabling Binary Authorization on the Cloud Run service, directly addresses this concern. Binary Authorization is a Google Cloud service that verifies container images before deployment, ensuring they meet predefined security policies. By enabling it on the Cloud Run service, you enforce checks before any new deployment is allowed. This aligns directly with the requirement to control which applications are deployed.

Option B, setting the organization policy constraint constraints/run.allowedBinaryAuthorizationPolicies, is necessary to specify which Binary Authorization policies are enforced on Cloud Run within your organization. Without this constraint, Binary Authorization wouldn't know which policies to apply, rendering it ineffective. You need to actively point to your defined policies for proper enforcement, therefore, this action is crucial for the solution to work.

Option C is incorrect. Although Binary Authorization can be used with Kubernetes, Cloud Run is a serverless platform and doesn't use the Kubernetes control plane, so Kubernetes configurations don't directly affect Cloud Run. Option D is incorrect because 'breakglass' is a temporary measure to bypass policies during emergencies, not a solution for standard policy enforcement. Option E, restricting trusted image projects, is helpful, but isn't the primary mechanism for verifying image content that Binary Authorization does. Binary Authorization verifies compliance with policies, while restricting projects only controls where the image is stored.

In summary, enabling Binary Authorization on Cloud Run (A) and configuring the associated organization policy to point to the desired Binary Authorization policy (B) work together to ensure only compliant container images are deployed on Cloud Run, meeting the stated requirements.

Authoritative Links:

Binary Authorization: <https://cloud.google.com/binary-authorization>

Cloud Run Binary Authorization: <https://cloud.google.com/run/docs/binary-authorization>

Organization Policies: <https://cloud.google.com/resource-manager/docs/organization-policy/overview>
constraints/run.allowedBinaryAuthorizationPolicies documentation: <https://cloud.google.com/resource-manager/docs/organization-policy/constraints/list-constraints#run.allowedBinaryAuthorizationPolicies>

Question: 198

CertyIQ

Your organization has on-premises hosts that need to access Google Cloud APIs. You must enforce private connectivity between these hosts, minimize costs, and optimize for operational efficiency.

What should you do?

- A. Set up VPC peering between the hosts on-premises and the VPC through the internet.
- B. Route all on-premises traffic to Google Cloud through an IPsec VPN tunnel to a VPC with Private Google Access enabled.
- C. Enforce a security policy that mandates all applications to encrypt data with a Cloud Key Management Service (KMS) key before you send it over the network.
- D. Route all on-premises traffic to Google Cloud through a dedicated or Partner Interconnect to a VPC with Private Google Access enabled.

Answer: B

Explanation:

The correct answer is **B. Route all on-premises traffic to Google Cloud through an IPsec VPN tunnel to a VPC with Private Google Access enabled.**

Here's why:

Private Connectivity: The requirement is for private connectivity, ruling out options that use the internet directly (like VPC peering via the internet as in A). Option B establishes a secure, encrypted connection over the public internet via IPsec VPN.

Cost Minimization: IPsec VPN is a more cost-effective option compared to dedicated interconnect (as in D). Dedicated Interconnect involves higher costs for physical connections and port fees.

Operational Efficiency: IPsec VPN is relatively easy to set up and manage. It doesn't involve the complexity of managing physical connections or dedicated infrastructure as required by Interconnect, providing operational efficiency.

Private Google Access: Enabling Private Google Access within the VPC allows on-premises hosts to reach Google Cloud APIs using internal IP addresses, further ensuring traffic does not traverse the public internet. This fulfills the private access requirement even with the VPN.

Why other options are incorrect: Option A doesn't fulfill private access. Option C addresses data encryption, but not the connectivity requirements. Option D is costlier and more operationally complex than a VPN, while not providing a significant benefit over a VPN in this particular scenario.

Therefore, using an IPsec VPN to a VPC with Private Google Access balances security, cost, and operational efficiency, fulfilling the problem's requirements.

Supporting Links:

Cloud VPN: <https://cloud.google.com/vpn/docs>

Private Google Access: <https://cloud.google.com/vpc/docs/private-google-access>

Choosing a connectivity option: <https://cloud.google.com/network-connectivity/docs/choose-connectivity>

Question: 199

CertyIQ

As part of your organization's zero trust strategy, you use Identity-Aware Proxy (IAP) to protect multiple applications. You need to ingest logs into a Security Information and Event Management (SIEM) system so that you are alerted to possible intrusions.

Which logs should you analyze?

- A.Data Access audit logs
- B.Policy Denied audit logs
- C.Cloud Identity user log events
- D.Admin Activity audit logs

Answer: A

Explanation:

The correct answer is **A. Data Access audit logs**. Here's a detailed justification:

IAP, as part of a zero-trust strategy, controls access to applications by verifying the user's identity and context. To detect intrusions, analyzing logs showing who accessed what data is crucial. Data Access audit logs specifically track read or write operations to Google Cloud resources, including applications protected by IAP. These logs provide detailed information on user actions, accessed resources, and timestamps, allowing for analysis of potential unauthorized data access patterns. Analyzing these patterns is essential for intrusion detection. Policy Denied logs (B) only show when access was explicitly blocked by a policy, not successful access attempts which can be malicious. Cloud Identity user log events (C) relate to user management, not data access through IAP. Admin Activity audit logs (D) capture administrative actions, which are less relevant for detecting intrusions targeting specific applications protected by IAP. Therefore, Data Access audit logs are the most appropriate to identify potential intrusions through IAP by providing details of successful data access events that might reveal malicious activity. By ingesting and analyzing these logs, security teams can identify anomalous access patterns and trigger alerts, effectively supporting the organization's zero-trust approach.

Supporting Concepts:

Zero Trust Security: Assumes no implicit trust, requiring authentication and authorization for every access request, which aligns with IAP functionality.

Data Access Audit Logs: Provide insights into user interactions with data, crucial for security monitoring and incident response.

SIEM: Centralizes security logs from various sources, facilitating comprehensive threat analysis.

Authoritative Links:

Google Cloud Logging: <https://cloud.google.com/logging/docs>

Audit Logging in Google Cloud: <https://cloud.google.com/logging/docs/audit/>

Identity-Aware Proxy Logging: <https://cloud.google.com/iap/docs/logs>

Question: 200

CertyIQ

Your company must follow industry specific regulations. Therefore, you need to enforce customer-managed encryption keys (CMEK) for all new Cloud Storage resources in the organization called org1.

What command should you execute?

A. organization policy: constraints/gcp.restrictStorageNonCmekServices

- binding at: org1

- policy type: allow

- policy value: all supported services

B. organization policy: constraints/gcp.restrictNonCmekServices

- binding at: org1

- policy type: deny

- policy value: storage.googleapis.com

C. organization policy: constraints/gcp.restrictStorageNonCmekServices

- binding at: org1

- policy type: deny

- policy value: storage.googleapis.com

D. organization policy: constraints/gcp.restrictNonCmekServices

- binding at: org1

- policy type: allow

- policy value: storage.googleapis.com

Answer: B

Explanation:

The correct answer is **B**. To enforce Customer-Managed Encryption Keys (CMEK) for all new Cloud Storage resources within an organization, you need to utilize an organization policy that restricts the creation of resources without CMEK enabled. Option B correctly identifies the constraint, binding location, action, and value to achieve this.

The key constraint `constraints/gcp.restrictNonCmekServices` is designed specifically to prevent resources from being created without CMEK. This constraint is applied at the organizational level `org1` to impact all projects and resources under this hierarchy. By setting the policy type to `deny`, any attempt to create a Cloud Storage resource without specifying a CMEK will be blocked. The policy value `storage.googleapis.com` indicates that this restriction applies to Cloud Storage services.

Option A is incorrect because the constraint `gcp.restrictStorageNonCmekServices` (with "Storage" before "NonCmek") is not the correct constraint for achieving this goal. Also, it incorrectly attempts to "allow" resources with non-CMEK, which is the opposite of what is desired. Option C uses the correct constraint and location, but incorrectly attempts to 'deny' `storage.googleapis.com`. Option D is also incorrect because it sets the policy type to `allow`, meaning it would allow non-CMEK usage rather than restrict it, in addition to using the wrong constraint.

Organization policies are a core mechanism in Google Cloud for managing governance and compliance, allowing centralized control over resource behavior. By combining the correct constraint, deny action, and targeted service in the organization policy, we effectively force CMEK usage, thereby ensuring regulatory compliance for all new Cloud Storage resources.

Authoritative Links:

Google Cloud Organization Policy Service: <https://cloud.google.com/resource-manager/docs/organization-policy/overview>

Google Cloud Organization Policy Constraints: <https://cloud.google.com/resource-manager/docs/organization-policy/org-policy-constraints>

constraints/gcp.restrictNonCmekServices: https://cloud.google.com/resource-manager/docs/organization-policy/constraints-list#constraint_gcp.restrictnoncmekservices

Question: 201

Your company's Google Cloud organization has about 200 projects and 1,500 virtual machines. There is no uniform

strategy for logs and events management, which reduces visibility for your security operations team. You need to design a logs management solution that provides visibility and allows the security team to view the environment's configuration.

What should you do?

- A.1. Create a dedicated log sink for each project that is in scope.
- 2. Use a BigQuery dataset with time partitioning enabled as a destination of the log sinks.
- 3. Deploy alerts based on log metrics in every project.
- 4. Grant the role "Monitoring Viewer" to the security operations team in each project.
- B.1. Create one log sink at the organization level that includes all the child resources.
- 2. Use as destination a Pub/Sub topic to ingest the logs into the security information and event management (SIEM) on-premises, and ensure that the right team can access the SIEM.
- 3. Grant the Viewer role at organization level to the security operations team.
- C.1. Enable network logs and data access logs for all resources in the "Production" folder.
- 2. Do not create log sinks to avoid unnecessary costs and latency.
- 3. Grant the roles "Logs Viewer" and "Browser" at project level to the security operations team.
- D.1. Create one sink for the "Production" folder that includes child resources and one sink for the logs ingested at the organization level that excludes child resources.
- 2. As destination, use a log bucket with a minimum retention period of 90 days in a project that can be accessed by the security team.
- 3. Grant the security operations team the role of Security Reviewer at organization level.

Answer: B

Explanation:

Option B is the most suitable solution because it addresses the need for centralized log management and security team visibility across a large Google Cloud organization. Creating a single organization-level log sink (step 1) ensures that all logs from all child resources are captured, providing comprehensive visibility. This approach avoids the administrative overhead of managing individual project-level sinks as suggested in Option A. Using a Pub/Sub topic (step 2) as the destination facilitates real-time log streaming to an on-premises SIEM, which is a common practice for security monitoring. This allows the security team to use their existing tools and workflows without significant changes. Granting the Viewer role at the organization level (step 3) allows the security team to monitor and analyze logs across the entire organization with a single point of access. Option A is less efficient because it requires managing multiple sinks and applying roles in every project, leading to increased management overhead. Option C doesn't centralize logs, relies on manual configuration, and avoids cost reduction, failing the visibility requirement. Option D introduces unnecessary complexity with folder-level and organization-level sinks when a single organization sink can capture all required logs. It also grants security roles which are broader than the need for log visibility. Option B provides a cost effective, centralized, and scalable solution, ideal for 200+ projects and 1500+ virtual machines.

Relevant Concepts:

Organization-Level Logging: Centralizing logs at the organization level is a best practice for comprehensive visibility and security monitoring.

Cloud Logging Sinks: Log sinks are used to export logs to different destinations.

Pub/Sub: A fully managed messaging service that is suitable for streaming logs.

Security Information and Event Management (SIEM): Tools used for security monitoring and analysis.

Least Privilege Principle: Granting only the necessary permissions to users and services.

Authoritative Links:

Cloud Logging Overview: <https://cloud.google.com/logging/docs/overview>

Routing and Storage Overview: <https://cloud.google.com/logging/docs/routing/overview>

Pub/Sub Overview: <https://cloud.google.com/pubsub/docs/overview>

IAM roles for Logging: <https://cloud.google.com/logging/docs/access-control>

Question: 202

Your Google Cloud organization allows for administrative capabilities to be distributed to each team through provision of a Google Cloud project with Owner role (roles/owner). The organization contains thousands of Google Cloud projects. Security Command Center Premium has surfaced multiple OPEN_MYSQL_PORT findings. You are enforcing the guardrails and need to prevent these types of common misconfigurations.

What should you do?

- A. Create a hierarchical firewall policy configured at the organization to deny all connections from 0.0.0.0/0.
- B. Create a hierarchical firewall policy configured at the organization to allow connections only from internal IP ranges.
- C. Create a Google Cloud Armor security policy to deny traffic from 0.0.0.0/0.
- D. Create a firewall rule for each virtual private cloud (VPC) to deny traffic from 0.0.0.0/0 with priority 0.

Answer: B

Explanation:

The correct answer is **B. Create a hierarchical firewall policy configured at the organization to allow connections only from internal IP ranges.**

Here's why:

Hierarchical Firewall Policies: These policies, applied at the organization level, enforce consistent firewall rules across all projects within the organization. This aligns with the requirement to enforce guardrails and prevent common misconfigurations like open MySQL ports across thousands of projects. Individual project owners cannot override these organization-level policies unless explicitly allowed through delegation.

Least Privilege: Allowing connections only from internal IP ranges adheres to the principle of least privilege. It limits access to the MySQL ports to internal networks, preventing unauthorized external access, which is the root cause of the OPEN_MYSQL_PORT finding.

Prevention of Misconfigurations: By explicitly allowing traffic from internal IPs and implicitly blocking everything else, you prevent accidental exposure of database ports to the internet, addressing the security concern. This reduces the burden on individual teams to correctly secure each project's resources.

Scalability: Given the thousands of projects, managing firewall rules individually (option D) is impractical. Hierarchical policies provide a scalable solution for consistent security enforcement.

Options A, C, and D: Option A (denying all connections) would break legitimate internal access, hindering application functionality. Option C involves Google Cloud Armor, which primarily protects web applications, not internal database ports. Option D requires managing and implementing rules across a large number of VPCs, making it cumbersome and prone to inconsistency.

In summary, option B provides a centrally manageable, scalable, and least-privilege-based approach to enforce consistent firewall rules across all projects, resolving the OPEN_MYSQL_PORT findings and preventing future occurrences.

Authoritative Links:

Hierarchical Firewall Policies: <https://cloud.google.com/vpc/docs/firewall-policies>

Network Firewall Rules: <https://cloud.google.com/vpc/docs/firewalls>

Principle of Least Privilege: https://en.wikipedia.org/wiki/Principle_of_least_privilege

Question: 203

Your organization must comply with the regulation to keep instance logging data within Europe. Your workloads

will be hosted in the Netherlands in region europe-west4 in a new project. You must configure Cloud Logging to keep your data in the country.

What should you do?

- A. Configure the organization policy constraint `gcp.resourceLocations` to europe-west4.
- B. Configure log sink to export all logs into a Cloud Storage bucket in europe-west4.
- C. Create a new log bucket in europe-west4, and redirect the `_Default` bucket to the new bucket.
- D. Set the logging storage region to europe-west4 by using the `gcloud` CLI logging settings update.

Answer: D

Explanation:

The correct answer is **D. Set the logging storage region to europe-west4 by using the `gcloud` CLI logging settings update.**

Here's why:

Cloud Logging, by default, stores logs in a global location, which isn't suitable for compliance requirements like data residency within Europe. To ensure logs are kept within the Netherlands (europe-west4), you must explicitly configure the storage location. Option D directly addresses this requirement. The `gcloud` CLI logging settings update command allows you to specify the logging storage location for a project, ensuring all future logs are stored within the designated region (europe-west4).

Option A, restricting resource locations with `gcp.resourceLocations`, limits where resources like VMs can be created but doesn't control where logs are stored. Option B, creating a log sink, exports logs to a separate storage location but still relies on the default Cloud Logging storage location initially. This doesn't guarantee the logs aren't initially processed or temporarily stored outside europe-west4. Option C, redirecting the `_Default` bucket, isn't the standard approach for regionalization; you should directly configure the logging settings.

Therefore, only Option D provides the precise mechanism to ensure the Cloud Logging service itself stores log data within the compliance-required location, europe-west4. The `gcloud` command directly instructs Cloud Logging to respect data residency requirements.

Further research:

Cloud Logging documentation on data residency: <https://cloud.google.com/logging/docs/region-considerations>

`gcloud` logging settings update command:

<https://cloud.google.com/sdk/gcloud/reference/logging/settings/update>

Cloud Logging overview: <https://cloud.google.com/logging/docs/overview>

Question: 204

CertyIQ

You are using Security Command Center (SCC) to protect your workloads and receive alerts for suspected security breaches at your company. You need to detect cryptocurrency mining software.

Which SCC service should you use?

- A. Virtual Machine Threat Detection
- B. Container Threat Detection
- C. Rapid Vulnerability Detection
- D. Web Security Scanner

Answer: A

Explanation:

The correct answer is **A. Virtual Machine Threat Detection**. Here's why:

Virtual Machine Threat Detection, a core service within Security Command Center (SCC), is specifically designed to identify malicious activities and suspicious processes running within your Google Cloud Compute Engine instances. Cryptocurrency mining software often operates as a hidden process consuming significant CPU and network resources, making it a prime target for VM Threat Detection. This service analyzes runtime behavior within VMs, utilizing threat intelligence feeds and machine learning to detect known malware signatures and anomalous activities indicative of cryptojacking.

Container Threat Detection (B) focuses on containerized environments like GKE and is not the most appropriate choice for detection on individual VM instances. While container mining is a real threat, this question specifically asks about detecting it within a general workload setup, which implies a wider scope than just containers. Rapid Vulnerability Detection (C) is geared towards identifying software vulnerabilities, not active malicious behavior like mining. Web Security Scanner (D) focuses on identifying vulnerabilities in web applications, which is not relevant to detecting cryptocurrency mining software running on servers. Therefore, Virtual Machine Threat Detection is the best fit to identify cryptocurrency mining software running on Compute Engine instances, making it the most effective service in this scenario.

Further Research:

Google Cloud Security Command Center Overview: <https://cloud.google.com/security-command-center>

Virtual Machine Threat Detection Documentation: <https://cloud.google.com/security-command-center/docs/concepts-vm-threat-detection>

Cryptojacking and Cloud Security: <https://www.trendmicro.com/vinfo/us/security/definition/cryptojacking>

Question: 205

CertyIQ

You are running applications outside Google Cloud that need access to Google Cloud resources. You are using workload identity federation to grant external identities Identity and Access Management (IAM) roles to eliminate the maintenance and security burden associated with service account keys. You must protect against attempts to spoof another user's identity and gain unauthorized access to Google Cloud resources.

What should you do? (Choose two.)

- A.Enable data access logs for IAM APIs.
- B.Limit the number of external identities that can impersonate a service account.
- C.Use a dedicated project to manage workload identity pools and providers.
- D.Use immutable attributes in attribute mappings.
- E.Limit the resources that a service account can access.

Answer: CD

Explanation:

Here's a breakdown of why options C and D are the correct choices for securing workload identity federation, while A, B, and E are not the most appropriate:

Option C: Use a dedicated project to manage workload identity pools and providers.

Reason: A dedicated project provides strong isolation and organizational separation for managing workload identity federation. By centralizing the management of pools and providers within a specific project, you limit

the blast radius if a compromise occurs. This also enables clearer IAM policies that govern who can manage external identities accessing Google Cloud. It promotes least privilege by restricting access to these critical configurations.

Concept: This aligns with the principle of segregation of duties and least privilege, both foundational for robust security practices. It prevents the potential spread of damage across multiple unrelated systems within your cloud organization.

Link: <https://cloud.google.com/iam/docs/workload-identity-federation> (Specifically, consider the recommendations around organization structure.)

Option D: Use immutable attributes in attribute mappings.

Reason: Immutable attributes in attribute mappings are essential for preventing spoofing attacks. When mapping external identity attributes (like subject or user ID) to Google Cloud identities, using immutable attributes ensures that malicious actors cannot alter or manipulate these identity attributes to impersonate legitimate users. If the attributes are dynamic or modifiable, it creates a window for abuse.

Concept: This leverages the principle of identity verification. By relying on attributes that cannot be changed by the external identity provider or an attacker, the mappings are more trustworthy and secure.

Link: https://cloud.google.com/iam/docs/workload-identity-federation#configuring_a_pool (Focus on attribute mapping and the importance of immutable attributes.)

Why other options are not the most appropriate:

Option A: Enable data access logs for IAM APIs. While logging is a good practice, it is primarily for audit and detection after an issue occurs. It doesn't actively prevent spoofing attempts during federation. Therefore, it is not as effective as C and D for this specific scenario.

Option B: Limit the number of external identities that can impersonate a service account. While this is a good security practice, it doesn't directly address the issue of spoofing within the scope of a given trusted external identity. This controls quantity rather than preventing identity manipulation.

Option E: Limit the resources that a service account can access. This is best practice, but it addresses permissions after a user is federated. This doesn't actively safeguard the federation process itself from identity spoofing. It helps limit the damage once access is granted, not control how access is initially established.

In summary, the best way to prevent identity spoofing in workload identity federation is to use a dedicated project to manage the federation process (isolation and control) and ensure that immutable attributes are used during attribute mapping (trustworthy authentication).

Question: 206

CertyIQ

You manage a BigQuery analytical data warehouse in your organization. You want to keep data for all your customers in a common table while you also restrict query access based on rows and columns permissions. Non-query operations should not be supported.

What should you do? (Choose two.)

- A. Create row-level access policies to restrict the result data when you run queries with the filter expression set to TRUE.
- B. Configure column-level encryption by using Authenticated Encryption with Associated Data (AEAD) functions with Cloud Key Management Service (KMS) to control access to columns at query runtime.
- C. Create row-level access policies to restrict the result data when you run queries with the filter expression set to FALSE.
- D. Configure dynamic data masking rules to control access to columns at query runtime.
- E. Create column-level policy tags to control access to columns at query runtime.

Answer: CE

Explanation:

Okay, let's break down why options C and E are the correct choices for securing a BigQuery data warehouse with row and column access restrictions, focusing on query-only access and excluding non-query operations.

Option C: Create row-level access policies to restrict the result data when you run queries with the filter expression set to FALSE.

This option is incorrect. When creating a row access policy, the filter expression determines which rows are visible. Setting the expression to FALSE effectively blocks all rows from being returned. It should be a condition related to the user context or attributes (such as user ID, group membership) to grant access based on a filter.

Option E: Create column-level policy tags to control access to columns at query runtime. This is correct. Policy tags, also known as Data Catalog policy tags, enable fine-grained column-level access control within BigQuery. By associating policy tags with columns and granting permissions on those tags, you can ensure users only see data in columns they are authorized to access. <https://cloud.google.com/bigquery/docs/column-policy-tags>

Option A: Create row-level access policies to restrict the result data when you run queries with the filter expression set to TRUE. Setting the expression to TRUE allows access to all rows. It does not provide any restriction. This option is incorrect.

Option B: Configure column-level encryption by using Authenticated Encryption with Associated Data (AEAD) functions with Cloud Key Management Service (KMS) to control access to columns at query runtime.

While AEAD functions with Cloud KMS offer a method of encryption in BigQuery, they don't directly translate to column-level access control at query runtime in the way policy tags do. Encrypting columns prevents unauthorized reading of the underlying data at rest or during export, but for query time control, you still need an appropriate access control. AEAD functions focus on data encryption, not direct access policy enforcement within BigQuery. <https://cloud.google.com/bigquery/docs/encryption-keys>

Option D: Configure dynamic data masking rules to control access to columns at query runtime.

Dynamic data masking is a great feature to partially hide data at query time, such as redacting sensitive information like email addresses. It doesn't provide the means to block an entire column from being visible in the result. It's used for data protection rather than access control which is needed here.

Summary of Why C and E are Correct (with C corrected) The most effective approach to restrict access on the common table and limit it to queries is using row level policies with a dynamic filter based on a user context and using column level access policies by utilizing policy tags. Row access policies using proper filtering criteria restrict visibility to rows that the user is authorized to see, while column policy tags enforce which columns are accessible in the results. These features ensure both row and column access restrictions are in place at query runtime with support for no non-query operations, as required by the scenario.

Question: 207

CertyIQ

Your DevOps team uses Packer to build Compute Engine images by using this process:

1. Create an ephemeral Compute Engine VM.
2. Copy a binary from a Cloud Storage bucket to the VM's file system.
3. Update the VM's package manager.
4. Install external packages from the internet onto the VM.

Your security team just enabled the organizational policy, constraints/ compute.vmExternallpAccess, to restrict the usage of public IP Addresses on VMs. In response, your DevOps team updated their scripts to remove public IP addresses on the Compute Engine VMs; however, the build pipeline is failing due to connectivity issues.

What should you do? (Choose two.)

- A.Provision an HTTP load balancer with the VM in an unmanaged instance group to allow inbound connections from the internet to your VM.
- B.Provision a Cloud NAT instance in the same VPC and region as the Compute Engine VM.
- C.Enable Private Google Access on the subnet that the Compute Engine VM is deployed within.
- D.Update the VPC routes to allow traffic to and from the internet.
- E.Provision a Cloud VPN tunnel in the same VPC and region as the Compute Engine VM.

Answer: BC

Explanation:

The scenario describes a Packer-based image building process that requires internet access for a temporary Compute Engine VM. The organization's security policy has disabled public IP addresses on VMs, breaking the build pipeline because the VM can no longer reach the internet to download packages.

Option B, **Provision a Cloud NAT instance in the same VPC and region as the Compute Engine VM**, is correct. Cloud NAT enables VMs without public IPs to initiate outbound connections to the internet through a managed NAT gateway. This allows the Packer VM to download packages and dependencies while adhering to the security policy. <https://cloud.google.com/nat/docs/overview>

Option C, **Enable Private Google Access on the subnet that the Compute Engine VM is deployed within**, is also correct. Private Google Access allows VMs without external IP addresses to access Google APIs and services, such as Cloud Storage, via Google's private network. This is necessary because the script copies a binary from Cloud Storage, and without public IP it cannot reach the Cloud Storage unless this option is enabled. <https://cloud.google.com/vpc/docs/configure-private-google-access>

Option A, provisioning an HTTP load balancer, is incorrect. Load balancers are designed for distributing traffic to multiple instances for service availability and scalability and are meant for incoming traffic. The Packer VM is making outgoing requests.

Option D, updating VPC routes to allow traffic to/from the internet, is incorrect, since the security policy prevents public IP addresses being assigned. To send traffic directly to the internet would mean to either have a public IP assigned, or have routes to the internet gateway, which would still require a public IP.

Option E, provisioning a Cloud VPN tunnel, is incorrect. VPNs establish private connections between networks, typically for connecting on-prem networks to GCP, which is not the use case. This is an overkill and not a solution for allowing a GCP VM without an external IP address to access the internet.

Therefore, Cloud NAT (B) handles the required outbound internet access for downloading packages and Private Google Access (C) grants access to other Google Cloud Services needed by the script, making B and C the appropriate choices to restore the build process without compromising security policies.

Question: 208

CertyIQ

Your organization recently activated the Security Command Center (SCC) standard tier. There are a few Cloud Storage buckets that were accidentally made accessible to the public. You need to investigate the impact of the incident and remediate it.

What should you do?

- A.1. Remove the Identity and Access Management (IAM) granting access to all Users from the buckets.
- 2. Apply the organization policy `storage.uniformBucketLevelAccess` to prevent regressions.
- 3. Query the data access logs to report on unauthorized access.
- B.1. Change permissions to limit access for authorized users.
- 2. Enforce a VPC Service Controls perimeter around all the production projects to immediately stop any unauthorized access.
- 3. Review the administrator activity audit logs to report on any unauthorized access.
- C.1. Change the bucket permissions to limit access.
- 2. Query the bucket's usage logs to report on unauthorized access to the data.
- 3. Enforce the organization policy `storage.publicAccessPrevention` to avoid regressions.
- D.1. Change bucket permissions to limit access.
- 2. Query the data access audit logs for any unauthorized access to the buckets.
- 3. After the misconfiguration is corrected, mute the finding in the Security Command Center.

Answer: C

Explanation:

Okay, let's break down why option C is the correct approach for addressing publicly accessible Cloud Storage buckets, within the context of Security Command Center (SCC) and incident response.

Option C is the most direct and efficient approach to address the immediate problem and prevent future occurrences. First, changing bucket permissions to limit access is the primary step in remediating the vulnerability. This action directly restricts public access, closing the security gap. Second, querying the bucket's usage logs allows for an audit trail of who accessed what. This helps understand the extent of the impact. These usage logs are distinct from data access logs, as they track access to bucket metadata, not just data itself. Finally, enforcing the `storage.publicAccessPrevention` organization policy ensures that such misconfigurations cannot occur again at the organization level. This proactive control provides a long-term solution to prevent similar future incidents.

Option A incorrectly suggests focusing on IAM grants, while bucket-level permissions are the root cause here. It also uses data access logs which track data access, while usage logs are more suited to track access to the bucket itself. Option B is an overkill response, and applying VPC Service Controls is unnecessary for this incident; also, reviewing administrator activity logs will not provide a direct view of unauthorized access to bucket data. Finally, option D does not mention the `publicAccessPrevention` organization policy, and it also does not correctly use the appropriate logs for auditing.

Therefore, Option C is the only option that directly addresses the immediate issue, investigates its impact, and prevents recurrence, making it the ideal response.

Authoritative Links:

Cloud Storage Access Control: <https://cloud.google.com/storage/docs/access-control>

Cloud Storage Usage Logs: <https://cloud.google.com/storage/docs/audit-logging>

Organization Policy `storage.publicAccessPrevention`: <https://cloud.google.com/resource-manager/docs/organization-policy/org-policy-constraints#storage-constraints>

Security Command Center: <https://cloud.google.com/security-command-center/docs>

Cloud Storage Audit Logging: <https://cloud.google.com/storage/docs/audit-logging>

Question: 209

CertyIQ

Your organization is transitioning to Google Cloud. You want to ensure that only trusted container images are deployed on Google Kubernetes Engine (GKE) clusters in a project. The containers must be deployed from a centrally managed Container Registry and signed by a trusted authority.

What should you do? (Choose two.)

- A.Enable Container Threat Detection in the Security Command Center (SCC) for the project.
- B.Configure the trusted image organization policy constraint for the project.
- C.Create a custom organization policy constraint to enforce Binary Authorization for Google Kubernetes Engine (GKE).
- D.Enable PodSecurity standards, and set them to Restricted.
- E.Configure the Binary Authorization policy with respective attestations for the project.

Answer: BE

Explanation:

Let's break down why options B and E are the correct choices for securing container deployments on GKE with trusted, signed images.

Option B, "Configure the trusted image organization policy constraint for the project," is crucial. This constraint, often referred to as `constraints/container.trustedImageProjects`, allows you to specify which container registries (projects) are permitted sources for images deployed within your Google Cloud project. By explicitly listing your centrally managed Container Registry project, you restrict deployments to only images hosted there, preventing unauthorized or malicious images from being deployed. This aligns directly with the requirement for centralized image management.

Option E, "Configure the Binary Authorization policy with respective attestations for the project," is the second essential step. Binary Authorization provides a mechanism to ensure that only containers that have been verified and signed by a trusted authority are allowed to run. Attestations, cryptographic signatures tied to specific image digests, prove that an image has passed your organization's validation process. By configuring a policy that requires these attestations, you enforce the requirement for signed images. Together, these two measures – limiting the source registry and requiring image signatures – form a strong defense against unauthorized container deployments.

Option A, "Enable Container Threat Detection in the Security Command Center (SCC)," is valuable for runtime security by detecting potential malicious activities inside containers, but it doesn't address the initial deployment of trusted images. It's a reactive rather than a proactive control. Option C, "Create a custom organization policy constraint to enforce Binary Authorization for Google Kubernetes Engine (GKE)," is redundant; Binary Authorization is already available and doesn't need a custom constraint. Option D, "Enable PodSecurity standards, and set them to Restricted," increases the overall security posture by limiting pod capabilities, but it doesn't focus specifically on trusted image verification.

Therefore, combining the trusted image organization policy constraint (B) to define permitted image sources, with Binary Authorization and its attestations (E) to enforce signing requirements is the direct, most effective solution to ensure only trusted, signed images are deployed on GKE clusters.

Relevant Links:

Organization Policy Constraints: <https://cloud.google.com/resource-manager/docs/organization-policy/org-policy-constraints>

Binary Authorization: <https://cloud.google.com/binary-authorization/docs>

Container Registry: <https://cloud.google.com/container-registry/docs>

Question: 210

CertyIQ

Your company uses Google Cloud and has publicly exposed network assets. You want to discover the assets and perform a security audit on these assets by using a software tool in the least amount of time.

What should you do?

- A.Run a platform security scanner on all instances in the organization.
- B.Identify all external assets by using Cloud Asset Inventory, and then run a network security scanner against them.
- C.Contact a Google approved security vendor to perform the audit.
- D.Notify Google about the pending audit, and wait for confirmation before performing the scan.

Answer: B

Explanation:

The correct answer is B, identifying external assets with Cloud Asset Inventory and then scanning them. This approach is the most efficient and targeted method for discovering and auditing publicly exposed network assets. Here's a breakdown:

Cloud Asset Inventory: This service is designed to provide a comprehensive view of all cloud resources within your organization. It allows you to quickly identify external-facing assets based on specific attributes, such as public IP addresses. This eliminates the need to manually enumerate your infrastructure.

<https://cloud.google.com/asset-inventory/docs/overview>

Targeted Scanning: Once you have identified the relevant external assets, you can then run a network security scanner against them. This focused approach saves time and resources by avoiding unnecessary scans of internal resources or non-publicly accessible components. This precision reduces both scan time and potential noise.

Efficiency: Running a platform scanner on all instances (Option A) would be inefficient and time-consuming, as it would scan resources that are not externally facing and may be beyond the audit's scope. Option C, contacting a vendor, introduces an external dependency and could increase turnaround time. Notifying Google before auditing (Option D) is not required and will add delays.

Security Best Practices: Identifying external assets first aligns with security best practices of focusing on the attack surface. Scanning the entire platform is resource-heavy, whereas focusing on only exposed assets provides actionable security intelligence.

Therefore, using Cloud Asset Inventory to discover external assets and then performing targeted network security scans provides the fastest and most effective path to auditing public-facing infrastructure. This method is more efficient and aligns better with a focused, security-first approach.

Question: 211

CertyIQ

Your organization wants to be compliant with the General Data Protection Regulation (GDPR) on Google Cloud. You must implement data residency and operational sovereignty in the EU.

What should you do? (Choose two.)

- A.Limit the physical location of a new resource with the Organization Policy Service "resource locations constraint."
- B.Use Cloud IDS to get east-west and north-south traffic visibility in the EU to monitor intra-VPC and inter-VPC communication.
- C.Limit Google personnel access based on predefined attributes such as their citizenship or geographic location by using Key Access Justifications.
- D.Use identity federation to limit access to Google Cloud resources from non-EU entities.
- E.Use VPC Flow Logs to monitor intra-VPC and inter-VPC traffic in the EU.

Answer: AC

Explanation:

The correct choices for achieving GDPR compliance with data residency and operational sovereignty in the EU are **A** and **C**.

Option A, using the Organization Policy Service's "resource locations constraint," directly addresses data residency requirements. This constraint allows you to restrict the physical location where new Google Cloud resources can be created, ensuring that data remains within the EU's geographical boundaries. This is a core tenet of GDPR, mandating that personal data of EU citizens be processed within the EU.

Option C, employing Key Access Justifications, enables operational sovereignty by providing control over Google personnel's access to customer data. By limiting access based on predefined attributes like citizenship or location, you can restrict access only to authorized EU-based personnel. This further ensures that data is handled by individuals under the jurisdiction and legal framework of the EU, enhancing control over data processing.

Option B, using Cloud IDS, and Option E, using VPC Flow Logs, while useful for security and monitoring, do not directly address the core GDPR requirements of data residency and operational sovereignty. They offer visibility into traffic but don't enforce physical location or limit access based on personnel attributes. Option D, while aiming to restrict access, does not use a mechanism as robust for the scope of personnel access and also doesn't address data residency.

Therefore, options A and C are the most suitable choices to satisfy the data residency and operational sovereignty requirements stipulated under GDPR when using Google Cloud.

Authoritative Links:

Google Cloud Organization Policy Service: <https://cloud.google.com/resource-manager/docs/organization-policy/overview>

Google Cloud Resource Locations Constraint: <https://cloud.google.com/resource-manager/docs/organization-policy/defining-locations>

Google Cloud Key Access Justifications: <https://cloud.google.com/security/key-access-justifications>

General Data Protection Regulation (GDPR): <https://gdpr-info.eu/>

Question: 212

CertyIQ

Your company is moving to Google Cloud. You plan to sync your users first by using Google Cloud Directory Sync (GCDS). Some employees have already created Google Cloud accounts by using their company email addresses that were created outside of GCDS. You must create your users on Cloud Identity.

What should you do?

- A. Configure GCDS and use GCDS search rules to sync these users.
- B. Use the transfer tool to migrate unmanaged users.
- C. Write a custom script to identify existing Google Cloud users and call the Admin SDK: Directory API to transfer their account.
- D. Configure GCDS and use GCDS exclusion rules to ensure users are not suspended.

Answer: B

Explanation:

The correct answer is **B. Use the transfer tool to migrate unmanaged users**. Here's why:

The scenario describes a situation where some employees have already created Google Cloud accounts using their company email addresses before the organization implemented Cloud Identity via Google Cloud

Directory Sync (GCDS). These users are considered "unmanaged" because they exist outside the organization's controlled Cloud Identity environment.

GCDS is designed to synchronize user data from an existing directory (like Active Directory) to Cloud Identity. However, it's not primarily intended for directly managing or migrating pre-existing unmanaged accounts. Attempting to synchronize these users through GCDS (option A) would likely result in conflicts or creation of duplicate accounts. Using exclusion rules (option D) wouldn't resolve the issue of migrating the accounts. Writing a custom script (option C), while technically possible, adds unnecessary complexity and overhead when a dedicated tool exists.

Google provides a specific tool for addressing this exact scenario: the **User Data Migration Service** or, more commonly, the **Transfer Tool**. This tool is designed to identify unmanaged users (those using company email addresses within Google accounts) and migrate them into the organization's Cloud Identity domain. It transfers the account's data (e.g., Drive files, emails) to the newly managed account.

Therefore, using the transfer tool is the most efficient, secure, and supported method for bringing these existing users under the organization's control within Cloud Identity. This process ensures the users retain their data while being managed by the company's Cloud Identity policies and security settings. This allows the organization to gain central management and maintain consistency across the environment.

For further information on using the transfer tool, refer to the following Google documentation:

[Transfer unmanaged users' accounts](#)
[About the User Data Migration Service](#)

Question: 213

CertyIQ

Your organization is using GitHub Actions as a continuous integration and delivery (CI/CD) platform. You must enable access to Google Cloud resources from the CI/CD pipelines in the most secure way.

What should you do?

- A. Create a service account key, and add it to the GitHub pipeline configuration file.
- B. Create a service account key, and add it to the GitHub repository content.
- C. Configure a Google Kubernetes Engine cluster that uses Workload Identity to supply credentials to GitHub.
- D. Configure workload identity federation to use GitHub as an identity pool provider.

Answer: D

Explanation:

The most secure approach to granting GitHub Actions access to Google Cloud resources is through Workload Identity Federation (WIF). WIF eliminates the need to store long-lived service account keys, which are a security risk if compromised. Option D directly addresses this by configuring WIF to treat GitHub as an identity provider. This allows GitHub Actions workflows to obtain short-lived Google Cloud credentials by exchanging GitHub-issued tokens, enhancing security. Option A and B propose using service account keys, which is highly discouraged due to the exposure risk if the key is leaked in the pipeline or repository. Option C suggests using Workload Identity on GKE but is irrelevant in this scenario as the CI/CD pipelines run in GitHub Actions, not within GKE. WIF allows external workload identities, such as GitHub Actions, to act as service accounts without needing a key, significantly improving the security posture. By utilizing workload identity federation, the need for static secrets and credentials is removed by employing short-lived credentials. Therefore, option D is the most secure and recommended practice for this scenario.

Further Reading:

Workload Identity Federation: <https://cloud.google.com/iam/docs/workload-identity-federation>

Securing GitHub Actions with WIF: <https://cloud.google.com/blog/products/identity-security/secure-github-actions-with-workload-identity-federation>

IAM Best Practices: <https://cloud.google.com/iam/docs/best-practices>

Question: 214

CertyIQ

Your organization processes sensitive health information. You want to ensure that data is encrypted while in use by the virtual machines (VMs). You must create a policy that is enforced across the entire organization.

What should you do?

- A. Implement an organization policy that ensures that all VM resources created across your organization use customer-managed encryption keys (CMEK) protection.
- B. Implement an organization policy that ensures all VM resources created across your organization are Confidential VM instances.
- C. Implement an organization policy that ensures that all VM resources created across your organization use Cloud External Key Manager (EKM) protection.
- D. No action is necessary because Google encrypts data while it is in use by default.

Answer: B

Explanation:

The correct answer is **B. Implement an organization policy that ensures all VM resources created across your organization are Confidential VM instances.**

Here's why:

The question specifically requires encryption while in use by the virtual machines. Traditional encryption methods, like CMEK or EKM (options A and C), focus on encrypting data at rest and in transit, not during processing within the VM's memory.

Confidential VMs, on the other hand, leverage hardware-based encryption using AMD SEV or Intel TDX technology. This mechanism encrypts the VM's memory, meaning data remains protected even when it's being actively processed by the CPU. This fulfills the core requirement of the scenario.

Option D is incorrect because while Google encrypts data at rest and in transit, it does not inherently encrypt data while in use by default for standard VMs.

An organization policy provides a centralized mechanism to enforce this requirement across the entire organization, ensuring that all newly created VMs are configured as Confidential VMs. By implementing this policy, the organization can maintain compliance with the requirement to protect sensitive health information while it is in use. This approach provides the strongest protection against attacks that attempt to steal data from the VM's memory.

Authoritative Links for Further Research:

Google Cloud Confidential Computing: <https://cloud.google.com/security/confidential-computing>

Confidential VM Documentation: <https://cloud.google.com/compute/confidential-vm/docs>

Organization Policies in Google Cloud: <https://cloud.google.com/resource-manager/docs/organization-policy/overview>

In summary, using Confidential VMs with an organization policy ensures the sensitive data is protected even when it's actively being used by the VMs in your organization.

Question: 215

You are a Cloud Identity administrator for your organization. In your Google Cloud environment, groups are used to manage user permissions. Each application team has a dedicated group. Your team is responsible for creating these groups and the application teams can manage the team members on their own through the Google Cloud console. You must ensure that the application teams can only add users from within your organization to their groups.

What should you do?

- A. Change the configuration of the relevant groups in the Google Workspace Admin console to prevent external users from being added to the group.
- B. Set an Identity and Access Management (IAM) policy that includes a condition that restricts group membership to user principals that belong to your organization.
- C. Define an Identity and Access Management (IAM) deny policy that denies the assignment of principals that are outside your organization to the groups in scope.
- D. Export the Cloud Identity logs to BigQuery. Configure an alert for external members added to groups. Have the alert trigger a Cloud Function instance that removes the external members from the group.

Answer: A

Explanation:

The correct answer is **A. Change the configuration of the relevant groups in the Google Workspace Admin console to prevent external users from being added to the group.**

Here's a detailed justification:

Google Workspace (formerly G Suite) provides granular controls for managing groups, specifically concerning who can be added as members. Option A directly leverages this built-in functionality. By modifying the group's settings within the Google Workspace Admin console, you can restrict membership to users only from your organization's domain, effectively preventing the addition of external users. This is a straightforward, native approach that doesn't require complex IAM policies or external scripting. It addresses the core requirement of limiting group membership to internal users at the source.

Options B, C, and D, while related to security and identity management, are not the most appropriate solutions in this scenario. Option B using IAM policies with conditions is more tailored for managing access to Google Cloud resources rather than user membership in Google Workspace groups. IAM policies are primarily for controlling what resources a user can access, not who can be a member of a group. Similarly, option C, using IAM deny policies, focuses on resource access control. Option D introduces unnecessary complexity with log export, alerting, and a Cloud Function. It's a reactive approach rather than a proactive prevention method, and it introduces a reliance on additional components. Furthermore, this option requires a considerable amount of unnecessary setup and management overhead.

Therefore, the most effective and efficient solution to ensure that only internal users can be added to Google Workspace groups is to utilize the built-in group settings in the Google Workspace Admin console.

Authoritative Links:

Google Workspace Admin help: Share your group with only people in your organization:

<https://support.google.com/groups/answer/2464926?hl=en>

Google Workspace Admin help: Create a group: <https://support.google.com/a/answer/3332290?hl=en> (for managing group membership and permissions)

Question: 216

CertyIQ

Your organization wants to be continuously evaluated against CIS Google Cloud Computing Foundations Benchmark v1.3.0 (CIS Google Cloud Foundation 1.3). Some of the controls are irrelevant to your organization and must be disregarded in evaluation. You need to create an automated system or process to ensure that only the relevant controls are evaluated.

What should you do?

- A. Mark all security findings that are irrelevant with a tag and a value that indicates a security exception. Select all marked findings, and mute them on the console every time they appear. Activate Security Command Center (SCC) Premium.
- B. Activate Security Command Center (SCC) Premium. Create a rule to mute the security findings in SCC so they are not evaluated.
- C. Download all findings from Security Command Center (SCC) to a CSV file. Mark the findings that are part of CIS Google Cloud Foundation 1.3 in the file. Ignore the entries that are irrelevant and out of scope for the company.
- D. Ask an external audit company to provide independent reports including needed CIS benchmarks. In the scope of the audit, clarify that some of the controls are not needed and must be disregarded.

Answer: B

Explanation:

Option B is the most suitable approach for automating the evaluation of CIS Google Cloud Foundation 1.3 controls while disregarding irrelevant ones. Security Command Center (SCC) Premium offers robust features for managing and customizing security findings. By activating SCC Premium, you gain access to its advanced capabilities, including the ability to create muting rules. These rules allow you to selectively suppress specific security findings based on predefined criteria, effectively excluding irrelevant controls from the evaluation process.

This approach avoids manual processes like tagging findings (Option A) or exporting and manipulating data (Option C). Manual efforts are error-prone, time-consuming, and don't provide continuous automated evaluation. Relying solely on an external audit (Option D) is not a method of continuous automated compliance assessment and can be costly and infrequent. SCC Premium offers a built-in, scalable, and automated solution. Muting rules ensure that your security posture is continuously assessed based on the relevant controls, reducing noise from irrelevant findings, and enabling efficient monitoring of what truly matters to the organization. By configuring muting rules effectively, you establish a dynamic evaluation process in line with the specific needs of your company, simplifying compliance efforts and saving resources.

For further research on Google Cloud Security Command Center and muting rules, please refer to the official documentation:

[Security Command Center Overview](#)

[Mute Findings](#)

[CIS Benchmarks for Google Cloud](#)

Question: 217

CertyIQ

You are routing all your internet facing traffic from Google Cloud through your on-premises internet connection. You want to accomplish this goal securely and with the highest bandwidth possible.

What should you do?

- A. Create an HA VPN connection to Google Cloud. Replace the default 0.0.0.0/0 route.
- B. Create a routing VM in Compute Engine. Configure the default route with the VM as the next hop.

C. Configure Cloud Interconnect with HA VPN. Replace the default 0.0.0.0/0 route to an on-premises destination.

D. Configure Cloud Interconnect and route traffic through an on-premises firewall.

Answer: D

Explanation:

The correct answer is **D. Configure Cloud Interconnect and route traffic through an on-premises firewall.** This approach provides the highest bandwidth and security required for routing all internet-facing Google Cloud traffic through an on-premises connection. Cloud Interconnect establishes a direct, private connection between the on-premises network and Google's network, bypassing the public internet and thus offering lower latency and higher bandwidth compared to VPNs. This direct connection is crucial when dealing with significant traffic volume. Furthermore, routing traffic through an on-premises firewall allows for centralized security policy enforcement.

Here's why the other options are less suitable:

A. Create an HA VPN connection to Google Cloud. Replace the default 0.0.0.0/0 route: While HA VPN provides redundancy and security, it does not offer the bandwidth of Cloud Interconnect. VPNs are inherently limited by internet bandwidth and incur additional overhead, which is unsuitable for large volumes of traffic.

B. Create a routing VM in Compute Engine. Configure the default route with the VM as the next hop: Using a Compute Engine instance as a router can be a complex and less scalable approach. It requires configuring and maintaining the VM, handling routing rules and introduces a single point of failure if not configured for high availability. Moreover, it wouldn't provide direct connectivity to on-premises resources.

C. Configure Cloud Interconnect with HA VPN. Replace the default 0.0.0.0/0 route to an on-premises destination: This solution is over-engineered. HA VPN on top of Cloud Interconnect adds unnecessary complexity and cost. Cloud Interconnect by itself provides a direct and highly available path; a VPN on top of that is not required for bandwidth or availability.

Cloud Interconnect's dedicated physical connections and direct access to Google's network infrastructure provide a far more robust and performant solution for routing large volumes of traffic than VPN connections. When coupled with an on-premises firewall, the setup ensures robust security and control over all internet-bound traffic.

Authoritative Links:

Cloud Interconnect Overview: <https://cloud.google.com/network-connectivity/docs/interconnect/concepts/overview>

Cloud Interconnect Use Cases: <https://cloud.google.com/network-connectivity/docs/interconnect/concepts/use-cases>

HA VPN Overview: <https://cloud.google.com/network-connectivity/docs/vpn/concepts/overview>

Question: 218

CertyIQ

Your organization uses Google Workspace Enterprise Edition for authentication. You are concerned about employees leaving their laptops unattended for extended periods of time after authenticating into Google Cloud. You must prevent malicious people from using an employee's unattended laptop to modify their environment.

What should you do?

A. Create a policy that requires employees to not leave their sessions open for long durations.

B. Review and disable unnecessary Google Cloud APIs.

C. Require strong passwords and 2SV through a security token or Google authenticator.

D.Set the session length timeout for Google Cloud services to a shorter duration.

Answer: D

Explanation:

The correct answer is **D. Set the session length timeout for Google Cloud services to a shorter duration.**

Here's why:

Option D directly addresses the risk of unattended laptops being misused. By configuring a shorter session timeout, Google Cloud services will automatically log out users after a period of inactivity. This limits the window of opportunity for unauthorized access, even if an employee leaves their authenticated laptop unattended. This aligns with the principle of least privilege, granting access only for the necessary time. Options A, B, and C, while good security practices, do not specifically target the risk of unattended authenticated sessions. While important, policy enforcement (A) can be unreliable and requires employee action. Disabling APIs (B) reduces attack surface but doesn't prevent session hijacking. Strong authentication (C) is crucial for initial login, but it does not protect against misuse of an active session. Setting shorter timeouts mitigates the risk by automatically revoking access. This is a fundamental security practice to prevent unauthorized actions by someone gaining physical access to an authenticated device. This forces re-authentication, ensuring the user is still authorized.

This approach doesn't burden the user too much, as a shorter timeout can be balanced with convenience and it still provides much needed protection.

Here are some links for further research:

Google Cloud Session Duration Settings: <https://cloud.google.com/identity/docs/manage-session-duration>

Google Workspace Security: <https://workspace.google.com/security/>

Principle of Least Privilege: https://csrc.nist.gov/glossary/term/least_privilege

Question: 219

CertyIQ

You are migrating an on-premises data warehouse to BigQuery, Cloud SQL, and Cloud Storage. You need to configure security services in the data warehouse. Your company compliance policies mandate that the data warehouse must:

- Protect data at rest with full lifecycle management on cryptographic keys.
- Implement a separate key management provider from data management.
- Provide visibility into all encryption key requests.

What services should be included in the data warehouse implementation? (Choose two.)

- A.Customer-managed encryption keys
- B.Customer-Supplied Encryption Keys
- C.Key Access Justifications
- D.Access Transparency and Approval
- E.Cloud External Key Manager

Answer: CE

Explanation:

The correct answer is **C. Key Access Justifications** and **E. Cloud External Key Manager (EKM).**

Here's why:

Cloud External Key Manager (EKM) directly addresses the requirement for a separate key management provider from data management. EKM allows you to use encryption keys hosted and managed outside of Google Cloud, fulfilling the mandate for an external key management solution. This contrasts with services where keys are managed within Google Cloud's infrastructure.

[Cloud EKM Documentation](#)

Key Access Justifications (KAJ) provides the necessary visibility into all encryption key requests. KAJ requires users to provide a justification for accessing encryption keys, creating an audit trail that meets the company's visibility requirement. It ensures every key access is documented and auditable.

[Key Access Justifications Documentation](#)

Why other options are not suitable:

Customer-managed encryption keys (CMEK): While CMEK provides key lifecycle management, it does not fulfill the requirement of a separate key management provider. The keys are still managed within Google Cloud KMS.

[CMEK Documentation](#)

Customer-Supplied Encryption Keys (CSEK): CSEK requires customers to manage the keys, but the keys cannot be managed in separate system, in fact CSEK are only supported with GCS, This option does not address the need for a separate key management service.

[CSEK Documentation](#)

Access Transparency and Approval: Access Transparency provides visibility into actions taken by Google Cloud support and engineering staff. Access Approval is used to approve access requests by Google employees. This service does not address key management needs.

[Access Transparency Documentation](#)

[Access Approval Documentation](#)

Therefore, combining **Cloud External Key Manager (EKM)** for separated key management and **Key Access Justifications (KAJ)** for auditability addresses all specified requirements of the security policy.

Question: 220

CertyIQ

You manage one of your organization's Google Cloud projects (Project A). A VPC Service Control (SC) perimeter is blocking API access requests to this project, including Pub/Sub. A resource running under a service account in another project (Project B) needs to collect messages from a Pub/Sub topic in your project. Project B is not included in a VPC SC perimeter. You need to provide access from Project B to the Pub/Sub topic in Project A using the principle of least privilege.

What should you do?

- A. Configure an ingress policy for the perimeter in Project A, and allow access for the service account in Project B to collect messages.
- B. Create an access level that allows a developer in Project B to subscribe to the Pub/Sub topic that is located in Project A.
- C. Create a perimeter bridge between Project A and Project B to allow the required communication between both projects.
- D. Remove the Pub/Sub API from the list of restricted services in the perimeter configuration for Project A.

Answer: A

Explanation:

The correct answer is **A. Configure an ingress policy for the perimeter in Project A, and allow access for the service account in Project B to collect messages.**

Here's the justification:

VPC Service Controls (VPC SC) act as a security perimeter around Google Cloud resources, restricting API access based on context. In this scenario, Project A has a perimeter blocking access, including to Pub/Sub, while Project B is outside the perimeter and needs access to Project A's Pub/Sub topic. To maintain least privilege and security, we shouldn't broadly remove the perimeter's restriction (Option D) or create a wide-open bridge (Option C). Option B is also incorrect because access levels don't apply to service accounts, which is what Project B uses in the question.

An ingress policy within the VPC SC perimeter allows for controlled access. By configuring an ingress policy for the perimeter in Project A specifically allowing the service account in Project B to access Pub/Sub, you provide the required access while enforcing the least privilege principle. You are allowing a specific service account from outside the perimeter to perform a defined operation (collecting messages) within it.

This approach minimizes the attack surface by limiting access to only what's absolutely necessary and prevents unauthorized access from other sources. This method aligns with the best practice of using ingress/egress policies to control network traffic crossing security boundaries.

Further research:

VPC Service Controls Documentation: <https://cloud.google.com/vpc-service-controls/docs>

Ingress Policies: <https://cloud.google.com/vpc-service-controls/docs/ingress-egress-rules>

Principle of Least Privilege: <https://cloud.google.com/security/principles/least-privilege>

Question: 221

CertyIQ

You define central security controls in your Google Cloud environment. For one of the folders in your organization, you set an organizational policy to deny the assignment of external IP addresses to VMs. Two days later, you receive an alert about a new VM with an external IP address under that folder.

What could have caused this alert?

- A. The VM was created with a static external IP address that was reserved in the project before the organizational policy rule was set.
- B. The organizational policy constraint wasn't properly enforced and is running in "dry run" mode.
- C. A project level, the organizational policy control has been overwritten with an "allow" value.
- D. The policy constraint on the folder level does not have any effect because of an "allow" value for that constraint on the organizational level.

Answer: C

Explanation:

The correct answer is **C. A project level, the organizational policy control has been overwritten with an "allow" value.**

Organizational policies in Google Cloud operate with a hierarchical inheritance model. Policies set at higher levels (like the organization level or folder level) are inherited by lower levels (folders or projects). However, these policies can be overridden at lower levels, leading to unexpected behavior. In this case, the folder-level policy denied external IP addresses. However, if a project within that folder defined its own organizational policy with an "allow" value for external IPs, this project-level policy would take precedence, effectively

overriding the folder-level restriction. This is the key reason why a VM with an external IP address could have been created despite the folder-level policy.

Option A is incorrect because reserving a static external IP address does not bypass the organizational policy prohibiting the assignment of such addresses. The policy restriction prevents the VM from being configured with an external IP during its creation or modification, regardless of whether the IP was previously reserved. Option B is incorrect because "dry run" mode would not allow the creation of a VM with an external IP, it would only log what would happen if the policy was enforced. Option D is incorrect because an allow at the organization level does not override policies at a lower level. A deny at any level trumps an allow higher up in the hierarchy.

Hierarchical Policies: <https://cloud.google.com/resource-manager/docs/organization-policy/understanding-hierarchy>**Organizational Policy Evaluation:** <https://cloud.google.com/resource-manager/docs/organization-policy/understanding-evaluation>

Question: 222

CertyIQ

Your company recently published a security policy to minimize the usage of service account keys. On-premises Windows-based applications are interacting with Google Cloud APIs. You need to implement Workload Identity Federation (WIF) with your identity provider on-premises.

What should you do?

- A. Set up a workload identity pool with your corporate Active Directory Federation Service (ADFS). Configure a rule to let principals in the pool impersonate the Google Cloud service account.
- B. Set up a workload identity pool with your corporate Active Directory Federation Service (ADFS). Let all principals in the pool impersonate the Google Cloud service account.
- C. Set up a workload identity pool with an OpenID Connect (OIDC) service on the same machine. Configure a rule to let principals in the pool impersonate the Google Cloud service account.
- D. Set up a workload identity pool with an OpenID Connect (OIDC) service on the same machine. Let all principals in the pool impersonate the Google Cloud service account.

Answer: A

Explanation:

The correct answer is **A**. Here's a detailed justification:

Workload Identity Federation (WIF) allows on-premises applications to access Google Cloud resources without relying on long-lived service account keys, which pose security risks. In this scenario, the company needs to integrate with their existing Active Directory Federation Service (ADFS), which is a common identity provider for Windows-based environments.

Option A proposes setting up a workload identity pool that trusts ADFS. This pool acts as a bridge, allowing identities authenticated by ADFS to obtain temporary Google Cloud credentials. A crucial step is configuring a rule within the pool. This rule maps specific identities from ADFS (principals) to the corresponding Google Cloud service account, allowing them to assume its permissions. This approach provides fine-grained access control and adheres to the principle of least privilege.

Option B is incorrect because granting all ADFS principals impersonation rights is too broad and insecure. It violates the principle of least privilege and increases the potential for unauthorized access. Option C, while leveraging the concept of OpenID Connect, doesn't align with the stated use case of integrating with on-premises ADFS. Implementing a separate OIDC service adds unnecessary complexity and overhead. Similarly, option D is incorrect because it suffers from the same broad permissions issue as option B, in addition to being an incorrect approach for the stated scenario.

By choosing option A, the company can secure its on-premises applications' access to Google Cloud using WIF, leveraging their existing ADFS infrastructure, while maintaining granular access control.

Authoritative Links for Further Research:

Workload Identity Federation: <https://cloud.google.com/iam/docs/workload-identity-federation>

Setting up Workload Identity Federation: <https://cloud.google.com/iam/docs/workload-identity-federation-setup>

ADFS as an Identity Provider: <https://learn.microsoft.com/en-us/windows-server/identity/ad-fs/ad-fs-overview>

Principle of Least Privilege: <https://owasp.org/www-project-top-ten/>

Question: 223

CertyIQ

After completing a security vulnerability assessment, you learned that cloud administrators leave Google Cloud CLI sessions open for days. You need to reduce the risk of attackers who might exploit these open sessions by setting these sessions to the minimum duration.

What should you do?

- A. Set the session duration for the Google session control to one hour.
- B. Set the reauthentication frequency for the Google Cloud Session Control to one hour.
- C. Set the organization policy constraint constraints/iam.allowServiceAccountCredentialLifetimeExtension to one hour.
- D. Set the organization policy constraint constraints/iam.serviceAccountKeyExpiryHours to one hour and inheritFromParent to false.

Answer: A

Explanation:

The correct answer is **A. Set the session duration for the Google session control to one hour.**

Here's why:

The core issue is mitigating the risk from long-lived, unattended gcloud CLI sessions. These sessions, authenticated with user credentials, could be hijacked if a user's machine is compromised. Google Cloud Session Control allows setting session duration limits specifically for interactive sessions like those used with the gcloud CLI. By configuring this, we force users to re-authenticate after a specified period, reducing the window of opportunity for an attacker. Setting the session duration to one hour drastically shortens the time an attacker could leverage a hijacked session before it expires.

Option B, setting the reauthentication frequency, would prompt for reauthentication within an active session, which isn't applicable to the described scenario of long-open sessions. Options C and D deal with service account credentials and their lifecycles, not directly with user session management. These are relevant for service-to-service communication, not interactive CLI sessions. While limiting the lifetime of service account credentials is important, it doesn't address the problem of open user sessions.

Session control policies directly target the vulnerability described in the question - the extended duration of interactive user sessions. By limiting the session duration, the exposure window is significantly minimized, reducing the overall risk.

Authoritative Links for further research:

Google Cloud Session Control: <https://cloud.google.com/identity/docs/session-control>

IAM Organization Policy Constraints: <https://cloud.google.com/resource-manager/docs/organization->

These links provide in-depth information on Google Cloud session control and organization policies, helping to understand the different security controls and their applications.

Question: 224

CertyIQ

You have numerous private virtual machines on Google Cloud. You occasionally need to manage the servers through Secure Socket Shell (SSH) from a remote location. You want to configure remote access to the servers in a manner that optimizes security and cost efficiency.

What should you do?

- A. Create a site-to-site VPN from your corporate network to Google Cloud.
- B. Configure server instances with public IP addresses. Create a firewall rule to only allow traffic from your corporate IPs.
- C. Create a firewall rule to allow access from the Identity-Aware Proxy (IAP) IP range. Grant the role of an IAP-secured Tunnel User to the administrators.
- D. Create a jump host instance with public IP. Manage the instances by connecting through the jump host.

Answer: C

Explanation:

The most secure and cost-effective approach to manage private VMs via SSH from a remote location is option C, utilizing Identity-Aware Proxy (IAP). IAP enables secure access to applications and resources based on user identity and context, without requiring public IP addresses for the VMs. This eliminates the need to expose VMs directly to the internet, reducing the attack surface. A firewall rule allowing access from the IAP IP range restricts traffic to only connections originating from the proxy service. By granting the "IAP-secured Tunnel User" role, administrators can establish SSH tunnels securely through the IAP, accessing the VMs without exposing them to external risks. This method minimizes the attack surface, improves security compared to public IP configurations, and avoids the costs associated with maintaining a dedicated VPN or jump host. Options A, B, and D present drawbacks. A site-to-site VPN (A) incurs ongoing operational and maintenance overhead and can be costly. Directly exposing VMs to public IPs (B), even with firewall rules, increases security risks. A jump host (D) introduces an extra hop, adding complexity and cost.

Authoritative Links:

Google Cloud IAP Documentation: <https://cloud.google.com/iap/docs>

Securing SSH with IAP: <https://cloud.google.com/iap/docs/using-tcp-forwarding>

Google Cloud Firewall Rules: <https://cloud.google.com/vpc/docs/firewalls>

Question: 225

CertyIQ

Your organization's record data exists in Cloud Storage. You must retain all record data for at least seven years. This policy must be permanent.

What should you do?

- A.1. Identify buckets with record data.
2. Apply a retention policy, and set it to retain for seven years.
3. Monitor the bucket by using log-based alerts to ensure that no modifications to the retention policy occurs.
- B.1. Identify buckets with record data.
2. Apply a retention policy, and set it to retain for seven years.

3. Remove any Identity and Access Management (IAM) roles that contain the storage buckets update permission.

C.1. Identify buckets with record data.

2. Enable the bucket policy only to ensure that data is retained.

3. Enable bucket lock.

D.1. Identify buckets with record data.

2. Apply a retention policy and set it to retain for seven years.

3. Enable bucket lock.

Answer: D

Explanation:

The correct answer is D because it provides the necessary steps to enforce a permanent retention policy on Cloud Storage data for seven years. Option D starts by identifying the relevant Cloud Storage buckets containing record data. Then, it applies a retention policy to these buckets, setting the duration for seven years. This ensures that objects within the buckets are retained for the specified period, preventing deletion or modification before the retention period expires. Finally, and most importantly, it enables Bucket Lock. Bucket Lock is a crucial feature that makes retention policies permanent. Once a bucket lock is enabled, the retention policy becomes immutable, meaning it cannot be modified or deleted, even by administrators. This ensures compliance with the stated requirement of a permanent retention policy. Options A and B are insufficient because they do not use bucket lock, meaning administrators with appropriate permissions could potentially modify or remove the retention policy. Option C omits the crucial initial step of actually applying a retention policy, and while it does mention bucket lock, applying a bucket policy alone is not sufficient for retention. Therefore, option D is the most comprehensive and correct answer as it implements the correct features in the right order to satisfy all the requirements.

Here are authoritative links for further research:

Cloud Storage Retention Policies: <https://cloud.google.com/storage/docs/retention-policy>

Cloud Storage Bucket Lock: <https://cloud.google.com/storage/docs/bucket-lock>

Question: 226

CertyIQ

Your organization wants to protect all workloads that run on Compute Engine VM to ensure that the instances weren't compromised by boot-level or kernel-level malware. Also, you need to ensure that data in use on the VM cannot be read by the underlying host system by using a hardware-based solution.

What should you do?

A.1. Use Google Shielded VM including secure boot, Virtual Trusted Platform Module (vTPM), and integrity monitoring.

2. Create a Cloud Run function to check for the VM settings, generate metrics, and run the function regularly.

B.1. Activate Virtual Machine Threat Detection in Security Command Center (SCC) Premium.

2. Monitor the findings in SCC.

C.1. Use Google Shielded VM including secure boot, Virtual Trusted Platform Module (vTPM), and integrity monitoring.

2. Activate Confidential Computing.

3. Enforce these actions by using organization policies.

D.1. Use secure hardened images from the Google Cloud Marketplace.

2. When deploying the images, activate the Confidential Computing option.

3. Enforce the use of the correct images and Confidential Computing by using organization policies.

Answer: C

Explanation:

The correct answer is **C** because it directly addresses the requirements for both boot-level/kernel-level protection and in-use data confidentiality using hardware-based solutions.

Shielded VMs (part of option C) provide verifiable integrity of the boot process, thus ensuring that the VM has not been compromised by boot or kernel level malware. This integrity verification is achieved using **secure boot** which verifies that the bootloader and operating system kernels have not been modified, a crucial aspect of preventing malware from interfering at startup. The **vTPM (Virtual Trusted Platform Module)** within Shielded VMs provides cryptographic support for secure booting and platform integrity measurements, allowing the system to verify that its state is correct. Furthermore, **integrity monitoring** provides continual verification of the running VM, alerting to unauthorized changes.

Confidential Computing (also part of option C) uses hardware-based encryption of data in use within the virtual machine's memory, meaning that even if the hypervisor or host system was compromised, the VM's memory contents would remain encrypted and unreadable. This fulfills the requirement of preventing data from being read by the underlying host system.

Finally, using **organization policies** (included in option C) ensures consistent enforcement of the Shielded VM and Confidential Computing settings across the entire organization, rather than relying on individual teams to implement this manually and consistently.

Option A is incorrect because although it uses Shielded VM, it doesn't provide the data in-use protection that comes from confidential computing. It also offers a less effective metric monitoring process through a cloud run function when integrity monitoring already provides the data. Option B is incorrect as it does not utilize secure boot mechanisms and does not provide encryption-in-use protection. Option D relies on hardened images, which provides good security practices for a running OS, however, that does not ensure boot integrity, protection of data in use at a hardware level, and does not explicitly utilize Shielded VM features to secure the boot process.

Therefore, option C provides all the solutions and methods to fulfill the security requirements of the scenario presented.

Relevant Links:

Shielded VMs: <https://cloud.google.com/security/shielded-vms>

Confidential Computing: <https://cloud.google.com/confidential-computing>

Organization Policies: <https://cloud.google.com/resource-manager/docs/organization-policy/overview>

Question: 227

CertyIQ

You are migrating your users to Google Cloud. There are cookie replay attacks with Google web and Google Cloud CLI SDK sessions on endpoint devices. You need to reduce the risk of these threats.

What should you do? (Choose two.)

- A. Configure Google session control to a shorter duration.
- B. Set an organizational policy for OAuth 2.0 access token with a shorter duration.
- C. Set a reauthentication policy for Google Cloud services to a shorter duration.
- D. Configure a third-party identity provider with session management.
- E. Enforce Security Key Authentication with 2SV.

Answer: AC

Explanation:

The correct answers are A and C. Let's break down why. Cookie replay attacks involve attackers intercepting

and reusing valid authentication cookies to gain unauthorized access. To mitigate this, reducing the lifespan of those cookies is critical. Option A, **configuring Google session control to a shorter duration**, directly addresses this. By forcing users to re-authenticate more frequently, the window of opportunity for a replay attack is significantly reduced.

Option C, **setting a reauthentication policy for Google Cloud services to a shorter duration**, also helps by requiring users to provide credentials again after a specific time, regardless of session validity. This is an additional security layer that mitigates attacks where a stolen cookie might still be considered active.

Option B, **setting an organizational policy for OAuth 2.0 access token with a shorter duration**, is not directly relevant to cookie replay attacks. Access tokens are used for API access and are not the primary vectors for this type of attack. Option D, **configuring a third-party identity provider with session management**, could be beneficial, but it does not directly remediate the inherent risk related to Google session cookies or replay attacks. Option E, **enforcing Security Key Authentication with 2SV**, adds a strong authentication layer, but it doesn't solve the problem of stolen cookies that are already valid. While a security key makes it harder for an attacker to gain a new session, it won't invalidate an already stolen session cookie. The selected options address the specific risk of cookie replay by ensuring that sessions and the related cookies are short-lived, and re-authentication is forced periodically.

Relevant links:

Google Workspace session settings: <https://support.google.com/a/answer/7182374?hl=en>

Google Cloud reauthentication policies: <https://cloud.google.com/iam/docs/reauth>

Understanding OAuth 2.0 access tokens: <https://oauth.net/2/access-tokens/>

Question: 228

CertyIQ

You manage a mission-critical workload for your organization, which is in a highly regulated industry. The workload uses Compute Engine VMs to analyze and process the sensitive data after it is uploaded to Cloud Storage from the endpoint computers. Your compliance team has detected that this workload does not meet the data protection requirements for sensitive data. You need to meet these requirements:

- Manage the data encryption key (DEK) outside the Google Cloud boundary.
- Maintain full control of encryption keys through a third-party provider.
- Encrypt the sensitive data before uploading it to Cloud Storage.
- Decrypt the sensitive data during processing in the Compute Engine VMs.
- Encrypt the sensitive data in memory while in use in the Compute Engine VMs.

What should you do? (Choose two.)

- A.Configure Customer Managed Encryption Keys to encrypt the sensitive data before it is uploaded to Cloud Storage, and decrypt the sensitive data after it is downloaded into your VMs.
- B.Configure Cloud External Key Manager to encrypt the sensitive data before it is uploaded to Cloud Storage, and decrypt the sensitive data after it is downloaded into your VMs.
- C.Create Confidential VMs to access the sensitive data.
- D.Migrate the Compute Engine VMs to Confidential VMs to access the sensitive data.
- E.Create a VPC Service Controls service perimeter across your existing Compute Engine VMs and Cloud Storage buckets.

Answer: BC

Explanation:

Okay, let's break down why options B and C are the correct choices for this scenario.

The core requirement is to manage data encryption keys outside of Google Cloud while ensuring sensitive data is protected both in transit and at rest, including memory during processing. Option B, using Cloud

External Key Manager (EKM), directly addresses the need to manage encryption keys with a third-party provider. EKM allows you to use keys stored in your own infrastructure or with a third-party, meeting the requirement for external key management and control. <https://cloud.google.com/kms/docs/ekm/overview> Specifically, this enables encrypting the data before it hits Cloud Storage and decrypting it after downloading into the VMs, covering both at-rest needs.

Option C, implementing Confidential VMs, is crucial for addressing the encryption-in-memory requirement. Confidential VMs leverage hardware-based memory encryption, which encrypts the VM's memory content while the VM is running. This ensures that even if an attacker gained access to the hypervisor, they would not be able to access the sensitive data residing in the VM's memory. <https://cloud.google.com/confidential-computing/docs/confidential-vm/overview> This satisfies the need for in-use data protection during processing within the Compute Engine instances.

Option A, Customer Managed Encryption Keys (CMEK), while managing keys, still involves Google Cloud for key management. This does not meet the need for full control through a third party. Option D is incorrect because migrating to Confidential VMs alone does not address the key management component. Option E, VPC Service Controls, focuses on network perimeter security and does not address the specific data protection needs. Therefore, combining EKM (for external key management) and Confidential VMs (for memory encryption) offers a comprehensive solution meeting all requirements.

Essentially, EKM secures the data at rest and in transit while Confidential VMs secure the data in memory during processing, creating a robust defense-in-depth approach.

Question: 229

CertyIQ

Your organization wants to be General Data Protection Regulation (GDPR) compliant. You want to ensure that your DevOps teams can only create Google Cloud resources in the Europe regions.

What should you do?

- A. Use Identity-Aware Proxy (IAP) with Access Context Manager to restrict the location of Google Cloud resources.
- B. Use the org policy constraint 'Google Cloud Platform – Resource Location Restriction' on your Google Cloud organization node.
- C. Use the org policy constraint 'Restrict Resource Service Usage' on your Google Cloud organization node.
- D. Use Identity and Access Management (IAM) custom roles to ensure that your DevOps team can only create resources in the Europe regions.

Answer: B

Explanation:

The correct answer is **B. Use the org policy constraint 'Google Cloud Platform – Resource Location Restriction' on your Google Cloud organization node.**

Here's why:

Organizational policies in Google Cloud allow administrators to centrally control resource configurations across an entire organization. The 'Google Cloud Platform – Resource Location Restriction' policy specifically governs where resources can be created. By applying this constraint at the organization node, you effectively establish a firm boundary limiting the permissible regions for resource creation, ensuring compliance with GDPR's data residency requirements within European regions. This approach is declarative and enforced by the Google Cloud platform, making it difficult for DevOps teams to bypass.

Option A, using IAP and Access Context Manager, focuses on controlling access based on context and user

identity, not restricting resource locations. Option C, 'Restrict Resource Service Usage,' limits which services can be used, not where they are deployed. Option D, using IAM custom roles, controls permissions at the identity level and doesn't directly prevent resource creation in non-EU regions. Therefore, only Option B directly addresses the requirement of limiting resource creation to specific regions.

Authoritative Links for Further Research:

Organization Policy Service: <https://cloud.google.com/resource-manager/docs/organization-policy/overview>

Resource Location Restriction Policy: https://cloud.google.com/resource-manager/docs/organization-policy/defining-constraints#resource_location_restriction

GDPR and Data Residency: https://commission.europa.eu/law/law-topic/data-protection/reform/rules-business-and-organisations_en

IAM Overview: <https://cloud.google.com/iam/docs/overview>

IAP Overview: <https://cloud.google.com/iap/docs/concepts-overview>

Question: 230

CertyIQ

For data residency requirements, you want your secrets in Google Clouds Secret Manager to only have payloads in europe-west1 and europe-west4. Your secrets must be highly available in both regions.

What should you do?

- A. Create your secret with a user managed replication policy, and choose only compliant locations.
- B. Create your secret with an automatic replication policy, and choose only compliant locations.
- C. Create two secrets by using Terraform, one in europe-west1 and the other in europe-west4.
- D. Create your secret with an automatic replication policy, and create an organizational policy to deny secret creation in non-compliant locations.

Answer: A

Explanation:

The correct answer is **A. Create your secret with a user-managed replication policy, and choose only compliant locations.**

Here's a detailed justification:

Google Cloud's Secret Manager allows you to manage and control access to your secrets. Data residency requirements necessitate that the secret data (payloads) reside within specific geographic locations. To achieve this with high availability, replication across multiple regions is needed.

Option A aligns perfectly with this requirement. By utilizing a **user-managed replication policy**, you gain explicit control over which regions your secret's payload will be replicated to. You can then specifically select europe-west1 and europe-west4 as the compliant locations, ensuring your data residency needs are met while maintaining high availability across both selected regions. The user-managed replication policy allows for more granular control than other options.

Option B, using an **automatic replication policy**, does not permit choosing the exact locations. This method automatically replicates the secret data, which does not guarantee that the data will reside only in the required regions, potentially violating data residency regulations.

Option C, creating two separate secrets, while achieving the goal of regionalization, does not allow for high availability across regions. While you could configure failovers, managing two separate secrets adds complexity and isn't the most efficient solution, as it could lead to inconsistencies. Secret Manager is designed to manage a single secret across multiple regions for consistency.

Option D, while attempting to control secret creation location using organizational policy, does not allow for specific regional replication. It might prevent the creation of secrets in non-compliant regions, but it doesn't control where the payloads reside when the secret is created using automatic replication.

Therefore, using a **user-managed replication policy** provides the most precise and secure method for meeting both data residency and high availability demands.

Authoritative Links for Further Research:

Google Cloud Secret Manager Documentation - Replication: <https://cloud.google.com/secret-manager/docs/replication>

Google Cloud Secret Manager Documentation - Replication Policy: <https://cloud.google.com/secret-manager/docs/replication-policy>

Google Cloud Secret Manager Documentation - Locations: <https://cloud.google.com/secret-manager/docs/locations>

Question: 231

CertyIQ

You are migrating an application into the cloud. The application will need to read data from a Cloud Storage bucket. Due to local regulatory requirements, you need to hold the key material used for encryption fully under your control and you require a valid rationale for accessing the key material.

What should you do?

- A. Encrypt the data in the Cloud Storage bucket by using Customer Managed Encryption Keys. Configure an IAM deny policy for unauthorized groups.
- B. Generate a key in your on-premises environment to encrypt the data before you upload the data to the Cloud Storage bucket. Upload the key to the Cloud Key Management Service (KMS). Activate Key Access Justifications (KAJ) and have the external key system reject unauthorized accesses.
- C. Encrypt the data in the Cloud Storage bucket by using Customer Managed Encryption Keys backed by a Cloud Hardware Security Module (HSM). Enable data access logs.
- D. Generate a key in your on-premises environment and store it in a Hardware Security Module (HSM) that is managed on-premises. Use this key as an external key in the Cloud Key Management Service (KMS). Activate Key Access Justifications (KAJ) and set the external key system to reject unauthorized accesses.

Answer: D

Explanation:

The correct answer is **D** because it directly addresses all requirements: holding key material under full control, requiring a valid rationale for access, and encrypting data in Cloud Storage. Option D achieves this by generating and storing the key in an on-premises Hardware Security Module (HSM), thereby ensuring complete control resides outside Google's infrastructure. This key is then used as an external key in Cloud KMS, which allows Cloud Storage to use it for encryption while maintaining customer control. Activating Key Access Justifications (KAJ) ensures that every attempt to use the key requires a valid and auditable justification, fulfilling the rationale requirement. The external key system can then reject unauthorized access based on these justifications. Options A, B, and C do not meet all requirements. Option A uses Google-managed infrastructure for keys and doesn't enforce justifications. Option B transfers the key to Cloud KMS, which does not retain full customer control and doesn't explicitly implement external authorization. Option C, while using HSM, relies on Google's Cloud HSM service, which, similar to Option A, does not provide the desired level of control over key material. Option D leverages the Bring Your Own Key (BYOK) model with an external key management system, providing the highest level of customer control and meeting the stated regulatory compliance requirements.

Key Concepts:

Customer Managed Encryption Keys (CMEK): Provides control over encryption keys used in Google Cloud.

Hardware Security Module (HSM): A physical device providing secure key generation, storage, and cryptographic operations.

Key Access Justifications (KAJ): A security feature that requires a valid reason for accessing encryption keys.

Bring Your Own Key (BYOK): A cloud security model that allows customers to manage their own encryption keys in a system of their choice and use them with the cloud provider.

Cloud Key Management Service (KMS): A Google Cloud service for managing cryptographic keys.

Authoritative Links:

Customer-Managed Encryption Keys (CMEK): <https://cloud.google.com/kms/docs/cmek>

Key Access Justifications: <https://cloud.google.com/kms/docs/key-access-justifications>

External Key Management: <https://cloud.google.com/kms/docs/ekm>

Question: 232

CertyIQ

Your organization uses the top-tier folder to separate application environments (prod and dev). The developers need to see all application development audit logs, but they are not permitted to review production logs. Your security team can review all logs in production and development environments. You must grant Identity and Access Management (IAM) roles at the right resource level for the developers and security team while you ensure least privilege.

What should you do?

- A.1. Grant logging.viewer role to the security team at the organization resource level.
2. Grant logging.viewer role to the developer team at the folder resource level that contains all the dev projects.
- B.1. Grant logging.viewer role to the security team at the organization resource level.
2. Grant logging.admin role to the developer team at the organization resource level.
- C.1. Grant logging.admin role to the security team at the organization resource level.
2. Grant logging.viewer role to the developer team at the folder resource level that contains all the dev projects.
- D.1. Grant logging.admin role to the security team at the organization resource level.
2. Grant logging.admin role to the developer team at the organization resource level.

Answer: A

Explanation:

Here's a breakdown of why option A is the correct answer, along with a detailed justification:

Justification:

Option A adheres to the principle of least privilege, granting only the necessary permissions to each group at the appropriate resource level.

Security Team Access (Organization Level): The security team requires visibility into all logs across both production and development environments. Granting the logging.viewer role at the organization level allows them to access logs from any resource within the organization, including all folders and projects. This is the most efficient and secure way to provide centralized monitoring.

Developer Team Access (Development Folder Level): Developers only need to see logs related to their development work. Granting the logging.viewer role at the folder level that encompasses all the development projects restricts their access to only development-related logs, thus preventing them from viewing sensitive production data. This approach also means they don't need access at the organization level.

Options B, C, and D are incorrect for the following reasons:

Option B: Granting logging.admin to developers at the organization level violates least privilege. logging.admin provides write access to logs, including the ability to modify or delete them, which developers do not need. This increases the risk of accidental or malicious log manipulation.

Option C: Granting logging.admin to the security team is overly permissive, even though they may have high access needs. logging.viewer is sufficient for their role, and logging.admin is unnecessary. Also, the issue with developer roles remains.

Option D: Granting logging.admin to both teams is completely inappropriate, providing unnecessary write access and severely breaching the principle of least privilege.

Key Concepts:

Principle of Least Privilege: This fundamental security principle dictates that users should be granted the minimum permissions necessary to perform their job function. It reduces the potential damage from accidental or malicious actions.

Resource Hierarchy: Google Cloud Platform (GCP) uses an organization, folders, and projects hierarchy to structure resources. This hierarchy allows for managing permissions at different levels, offering granular access control.

IAM Roles: IAM roles define the type of access granted to principals (users, groups, service accounts) on resources. Different roles provide different levels of permissions, such as read-only (logging.viewer) and full administrative (logging.admin) access.

Authoritative Links for Further Research:

IAM Overview: <https://cloud.google.com/iam/docs/overview>

IAM Roles: <https://cloud.google.com/iam/docs/understanding-roles>

Logging Roles: <https://cloud.google.com/logging/docs/access-control>

Resource Hierarchy: <https://cloud.google.com/resource-manager/docs/cloud-platform-resource-hierarchy>

By using option A, we ensure that both the security and developer teams have the correct level of access to logs without violating the least privilege principle.

Question: 233

CertyIQ

You manage a fleet of virtual machines (VMs) in your organization. You have encountered issues with lack of patching in many VMs. You need to automate regular patching in your VMs and view the patch management data across multiple projects.

What should you do? (Choose two.)

- A. View patch management data in VM Manager by using OS patch management.
- B. View patch management data in Artifact Registry.
- C. View patch management data in a Security Command Center dashboard.
- D. Deploy patches with Security Command Center by using Rapid Vulnerability Detection.
- E. Deploy patches with VM Manager by using OS patch management.

Answer: AE

Explanation:

Okay, let's break down why options A and E are the correct choices for automating VM patching and viewing patch data across projects, and why the others are not suitable.

Justification for Option A (View patch management data in VM Manager by using OS patch management):

VM Manager's OS patch management feature is specifically designed for managing patches across Google Compute Engine VMs. It provides a centralized view of the patch status of your VMs across different projects. This allows you to easily see which VMs are missing patches, and what patches are available. This aligns directly with the requirement of viewing patch management data across multiple projects. VM Manager aggregates this data, making it readily accessible through the Google Cloud Console.

Justification for Option E (Deploy patches with VM Manager by using OS patch management):

VM Manager's OS patch management capabilities not only allow you to view patch data but also to deploy patches automatically. You can define patch policies and schedule regular patching runs. This satisfies the requirement of automating regular patching of your VMs. VM Manager's integration with Compute Engine makes it the natural choice for managing VM patching.

Why other options are incorrect:

Option B (View patch management data in Artifact Registry): Artifact Registry is a service for storing and managing container images and other artifacts. It's not designed for managing patch information for VMs. While images may contain pre-patched software, Artifact Registry doesn't provide the live patch status of running VMs.

Option C (View patch management data in a Security Command Center dashboard): Security Command Center provides broad security visibility across your Google Cloud environment, including potential vulnerabilities. It can highlight VMs with missing patches as a vulnerability, but it doesn't provide the same detailed patch management data and controls that VM Manager offers.

Option D (Deploy patches with Security Command Center by using Rapid Vulnerability Detection): Security Command Center's Rapid Vulnerability Detection (RVD) feature identifies vulnerabilities, including missing patches. However, while RVD will highlight these issues, it doesn't directly deploy the patches to fix the vulnerabilities, nor does it provide a mechanism for scheduling regular patch application to VMs. Security Center's primary focus is on detection and reporting.

In conclusion:

VM Manager is the core service for both viewing patch status and automating patch deployments on Compute Engine VMs. It has features tailored for these tasks (OS patch management) which allows users to manage patching across multiple projects with centralized visibility. Security Command Center is more suited for security monitoring, identifying vulnerabilities, but does not deploy patches and does not provide detailed patch management information. Artifact Registry is not involved in VM patch management.

Authoritative Links for Further Research:

VM Manager Overview: <https://cloud.google.com/vm-manager/docs/overview>

OS Patch Management with VM Manager: <https://cloud.google.com/vm-manager/docs/os-patch-management>

Security Command Center Overview: <https://cloud.google.com/security-command-center/docs>

Artifact Registry Overview: <https://cloud.google.com/artifact-registry/docs/overview>

Question: 234

CertyIQ

Your organization uses BigQuery to process highly sensitive, structured datasets. Following the "need to know" principle, you need to create the Identity and Access Management (IAM) design to meet the needs of these users:

- Business user: must access curated reports.
- Data engineer: must administrate the data lifecycle in the platform.
- Security operator: must review user activity on the data platform.

What should you do?

A. Configure data access log for BigQuery services, and grant Project Viewer role to security operator.

- B. Set row-based access control based on the “region” column, and filter the record from the United States for data engineers.
- C. Create curated tables in a separate dataset and assign the role roles/bigquery.dataViewer.
- D. Generate a CSV data file based on the business user's needs, and send the data to their email addresses.

Answer: C

Explanation:

Option C is the correct approach because it aligns with the principle of least privilege and provides the necessary access controls for each user persona. Creating curated tables in a separate dataset allows for a clear separation of concerns. Business users are granted the roles/bigquery.dataViewer role, which grants them access to only view the curated reports, thus fulfilling their requirement. This approach avoids granting them unnecessary access to the raw data, minimizing potential security risks. Data engineers would have separate roles to manage the original datasets, but this is not directly relevant to the curated data. Options A and B are incorrect since they are addressing other security concerns outside the scope of the specific user requirements in the question. Option D is not a good security practice because it uses email distribution which is not secure or scalable for sensitive data, also making the reports static and not interactive. Overall, option C is a suitable solution since it implements granular, need-to-know access controls, using IAM roles to restrict permissions appropriately.

Further Research:

BigQuery IAM Roles: <https://cloud.google.com/bigquery/docs/access-control>

Principle of Least Privilege: <https://cloud.google.com/security/infrastructure/design/least-privilege>

Dataset Permissions: https://cloud.google.com/bigquery/docs/datasets#dataset_permissions

Question: 235

CertyIQ

You are setting up a new Cloud Storage bucket in your environment that is encrypted with a customer managed encryption key (CMEK). The CMEK is stored in Cloud Key Management Service (KMS), in project “prj-a”, and the Cloud Storage bucket will use project “prj-b”. The key is backed by a Cloud Hardware Security Module (HSM) and resides in the region europe-west3. Your storage bucket will be located in the region europe-west1. When you create the bucket, you cannot access the key, and you need to troubleshoot why.

What has caused the access issue?

- A. A firewall rule prevents the key from being accessible.
- B. Cloud HSM does not support Cloud Storage.
- C. The CMEK is in a different project than the Cloud Storage bucket.
- D. The CMEK is in a different region than the Cloud Storage bucket.

Answer: D

Explanation:

The correct answer is D, "The CMEK is in a different region than the Cloud Storage bucket." Cloud KMS keys used for Cloud Storage CMEK encryption must reside in the same region as the Cloud Storage bucket. This regional alignment ensures low latency and optimized performance for encryption and decryption operations. Cloud Storage relies on the key being locally accessible within the same region. In this scenario, the KMS key is in europe-west3, while the storage bucket is in europe-west1. This regional mismatch prevents the bucket from accessing the key, leading to the access issue. While CMEKs can be in different projects, that's not the problem here. Cloud HSM does support Cloud Storage encryption, eliminating option B. Firewall rules do not directly control access to KMS keys, making option A incorrect. The KMS service uses IAM for access control. The key regional limitation is a core architectural requirement. Therefore, the primary cause of the access

issue is the regional disparity between the CMEK and the Cloud Storage bucket.

Further research:

Cloud KMS Locations: <https://cloud.google.com/kms/docs/locations> - Explains the regionality of Cloud KMS keys and its importance.

Cloud Storage CMEK: <https://cloud.google.com/storage/docs/encryption/customer-managed-keys> - Provides information on using CMEK with Cloud Storage, including regional requirements.

Cloud HSM Overview: <https://cloud.google.com/hsm/docs/overview> - Details on Cloud HSM functionality including usage with other GCP services.

Question: 236

CertyIQ

You are deploying regulated workloads on Google Cloud. The regulation has data residency and data access requirements. It also requires that support is provided from the same geographical location as where the data resides.

What should you do?

- A. Enable Access Transparency Logging.
- B. Deploy Assured Workloads.
- C. Deploy resources only to regions permitted by data residency requirements.
- D. Use Data Access logging and Access Transparency logging to confirm that no users are accessing data from another region.

Answer: B

Explanation:

The correct answer is **B. Deploy Assured Workloads.**

Here's why: Assured Workloads is specifically designed to address compliance and regulatory needs, particularly those concerning data residency, access controls, and support localization. When you deploy Assured Workloads, you create a dedicated environment that is configured to meet specific compliance standards like those requiring data to reside and be accessed within a defined geographic location. Importantly, it enables Google Cloud to provide support from personnel located within the same geographic region as the data, satisfying the crucial support requirement in the scenario.

Options A, C, and D, while relevant for security, do not fully address all the aspects of this specific problem.

A. Enable Access Transparency Logging: While Access Transparency logs are vital for audit trails and provide visibility into actions taken by Google Cloud personnel, they do not inherently enforce data residency or localized support. It is for providing transparency of Google support action not the actual support.

C. Deploy resources only to regions permitted by data residency requirements: This is a fundamental step towards data residency compliance, but does not offer a compliance environment or guarantee localized support.

D. Use Data Access logging and Access Transparency logging to confirm that no users are accessing data from another region: These logs provide detection mechanisms for unauthorized access, however, they are not preventing or guaranteeing compliant access or localized support.

Assured Workloads integrates data residency, localized support, and compliance management into a single offering, making it the ideal solution for regulated workloads requiring those features.

Authoritative links:

Google Cloud Assured Workloads: <https://cloud.google.com/assured-workloads>

Question: 237

CertyIQ

Your organization wants full control of the keys used to encrypt data at rest in their Google Cloud environments. Keys must be generated and stored outside of Google and integrate with many Google Services including BigQuery.

What should you do?

- A. Use customer-supplied encryption keys (CSEK) with keys generated on trusted external systems. Provide the raw CSEK as part of the API call.
- B. Create a KMS key that is stored on a Google managed FIPS 140-2 level 3 Hardware Security Module (HSM). Manage the Identity and Access Management (IAM) permissions settings, and set up the key rotation period.
- C. Use Cloud External Key Management (EKM) that integrates with an external Hardware Security Module (HSM) system from supported vendors.
- D. Create a Cloud Key Management Service (KMS) key with imported key material. Wrap the key for protection during import. Import the key generated on a trusted system in Cloud KMS.

Answer: C

Explanation:

The correct answer is **C. Use Cloud External Key Management (EKM) that integrates with an external Hardware Security Module (HSM) system from supported vendors.**

Cloud EKM directly addresses the requirement for full control of encryption keys generated and stored outside of Google Cloud while still enabling integration with services like BigQuery. EKM achieves this by allowing Google Cloud services to use encryption keys managed by the customer's external key management system (typically an HSM), without the actual key material ever leaving that system. This ensures that Google does not have access to the underlying cryptographic keys. This approach satisfies the organization's desire for complete key control and supports their security posture. In contrast, CSEK (option A) requires providing the raw key material in every API call, creating a considerable security risk and management overhead. Cloud KMS keys managed by Google (option B) do not provide the desired level of control since Google manages the infrastructure where the keys are stored. While option D, importing key material into Cloud KMS, provides more control than managed keys, it still means the key resides within Google's infrastructure, which is against the requirement.

Therefore, Cloud EKM is the only solution that aligns with the need to generate and store keys externally while integrating with Google Cloud services. For further details, you can refer to the official Google Cloud documentation on Cloud External Key Management: <https://cloud.google.com/kms/docs/ekm> and also the Cloud KMS overview: <https://cloud.google.com/kms/docs/>.

Question: 238

CertyIQ

Your company is concerned about unauthorized parties gaining access to the Google Cloud environment by using a fake login page. You must implement a solution to protect against person-in-the-middle attacks.

Which security measure should you use?

- A. Security key
- B. Google prompt
- C. Text message or phone call code

Answer: A

Explanation:

The correct answer is A, **Security key**. Security keys are hardware-based authentication devices that provide strong protection against phishing and man-in-the-middle attacks. They leverage cryptographic protocols, typically FIDO2/WebAuthn, to verify user identity directly with the service, not just a website. This process avoids the vulnerability of entering credentials on a fake login page, because the key needs to physically interact with the genuine service. Options B, C, and D are all forms of two-factor authentication (2FA), but they are susceptible to sophisticated phishing attacks that can intercept the codes and use them to gain access. Google prompt relies on a push notification, while SMS/phone call and authenticator apps require the user to re-enter a generated code. These methods can still be compromised by an attacker who has set up a fraudulent site. Security keys eliminate the middleman by verifying directly with the user's device, thereby significantly enhancing resistance to phishing attempts by ensuring that only a user's approved device can sign into the legitimate Google Cloud environment. Thus, security keys are the most robust method to counter man-in-the-middle attacks when compared to other available options.

Further research:

Google Cloud documentation on security keys: <https://cloud.google.com/identity/docs/security-keys>

FIDO Alliance website on FIDO2/WebAuthn: <https://fidoalliance.org/fido2/>

NIST guidelines on Multi-factor authentication: <https://csrc.nist.gov/publications/detail/sp/800-63b/final>

Question: 239

CertyIQ

You control network traffic for a folder in your Google Cloud environment. Your folder includes multiple projects and Virtual Private Cloud (VPC) networks. You want to enforce on the folder level that egress connections are limited only to IP range 10.58.5.0/24 and only from the VPC network "dev-vpc". You want to minimize implementation and maintenance effort.

What should you do?

- A.1. Leave the network configuration of the VMs in scope unchanged.
- 2. Create a new project including a new VPC network "new-vpc".
- 3. Deploy a network appliance in "new-vpc" to filter access requests and only allow egress connections from "dev-vpc" to 10.58.5.0/24.
- B.1. Leave the network configuration of the VMs in scope unchanged.
- 2. Enable Cloud NAT for "dev-vpc" and restrict the target range in Cloud NAT to 10.58.5.0/24.
- C.1. Attach external IP addresses to the VMs in scope.
- 2. Define and apply a hierarchical firewall policy on folder level to deny all egress connections and to allow egress to IP range 10.58.5.0/24 from network dev-vpc.
- D.1. Attach external IP addresses to the VMs in scope.
- 2. Configure a VPC Firewall rule in "dev-vpc" that allows egress connectivity to IP range 10.58.5.0/24 for all source addresses in this network.

Answer: C

Explanation:

The correct answer is C. Hierarchical firewall policies, applied at the folder level, offer centralized control over network traffic across all projects and VPCs within that folder, fulfilling the requirement of minimal implementation and maintenance effort. By attaching external IP addresses to the VMs, they become subject to the firewall rules. Applying a hierarchical firewall policy at the folder level is the most efficient way to implement a common network security policy across multiple VPCs without modifying individual project

network configurations. The policy allows a specific egress rule for the allowed destination range (10.58.5.0/24) originating from the specified VPC ("dev-vpc"), while a general deny rule blocks all other egress traffic. This directly enforces the specified restrictions at the desired level. This approach avoids complex network setups or the use of NAT gateways that can be more difficult to manage. Options A and B involve creating additional infrastructure (new VPC or NAT gateways) which is against the requirement of minimizing implementation and maintenance effort. Option D is also incorrect as it only configures firewall rules inside a single VPC ("dev-vpc"), not at the folder level, which is required by the question.

Authoritative links:

Hierarchical firewall policies: Explains how hierarchical firewall policies provide centralized control.

VPC firewall rules: Explains the basics of VPC firewall rules, which are used by the policy.

External IP Addresses: Explanation of using external IP addresses for VMs to connect to external networks.

Question: 240

CertyIQ

Your customer has an on-premises Public Key Infrastructure (PKI) with a certificate authority (CA). You need to issue certificates for many HTTP load balancer frontends. The on-premises PKI should be minimally affected due to many manual processes, and the solution needs to scale.

What should you do?

- A. Use Certificate Manager to issue Google managed public certificates and configure it at HTTP the load balancers in your infrastructure as code (IaC).
- B. Use a subordinate CA in the Google Certificate Authority Service from the on-premises PKI system to issue certificates for the load balancers.
- C. Use Certificate Manager to import certificates issued from on-premises PKI and for the frontends. Leverage the gcloud tool for importing.
- D. Use the web applications with PKCS12 certificates issued from subordinate CA based on OpenSSL on-premises. Use the gcloud tool for importing. Use the External TCP/UDP Network load balancer instead of an external HTTP Load Balancer.

Answer: B

Explanation:

The correct answer is **B. Use a subordinate CA in the Google Certificate Authority Service from the on-premises PKI system to issue certificates for the load balancers.**

Here's why:

Scalability and Minimal On-Premises Impact: Creating a subordinate CA within Google's Certificate Authority Service (CAS) allows for the delegation of certificate issuance without directly burdening the on-premises PKI. This approach provides a scalable solution as Google manages the infrastructure for certificate issuance, and the on-premises system acts as the root of trust, minimizing its direct involvement in day-to-day operations.

Automation: Google CAS is designed for automation. Once a subordinate CA is established, certificates can be issued programmatically for each load balancer frontend, eliminating the need for manual processes with the on-premises system.

Centralized Management: Google CAS provides a centralized location to manage the lifecycle of these certificates, which are directly integrated with Google Cloud load balancers, simplifying overall certificate management.

Security: The on-premises PKI remains the root of trust. This means that the subordinate CA inherits the security posture established by the on-premises PKI and benefits from Google's security infrastructure.

Let's examine why the other options are less suitable:

A. Use Certificate Manager to issue Google managed public certificates...: While easy to implement, this approach bypasses the requirement of using the on-premises PKI, which is a stated condition in the problem. It does not offer an integration point for the existing PKI infrastructure.

C. Use Certificate Manager to import certificates issued from on-premises PKI...: Manually importing each certificate from the on-premises PKI for each load balancer would be cumbersome and not scalable, contradicting the requirement for minimal manual processes. It would also create a burden on the on-premises PKI.

D. Use the web applications with PKCS12 certificates...and use the External TCP/UDP Network Load balancer instead...: This approach changes the load balancer type and requires handling certificates in the web applications, increasing complexity and violating the intended architecture. It doesn't address the core need for a managed, scalable certificate solution linked to the existing on-premises PKI.

Authoritative Links:

Google Cloud Certificate Authority Service: <https://cloud.google.com/certificate-authority-service>

Google Cloud Certificate Manager: <https://cloud.google.com/certificate-manager>

Creating Subordinate CA: <https://cloud.google.com/certificate-authority-service/docs/how-to/create-subordinate>

In summary, using a subordinate CA in Google CAS provides the best balance between leveraging the existing on-premises PKI, ensuring scalability and automation for issuing load balancer certificates, and minimizing manual effort. It aligns well with the requirements and best practices for cloud-based certificate management.

Question: 241

CertyIQ

You are developing a new application that uses exclusively Compute Engine VMs. Once a day, this application will execute five different batch jobs. Each of the batch jobs requires a dedicated set of permissions on Google Cloud resources outside of your application. You need to design a secure access concept for the batch jobs that adheres to the least-privilege principle.

What should you do?

- A.1. Create a general service account “g-sa” to orchestrate the batch jobs.
- 2. Create one service account per batch job “b-sa-[1-5]”. Grant only the permissions required to run the individual batch jobs to the service accounts and generate service account keys for each of these service accounts.
- 3. Store the service account keys in Secret Manager. Grant g-sa access to Secret Manager and run the batch jobs with the permissions of b-sa-[1-5].
- B.1. Create a general service account “g-sa” to execute the batch jobs.
- 2. Grant the permissions required to execute the batch jobs to g-sa.
- 3. Execute the batch jobs with the permissions granted to g-sa.
- C.1. Create a workload identity pool and configure workload identity pool providers for each batch job.
- 2. Assign the workload identity user role to each of the identities configured in the providers.
- 3. Create one service account per batch job “b-sa-[1-5]”, and grant only the permissions required to run the individual batch jobs to the service accounts.
- 4. Generate credential configuration files for each of the providers. Use these files to execute the batch jobs with the permissions of b-sa-[1-5].
- D.1. Create a general service account “g-sa” to orchestrate the batch jobs.
- 2. Create one service account per batch job “b-sa-[1-5]”, and grant only the permissions required to run the individual batch jobs to the service accounts.
- 3. Grant the Service Account Token Creator role to g-sa. Use g-sa to obtain short-lived access tokens for b-sa-[1-5] and to execute the batch jobs with the permissions of b-sa-[1-5].

Answer: D

Explanation:

The correct approach is **D**, leveraging service account impersonation for least privilege. Option A is flawed because managing and securing service account keys is inherently risky, contradicting security best practices. Option B violates the principle of least privilege by granting all required permissions to a single service account. Option C is overly complex for this scenario; Workload Identity is more suited for applications running outside of Google Cloud or in different environments like Kubernetes.

Option D is the most secure and efficient solution. It uses a single, orchestrating service account (g-sa) which doesn't have direct access to sensitive resources. Instead, g-sa is granted the "Service Account Token Creator" role which allows it to generate short-lived access tokens for the dedicated service accounts (b-sa-[1-5]). Each b-sa is configured with the minimum permissions necessary for its specific batch job. Thus, jobs run with the least privilege required. This design avoids persistent credentials, minimizing attack surfaces and enhancing security posture. The short-lived tokens further reduce the risk if a token is compromised. This method leverages Google Cloud's recommended practices for service account management.

For more information on service account impersonation, refer to:

[Google Cloud documentation on service account impersonation](#)

[Google Cloud documentation on managing service accounts](#)

[Best practices for using service accounts](#)

Question: 242

CertyIQ

Your Google Cloud environment has one organization node, one folder named "Apps", and several projects within that folder. The organizational node enforces the constraints/iam.allowedPolicyMemberDomains organization policy, which allows members from the terramearth.com organization. The "Apps" folder enforces the constraints/iam.allowedPolicyMemberDomains organization policy, which allows members from the flowlogistic.com organization. It also has the inheritFromParent: false property.

You attempt to grant access to a project in the "Apps" folder to the user .

What is the result of your action and why?

- A. The action succeeds because members from both organizations, terramearth.com or flowlogistic.com, are allowed on projects in the "Apps" folder.
- B. The action succeeds and the new member is successfully added to the project's Identity and Access Management (IAM) policy because all policies are inherited by underlying folders and projects.
- C. The action fails because a constraints/iam.allowedPolicyMemberDomains organization policy must be defined on the current project to deactivate the constraint temporarily.
- D. The action fails because a constraints/iam.allowedPolicyMemberDomains organization policy is in place and only members from the flowlogistic.com organization are allowed.

Answer: D

Explanation:

Here's a breakdown of why the correct answer is **D**, along with supporting information:

The key to this problem lies in understanding how organization policies, specifically constraints/iam.allowedPolicyMemberDomains, work with inheritance. The organization node sets a policy allowing members from terramearth.com. However, the "Apps" folder overrides this policy with its own, which allows only members from flowlogistic.com, because inheritFromParent: false is specified. This means the folder does not inherit the policy from its parent, the organization node.

When you attempt to grant access to , that user belongs to terramearth.com. The effective policy for the project within the "Apps" folder is the policy defined at the folder level which restricts access to only members of flowlogistic.com. Because doesn't belong to the allowed domain, your action

fails. The organization policy is not something that can be deactivated on the fly at the project level. Instead, the project's policy is a combination of what is inherited and then overridden. Therefore, it is not enough to add a policy at the project level to override the folder's restriction.

Therefore, only members from flowlogistic.com can be granted access to projects within the "Apps" folder. Options A, B, and C are all incorrect because they misinterpret the behavior of inheritance and policy overrides.

Authoritative Links:

Organization Policy Service: <https://cloud.google.com/resource-manager/docs/organization-policy/overview>
Understanding Policy Hierarchy: <https://cloud.google.com/resource-manager/docs/organization-policy/understanding-hierarchy>

constraints/iam.allowedPolicyMemberDomains constraint: https://cloud.google.com/resource-manager/docs/organization-policy/constraints-list#constraint_iam.allowedPolicyMemberDomains

Setting Organization Policies: <https://cloud.google.com/resource-manager/docs/organization-policy/setting-policies>

Question: 243

CertyIQ

An administrative application is running on a virtual machine (VM) in a managed group at port 5601 inside a Virtual Private Cloud (VPC) instance without access to the internet currently. You want to expose the web interface at port 5601 to users and enforce authentication and authorization Google credentials.

What should you do?

- A. Configure the bastion host with OS Login enabled and allow connection to port 5601 at VPC firewall. Log in to the bastion host from the Google Cloud console by using SSH-in-browser and then to the web application.
- B. Modify the VPC routing with the default route point to the default internet gateway. Modify the VPC Firewall rule to allow access from the internet 0.0.0.0/0 to port 5601 on the application instance.
- C. Configure Secure Shell Access (SSH) bastion host in a public network, and allow only the bastion host to connect to the application on port 5601. Use a bastion host as a jump host to connect to the application.
- D. Configure an HTTP Load Balancing instance that points to the managed group with Identity-Aware Proxy (IAP) protection with Google credentials. Modify the VPC firewall to allow access from IAP network range.

Answer: D

Explanation:

Okay, let's break down why option D is the correct solution and why the others are not ideal for this scenario.

The core requirement is to expose a web interface on port 5601, enforce authentication and authorization using Google credentials, and the application is currently isolated within a VPC without internet access.

Option D, configuring an HTTP Load Balancer with Identity-Aware Proxy (IAP), directly addresses all these needs. The load balancer provides a single point of access to the application's managed instance group. IAP acts as a gatekeeper, enforcing Google account authentication and authorization before allowing access to the application. Critically, IAP also handles the secure authentication without exposing the VM directly to the public internet. The VPC firewall rule is then modified to only allow traffic from IAP's known IP ranges, further securing the application. This setup is efficient, scalable, and integrates well with Google Cloud's identity and access management capabilities.

Option A, using a bastion host with OS Login, does not meet the requirement of directly exposing a web interface with authentication for all users. It's designed for SSH access by administrators, not web-based application usage.

Option B, exposing the application directly to the internet via a default internet gateway and firewall rule, is a security risk. It bypasses any authentication layer and exposes the application to potential attacks. This approach is highly discouraged for production environments.

Option C, using a bastion host for connection, while more secure than Option B, is still not optimal. It doesn't implement proper authentication for web access and is not scalable, requiring users to go through an intermediary system. It is better for administrative tasks, not for general user access to a web application.

In summary, option D provides the most secure, scalable, and user-friendly solution by utilizing the Identity-Aware Proxy with HTTP Load Balancing. It aligns with best practices for accessing applications protected with Google account authentication in Google Cloud.

Authoritative Links for Further Research:

Identity-Aware Proxy (IAP): <https://cloud.google.com/iap>

HTTP(S) Load Balancing: <https://cloud.google.com/load-balancing/docs/https>

Managed Instance Groups (MIGs): <https://cloud.google.com/compute/docs/instance-groups>

VPC Firewall Rules: <https://cloud.google.com/vpc/docs/firewalls>

Question: 244

CertyIQ

Your company's users access data in a BigQuery table. You want to ensure they can only access the data during working hours.

What should you do?

- A. Assign a BigQuery Data Viewer role along with an IAM condition that limits the access to specified working hours.
- B. Run a gsutil script that assigns a BigQuery Data Viewer role, and remove it only during the specified working hours.
- C. Assign a BigQuery Data Viewer role to a service account that adds and removes the users daily during the specified working hours.
- D. Configure Cloud Scheduler so that it triggers a Cloud Functions instance that modifies the organizational policy constraint for BigQuery during the specified working hours.

Answer: A

Explanation:

The correct answer is A. Here's a detailed justification:

Option A leverages IAM Conditions, a powerful feature in Google Cloud that allows you to define fine-grained access control based on attributes like date, time, or resource tags. By assigning the BigQuery Data Viewer role along with an IAM condition specifying working hours, you ensure users can only access the data during those defined times. This method is declarative, meaning it defines the desired state of access rather than relying on scripts or manual processes to manage access changes. This is a best practice for security and scalability.

Option B, using a gsutil script to add and remove roles, introduces operational overhead and is prone to errors. Script-based management can be difficult to maintain and debug and might lead to inconsistencies in access control.

Option C introduces unnecessary complexity by using a service account for managing user access and involves the risk of the service account having more privileges than needed, violating the principle of least privilege.

Option D, using Cloud Scheduler and Cloud Functions to modify organizational policy, is overkill for this scenario. Organizational policies are designed for broad, organization-wide constraints, not for time-based user access to specific resources like a BigQuery table. This approach is complex and not the intended use case for organizational policies.

IAM conditions directly address the requirement for time-based access control, providing a simpler, more secure, and scalable solution. This approach is also more auditable, as access policies are managed within the IAM framework.

Authoritative links:

IAM Conditions: <https://cloud.google.com/iam/docs/conditions-overview>

BigQuery IAM Roles: <https://cloud.google.com/bigquery/docs/access-control>

Principle of Least Privilege: <https://cloud.google.com/security/best-practices/least-privilege>

Question: 245

CertyIQ

You have placed several Compute Engine instances in a private subnet. You want to allow these instances to access Google Cloud services, like Cloud Storage, without traversing the internet. What should you do?

- A. Enable Private Google Access for the private subnet.
- B. Configure Private Service Connect for the private subnet's Virtual Private Cloud (VPC) and allocate an IP range for the Compute Engine instances.
- C. Reserve and assign static external IP addresses for the Compute Engine instances.
- D. Create a Cloud NAT gateway for the region where the private subnet is configured.

Answer: A

Explanation:

The correct answer is **A. Enable Private Google Access for the private subnet**. Here's a detailed justification:

Private Google Access allows virtual machine (VM) instances in a private subnet to reach Google APIs and services without using external IP addresses or traversing the public internet. This enhances security by keeping traffic within Google's network. When Private Google Access is enabled on a subnet, VMs within that subnet can communicate with Google Cloud services like Cloud Storage, BigQuery, and others using Google's internal network. This communication is done using internal IP addresses and does not require instances to have external IPs.

Option B, configuring Private Service Connect, is used to access services hosted within other VPC networks or external services. It's not the intended solution for accessing Google APIs from your own VPC. Option C, reserving static external IPs, would explicitly expose instances to the internet, which contradicts the goal of avoiding internet traversal. Finally, option D, Cloud NAT, is used for providing internet access to private instances, which is not necessary when only accessing Google APIs.

Therefore, enabling Private Google Access for the subnet directly addresses the requirement by allowing private VMs to use Google's internal network to reach its services, enhancing security and keeping traffic within the Google Cloud infrastructure. This is the most straightforward and efficient solution to the problem outlined.

Authoritative Links for Further Research:

Private Google Access: <https://cloud.google.com/vpc/docs/private-google-access>

Private Service Connect: <https://cloud.google.com/vpc/docs/private-service-connect>

Cloud NAT: <https://cloud.google.com/nat/docs/overview>

Question: 246

CertyIQ

Your organization relies heavily on Cloud Run for its containerized applications. You utilize Cloud Build for image creation, Artifact Registry for image storage, and Cloud Run for deployment. You must ensure that containers with vulnerabilities rated above a common vulnerability scoring system (CVSS) score of "medium" are not deployed to production. What should you do?

- A. Implement vulnerability scanning as part of the Cloud Build process. If any medium or higher vulnerabilities are detected, manually rebuild the image with updated components.
- B. Perform manual vulnerability checks post-build, but before Cloud Run deployment. Implement a manual security-engineer-driven remediation process.
- C. Configure Binary Authorization on Cloud Run to enforce image signatures. Create policies to allow deployment only for images passing a defined vulnerability threshold.
- D. Utilize a vulnerability scanner during the Cloud Build stage and set Artifact Registry permissions to block images containing vulnerabilities above "medium."

Answer: C

Explanation:

The correct answer is **C: Configure Binary Authorization on Cloud Run to enforce image signatures. Create policies to allow deployment only for images passing a defined vulnerability threshold.**

Here's why: Binary Authorization is a powerful Google Cloud service designed to enforce policies governing container deployments. It operates at the deployment stage, making it ideal for preventing vulnerable images from reaching production. By requiring image signatures, Binary Authorization establishes a chain of trust, verifying images are authorized before they're deployed. Furthermore, policy configuration enables setting a specific vulnerability threshold; in this case, blocking images with "medium" or higher CVSS scores, which directly addresses the requirement. This is a crucial security layer in the CI/CD pipeline, ensuring that only compliant images are promoted to production. Options A and B are insufficient due to their reliance on manual actions (A), or the possibility of human error (B). Option D focuses on blocking images in the registry, but this approach doesn't fully prevent someone from overriding such restriction. Binary Authorization provides a much stronger, policy-driven, and automated approach at the point of deployment. It works seamlessly with existing build and registry components, making it a perfect fit for this scenario.

Further Research:

Binary Authorization Overview: <https://cloud.google.com/binary-authorization/docs/overview>

Using Binary Authorization with Cloud Run: <https://cloud.google.com/binary-authorization/docs/how-to/enforce-cloud-run>

CVSS Scoring: <https://www.first.org/cvss/>

Question: 247

CertyIQ

You run a web application on top of Cloud Run that is exposed to the internet with an Application Load Balancer. You want to ensure that only privileged users from your organization can access the application. The proposed solution must support browser access with single sign-on. What should you do?

- A. Change Cloud Run configuration to require authentication. Assign the role of Cloud Run Invoker to the group of privileged users.
- B. Create a group of privileged users in Cloud Identity. Assign the role of Cloud Run User to the group directly on the Cloud Run service.
- C. Change the Ingress Control configuration of Cloud Run to internal and create firewall rules to allow only access from known IP addresses.

D. Activate Identity-Aware Proxy (IAP) on the Application Load Balancer backend. Assign the role of IAP-secured Web App User to the group of privileged users.

Answer: D

Explanation:

The correct answer is **D: Activate Identity-Aware Proxy (IAP) on the Application Load Balancer backend. Assign the role of IAP-secured Web App User to the group of privileged users.**

Here's why:

Identity-Aware Proxy (IAP) is specifically designed to control access to applications running behind load balancers based on user identity, not just network location. This perfectly aligns with the requirement to allow only privileged users from the organization access using browser-based single sign-on (SSO). IAP integrates seamlessly with Google Cloud Identity and allows you to grant access based on users' identities or groups.

Option A is insufficient because while Cloud Run authentication restricts access, it doesn't enforce user-specific access via single sign-on, instead it requires API Key based or service account based access which doesn't meet the requirement of browser access. Option B doesn't offer the single-sign on browser based access required by the question either. Also, Cloud Run User role is for managing the Cloud Run service not for accessing the application. Option C is unsuitable as restricting access via IP addresses doesn't address user-based access control and also won't work for users accessing from different IP addresses.

IAP, on the other hand, sits at the Application Load Balancer and intercepts all requests before they reach the backend. It verifies user identity against Google Cloud Identity and, if authorized, forwards the request to the Cloud Run application. Assigning the "IAP-secured Web App User" role to the privileged user group ensures only those authorized users will have access after the IAP authentication is successful. This provides a secure, user-centric, SSO-enabled solution for your web application.

Further Research:

[Identity-Aware Proxy overview](#)

[Setting up IAP with a load balancer](#)

[IAP roles](#)

Question: 248

CertyIQ

During a routine security review, your team discovered a suspicious login attempt to impersonate a highly privileged but regularly used service account by an unknown IP address. You need to effectively investigate in order to respond to this potential security incident. What should you do?

- A. Enable Cloud Audit Logs for the resources that the service account interacts with. Review the logs for further evidence of unauthorized activity.
- B. Review Cloud Audit Logs for activity related to the service account. Focus on the time period of the suspicious login attempt.
- C. Run a vulnerability scan to identify potentially exploitable weaknesses in systems that use the service account.
- D. Check Event Threat Detection in Security Command Center for any related alerts. Cross-reference your findings with Cloud Audit Logs.

Answer: D

Explanation:

Option D, checking Event Threat Detection in Security Command Center and cross-referencing with Cloud

Audit Logs, is the most effective initial response. Event Threat Detection (ETD) within Security Command Center is specifically designed to identify anomalous and potentially malicious activities, such as suspicious login attempts. It provides alerts based on predefined rules and machine learning models, offering a quicker path to identifying the specific login attempt and other related anomalies. Crucially, ETD is designed to surface significant events that warrant investigation. By starting here, the team can rapidly focus on the highest-risk areas.

Cloud Audit Logs, while valuable, record a broader range of activities and require more manual analysis to pinpoint a specific incident. Using ETD provides a focused starting point for the investigation, making the process more efficient. If ETD identifies alerts relating to the suspicious login, the team can then examine Cloud Audit Logs to understand the full context, timeline, and scope of the unauthorized access. Cross-referencing between ETD alerts and Cloud Audit Logs enables a more thorough investigation and facilitates informed decision-making about subsequent actions. The other options (A and C) are less relevant at this immediate stage. Enabling Cloud Audit Logs is unnecessary since they are already on by default. Running a vulnerability scan (C) is also not the priority during an active investigation of this type. The goal is to respond to a specific security incident, not a general vulnerability assessment. **Authoritative Links:**

Security Command Center Overview: <https://cloud.google.com/security-command-center/docs/concepts-overview>

Event Threat Detection: <https://cloud.google.com/security-command-center/docs/how-to-use-event-threat-detection>

Cloud Audit Logs Overview: <https://cloud.google.com/logging/docs/audit/>

Question: 249

CertyIQ

Your organization has an operational image classification model running on a managed AI service on Google Cloud. You are in a configuration review with stakeholders and must describe the security responsibilities for the image classification model. What should you do?

- A. Explain that using platform-as-a-service (PaaS) transfers security concerns to Google. Describe the need for strict API usage limits to protect against unexpected usage and billing spikes.
- B. Explain the security aspects of the code that transforms user-uploaded images using Google's service. Define Cloud IAM for fine-grained access control within the development team.
- C. Explain Google's shared responsibility model. Focus the configuration review on Identity and Access Management (IAM) permissions, secure data upload/download procedures, and monitoring logs for any potential malicious activity.
- D. Explain the development of custom network firewalls around the image classification service for deep intrusion detection and prevention. Describe vulnerability scanning tools for known vulnerabilities.

Answer: C

Explanation:

The correct answer is C because it accurately reflects the shared responsibility model inherent in cloud computing, specifically with Google Cloud's managed AI services. Option C emphasizes that while Google manages the underlying infrastructure, the customer is still responsible for securing their data and access to the service. This includes managing IAM permissions to control who can access and modify the model and its associated resources. Secure data upload/download procedures, are paramount to prevent data breaches or tampering, making them a shared responsibility. Monitoring logs is also a key aspect of security, allowing for the detection and investigation of suspicious activities. Option A is incorrect as it oversimplifies the shared responsibility model by stating that all security concerns are transferred to Google with PaaS which is not true. Option B focuses on aspects that while important, are less relevant to the overall security discussion during a configuration review. Option D suggests a level of control that's not typical for managed services, and creating custom network firewalls for managed AI services is an overly complex and often unnecessary

approach when IAM policies and network access control lists are more appropriate. Therefore, option C offers the most comprehensive and appropriate answer by focusing on the aspects of security that the user has control over and thus are accountable for.

Further research:

Google Cloud Shared Responsibility Model: <https://cloud.google.com/security/overview/shared-responsibility>

Cloud IAM: <https://cloud.google.com/iam/docs/overview>

Security Best Practices for Google Cloud: <https://cloud.google.com/security/best-practices>

Question: 250

CertyIQ

You are managing data in your organization's Cloud Storage buckets and are required to retain objects. To reduce storage costs, you must automatically downgrade the storage class of objects older than 365 days to Coldline storage. What should you do?

- A. Use Cloud Asset Inventory to generate a report of the configuration of all storage buckets. Examine the Lifecycle management policy settings and ensure that they are set correctly.
- B. Set up a CloudRun Job with Cloud Scheduler to execute a script that searches for and removes files older than 365 days from your Cloud Storage.
- C. Enable the Autoclass feature to manage all aspects of bucket storage classes.
- D. Define a lifecycle policy JSON with an action on SetStorageClass to COLDLINE with an age condition of 365 and matchStorageClass STANDARD.

Answer: D

Explanation:

The correct answer is D, defining a lifecycle policy to automatically transition objects to Coldline storage after 365 days. Cloud Storage lifecycle management policies are designed specifically for this purpose. They allow you to configure rules that automatically perform actions on objects based on their age, storage class, and other criteria. Option D leverages this functionality by setting an action to change the storage class to COLDLINE when an object's age exceeds 365 days and its current class is STANDARD. This is a cost-effective and automated solution that directly addresses the requirement.

Option A is incorrect because while Cloud Asset Inventory helps with understanding configurations, it does not execute the necessary transition itself. Option B is less efficient and more complex. Cloud Run and Cloud Scheduler introduce unnecessary overhead when lifecycle management is available natively in Cloud Storage. Manually deleting files, as mentioned in option B, isn't the goal; the goal is to change storage class to save costs, not delete the data. Option C's Autoclass is too broad and would manage all aspects of the storage class changes. While Autoclass would potentially address the cost reduction, it would not be the most granular approach.

Therefore, option D is the most suitable answer because it directly aligns with the best practice for managing object lifecycles in Google Cloud Storage, allowing for automated cost optimization using the platform's built-in features.

Authoritative Links:

Lifecycle Management: <https://cloud.google.com/storage/docs/lifecycle>

Setting Lifecycle Conditions: <https://cloud.google.com/storage/docs/lifecycle#condition>

Setting Lifecycle Actions: <https://cloud.google.com/storage/docs/lifecycle#action>

Storage Classes: <https://cloud.google.com/storage/docs/storage-classes>

Question: 251

Your organization has a centralized identity provider that is used to manage human and machine access. You want to leverage this existing identity management system to enable on-premises applications to access Google Cloud without hard coded credentials. What should you do?

- A.Enable Secure Web Proxy. Create a proxy subnet for each region that Secure Web Proxy will be deployed. Deploy an SSL certificate to Certificate Manager. Create a Secure Web Proxy policy and rules that allow access to Google Cloud services.
- B.Enable Workforce Identity Federation. Create a workforce identity pool and specify the on-premises identity provider as a workforce identity pool provider. Create an attribute mapping to map the on-premises identity provider token to a Google STS token. Create an IAM binding that binds the required role(s) to the external identity by specifying the project ID, workload identity pool, and attribute that should be matched.
- C.Enable Identity-Aware Proxy (IAP). Configure IAP by specifying the groups and service accounts that should have access to the application. Grant these identities the IAP-secured web app user role.
- D.Enable Workload Identity Federation. Create a workload identity pool and specify the on-premises identity provider as a workload identity pool provider. Create an attribute mapping to map the on-premises identity provider token to a Google STS token. Create a service account with the necessary permissions for the workload. Grant the external identity the Workload Identity user role on the service account.

Answer: D

Explanation:

The correct answer is D, enabling Workload Identity Federation. Here's why: The problem requires enabling on-premises applications to access Google Cloud resources without hardcoded credentials, using an existing centralized identity provider. Workload Identity Federation directly addresses this.

Workload Identity Federation allows on-premises applications (or workloads running outside Google Cloud) to assume Google Cloud service account identities without the need to store and manage long-lived service account keys. This is achieved by mapping external identities to temporary Google Security Token Service (STS) tokens. Option D outlines this process accurately: First, a workload identity pool is created, designating the on-premises identity provider as the source of truth for identities. Next, an attribute mapping translates the tokens from the on-premises system into something Google STS can understand. Finally, a service account is created with the needed permissions, and the external identity is granted permission to use that service account through the Workload Identity User role.

Option B, Workforce Identity Federation, is designed for human users, not applications. Option A, Secure Web Proxy, is for securing internet traffic, not directly for federating identities. Option C, Identity-Aware Proxy (IAP), adds access control to web applications but doesn't address the need for on-premises applications to obtain temporary credentials in a secure way. Workload Identity Federation is purpose-built for this scenario, providing a secure and centralized way to grant external workloads access to Google Cloud services. The federation process makes use of short-lived credentials that are derived from the on-premise identity provider, thus removing the requirement for service account keys and enhancing the security posture of the access.

Authoritative Links:

[Workload Identity Federation Overview](#)
[About Workforce Identity Federation](#)
[Secure Web Proxy](#)
[Identity-Aware Proxy](#)

Question: 252

Your organization is migrating a sensitive data processing workflow from on-premises infrastructure to Google

Cloud. This workflow involves the collection, storage, and analysis of customer information that includes personally identifiable information (PII). You need to design security measures to mitigate the risk of data exfiltration in this new cloud environment. What should you do?

- A. Encrypt all sensitive data in transit and at rest. Establish secure communication channels by using TLS and HTTPS protocols.
- B. Implement a Cloud DLP solution to scan and identify sensitive information, and apply redaction or masking techniques to the PII. Integrate VPC SC with your network security controls to block potential data exfiltration attempts.
- C. Restrict all outbound network traffic from cloud resources. Implement rigorous access controls and logging for all sensitive data and the systems that process the data.
- D. Rely on employee expertise to prevent accidental data exfiltration incidents.

Answer: B

Explanation:

The correct answer is **B**. Here's why:

Option B directly addresses the risk of data exfiltration for sensitive PII by implementing preventative and detective measures. Cloud Data Loss Prevention (DLP) is designed to identify, classify, and protect sensitive data like PII, actively scanning data in motion and at rest. Applying redaction or masking techniques obscures sensitive information, minimizing the risk if data is accidentally exposed. Integrating Virtual Private Cloud Service Controls (VPC SC) adds a network-level perimeter, preventing data from leaving the defined boundaries of your VPC, thus effectively blocking data exfiltration attempts.

Option A, while important for data protection, doesn't actively prevent data exfiltration at the level that option B does. Encryption protects against unauthorized access to data at rest and during transit but doesn't prevent intentional or accidental outbound transmission of sensitive information. TLS and HTTPS secure communication but don't address where the data might go once it's decrypted at its destination.

Option C, restricting all outbound traffic, is not feasible in most real-world scenarios and can hinder the utility of your workflow. While limiting outbound traffic is a part of zero-trust principles, it's often too restrictive without sophisticated configuration. Rigorous access controls and logging are essential security measures but aren't as direct a control against data exfiltration as DLP combined with VPC SC.

Option D is highly insufficient. Relying solely on employee expertise is unreliable and neglects the potential for human error or malicious intent. It's a very risky approach for protecting sensitive data.

In summary, option B takes a multi-layered approach using both data-centric (DLP) and network-centric (VPC SC) security mechanisms, providing active and targeted mitigation against data exfiltration. Cloud DLP proactively identifies and masks PII, while VPC SC restricts network traffic to prevent unauthorized external transmission, making it the most effective solution for the scenario presented.

Authoritative Links for Further Research:

Google Cloud DLP: <https://cloud.google.com/dlp/docs>

Google Cloud VPC Service Controls: <https://cloud.google.com/vpc-service-controls/docs>

Google Cloud Security Overview: <https://cloud.google.com/security/overview>

Question: 253

CertyIQ

Your organization is building a chatbot that is powered by generative AI to deliver automated conversations with internal employees. You must ensure that no data with personally identifiable information (PII) is communicated through the chatbot. What should you do?

- A. Encrypt data at rest for both input and output by using Cloud KMS, and apply least privilege access to the

encryption keys.

B. Discover and transform PII data in both input and output by using the Cloud Data Loss Prevention (Cloud DLP) API.

C. Prevent PII data exfiltration by using VPC-SC to create a safe scope around your chatbot.

D. Scan both input and output by using data encryption tools from the Google Cloud Marketplace.

Answer: B

Explanation:

The correct answer is **B. Discover and transform PII data in both input and output by using the Cloud Data Loss Prevention (Cloud DLP) API.**

Here's why:

Cloud Data Loss Prevention (Cloud DLP) is specifically designed to identify, classify, and protect sensitive data, including PII. It can scan text, images, and other data formats to detect patterns like email addresses, social security numbers, and phone numbers. By utilizing Cloud DLP both for the input to the chatbot and for its responses, you can ensure that PII is either masked, tokenized, or removed entirely before it is processed or communicated. This mitigates the risk of PII leaks through the chatbot interactions.

Option A, encrypting data at rest, addresses data security while stored, but doesn't prevent PII from being processed or transmitted through the chatbot. Encryption does not identify the data type and does not protect data during its processing.

Option C, using VPC Service Controls (VPC-SC), establishes a security perimeter but does not directly detect or transform PII within the data itself. VPC-SC controls network access but cannot inspect the content for PII.

Option D, using data encryption tools from the Google Cloud Marketplace, doesn't offer the specific PII detection and transformation capabilities that Cloud DLP provides. While encryption can protect data, it doesn't address the issue of PII flowing through the chatbot.

Cloud DLP is the ideal choice here because it focuses on data inspection and transformation, which is the core requirement for preventing PII leaks through a conversational AI system.

Authoritative links:

Cloud DLP Overview: <https://cloud.google.com/dlp/docs/overview>

Cloud DLP Concepts: <https://cloud.google.com/dlp/docs/concepts-inspecting-data>

Cloud DLP Transforms: <https://cloud.google.com/dlp/docs/concepts-transforms>

Question: 254

CertyIQ

Your organization has applications that run in multiple clouds. The applications require access to a Google Cloud resource running in your project. You must use short-lived access credentials to maintain security across the clouds. What should you do?

A. Create a managed workload identity. Bind an attested identity to the Compute Engine workload.

B. Create a service account key. Download the key to each application that requires access to the Google Cloud resource.

C. Create a workload identity pool with a workload identity provider for each external cloud. Set up a service account and add an IAM binding for impersonation.

D. Create a VPC firewall rule for ingress traffic with an allowlist of the IP ranges of the external cloud applications.

Answer: C

Explanation:

Option C, creating a workload identity pool with workload identity providers for each external cloud, is the correct approach for secure, short-lived access to Google Cloud resources from multi-cloud applications. This method leverages Workload Identity Federation, which allows applications running outside Google Cloud to authenticate as a Google Cloud service account without needing long-lived keys. Each external cloud becomes a workload identity provider. A service account in Google Cloud is then configured to be impersonated. This setup uses short-lived tokens issued by the external cloud's identity provider, mapped to the Google Cloud service account via the workload identity pool. This significantly enhances security by eliminating the risk of managing and exposing service account keys. Options A, B, and D are unsuitable. Option A doesn't directly allow external resources to assume a Google Cloud service account. Option B is a major security risk due to the management and distribution of long-lived service account keys. Option D manages network access but not service account access, failing to address the requirement for credential-based access. Option C provides the needed mechanism to generate short-lived credentials for access and reduces the security risk associated with key management.

Authoritative Links:

Workload Identity Federation: <https://cloud.google.com/iam/docs/workload-identity-federation>

Understanding Workload Identity: <https://cloud.google.com/kubernetes-engine/docs/how-to/workload-identity>

Impersonating service accounts: <https://cloud.google.com/iam/docs/impersonating-service-accounts>

Question: 255

CertyIQ

Your organization's financial modeling application is already deployed on Google Cloud. The application processes large amounts of sensitive customer financial data. Application code is old and poorly understood by your current software engineers. Recent threat modeling exercises have highlighted the potential risk of sophisticated side-channel attacks against the application while the application is running. You need to further harden the Google Cloud solution to mitigate the risk of these side-channel attacks, ensuring maximum protection for the confidentiality of financial data during processing, while minimizing application problems. What should you do?

- A. Enforce stricter access controls for Compute Engine instances by using service accounts, least privilege IAM policies, and limit network access.
- B. Implement a runtime library designed to introduce noise and timing variations into the application's execution which will disrupt side-channel attack.
- C. Migrate the application to Confidential VMs to provide hardware-level encryption of memory and protect sensitive data during processing.
- D. Utilize customer-managed encryption keys (CMEK) to ensure complete control over the encryption process.

Answer: C

Explanation:

The correct answer is **C. Migrate the application to Confidential VMs to provide hardware-level encryption of memory and protect sensitive data during processing.**

Here's the justification:

Confidential VMs directly address the stated risk of side-channel attacks by providing hardware-level encryption for memory. This ensures that data is encrypted even while in use by the virtual machine, making it significantly harder for attackers to exploit vulnerabilities to extract sensitive information. Traditional security measures like access controls (option A) and CMEK (option D) primarily focus on protecting data at rest and in transit but not during processing in memory, which is the focus of side-channel attacks. Introducing runtime

noise (option B) could potentially mitigate some side-channel attacks, but it introduces complexity and the possibility of application instability, and isn't as robust as hardware-based security. Confidential VMs minimize application changes and offer a higher level of protection by leveraging specialized hardware, making it the best solution for minimizing disruptions while maximizing protection against side-channel attacks. They provide a trust anchor by leveraging a specialized processor and encryption of memory on the host. This is a more proactive and fundamentally stronger defense mechanism against side-channel attacks than other software-based approaches. The goal is to protect data during processing, and Confidential VMs deliver this with minimal application impact.

Relevant Links:

Google Cloud Confidential Computing: <https://cloud.google.com/confidential-computing>

Confidential Virtual Machines: <https://cloud.google.com/compute/confidential-vm>

Side-Channel Attacks: https://en.wikipedia.org/wiki/Side-channel_attack

Question: 256

CertyIQ

Your organization has two VPC Service Controls service perimeters, Perimeter-A and Perimeter-B, in Google Cloud. You want to allow data to be copied from a Cloud Storage bucket in Perimeter-A to another Cloud Storage bucket in Perimeter-B. You must minimize exfiltration risk, only allow required connections, and follow the principle of least privilege. What should you do?

- A. Configure a perimeter bridge between Perimeter-A and Perimeter-B, and specify the Cloud Storage buckets as the resources involved.
- B. Configure a perimeter bridge between the projects hosting the Cloud Storage buckets in Perimeter-A and Perimeter-B.
- C. Configure an egress rule for the Cloud Storage bucket in Perimeter-A and a corresponding ingress rule in Perimeter-B.
- D. Configure a bidirectional egress/ingress rule for the Cloud Storage buckets in Perimeter-A and Perimeter-B.

Answer: A

Explanation:

The correct answer is **A. Configure a perimeter bridge between Perimeter-A and Perimeter-B, and specify the Cloud Storage buckets as the resources involved.**

Here's why:

VPC Service Controls perimeters establish security boundaries around Google Cloud resources. To allow controlled communication between perimeters, especially when data transfer is involved, perimeter bridges are crucial. They allow explicitly permitted traffic to pass between perimeters, respecting the principle of least privilege.

Option A directly addresses the requirement by creating a bridge between the two perimeters, specifically for the Cloud Storage buckets in question. This granular approach minimizes exfiltration risks by only allowing the necessary data flow between the designated resources, adhering to the security best practice of restricting access to the minimum required. Perimeter bridges allow only traffic between the resources specified, nothing else.

Option B, while potentially working, is less restrictive and less secure. Creating a bridge at the project level allows all resources within those projects to communicate, going against the principle of least privilege. This could inadvertently expose more resources than necessary, raising the risk of unintended data exfiltration.

Option C, using egress/ingress rules, is designed for use with VPC networks and subnets and wouldn't be appropriate for communication across VPC Service Control perimeters without using a perimeter bridge. A

perimeter bridge can configure rules for resources and projects in one perimeter with resources and projects from another.

Option D, while potentially functioning, is less granular and more permissive than a perimeter bridge. It creates a bidirectional opening, which is not needed for the specified use case. It increases the attack surface and is considered less secure because it is providing a bi-directional traffic flow which is not needed for the task.

Therefore, option A provides the most secure and least-privilege approach, making it the best choice.

Authoritative Links:

VPC Service Controls Overview: <https://cloud.google.com/vpc-service-controls/docs/overview>

VPC Service Controls Perimeter Bridge: <https://cloud.google.com/vpc-service-controls/docs/perimeter-bridge>

VPC Service Controls Egress Rules: <https://cloud.google.com/vpc-service-controls/docs/egress-rules>

Question: 257

CertyIQ

You are running code in Google Kubernetes Engine (GKE) containers in Google Cloud that require access to objects stored in a Cloud Storage bucket. You need to securely grant the Pods access to the bucket while minimizing management overhead. What should you do?

- A. Create a service account. Grant bucket access to the Pods by using Workload Identity Federation for GKE.
- B. Create a service account with keys. Store the keys in Secret Manager with a 30-day rotation schedule. Reference the keys in the Pods.
- C. Create a service account with keys. Store the keys as a Kubernetes secret. Reference the keys in the Pods.
- D. Create a service account with keys. Store the keys in Secret Manager. Reference the keys in the Pods.

Answer: A

Explanation:

The correct answer is A, using Workload Identity Federation for GKE. This method provides a secure and manageable way for GKE Pods to access Google Cloud services like Cloud Storage without needing to handle service account keys directly. Workload Identity Federation allows your GKE service accounts to act as a Google Cloud service account, enabling granular access control using IAM. By associating a Kubernetes service account with a Google Cloud service account, Pods using that Kubernetes service account automatically assume the permissions of the Google Cloud service account. This eliminates the need to create, store, and manage service account keys, which are security risks. Option B is less secure due to manual key management, which could be compromised if leaked or misconfigured. Managing secrets in Secret Manager introduces extra complexity. Option C storing keys as Kubernetes secrets is also a security risk since secrets are stored unencrypted by default within Kubernetes. The keys would need to be handled separately, including rotation, increasing security concerns. Option D creates an additional step of retrieving keys from Secret Manager which also adds security complexities and introduces a dependency. Workload Identity Federation simplifies the process and enhances security by eliminating the need for key management within the cluster. This approach is aligned with the principle of least privilege, granting only the necessary permissions to the Pods. Using Workload Identity also enables auditability, as actions are logged based on the assumed service account. This method provides a robust and highly recommended approach for access control in GKE.

Relevant links for further research:

Workload Identity Federation for GKE: <https://cloud.google.com/kubernetes-engine/docs/how-to/workload-identity>

IAM concepts: <https://cloud.google.com/iam/docs/overview>

Kubernetes Secrets: <https://kubernetes.io/docs/concepts/configuration/secret/>

Google Cloud Secret Manager: <https://cloud.google.com/secret-manager>

Question: 258

CertyIQ

Your organization is adopting Google Cloud and wants to ensure sensitive resources are only accessible from devices within the internal on-premises corporate network. You must configure Access Context Manager to enforce this requirement. These considerations apply:

- The internal network uses IP ranges 10.100.0.0/16 and 192.168.0.0/16.
- Some employees work remotely but connect securely through a company-managed virtual private network (VPN). The VPN dynamically allocates IP addresses from the pool 172.16.0.0/20.
- Access should be restricted to a specific Google Cloud project that is contained within an existing service perimeter.

What should you do?

- A.Create an access level named "Authorized Devices." Utilize the Device Policy attribute to require corporate-managed devices. Apply the access level to the Google Cloud project and instruct all employees to enroll their devices in the organization's management system.
- B.Create an access level titled "Internal Network Only." Add a condition with these attributes:
 - IP Subnetworks: 10.100.0.0/16, 192.168.0.0/16
 - Device Policy: Require OS as Windows or macOS. Apply this access level to the sensitive Google Cloud project.
- C.Create an access level titled "Corporate Access." Add a condition with the IP Subnetworks attribute, including the ranges: 10.100.0.0/16, 192.168.0.0/16, 172.16.0.0/20. Assign this access level to a service perimeter encompassing the sensitive project.
- D.Create a new IAM role called "InternalAccess. Add the IP ranges 10.100.0.0/16, 192.16.0.0/16, and 172.16.0.0/20 to the role as an IAM condition. Assign this role to IAM groups corresponding to on-premises and VPN users. Grant this role the necessary permissions on the resource within this sensitive Google Cloud project.

Answer: C

Explanation:

Option C is the correct approach because it directly addresses the requirement of restricting access to a specific Google Cloud project based on network location, utilizing Access Context Manager. Access Context Manager focuses on context-aware access control, which means decisions are based not only on who is accessing, but how they are accessing. Option C creates an access level called "Corporate Access" that defines a condition using the IP Subnetworks attribute, encompassing all the required IP address ranges: 10.100.0.0/16 (on-premises), 192.168.0.0/16 (on-premises), and 172.16.0.0/20 (VPN). This means only connections originating from these IP ranges will satisfy this access level. Furthermore, it specifies that this access level is assigned to a service perimeter containing the sensitive project, ensuring that the restriction applies to the designated resources. A service perimeter, a core component of VPC Service Controls, creates a secure boundary around cloud resources and enforces access control policies. Options A, B and D are incorrect. Option A requires device management, which is not a stated requirement. Option B only allows Windows or MacOS operating system which is incorrect and it does not include the VPN IP range. Option D is incorrect because IAM conditions only supports attribute-based access control (ABAC) which restricts access based on the attributes associated with resources, users or requests. The condition can not be used on IP addresses. Access Context Manager, in contrast, focuses on context-aware access control based on the attributes of the context of the access request (like IP addresses, device posture).

Authoritative Links:

Access Context Manager Overview: <https://cloud.google.com/access-context-manager/docs/overview>

Access Level Conditions: <https://cloud.google.com/access-context-manager/docs/access-level-conditions>

Question: 259

CertyIQ

Your team maintains 1PB of sensitive data within BigQuery that contains personally identifiable information (PII). You need to provide access to this dataset to another team within your organization for analysis purposes. You must share the BigQuery dataset with the other team while protecting the PII. What should you do?

- A.Utilize BigQuery's row-level access policies to mask PII columns based on the other team's user identities.
- B.Export the BigQuery dataset to Cloud Storage. Create a VPC Service Control perimeter and allow only their team's project access to the bucket.
- C.Implement data pseudonymization techniques to replace the PII fields with non-identifiable values. Grant the other team access to the pseudonymized dataset.
- D.Create a filtered copy of the dataset and replace the sensitive data with hash values in a separate project. Grant the other team access to this new project.

Answer: C

Explanation:

Option C, implementing data pseudonymization, is the most appropriate solution because it directly addresses the core requirement of protecting PII while enabling data analysis. Pseudonymization replaces identifiable information with non-identifying values, preserving data utility while minimizing re-identification risks. This approach allows the other team to perform their analysis without exposing sensitive data. Row-level access policies (Option A) are primarily for controlling access based on user identities, not masking data, and wouldn't effectively hide PII if the team has access to those rows. Exporting data to Cloud Storage with VPC Service Controls (Option B) protects the storage location but doesn't inherently obfuscate PII within the data. Option D, creating a filtered copy and hashing, is a more complicated approach than pseudonymization and would likely make the data less useful for analysis, and managing a separate project increases overhead. Pseudonymization, in contrast, allows the other team to work directly with a data set where the sensitive fields are not immediately identifiable. Also, hash functions are one-way and can only provide limited security benefits in this case as the resulting hash could still be subject to rainbow table or brute-force attacks, which are not as secure as proper pseudonymization techniques. Furthermore, this approach introduces added management and data synchronization complexities. Pseudonymization offers a more robust balance between data privacy and analytical utility.

For further information, consider researching the following:

Pseudonymization: <https://iapp.org/resources/article/pseudonymization-and-anonymization-the-difference/>

Data Masking: <https://cloud.google.com/dlp/docs/concepts-data-masking>

BigQuery Security: <https://cloud.google.com/bigquery/docs/security-overview>

VPC Service Controls: <https://cloud.google.com/vpc-service-controls/docs/overview>

Question: 260

CertyIQ

Your organization uses Google Cloud to process large amounts of location data for analysis and visualization. The location data is potentially sensitive. You must design a solution that allows storing and processing the location data securely, minimizing data exposure risks, and adhering to both regulatory guidelines and your organization's internal data residency policies. What should you do?

- A.Enable location restrictions on Compute Engine instances and virtual disk resources where the data is handled. Apply labels to tag geographic metadata for all stored data.
- B.Use the Cloud Data Loss Prevention (Cloud DLP) API to scan for sensitive location data before any storage or

processing. Create Cloud Storage buckets with global availability for optimal performance, relying on Cloud DLP results to filter and control data access.

C. Create regional Cloud Storage buckets with Object Lifecycle Management policies that limit data lifetime. Enable fine-grained access controls by using IAM conditions. Encrypt data with customer-managed encryption keys (CMEK) generated within specific Cloud KMS key locations.

D. Store data within BigQuery in a specified region by using dataset location configuration. Use authorized views and row-level security to enforce geographic access restrictions. Encrypt data within BigQuery tables by using customer-managed encryption keys (CMEK).

Answer: D

Explanation:

Option D is the most suitable solution because it directly addresses the requirements of secure storage, processing, and access control of sensitive location data while adhering to data residency policies. BigQuery's dataset location configuration ensures the data resides in the specified region, fulfilling data residency mandates. Authorized views and row-level security in BigQuery allow fine-grained access control based on user roles and geographical requirements, limiting exposure. Encrypting data within BigQuery tables using customer-managed encryption keys (CMEK) adds an extra layer of security, giving the organization control over encryption keys. Furthermore, BigQuery's analytical capabilities enable efficient processing and analysis of large datasets. Options A, B, and C are less optimal. Option A's reliance on location restrictions and labeling isn't as granular or secure as the approach D provides. Option B uses global storage with Cloud DLP, violating data residency. Option C's Object Lifecycle Management is for time limits, not geographical restriction, and its IAM conditions are less granular than the row-level options available within BigQuery.

Key Concepts Justifications:

Data Residency: Storing data in specific regions within BigQuery using the dataset location configuration ensures compliance with geographical data residency policies.

<https://cloud.google.com/bigquery/docs/locations>

Fine-grained Access Control: BigQuery's authorized views and row-level security enable granular control over data access, restricting users to only what they're authorized to see and based on geographic criteria.

<https://cloud.google.com/bigquery/docs/access-control>

Encryption with Customer-Managed Keys (CMEK): Using CMEK provides the organization with full control over data encryption keys, improving security. <https://cloud.google.com/kms/docs/cmek>

Data Analysis: BigQuery is optimized for large-scale data analysis, allowing efficient processing of location data. <https://cloud.google.com/bigquery/docs/introduction>

Question: 261

CertyIQ

Your organization utilizes Cloud Run services within multiple projects underneath the non-production folder which requires primarily internal communication. Some services need external access to approved fully qualified domain names (FQDN) while other external traffic must be blocked. Internal applications must not be exposed. You must achieve this granular control with allowlists overriding broader restrictions only for designated VPCs. What should you do?

A. Implement a global-level allowlist rule for the necessary FQDNs within a hierarchical firewall policy. Apply this policy across all VPCs in the organization and configure Cloud NAT without any additional filtering.

B. Create a folder-level deny-all rule for outbound traffic within a hierarchical firewall policy. Define FQDN allowlist rules in separate policies and associate them with the necessary VPCs. Configure Cloud NAT for these VPCs.

C. Create a project-level deny-all rule within a hierarchical structure and apply it broadly. Override this rule with separate FQDN allowlists defined in VPC-level firewall policies associated with the relevant VPCs.

D. Configure Cloud NAT with IP-based filtering to permit outbound traffic only to the allowlist d FQDNs' IP ranges. Apply Cloud NAT uniformly to all VPCs within the organization's folder structure.

Answer: B

Explanation:

Okay, let's break down why option B is the correct solution for this scenario.

The core requirement is to implement granular outbound traffic control for Cloud Run services, allowing specific FQDNs while blocking all other external traffic, and ensuring internal applications are not exposed. Hierarchical Firewall Policies (HFP) provide a centralized way to manage firewall rules across an organization, folders, and projects, allowing for inheritance and overriding of rules.

Option B uses this capability effectively. It starts with a folder-level deny-all outbound rule using an HFP, which creates a blanket restriction for all non-production projects. This satisfies the requirement of blocking most external traffic by default. Then, it defines separate HFP allowlist rules specifically for the required FQDNs, which are associated with relevant VPCs. These more specific allowlist rules, at the VPC level, override the broader folder-level deny-all rule within their respective VPCs. This ensures only traffic to approved FQDNs are permitted. Finally, Cloud NAT is configured for these VPCs, which is necessary to enable outbound internet access for the Cloud Run services.

Let's examine why other options are less suitable. Option A proposes a global-level allowlist, which doesn't provide the granular control needed since it will not restrict traffic to other non-approved external destinations. Option C suggests project-level deny rules, which don't leverage the hierarchical nature of HFPs effectively. Option D proposes IP-based filtering with Cloud NAT. While this might be possible, it can be complex to maintain, as IP ranges associated with FQDNs can change. FQDN based filtering is preferable, especially given that HFPs support it.

Option B provides the most secure and efficient solution aligning to Google's recommended practice of using a deny-by-default posture, and adding allow exceptions as needed.

Key Concepts:

Hierarchical Firewall Policies (HFP): A Google Cloud feature allowing for centralized management of firewall rules at the organization, folder, and project levels.

Deny-by-Default: A security principle where all traffic is blocked by default, and only explicitly allowed traffic is permitted.

Cloud NAT: A Google Cloud service that allows instances without external IP addresses to access the internet.

FQDN (Fully Qualified Domain Name): The complete domain name for a specific host, allowing for URL or DNS based filtering

Authoritative Links:

Hierarchical Firewall Policies: <https://cloud.google.com/vpc/docs/firewall-policies>

Cloud NAT: <https://cloud.google.com/nat/docs/overview>

Firewall Rule Concepts <https://cloud.google.com/vpc/docs/firewalls>

Question: 262

CertyIQ

Your organization hosts a sensitive web application in Google Cloud. To protect the web application, you've set up a virtual private cloud (VPC) with dedicated subnets for the application's frontend and backend components. You must implement security controls to restrict incoming traffic, protect against web-based attacks, and monitor internal traffic. What should you do?

A. Configure Cloud Firewall to permit allow-listed traffic only, deploy Google Cloud Armor with predefined rules for blocking common web attacks, and deploy Cloud Intrusion Detection System (IDS) to detect internal traffic anomalies.

B.Configure Google Cloud Armor to allow incoming connections, configure DNS Security Extensions (DNSSEC) on Cloud DNS to secure against common web attacks, and deploy Cloud Intrusion Detection System (Cloud IDS) to detect internal traffic anomalies.

C.Configure Cloud Intrusion Detection System (Cloud IDS) to monitor incoming connections, deploy Identity-Aware Proxy (IAP) to block common web attacks, and deploy Google Cloud Armor to detect internal traffic anomalies.

D.Configure Cloud DNS to secure incoming traffic, deploy Cloud Intrusion Detection System (Cloud IDS) to detect common web attacks, and deploy Google Cloud Armor to detect internal traffic anomalies.

Answer: A

Explanation:

Option A is the correct approach because it utilizes the appropriate Google Cloud security services to address the specific requirements outlined: restricting incoming traffic, protecting against web attacks, and monitoring internal traffic. Firstly, **Cloud Firewall** is the foundational network security layer, enabling you to define allow-list rules based on IP ranges, protocols, and ports, thus limiting incoming traffic to only what is explicitly permitted. This is critical for a defense-in-depth strategy. Secondly, **Google Cloud Armor** is a web application firewall (WAF) that provides protection against common web-based attacks like SQL injection and cross-site scripting by enforcing predefined or customized security rules. This specifically addresses the web application protection requirement. Lastly, **Cloud Intrusion Detection System (Cloud IDS)** monitors network traffic for malicious activity and anomalies, allowing you to detect potential threats inside the VPC including lateral movement attempts. This is vital for internal traffic monitoring. Option B incorrectly uses DNSSEC for web attack protection and does not effectively limit incoming traffic initially. Option C misuses IAP for web attack blocking and Cloud IDS for incoming connections, which is not its primary function. Option D misplaces DNS in the security context and Cloud IDS for web attacks. Therefore, option A offers the most comprehensive and appropriate security controls.

Authoritative Links:

Cloud Firewall: <https://cloud.google.com/firewall/docs>

Google Cloud Armor: <https://cloud.google.com/armor/docs>

Cloud Intrusion Detection System (Cloud IDS): <https://cloud.google.com/ids/docs>

Question: 263

CertyIQ

Your organization relies heavily on virtual machines (VMs) in Compute Engine. Due to team growth and resource demands, VM sprawl is becoming problematic. Maintaining consistent security hardening and timely package updates poses an increasing challenge. You need to centralize VM image management and automate the enforcement of security baselines throughout the virtual machine lifecycle. What should you do?

A.Use VM Manager to automatically distribute and apply patches to VMs across your projects. Integrate VM Manager with hardened, organization-standard VM images stored in a central repository.

B.Configure the sole-tenancy feature in Compute Engine for all projects. Set up custom organization policies in Policy Controller to restrict the operating systems and image sources that teams are allowed to use.

C.Create a Cloud Build trigger to build a pipeline that generates hardened VM images. Run vulnerability scans in the pipeline, and store images with passing scans in a registry. Use instance templates pointing to this registry.

D.Activate Security Command Center Enterprise. Use VM discovery and posture management features to monitor hardening state and trigger automatic responses upon detection of issues.

Answer: A

Explanation:

Justification for Answer A:

Option A, utilizing VM Manager alongside a centralized image repository, offers the most direct and comprehensive solution to the stated problem. VM Manager excels at automating patch management across a fleet of Compute Engine VMs, addressing the challenge of timely package updates. By integrating it with hardened, organization-standard VM images stored in a central repository, you ensure that all VMs are consistently deployed with the desired security baseline. This centralized approach simplifies image management and reduces the risk of configuration drift.

The key here is proactive management. Instead of reacting to vulnerabilities, VM Manager allows for automatic application of patches, thereby closing potential security gaps more quickly. VM Manager, through its ability to manage guest OS, is designed for patching, OS configuration, etc. When coupled with hardened images, this allows for a streamlined approach to consistently configuring machines. The central image repository ensures that teams use pre-approved and tested images, mitigating the VM sprawl issue by enforcing consistent deployment methods.

Options B, C, and D, while containing elements that are helpful, do not fully address the challenge. Option B, while focusing on isolation and policy enforcement, doesn't directly address patching and consistent image management. Option C, while useful for creating hardened images, is not a real time management tool like VM Manager. Option D is mainly about monitoring and reporting; it doesn't take care of patching or image management.

In summary, combining VM Manager's patching capabilities with a central repository of hardened images delivers the most effective approach for automating security baseline enforcement and mitigating VM sprawl, aligning with the core requirements of the scenario.

Supporting Links:

VM Manager Documentation: <https://cloud.google.com/vm-manager/docs>

Compute Engine Images Documentation: <https://cloud.google.com/compute/docs/images>

Google Cloud Patch Management with VM Manager: <https://cloud.google.com/blog/products/management-tools/google-cloud-patch-management-with-vm-manager-now-ga>

Question: 264

CertyIQ

Customers complain about error messages when they access your organization's website. You suspect that the web application firewall rules configured in Cloud Armor are too strict. You want to collect request logs to investigate what triggered the rules and blocked the traffic. What should you do?

- A. Modify the Application Load Balancer backend and increase the log sample rate to a higher number.
- B. Enable logging in the Application Load Balancer backend and set the log level to VERBOSE in the Cloud Armor policy.
- C. Change the configuration of suspicious web application firewall rules in the Cloud Armor policy to preview mode.
- D. Create a log sink with a filter for logs containing `redirected_by_security_policy` and set a BigQuery dataset as destination.

Answer: B

Explanation:

The correct answer is **B. Enable logging in the Application Load Balancer backend and set the log level to VERBOSE in the Cloud Armor policy.** Here's a detailed justification:

To effectively troubleshoot why users are encountering errors due to overly strict Cloud Armor rules, you need detailed logs of the requests being processed and how they interact with the security policy. Option B directly addresses this need.

Enabling logging in the Application Load Balancer backend provides a foundation for capturing traffic information. However, simply enabling logs is not enough; we need specific details about Cloud Armor's actions. Setting the Cloud Armor policy log level to VERBOSE is crucial. VERBOSE logging captures detailed information about how each request is evaluated against the Cloud Armor rules, including which rule was triggered and the associated action taken (like blocking). This allows you to pinpoint the specific rules causing the disruptions.

Option A is incorrect because increasing the sampling rate of the load balancer logs will only give you more general logs related to the traffic. This lacks the specific security policy details required for troubleshooting Cloud Armor rules. Option C, while helpful for understanding the impact of specific rules in a live environment, is not the primary mechanism for capturing detailed logging data for analysis. Preview mode will not generate logs; it just simulates the action. Option D is not optimal because while it uses the log sink method, this sink needs the verbose log to work. If the verbose log is not activated in Cloud Armor, you cannot use a sink.

By combining backend logging with VERBOSE Cloud Armor policy logging, you gain the detailed visibility needed to identify the problematic rules and refine your security configuration without affecting service availability. This makes Option B the most effective approach for diagnosing and resolving the customer-reported errors.

Relevant Concepts:

Cloud Armor: Google Cloud's web application firewall (WAF) service that protects applications from various web-based attacks.

Application Load Balancer (ALB): Distributes traffic across multiple backend servers to ensure high availability and scalability.

Logging: The process of recording events and activities for monitoring, analysis, and troubleshooting.

Log Level: Determines the amount of detail captured in logs. VERBOSE mode provides the most detailed information.

Security Policies: Rules configured within a WAF to filter or block malicious traffic.

Authoritative Links:

Cloud Armor Logging: <https://cloud.google.com/armor/docs/logging>

Application Load Balancer Logging: <https://cloud.google.com/load-balancing/docs/logging>

Question: 265

CertyIQ

Your organization must follow the Payment Card Industry Data Security Standard (PCI DSS). To prepare for an audit, you must detect deviations on an infrastructure-as-a-service level in your Google Cloud landing zone. What should you do?

- A. Create a data profile covering all payment relevant data types. Configure Data Discovery and a risk analysis job in Google Cloud Sensitive Data Protection to analyze findings.
- B. Use the Google Cloud Compliance Reports Manager to download the latest version of the PCI DSS report. Analyze the report to detect deviations.
- C. Create an Assured Workloads folder in your Google Cloud organization. Migrate existing projects into the folder and monitor for deviations in the PCI DSS.
- D. Activate Security Command Center Premium. Use the Compliance Monitoring product to filter findings that may not be PCI DSS compliant.

Answer: D

Explanation:

The correct answer is **D. Activate Security Command Center Premium. Use the Compliance Monitoring**

product to filter findings that may not be PCI DSS compliant.

Here's why: Security Command Center Premium includes a Compliance Monitoring feature specifically designed to assess and track adherence to industry standards like PCI DSS. It provides out-of-the-box detectors that scan your Google Cloud environment, identify deviations from the standard's requirements, and flag potential non-compliance issues. This automated approach is ideal for continuous monitoring and detection of infrastructure-as-a-service level deviations, which is the core need stated in the question.

Option A focuses on data-level compliance using Sensitive Data Protection, which is crucial but not the primary solution for infrastructure deviations. While useful, data profiling and risk analysis don't directly monitor PCI DSS compliance at the infrastructure level. Option B, using Compliance Reports Manager, only offers reports on Google's compliance, not your specific environment's. While these reports are informative, they don't actively help detect deviations within your project. Option C's Assured Workloads focuses on creating a hardened environment, but doesn't inherently provide real-time, automated deviation detection at the required granularity like Security Command Center's Compliance Monitoring.

Security Command Center's Compliance Monitoring offers a tailored and continuous view of your infrastructure's posture regarding PCI DSS. It allows you to proactively identify, investigate, and remediate deviations, preparing you more effectively for audits. This automation reduces the manual effort involved in compliance, making it the superior choice in this scenario.

Authoritative Links:

Security Command Center Compliance Monitoring: <https://cloud.google.com/security-command-center/docs/concepts-compliance-monitoring>

PCI DSS on Google Cloud: <https://cloud.google.com/security/compliance/pci-dss>

Security Command Center Overview: <https://cloud.google.com/security-command-center/docs/overview>

Question: 266

CertyIQ

Your organization is migrating a complex application to Google Cloud. The application has multiple internal components that interact with each other across several Google Cloud projects. Security is a major concern, and you must design an authorization scheme for administrators that aligns with the principles of least privilege and separation of duties. What should you do?

- A. Identify the users who will migrate the application, revoke the default user roles and assign the users with purposely created custom roles.
- B. Use multiple external identity providers (IdP) configured to use different SAML profiles and federate the IdPs for each application component.
- C. Configure multi-factor authentication (MFA) to enforce the use of physical tokens for all users who will migrate the application.
- D. No action needed. When a Google Cloud organization is created, the appropriate permissions are automatically assigned to all users in the domain.

Answer: A

Explanation:

The correct answer is A. Here's why:

Option A directly addresses the principles of least privilege and separation of duties. By revoking default, often overly permissive roles and assigning custom roles tailored to specific migration tasks, you ensure users only have the necessary permissions to complete their work. This reduces the potential attack surface and limits the blast radius in case of compromised credentials. Custom roles allow fine-grained control over access, aligning perfectly with security best practices.

Options B, C, and D are not appropriate for the core authorization challenge. Option B, using multiple federated IdPs, adds unnecessary complexity for internal authorization and does not address least privilege principles within Google Cloud projects. Option C, enforcing MFA, is vital for authentication, not authorization. While enhancing security, it does not dictate specific access levels. Option D is incorrect as Google Cloud does not automatically assign appropriate permissions; you must configure roles and permissions based on your needs.

In a complex multi-project environment, relying on default roles is a significant security risk, especially when numerous components interact. Custom roles defined using Identity and Access Management (IAM) within Google Cloud enable you to implement granular authorization policies for administrators, ensuring that each user only has access to the resources and actions necessary for their role. This approach significantly mitigates the risk of accidental or malicious misuse of elevated permissions and aligns with the principle of separation of duties. This minimizes lateral movement possibilities in the case of a security breach.

Authoritative links:

Google Cloud IAM Overview: <https://cloud.google.com/iam/docs/overview>

Creating and managing custom roles: <https://cloud.google.com/iam/docs/understanding-custom-roles>

Best practices for using IAM: <https://cloud.google.com/iam/docs/best-practices>

Question: 267

CertyIQ

Your organization operates in a highly regulated industry and needs to implement strict controls around temporary access to sensitive Google Cloud resources. You have been using Access Approval to manage this access, but your compliance team has mandated the use of a custom signing key. Additionally, they require that the key be stored in a hardware security module (HSM) located outside Google Cloud. You need to configure Access Approval to use a custom signing key that meets the compliance requirements. What should you do?

- A. Create a new asymmetric signing key in Cloud Key Management System (Cloud KMS) using a supported algorithm and grant the Access Approval service account the IAM signerVerifier role on the key.
- B. Export your existing Access Approval signing key as a PEM file. Upload the file to your external HSM and reconfigure Access Approval to use the key from the HSM.
- C. Create a signing key in your external HSM. Integrate the HSM with Cloud External Key Manager (Cloud EKM) and make the key available within your project. Configure Access Approval to use this key.
- D. Create a new asymmetric signing key in Cloud KMS and configure the key with a rotation period of 30 days. Add the corresponding public key to your external HSM.

Answer: C

Explanation:

The correct answer is **C**. Here's why:

Option C addresses all the requirements outlined in the scenario. The compliance team mandates a custom signing key stored outside of Google Cloud within an HSM. Cloud EKM (External Key Manager) is specifically designed to allow the use of encryption keys managed by external key management systems, including HSMs, with Google Cloud services. This directly satisfies the requirement of using an HSM. By creating the key in the external HSM and integrating it with Cloud EKM, the key becomes accessible to Google Cloud while remaining under the organization's control. Finally, configuring Access Approval to use this EKM-managed key completes the desired setup.

Option A is incorrect because Cloud KMS keys reside within Google Cloud and do not meet the external HSM requirement. Exporting the existing Access Approval key in Option B is also incorrect because the requirement specifies the use of a custom signing key stored in an external HSM rather than using the existing Access Approval managed key outside of Google Cloud. Option D, while using Cloud KMS, also does not meet the requirement of storing the key outside of Google Cloud. It also incorrectly focuses on key

rotation and using the public key in the HSM rather than integrating it using EKM.

Cloud EKM allows Google Cloud services to access data encrypted with keys stored in customer-managed key management systems. This approach is crucial for organizations with strict security and compliance requirements that mandate control over their encryption keys. Access Approval can be configured to use these EKM-managed keys for signing approval requests. This provides an auditable and secure access pathway for Google Cloud resources.

Supporting Links:

Cloud External Key Manager (Cloud EKM): <https://cloud.google.com/kms/docs/ekm>

Access Approval: <https://cloud.google.com/access-approval>

Access Approval with Cloud EKM: <https://cloud.google.com/access-approval/docs/ekm>

Question: 268

CertyIQ

Your organization has sensitive data stored in BigQuery and Cloud Storage. You need to design a solution that provides granular and flexible control authorization to read data. What should you do?

- A. Deidentify sensitive fields within the dataset by using data leakage protection within the Sensitive Data Protection services.
- B. Use Cloud External Key Manager (Cloud EKM) to encrypt the data in BigQuery and Cloud Storage.
- C. Grant identity and access management (IAM) roles and permissions to principals.
- D. Enable server-side encryption on the data in BigQuery and Cloud Storage.

Answer: C

Explanation:

The correct answer is **C. Grant identity and access management (IAM) roles and permissions to principals.** This is the most appropriate solution for granular and flexible control over data access in Google Cloud. IAM allows you to define who (principals) has what type of access (permissions) to specific resources (BigQuery datasets and Cloud Storage buckets). You can grant different roles at various levels of granularity - project, dataset, or even specific table/bucket level. This enables fine-grained control.

Options A, B, and D, while important for data security, do not directly address granular access control. De-identification (A) obscures sensitive data but doesn't control who can see it in the first place. Cloud EKM (B) enhances encryption but does not manage user access. Server-side encryption (D) similarly protects data at rest, but is separate from authorization mechanisms. IAM's ability to create a least-privilege approach ensures users only access data necessary for their tasks, minimizing risk. The flexibility of IAM allows you to adjust permissions based on changes in user roles and projects. Therefore, IAM is the core tool for access authorization, aligning with security best practices and the requirement for granular and flexible control.

For further research, consult these authoritative links:

Google Cloud IAM Documentation: <https://cloud.google.com/iam/docs>

BigQuery Access Control: <https://cloud.google.com/bigquery/docs/access-control-overview>

Cloud Storage IAM Permissions: <https://cloud.google.com/storage/docs/access-control/iam-permissions>

Question: 269

CertyIQ

Your organization is using Security Command Center Premium as a central tool to detect and alert on security threats. You also want to alert on suspicious outbound traffic that is targeting domains of known suspicious web services. What should you do?

- A. Create a DNS Server Policy in Cloud DNS and turn on logs. Attach this policy to all Virtual Private Cloud networks with internet connectivity.
- B. Forward all logs to Chronicle Security Information and Event Management. Create an alert for suspicious egress traffic to the internet.
- C. Create a Cloud Intrusion Detection endpoint. Connect this endpoint to all Virtual Private Cloud networks with internet connectivity.
- D. Create an egress firewall policy with Threat Intelligence as the destination. Attach this policy to all Virtual Private Cloud networks with internet connectivity.

Answer: B

Explanation:

Option B is the most appropriate solution because it leverages Chronicle Security Information and Event Management (SIEM) for advanced threat detection based on log analysis. Here's why:

Log Centralization: Chronicle SIEM is designed to ingest and analyze vast amounts of security logs from various sources, including Google Cloud. Forwarding logs to Chronicle provides a centralized view of network activity.

Advanced Threat Detection: Chronicle excels at identifying complex patterns and anomalies in log data that might indicate suspicious behavior. It has built-in threat intelligence and analysis capabilities that go beyond basic firewall rules.

Custom Alerting: Chronicle allows you to create custom alerts based on specific criteria. In this case, you can define rules that trigger alerts when outbound traffic is detected targeting domains known for malicious activity.

DNS Logs are Not Sufficient: Option A focuses on DNS logs, which can provide some insight into outbound communication. However, they don't capture the complete picture of network traffic (e.g., they don't contain HTTP/HTTPS traffic after DNS resolution) and are less granular for detailed security analysis compared to full network logs processed by a SIEM.

Cloud Intrusion Detection: Option C would be useful for analyzing traffic patterns, but it does not natively identify if destination IPs/domains are known for malicious activity. A Cloud Intrusion Detection endpoint alone won't tell you if traffic is going to known bad destinations. It's also not ideal for analysis on stored logs.

Firewall limitations: Option D is a good measure for prevention, but the question is focusing on detection and alerting of threats, using Security Command Center capabilities, not a prevention strategy by using a firewall policy. Also, firewalls don't allow you to create complex rules based on data enrichment or historic traffic patterns.

In summary, forwarding logs to Chronicle Security Information and Event Management provides the necessary analytical capabilities to detect and alert on suspicious outbound traffic targeting known bad domains, effectively addressing the problem statement.

Authoritative links for further research:

Chronicle SIEM: <https://cloud.google.com/chronicle/>

Security Command Center: <https://cloud.google.com/security-command-center>

Google Cloud Logging: <https://cloud.google.com/logging>

Question: 270

CertyIQ

You work for a healthcare provider that is expanding into the cloud to store and process sensitive patient data. You must ensure the chosen Google Cloud configuration meets these strict regulatory requirements:

- Data must reside within specific geographic regions.
- Certain administrative actions on patient data require explicit approval from designated compliance officers.
- Access to patient data must be auditable.

What should you do?

- A. Select a standard Google Cloud region. Restrict access to patient data based on user location and job function by using Access Context Manager. Enable both Cloud Audit Logging and Access Transparency.
- B. Deploy an Assured Workloads environment in an approved region. Configure Access Approval for sensitive operations on patient data. Enable both Cloud Audit Logs and Access Transparency.
- C. Deploy an Assured Workloads environment in multiple regions for redundancy. Utilize custom IAM roles with granular permissions. Isolate network-level data by using VPC Service Controls.
- D. Select multiple standard Google Cloud regions for high availability. Implement Access Control Lists (ACLs) on individual storage objects containing patient data. Enable Cloud Audit Logs.

Answer: B

Explanation:

The correct answer is **B** because it directly addresses all requirements outlined. Deploying an **Assured Workloads environment** (1) ensures data residency within specific geographic regions as it offers compliance with specific regulatory requirements including data location. This is critical for healthcare data due to stringent location-based regulations. **Access Approval** (2) provides the explicit approval mechanism for sensitive operations, requiring compliance officers to authorize actions before they occur. This satisfies the need for oversight of certain administrative activities. Enabling **Cloud Audit Logs** (3) and **Access Transparency** (4) guarantees comprehensive auditing of access to patient data and actions performed on it by both Google and customer personnel.

Option A fails to guarantee data residency and lacks the granular approval mechanism of Access Approval. Option C's redundancy and custom IAM roles, while beneficial, don't address data residency explicitly and lacks the explicit approval process as well as the assurance of Assured Workloads. Option D's reliance on ACLs is impractical for large-scale management and lacks the comprehensive oversight provided by Access Approval and Assured Workloads. In summary, Option B provides the most complete solution, offering a secure, compliant environment tailored to the healthcare provider's needs.

[1] **Assured Workloads:** <https://cloud.google.com/assured-workloads/docs> [2] **Access Approval:** <https://cloud.google.com/access-approval/docs> [3] **Cloud Audit Logs:** <https://cloud.google.com/logging/docs/audit> [4] **Access Transparency:** <https://cloud.google.com/access-transparency/docs>

Question: 271

CertyIQ

You work for a multinational organization that has systems deployed across multiple cloud providers, including Google Cloud. Your organization maintains an extensive on-premises security information and event management (SIEM) system. New security compliance regulations require that relevant Google Cloud logs be integrated seamlessly with the existing SIEM to provide a unified view of security events. You need to implement a solution that exports Google Cloud logs to your on-premises SIEM by using a push-based, near real-time approach. You must prioritize fault tolerance, security, and auto scaling capabilities. In particular, you must ensure that if a log delivery fails, logs are re-sent. What should you do?

- A. Create a Pub/Sub topic for log aggregation. Write a custom Python script on a Cloud Function. Leverage the Cloud Logging API to periodically pull logs from Google Cloud and forward the logs to the SIEM. Schedule the Cloud Function to run twice per day.
- B. Collect all logs into an organization-level aggregated log sink and send the logs to a Pub/Sub topic. Implement a primary Dataflow pipeline that consumes logs from this Pub/Sub topic and delivers the logs to the SIEM. Implement a secondary Dataflow pipeline that replays failed messages.
- C. Deploy a Cloud Logging sink with a filter that routes all logs directly to a syslog endpoint. The endpoint is based on a single Compute Engine hosted on Google Cloud that routes all logs to the on-premises SIEM. Implement a Cloud Function that triggers a retry action in case of failure.

D.Utilize custom firewall rules to allow your SIEM to directly query Google Cloud logs. Implement a Cloud Function that notifies the SIEM of a failed delivery and triggers a retry action.

Answer: B

Explanation:

Okay, let's break down why option B is the best solution for this scenario.

Option B proposes a robust, scalable, and fault-tolerant method for pushing Google Cloud logs to an on-premises SIEM, meeting all the requirements. First, it utilizes an organization-level aggregated log sink, ensuring that all relevant logs from across the Google Cloud environment are captured in one place. This is then routed to a Pub/Sub topic, creating a decoupling layer between the log source and consumption, enhancing system flexibility and scalability. Dataflow, a powerful stream processing service, is then used to consume and transform these logs before sending them to the on-premises SIEM. Critically, this approach includes a secondary Dataflow pipeline specifically to replay failed messages. This addresses the crucial requirement for reliable log delivery and fault tolerance. Dataflow's auto-scaling capabilities ensure the system can handle fluctuating log volumes efficiently. This architecture, based on publish/subscribe messaging and stream processing, is designed for near real-time data ingestion and ensures data resilience. The push-based model also aligns with the prompt's requirement. This is vastly superior to the pull approach of option A which introduces higher latency and is not as scalable. Options C and D also lack the sophisticated data processing and retry mechanism present in B and also do not adhere to the push based strategy. Therefore, Option B stands out for its complete solution that addresses all requirements including fault tolerance, scalability, security, and adherence to near-real time push based log forwarding.

Further Research:

Google Cloud Logging: <https://cloud.google.com/logging>

Pub/Sub: <https://cloud.google.com/pubsub>

Dataflow: <https://cloud.google.com/dataflow>

Aggregated Log Sinks: <https://cloud.google.com/logging/docs/export/aggregated-sinks>

Question: 272

CertyIQ

You work for a global company. Due to compliance requirements, certain Compute Engine instances that reside within specific projects must be located exclusively in cloud regions within the European Union (EU). You need to ensure that existing non-compliant workloads are remediated and prevent future Compute Engine instances from being launched in restricted regions. What should you do?

- A. Use a third-party configuration management tool to monitor the location of Compute Engine instances. Automatically delete or migrate non-compliant instances, including existing deployments.
- B. Deploy a Security Command Center source to detect Compute Engine instances created outside the EU. Use a custom remediation function to automatically relocate the instances, run the function once a day.
- C. Use organization policy constraints in Resource Manager to enforce allowed regions for Compute Engine instance creation within specific projects.
- D. Set an organization policy that denies the creation of Compute Engine instances outside the EU. Apply the policy to the appropriate projects. Identify existing non-compliant instances and migrate the instances to compliant EU regions.

Answer: D

Explanation:

The correct answer is **D** because it directly addresses both the remediation of existing non-compliant instances and the prevention of future violations using Google Cloud's native capabilities. Option D leverages **Organization Policies**, which are a fundamental part of Google Cloud's Resource Manager, designed to

centrally control configurations across an organization. By setting a constraint that denies Compute Engine instance creation outside the EU, future non-compliance is prevented. Crucially, it also includes the vital step of identifying and migrating existing non-compliant instances.

Option A relies on a third-party tool, which adds unnecessary complexity and potentially introduces a single point of failure, deviating from the principle of using native tools for core governance tasks. Option B uses Security Command Center, which is excellent for threat detection but isn't the primary method for enforcing region restrictions; the remediation approach is also suboptimal and not consistently triggered. Option C only addresses the preventative aspect of the problem and doesn't provide any guidance on how to remediate existing resources. The most effective and simplest way to enforce regional restrictions is through organization policy constraints.

Therefore, using organization policies as in option D is the recommended approach because it is direct, efficient, and uses Google Cloud's built-in tools for policy management. This approach aligns with best practices for security and compliance management in Google Cloud.

Relevant documentation:

Organization policies: <https://cloud.google.com/resource-manager/docs/organization-policy/overview>

Compute Engine constraints: <https://cloud.google.com/resource-manager/docs/organization-policy/org-policy-constraints#compute-constraints>

Question: 273

CertyIQ

You are working with developers to secure custom training jobs running on Vertex AI. For compliance reasons, all supported data types must be encrypted by key materials that reside in the Europe region and are controlled by your organization. The encryption activity must not impact the training operation in Vertex AI. What should you do?

- A. Encrypt the code, training data, and metadata with Google default encryption. Use customer-managed encryption keys (CMEK) for the trained models exported to Cloud Storage buckets.
- B. Encrypt the code, training data, metadata, and exported trained models with customer-managed encryption keys (CMEK).
- C. Encrypt the code, training data, and exported trained models with customer-managed encryption keys (CMEK).
- D. Encrypt the code, training data, and metadata with Google default encryption. Implement an organization policy that enforces a constraint to restrict the Cloud KMS location to the Europe region.

Answer: B

Explanation:

Okay, let's break down why option B is the correct answer.

The core requirement is to encrypt all supported data types related to Vertex AI training jobs with customer-managed encryption keys (CMEK) residing in Europe. This requirement stems from compliance needs, emphasizing control over encryption keys and their geographical location.

Option B, "Encrypt the code, training data, metadata, and exported trained models with customer-managed encryption keys (CMEK)", directly addresses this need. CMEK provides you with full control over the encryption keys, allowing you to choose the region (Europe in this case) where they are stored and managed using Cloud KMS. By using CMEK for all relevant data – code, training data, metadata, and exported models – you ensure that every step of the training process is protected by your keys and in your desired region.

Options A, C, and D fall short of the complete encryption mandate. Option A only applies CMEK to exported models, leaving the training data and associated metadata exposed with Google-managed encryption, not fulfilling the key control requirement. Option C misses the metadata leaving this essential data inadequately

secured. Option D does address key location by using policy but not to the encryption itself, failing on requirement to protect the data with keys you control.

The key concept here is the separation of responsibilities with CMEK. Google handles the encryption/decryption, but you retain control of the encryption keys, aligning with the compliance requirement. The key location constraint can be applied as a secondary enforcement mechanism. CMEK has no operational impact to the training in Vertex AI and it is configured as an attribute of the Vertex AI objects or resources.

Therefore, Option B is the only option that completely satisfies the given requirements by applying the correct encryption method and scope with the correct location.

Authoritative Links for further research:

Google Cloud CMEK: <https://cloud.google.com/kms/docs/cmek>

Vertex AI CMEK: <https://cloud.google.com/vertex-ai/docs/general/cmek>

Cloud KMS: <https://cloud.google.com/kms>

Question: 274

CertyIQ

Your EU-based organization stores both Personally Identifiable Information (PII) and non-PII data in Cloud Storage buckets across multiple Google Cloud regions. EU data privacy laws require that the PII data must not be stored outside of the EU. To help meet this compliance requirement, you want to detect if Cloud Storage buckets outside of the EU contain healthcare data. What should you do?

- A. Create a Sensitive Data Protection job. Specify the infoType of data to be detected and run the job across all Google Cloud Storage buckets.
- B. Create a log sink with a filter on resourceLocation.currentLocations. Trigger an alert if a log message appears with a non- EUcountry.
- C. Activate Security Command Center Premium. Use compliance monitoring to detect resources that do not follow the applicable healthcare regulation.
- D. Enforce the gcp.resourceLocations organization policy and add "EU" in a custom rule that only applies on resources with the tag "healthcare".

Answer: A

Explanation:

The correct answer is **A. Create a Sensitive Data Protection job. Specify the infoType of data to be detected and run the job across all Google Cloud Storage buckets.**

Here's why:

Option A directly addresses the core requirement: detecting healthcare PII data within Cloud Storage buckets, irrespective of their location. Sensitive Data Protection (formerly DLP) excels at this task by analyzing content and identifying sensitive information based on predefined infoTypes (e.g., names, addresses, medical records). By scanning all buckets, it can flag those outside the EU containing PII. This approach is proactive and identifies the specific problem data location.

Option B is inadequate as logs don't contain the content of the data files; they only capture operations/changes related to storage buckets. Logs can indicate the location of a bucket, but not whether sensitive data within the bucket resides outside of the EU. A log sink could potentially detect a new bucket created in a non-EU location but it wouldn't identify if PII exists in those buckets.

Option C, Security Command Center Premium, is valuable for broader security posture management and compliance, but it doesn't have the granular content analysis capability that is essential for detecting specific

PII as detailed by infoType in files like Sensitive Data Protection does. While it can detect policy violations and misconfigurations it does not inspect the data within a resource. It cannot identify that specific PII data is located in the wrong location.

Option D, using resource location policies, prevents new resource creation outside a designated location but does nothing about data already present. It also doesn't find specific PII data inside existing resources and is therefore not a means of detecting the data that is required. It's a good preventative control, not a detection method for previously stored data.

Therefore, only option A, utilizing Sensitive Data Protection, offers the required combination of deep content inspection and sensitive data identification to fulfill the organization's compliance requirements.

Authoritative Links:

Sensitive Data Protection: <https://cloud.google.com/dlp/docs>

InfoTypes: <https://cloud.google.com/dlp/docs/infotypes-reference>

Cloud Storage: <https://cloud.google.com/storage/docs>

Security Command Center: <https://cloud.google.com/security-command-center/docs>

Resource Location Policies: <https://cloud.google.com/resource-manager/docs/organization-policy/defining-locations>

Question: 275

CertyIQ

Your organization is migrating business critical applications to Google Cloud across multiple projects. You only have the required IAM permission at the Google Cloud organization level. You want to grant project access to support engineers from two partner organizations using their existing identity provider (IdP) credentials. What should you do?

- A. Create two single sign-on (SSO) profiles for the internal and partner IdPs by using SSO for Cloud Identity.
- B. Create users manually by using the Google Cloud console. Assign the users to groups.
- C. Create two workforce identity pools for the partner IdPs.
- D. Sync user identities from their existing IdPs to Cloud Identity by using Google Cloud Directory Sync (GCDS).

Answer: D

Explanation:

Okay, let's break down why option D is the correct solution for granting partner engineers access to Google Cloud projects, while explaining why the other options aren't suitable.

The core requirement is to enable engineers from two external partner organizations to access Google Cloud resources using their existing IdP credentials. We also know that the user has organization-level IAM permissions and needs to grant project-level access.

Option D, "Sync user identities from their existing IdPs to Cloud Identity by using Google Cloud Directory Sync (GCDS)," is the most appropriate because:

Identity Federation: This method leverages the concept of identity federation. GCDS synchronizes user identities and group memberships from the partners' existing IdPs (like Active Directory or other SAML-based providers) to Google Cloud Identity. This avoids creating and managing separate user accounts within Google Cloud.

Seamless Access: Partner engineers can then authenticate to Google Cloud using their familiar credentials, which simplifies their workflow and reduces management overhead.

Centralized Management: After synchronization, you can manage access to Google Cloud projects through IAM roles and groups within Google Cloud.

Scalability: GCDS supports synchronization from various directories, making it suitable for multiple partners and scaling as required.

Let's look at why the other options are less suitable:

Option A (SSO Profiles with Cloud Identity): Creating SSO profiles directly within Cloud Identity would force partner organizations to use Cloud Identity directly and change their existing setups, requiring extra overhead. Also, Cloud Identity doesn't act as an IDP for others.

Option B (Manual User Creation): Manually creating users is not scalable or sustainable, especially for partner organizations with potentially changing personnel. It adds administrative overhead and creates a local user management process within Google Cloud that is difficult to maintain.

Option C (Workforce Identity Pools): Workforce identity pools are more focused on granting external access to applications rather than providing direct access to cloud resources and projects. They don't sync users and identities.

In summary, Option D effectively leverages Google Cloud Directory Sync to bridge the identity management gap and enable partner access to your Google Cloud projects using their existing credentials, promoting secure and efficient collaboration.

Authoritative Links for Further Research:

Google Cloud Directory Sync (GCDS): <https://support.google.com/a/answer/1069333?hl=en>

Identity Federation: <https://cloud.google.com/iam/docs/federated-identities>

Cloud Identity: <https://cloud.google.com/identity/>

Question: 276

CertyIQ

You are creating a secure network architecture. You must fully isolate development and production environments, and prevent any network traffic between the two environments. The network team requires that there is only one central entry point to the cloud network from the on-premises environment. What should you do?

- A. Create one Virtual Private Cloud (VPC) network per environment. Add the on-premises entry point to the production VPC. Peer the VPCs with each other and create firewall rules to prevent traffic.
- B. Create one shared Virtual Private Cloud (VPC) network and use it as the entry point to the cloud network. Create separate subnets per environment. Create firewall rules to prevent traffic.
- C. Create one Virtual Private Cloud (VPC) network per environment. Create a VPC Service Controls perimeter per environment and add one environment VPC to each.
- D. Create one Virtual Private Cloud (VPC) network per environment. Create one additional VPC for the entry point to the cloud network. Peer the entry point VPC with the environment VPCs.

Answer: D

Explanation:

Okay, let's break down why option D is the correct solution and why the others are not ideal for isolating environments and maintaining a single entry point.

Justification for Option D:

Option D proposes creating separate VPC networks for the development and production environments. This establishes a fundamental layer of isolation, as VPCs are logically isolated network spaces within Google Cloud. It further suggests creating a dedicated VPC solely for the on-premises entry point. This crucial "entry point VPC" acts as a central hub, routing traffic from the on-premises network into the respective environment VPCs via VPC peering. VPC peering enables private network communication across VPCs, eliminating the need to traverse the public internet. This three-VPC architecture ensures complete network isolation between dev and prod environments while maintaining a single, controlled entry point. The

separation avoids any chance of direct network traffic between the environments.

Why Other Options are Incorrect:

Option A: While creating separate VPCs is a good first step, VPC peering with firewall rules for traffic blocking is insufficient. Peering, by nature, creates a network connection, which could be accidentally or maliciously misconfigured. This method does not provide hard isolation needed and depends on correct firewall configuration.

Option B: Using a single shared VPC for both environments is flawed. Even with separate subnets and firewall rules, a shared VPC increases the risk of misconfigurations or accidental access, defeating the goal of complete isolation. While subnets create segmentation, they don't enforce the strong isolation that separate VPCs provide.

Option C: Using VPC Service Controls (VPC SC) per environment with VPCs adds data exfiltration protection, but it does not address the core network isolation requirement. VPC SC focuses on data governance, not on strict network segregation, and it doesn't replace the need for distinct VPCs to prevent traffic flow.

Key Concepts and Why they Support Option D:

Virtual Private Cloud (VPC): VPCs provide logically isolated networks. Using separate VPCs for development and production ensures no direct network paths exist between them without explicit peering.

VPC Peering: Allows private network communication between VPCs. By peering environment VPCs with the entry-point VPC, you maintain a controlled routing mechanism without exposing the environments directly to the on-premises network.

Least Privilege: Option D upholds the principle of least privilege by minimizing the network paths and potential exposure to each environment.

Network Segmentation: Option D employs strong network segmentation through the use of entirely separate VPC networks.

Authoritative Links:

VPC Overview: <https://cloud.google.com/vpc/docs/vpc>

VPC Peering: <https://cloud.google.com/vpc/docs/vpc-peering>

VPC Service Controls Overview: <https://cloud.google.com/vpc-service-controls/docs/overview>

In conclusion, option D correctly addresses the need for complete environment isolation and a singular entry point by utilizing the core network features of Google Cloud (separate VPCs and peering) for a secure and well-structured solution.

Question: 277

CertyIQ

You work for a large organization that is using Cloud Identity as the identity provider (IdP) on Google Cloud. Your InfoSec team has mandated the enforcement of a strong password with a length between 12 and 16 characters for all users. After configuring this requirement, users are still able to access the Google Cloud console with passwords that are less than 12 characters. You need to fix this problem within the Admin console. What should you do?

- A. Review each user's password configuration and reset existing passwords.
- B. Review the organization password management setting and select Enforce password policy at the next sign-in.
- C. Review each user's password configuration and select Enforce strong password.
- D. Review the organization password management setting and select Enforce strong password.

Answer: D

Explanation:

The correct answer is **D. Review the organization password management setting and select Enforce strong password.**

Here's the justification:

The problem stems from the fact that while a password policy might be configured, it isn't necessarily enforced by default. Cloud Identity's password policy settings apply at the organization level, not individually for each user. Therefore, reviewing individual user password configurations (options A and C) is ineffective. The enforcement needs to be applied organization-wide. Option B suggests "Enforce password policy at the next sign-in," which sounds like it might work, but it's not the correct setting in Cloud Identity's admin console for enforcing the strength of the password (length, complexity). Option D, "Enforce strong password," is the specific setting within the organizational password management section that activates the password strength requirements, including the specified 12-16 character length. This action makes Cloud Identity require users to adhere to the configured password policy when authenticating. In essence, configuring the password policy is one step; enforcing it through the correct setting is another. By selecting "Enforce strong password" at the organization level, the organization ensures that all users adhere to the previously defined password strength policy. This enforces the minimum length requirement of 12 characters for all user passwords upon their next sign in or any new password creation.

Here are some authoritative links for further research:

Google Workspace Admin Help - Set password requirements for users:

<https://support.google.com/a/answer/33363>

Google Cloud Identity Documentation - Password management: (This is a general documentation set; specific pages can be accessed through search within it, e.g. on managing password policies)

<https://cloud.google.com/identity/docs>

Google Workspace Admin Help - Enforce strong passwords: (This specific setting might not have a standalone article, but it's discussed within the 'Set password requirements' documentation linked above)

Question: 278

CertyIQ

Your organization is preparing to build business services in Google Cloud for the first time. You must determine where to apply appropriate controls or policies. You must also identify what aspects of your cloud deployment are managed by Google. What should you do?

- A. Model your deployment on the Google Enterprise foundations blueprint. Follow the blueprint exactly and rely on the blueprint to maintain the posture necessary for your business.
- B. Use the Risk Manager tool in the Risk Protection Program to generate a report on your cloud security posture. Obtain cyber insurance coverage.
- C. Subscribe to the Google Cloud release notes to keep up on product updates and when new services are available. Evaluate new services for appropriate use before enabling their API.
- D. Study the shared responsibilities model. Depending on your business scenario, you might need to consider your responsibilities based on the location of your business offices, your customers, and your data.

Answer: D

Explanation:

The correct answer is D because understanding the shared responsibility model is crucial for establishing appropriate security controls in the cloud. This model dictates that while Google manages the underlying infrastructure (hardware, software, facilities), the customer is responsible for securing what they put "in" the cloud (data, applications, access, etc.). Option A is inadequate because while blueprints offer valuable starting points, they aren't a one-size-fits-all solution and might not fully address specific business needs or

compliance requirements. Option B focuses on risk assessment and insurance, which are important but don't address the core issue of understanding responsibilities. Option C highlights staying updated on product releases, but it doesn't tackle the foundational aspect of the shared responsibility model. Option D correctly emphasizes the need to analyze responsibilities considering factors like business location, customer base, and data location, as these all affect which controls must be implemented and who is responsible. Failing to understand these aspects would result in security gaps and potential risks. Specifically, data location influences compliance requirements (like GDPR) and requires different access controls. Business locations might necessitate network segmentation or specific security policies. The customer base might involve different contractual agreements. Therefore, a nuanced approach is needed, not just following blueprints or getting insurance. The shared responsibility model is fundamental to cloud security, and option D most accurately reflects this understanding.

Here are some resources to further research the shared responsibility model:

Google Cloud's Shared Responsibility Model: <https://cloud.google.com/security/overview/shared-responsibility>

NIST Special Publication 800-44 Version 2, Cloud Computing:

<https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-144.pdf> (While this document is a bit older, it provides a foundational understanding of the model)

Cloud Security Alliance (CSA) - The Shared Responsibility Model:

<https://cloudsecurityalliance.org/blog/2020/08/21/the-shared-responsibility-model-what-is-it-and-why-should-i-care/>

Question: 279

CertyIQ

Your organization operates a hybrid cloud environment and has recently deployed a private Artifact Registry repository in Google Cloud. On-premises developers cannot resolve the Artifact Registry hostname and therefore cannot push or pull artifacts. You've verified the following:

- Connectivity to Google Cloud is established by Cloud VPN or Cloud Interconnect.
- No custom DNS configurations exist on-premises.
- There is no route to the internet from the on-premises network.

You need to identify the cause and enable the developers to push and pull artifacts. What is likely causing the issue and what should you do to fix the issue?

- A.On-premises DNS servers lack the necessary records to resolve private Google API domains. Create DNS records for `restricted.googleapis.com` or `private.googleapis.com` pointing to Google's published IP ranges.
- B.Developers must be granted the `artifactregistry.writer` IAM role. Grant the relevant developer group this role.
- C.Private Google Access is not enabled for the subnet hosting the Artifact Registry. Enable Private Google Access for the appropriate subnet.
- D.Artifact Registry requires external HTTP/HTTPS access. Create a new firewall rule allowing ingress traffic on ports 80 and 443 from the developer's IP ranges.

Answer: A

Explanation:

The issue stems from the fact that on-premises DNS servers are unable to resolve the private Google API domain needed to access the Artifact Registry. Since on-premises developers can't directly reach the internet and the Artifact Registry is private, the usual public DNS resolution won't work. They need to resolve either `restricted.googleapis.com` or `private.googleapis.com` to Google's specific IP addresses. Option A correctly identifies this and proposes creating custom DNS records on the on-premises DNS servers to point these domains to the correct Google-published IP ranges. This is essential for the on-premises systems to find the necessary endpoints within Google's network. Option B is incorrect as IAM roles control access to the registry,

not DNS resolution. Option C is also incorrect because Private Google Access is used to allow VMs inside a Google Cloud VPC to access Google APIs without external IPs, it's not relevant to on-premises resolution of private API endpoints. Finally, option D is incorrect since Artifact Registry, especially when using private connections, doesn't require open HTTP/HTTPS access. It leverages Google's internal network once the proper DNS is configured. Therefore, correctly configuring the on-premises DNS is the critical step.

Supporting Concepts:

Private Google Access: Allows VMs within a VPC network without external IPs to access Google APIs, not on-prem access.

DNS Resolution: Critical for connecting to services using domain names instead of IP addresses.

Private Services Access: Enables private communication between your VPC network and Google services, it is relevant for the underlying VPC infrastructure in Google Cloud not for on-prem routing.

Hybrid Cloud Networking: Involves connecting on-prem infrastructure with cloud-based services, requiring careful configuration of networking and DNS.

Authoritative Links:

Setting up Private Google Access: <https://cloud.google.com/vpc/docs/configure-private-google-access>
Using restricted.googleapis.com/private.googleapis.com: <https://cloud.google.com/vpc/docs/private-access-options> (Search for restricted and private in the documentation)

Artifact Registry Network configuration: <https://cloud.google.com/artifact-registry/docs/network-config>

Question: 280

CertyIQ

Your organization has an application hosted in Cloud Run. You must control access to the application by using Cloud Identity-Aware Proxy (IAP) with these requirements:

- Only users from the AppDev group may have access.
- Access must be restricted to internal network IP addresses.

What should you do?

- A. Deploy a VPN gateway and instruct the AppDev group to connect to the company network before accessing the application.
- B. Create an access level that includes conditions for internal IP address ranges and AppDev groups. Apply this access level to the application's IAP policy.
- C. Configure firewall rules to limit access to IAP based on the AppDev group and source IP addresses.
- D. Configure IAP to enforce multi-factor authentication (MFA) for all users and use network intrusion detection systems (NIDS) to block unauthorized access attempts.

Answer: B

Explanation:

Option B is the correct approach because it directly addresses both requirements using Google Cloud's Identity-Aware Proxy (IAP) and Access Levels. IAP controls access to applications based on user identity and context. Access Levels allow you to define granular access policies based on attributes like user groups and IP address ranges. Creating an access level that includes conditions for both the AppDev group membership and internal IP address ranges ensures that only members of the specified group accessing from internal networks can gain access to the Cloud Run application. This approach centralizes access control within IAP, eliminating the need for alternative solutions or configurations. Option A would only address the internal IP requirement but not the user group. Option C would incorrectly use firewall rules to filter IAP traffic, IAP's core purpose is identity and context, while firewalls primarily deal with network level access. Option D suggests MFA which doesn't address IP and only addresses part of the security policy, and NIDS is a

detection mechanism, not access control. Therefore, Option B provides the most accurate, efficient, and secure solution, by leveraging the intended capabilities of Cloud IAP and Access Levels.

Authoritative links for further research:

Cloud Identity-Aware Proxy (IAP): <https://cloud.google.com/iap/docs>

Access Levels: <https://cloud.google.com/access-context-manager/docs/access-levels>

Cloud Run Security: <https://cloud.google.com/run/docs/configuring/security>

Question: 281

CertyIQ

You just implemented a Secure Web Proxy instance on Google Cloud for your organization. You were able to reach the internet when you tested this configuration on your test instance. However, developers cannot access the allowed URLs on the Secure Web Proxy instance from their Linux instance on Google Cloud. You want to solve this problem with developers. What should you do?

- A. Configure a Cloud NAT gateway to enable internet access from the developer instance subnet.
- B. Ensure that the developers have restarted their instance and HTTP service is enabled.
- C. Ensure that the developers have explicitly configured the proxy address on their instance.
- D. Configure a firewall rule to allow HTTP/S from the developer instance.

Answer: C

Explanation:

The correct answer is **C. Ensure that the developers have explicitly configured the proxy address on their instance.**

Here's a detailed justification:

The core issue is that while the Secure Web Proxy is functional (tested successfully from a test instance), the developers' Linux instances can't utilize it. This indicates the proxy itself is not the problem, but rather the lack of communication setup from the developer instances to the proxy. Simply having a working proxy doesn't automatically direct all traffic through it. Client systems need to be configured to know where the proxy server is and how to use it.

Option A is incorrect because Cloud NAT is used for outbound internet access for instances without external IPs. The developers need to use the Secure Web Proxy not NAT. Option B is incorrect because restarting the instance or HTTP services won't address the lack of proxy configuration. Option D might be necessary, but is not the primary concern when trying to troubleshoot the inability to use a proxy.

Option C highlights the correct problem. Linux instances require manual configuration to use a proxy server. This involves setting environment variables (like `http_proxy`, `https_proxy`) or configuring proxy settings in applications that need to access the internet. Without these explicit configurations, the developers' instances bypass the Secure Web Proxy and attempt to connect to the internet directly (which may be blocked by firewall rules or lack of a public IP).

The testing done on a single "test instance" doesn't indicate that all other instances are correctly configured to use the Secure Web Proxy. The proxy itself is running, and allowing access, but other instances have to be told to use it.

Key Cloud Concepts:

Secure Web Proxy: Acts as an intermediary between clients and the internet, enforcing security policies.

Explicit Proxy Configuration: Clients must be configured to direct traffic through the proxy. This isn't automatic.

Network Configuration: How individual machines/instances are set up to route traffic.

Outbound Access: Control how VMs access the internet.

Authoritative Links for further research:

Google Cloud Secure Web Proxy Documentation: <https://cloud.google.com/secure-web-proxy/docs>

Setting Proxy Environment Variables in Linux: Search online for articles related to http_proxy, https_proxy environment variables in Linux. Example (not google specific): <https://www.cyberciti.biz/faq/linux-unix-set-proxy-environment-variable/>

Therefore, explicitly configuring the proxy address on the developer's instance is the necessary action to allow them to use the Secure Web Proxy effectively.

Question: 282

CertyIQ

You have just created a new log bucket to replace the _Default log bucket. You want to route all log entries that are currently routed to the _Default log bucket to this new log bucket, in the most efficient manner. What should you do?

- A. Create exclusion filters for the _Default sink to prevent it from receiving new logs. Create a user-defined sink, and select the new log bucket as the sink destination.
- B. Disable the _Default sink. Create a user-defined sink and select the new log bucket as the sink destination.
- C. Create a user-defined sink with inclusion filters copied from the _Default sink. Select the new log bucket as the sink destination.
- D. Edit the _Default sink, and select the new log bucket as the sink destination.

Answer: C

Explanation:

The correct answer is **C. Create a user-defined sink with inclusion filters copied from the _Default sink. Select the new log bucket as the sink destination.**

Here's the justification:

The primary goal is to efficiently redirect logs from the _Default bucket to a new bucket. Option C achieves this while ensuring no logs are lost during the transition. The _Default sink cannot be directly modified (option D), making it unsuitable. Option B, disabling the _Default sink, is problematic because you would lose log ingestion while configuring the new sink, violating the goal of an efficient transfer. Exclusion filters in option A, combined with a new sink, is an inefficient and error-prone method that also has a period of lost logs. By creating a new user-defined sink and replicating the inclusion filters from the _Default sink, we effectively duplicate the log routing logic to a new destination. The new sink, selecting the new bucket, will then capture the same logs that the _Default sink would have received, eliminating the gap. This approach allows for a seamless switchover. Inclusion filters define what logs are included in the sink. Once this new sink is created, logs will be directed to the new bucket and the old bucket can be deleted (after the retention period has passed). This approach ensures no loss of log data and fulfills the efficiency requirement. This process is preferable to modifying an existing log sink or temporarily disabling a log sink. The _Default sink can be safely deleted once the new sink is proven to be functioning.

Supporting Concepts:

Cloud Logging Sinks: Sinks define where log entries are routed. They use filters to determine which logs to include.

_Default Sink: A predefined sink in Google Cloud Logging that routes all logs to the _Default bucket.

User-Defined Sinks: Custom sinks created by users to route logs to different destinations.

Inclusion Filters: Define criteria for selecting log entries to be routed.

Log Routing Efficiency: Minimizing downtime and configuration steps during log routing changes.

Authoritative Links:

Google Cloud Logging - Sinks: <https://cloud.google.com/logging/docs/concepts/export/sink>

Google Cloud Logging - Routing Logs: <https://cloud.google.com/logging/docs/routing>

Question: 283

CertyIQ

Your organization's use of the Google Cloud has grown substantially and there are many different groups using different cloud resources independently. You must identify common misconfigurations and compliance violations across the organization and track findings for remedial action in a dashboard. What should you do?

- A. Create a filter set in Cloud Asset Inventory to identify service accounts with high privileges and IAM principals with Gmail domains.
- B. Scan and alert vulnerabilities and misconfigurations by using Secure Health Analytics detectors in Security Command Center Premium.
- C. Set up filters on Cloud Audit Logs to flag log entries for specific, risky API calls, and display the calls in a Cloud Log Analytics dashboard.
- D. Alert and track emerging attacks detected in your environment by using Event Threat Detection detectors.

Answer: B

Explanation:

The correct answer is **B. Scan and alert vulnerabilities and misconfigurations by using Secure Health Analytics detectors in Security Command Center Premium.** Here's why:

Security Command Center (SCC) Premium, particularly its Secure Health Analytics component, is specifically designed for identifying and tracking misconfigurations and compliance violations across a Google Cloud organization. Secure Health Analytics detectors continuously scan resources against predefined rulesets (like CIS benchmarks or custom policies), flagging deviations from best practices. This aligns directly with the requirement to "identify common misconfigurations and compliance violations." The findings are surfaced in a centralized dashboard, fulfilling the need to "track findings for remedial action in a dashboard." This makes option B the most direct and suitable solution.

Option A, using Cloud Asset Inventory filters, is helpful for understanding your asset inventory but doesn't actively scan for misconfigurations or track them for remediation. Option C, focusing on Cloud Audit Logs, is useful for auditing actions but isn't the most effective tool for identifying and tracking compliance issues; it primarily deals with after-the-fact event analysis. Option D, Event Threat Detection, targets active attacks, not misconfigurations or compliance violations. Event Threat Detection is reactive whereas the goal is proactive. Therefore, while potentially valuable, it doesn't address the core problem described in the scenario.

In essence, Security Command Center Premium with Secure Health Analytics provides the proactive, continuous scanning, and centralized dashboard required to meet the specific objectives stated in the question.

For further research:

Google Cloud Security Command Center: <https://cloud.google.com/security-command-center>

Secure Health Analytics documentation: <https://cloud.google.com/security-command-center/docs/concepts-secure-health-analytics>

Misconfigurations and Compliance: <https://cloud.google.com/security/compliance>

Question: 284

CertyIQ

You are responsible for a set of Cloud Functions running on your organization's Google Cloud environment. During the last annual security review, secrets were identified in environment variables of some of these Cloud Functions. You must ensure that secrets are identified in a timely manner. What should you do?

- A. Implement regular peer reviews to assess the environment variables and identify secrets in your Cloud Functions. Raise a security incident if secrets are discovered.
- B. Implement a Cloud Function that scans the environment variables multiple times a day, and creates a finding in Security Command Center if secrets are discovered.
- C. Use Sensitive Data Protection to scan the environment variables multiple times per day, and create a finding in Security Command Center if secrets are discovered.
- D. Integrate dynamic application security testing into the CI/CD pipeline that scans the application code for the Cloud Functions. Fail the build process if secrets are discovered.

Answer: D

Explanation:

The correct answer is **D**. Integrating dynamic application security testing (DAST) into the CI/CD pipeline is the most proactive and effective method for preventing secrets from reaching production in Cloud Functions. DAST tools analyze the running application and can detect exposed secrets in environment variables or code at runtime during the build process. By failing the build process if secrets are discovered, you prevent the deployment of vulnerable code, significantly reducing the risk of exposure. Options A, B, and C offer reactive approaches. Peer reviews (A) are manual, prone to human error, and not scalable. A custom Cloud Function (B) or Sensitive Data Protection (C) can detect secrets after deployment, but they do not stop vulnerable code from being deployed initially. DAST, in contrast, shifts security left, catching issues earlier in the development cycle. This is a core principle of DevSecOps. Failing the build forces developers to address issues before they reach production. Thus, DAST provides an automated, integrated, and preventive approach, aligning with best practices for secure application development and deployment on Google Cloud.

Supporting Links:

Dynamic Application Security Testing (DAST): <https://owasp.org/www-project-top-ten/> (Search for "DAST") - OWASP provides information on DAST and its role in secure development.

DevSecOps: <https://cloud.google.com/devops/> - Google Cloud's resource on DevOps principles including security practices.

Security Command Center: <https://cloud.google.com/security-command-center> - Though Security Command Center is used by some options, DAST integration is crucial to PREVENT exposure.

Cloud Build: <https://cloud.google.com/build> - Documentation on using Google Cloud Build for CI/CD pipelines, where DAST would be integrated.

Question: 285

CertyIQ

Your organization is developing a new SaaS application on Google Cloud. Stringent compliance standards require visibility into privileged account activity, and potentially unauthorized changes and misconfigurations to the application's infrastructure. You need to monitor administrative actions, log changes to IAM roles and permissions, and be able to trace potentially unauthorized configuration changes. What should you do?

- A. Create log sinks to Cloud Storage for long-term retention. Set up log-based alerts in Cloud Logging based on relevant log types. Enable VPC Flow Logs for network visibility.
- B. Deploy Cloud IDS and activate Firewall Rules Logging. Create a custom dashboard in Security Command Center to visualize potential intrusion attempts.
- C. Detect sensitive administrative actions by using Cloud Logging with custom filters. Enable VPC Flow Logs with BigQuery exports for rapid analysis of network traffic patterns.

D.Enable Event Threat Detection and Security Health Analytics in Security Command Center. Set up detailed logging for IAM-related activity and relevant project resources by deploying Cloud Audit Logs.

Answer: D

Explanation:

Option D is the correct approach for achieving comprehensive visibility into privileged account activity and infrastructure changes required by stringent compliance standards. Enabling Event Threat Detection in Security Command Center actively monitors and alerts on potential security threats, including unauthorized or suspicious activity. Security Health Analytics provides valuable insights by identifying misconfigurations and vulnerabilities, aligning with the need to trace potentially unauthorized configuration changes.

Crucially, detailed logging is paramount for this use case. Cloud Audit Logs, when enabled for IAM-related activity and project resources, provide a complete and auditable trail of who did what, when, and where. This includes changes to IAM roles and permissions, as well as configuration modifications to relevant services. These logs are essential for tracing misconfigurations and demonstrating compliance. This is preferable to other approaches which either focus on network activity or rely on custom logging and filters, that do not fully encompass the breadth of observability required.

Option A, while useful for long-term log retention and alerts, doesn't provide the proactive threat detection and security posture assessment offered by Security Command Center. Option B, focuses on network level security and is not sufficient to meet the requirements. Option C, relies on custom filters which can be cumbersome to maintain and may miss key events. It also lacks the proactive threat detection capabilities of Security Command Center. Therefore, option D provides the most comprehensive and direct solution for the specified requirements.

Relevant Links:

[Cloud Audit Logs](#): Understanding and using audit logs.

[Security Command Center](#): Overview of Security Command Center capabilities.

[Event Threat Detection](#): Learn about Event Threat Detection within Security Command Center.

[Security Health Analytics](#): Explore Security Health Analytics for vulnerability detection.

Question: 286

CertyIQ

Your application development team is releasing a new critical feature. To complete their final testing, they requested 10 thousand real transaction records. The new feature includes format checking on the primary account number (PAN) of a credit card. You must support the request and minimize the risk of unintended personally identifiable information (PII) exposure. What should you do?

- A.Run the new application by using Confidential Computing to ensure PII and card PAN is encrypted in use.
- B.Scan and redact PII from the records by using the Cloud Data Loss Prevention API. Perform format-preserving encryption on the card PAN.
- C.Encrypt the records by using Cloud Key Management Service to protect the PII and card PAN.
- D.Build a tool to replace the card PAN and PII fields with randomly generated values.

Answer: A

Explanation:

The question requires a solution that balances the need for realistic test data with the critical requirement of protecting Personally Identifiable Information (PII), specifically credit card Primary Account Numbers (PANs). Option A, suggesting Confidential Computing, is incorrect. While Confidential Computing does protect data in use, it is not the primary solution for masking PII before testing. It's used for securely processing sensitive

data in memory and doesn't address the initial problem of creating secure test data.

Option B, using Cloud Data Loss Prevention (DLP) API, is the correct approach. DLP is designed to identify and redact sensitive data, including PII. The format-preserving encryption (FPE) aspect is crucial for this specific case. FPE ensures the PANs remain in a valid format for testing while masking their true values. This maintains data fidelity for the application's format checking feature.

Option C, which proposes encrypting records with Cloud KMS, would provide data at rest protection. However, it doesn't address the requirement of removing or masking the actual PII from the test data and make the PANs useful for testing the new format checking feature.

Option D, a tool to randomly generate values, might be acceptable for PII but fails to meet the requirement for realistically formatted PAN data to test the new format checking feature. Random data would likely not satisfy the specific format and validation rules associated with PANs. FPE in Option B is the only method that generates valid PAN formats.

Therefore, the combination of DLP for PII redaction and FPE for PANs in option B is the most comprehensive solution that satisfies both the functional requirements of the test and the need for PII protection.

Supporting Links:

Google Cloud DLP: <https://cloud.google.com/dlp/docs>

Format-Preserving Encryption: <https://cloud.google.com/dlp/docs/transformations-format-preserving-encryption>

Question: 287

CertyIQ

You work for a banking organization. You are migrating sensitive customer data to Google Cloud that is currently encrypted at rest while on-premises. There are strict regulatory requirements when moving sensitive data to the cloud. Independent of the cloud service provider, you must be able to audit key usage and be able to deny certain types of decrypt requests. You must choose an encryption strategy that will ensure robust security and compliance with the regulations. What should you do?

- A.Utilize Google default encryption and Cloud IAM to keep the keys within your organization's control.
- B.Implement Cloud External Key Manager (Cloud EKM) with Access Approval, to integrate with your existing on-premises key management solution.
- C.Implement Cloud External Key Manager (Cloud EKM) with Key Access Justifications to integrate with your existing one premises key management solution.
- D.Utilize customer-managed encryption keys (CMEK) created in a dedicated Google Compute Engine instance with Confidential Compute encryption, under your organization's control.

Answer: B

Explanation:

Okay, let's break down why option B is the most suitable answer for this scenario.

The core requirement is to maintain independent auditability and control over encryption keys for sensitive data migrated to Google Cloud, specifically to fulfill strict regulatory compliance. Google's default encryption does not meet this, as the keys are managed by Google, and usage audit logs are not entirely transparent to the customer. Option A, utilizing Google default encryption and Cloud IAM, while offering some access control, does not fulfill the independent audit and key control requirements. It relies on Google managing the encryption keys.

Customer-managed encryption keys (CMEK), as suggested in option D, give you control over key generation and storage but do not allow for fine-grained control over decrypt requests or independent auditing that the

question requires. This option also relies on Compute Engine, adding unnecessary infrastructure overhead.

Cloud External Key Manager (Cloud EKM), as offered in options B and C, is the right approach. It allows organizations to manage their keys outside Google Cloud, typically in an on-premises Hardware Security Module (HSM) or a third-party key management system. This enables independent auditing as the key usage is logged and controlled by the organization itself outside Google's purview.

The critical differentiator between B and C lies in the access control mechanism. Key Access Justifications (KAJ), described in option C, primarily focuses on providing context for access requests for compliance and auditing, and it's not designed to deny decryption requests based on specific criteria. On the other hand, Access Approval, used with Cloud EKM as in Option B, provides a mechanism to review and approve or deny access to the keys for Google Cloud services based on pre-defined policies. This allows granular control, directly fulfilling the requirement to "deny certain types of decrypt requests." Therefore, implementing Cloud EKM with Access Approval (B) integrates existing key management systems while adding a crucial layer of control over decryption.

In summary, option B, implementing Cloud EKM with Access Approval, provides the most robust security and compliance framework. It gives the organization full control over encryption keys stored externally, independent auditability, and the ability to deny certain decrypt requests, all of which directly address the organization's stringent requirements.

Authoritative Links for Further Research:

Google Cloud External Key Manager (Cloud EKM): <https://cloud.google.com/kms/docs/ekm>

Google Cloud Access Approval: <https://cloud.google.com/access-approval/docs>

Key Access Justifications: <https://cloud.google.com/security/products/key-access-justifications>

Question: 288

CertyIQ

Your organization is developing an application that will have both corporate and public end-users. You want to centrally manage those customers' identities and authorizations. Corporate end users must access the application by using their corporate user and domain name. What should you do?

- A. Add the corporate and public end-user domains to domain restricted sharing on the organization.
- B. Federate the customers' identity provider (IdP) with Workforce Identity Federation in your application's project.
- C. Do nothing. Google Workspace identities will allow you to filter personal accounts and disable their access.
- D. Use a customer identity and access management tool (CIAM) like Identity Platform.

Answer: B

Explanation:

The correct answer is **B. Federate the customers' identity provider (IdP) with Workforce Identity Federation in your application's project.**

Here's why:

Workforce Identity Federation in Google Cloud is specifically designed to manage identities from external sources, like a corporate identity provider (IdP). This approach allows corporate users to access the application using their existing credentials and domain name, fulfilling the requirement. By federating the IdP, you establish a trust relationship, enabling users to authenticate with their corporate system while granting them access within Google Cloud. This avoids the need to create and manage separate user accounts within Google Cloud. Option A, domain restricted sharing, is relevant for Google Workspace sharing, not application authentication. Option C, relying solely on Google Workspace filtering, is insufficient because it doesn't

provide proper federation or integration with external IdPs. Option D, using a CIAM like Identity Platform, is better suited for public end-users or when a dedicated CIAM solution is required, whereas Workforce Identity Federation is ideal for corporate users with existing IdPs. Workforce Identity Federation directly addresses the need for centralized management and authentication using corporate credentials. It allows fine-grained control over resource access based on user roles and attributes coming from the IdP.

Key Concepts:

Identity Federation: Linking different identity systems for unified authentication and authorization.

Workforce Identity Federation: A Google Cloud service that lets you use your existing workforce identity provider (IdP) to authenticate and authorize users.

Identity Provider (IdP): A system that manages user identities and authenticates users.

Centralized Identity Management: Managing user identities and authorizations from a single point for consistency and security.

Authoritative Links for further research:

Workforce Identity Federation overview: <https://cloud.google.com/iam/docs/workforce-identity-federation>

About Identity Federation: https://en.wikipedia.org/wiki/Federated_identity

Choose a Google Cloud identity solution: <https://cloud.google.com/docs/security/solutions/identity/choose-identity>

Question: 289

CertyIQ

You work for an organization that handles sensitive customer data. You must secure a series of Google Cloud Storage buckets housing this data and meet these requirements:

- Multiple teams need varying access levels (some read-only, some read-write).
- Data must be protected in storage and at rest.
- It's critical to track file changes and audit access for compliance purposes.
- For compliance purposes, the organization must have control over the encryption keys.

What should you do?

A.Create IAM groups for each team and manage permissions at the group level. Employ server-side encryption and Object Versioning by Google Cloud Storage. Configure cloud monitoring tools to alert on anomalous data access patterns.

B.Set individual permissions for each team and apply access control lists (ACLs) to each bucket and file. Enforce TLS encryption for file transfers. Enable Object Versioning and Cloud Audit Logs for the storage buckets.

C.Use predefined IAM roles tailored to each team's access needs, such as Storage Object Viewer and Storage Object User. Utilize customer-supplied encryption keys (CSEK) and enforce TLS encryption. Turn on both Object Versioning and Cloud Audit Logs for the storage buckets.

D.Assign IAM permissions for all teams at the object level. Implement third-party software to encrypt data at rest. Track data access by using network logs.

Answer: C

Explanation:

Option C is the most appropriate solution because it directly addresses all requirements outlined. Utilizing predefined IAM roles like "Storage Object Viewer" and "Storage Object User" aligns with the principle of least privilege, granting only necessary permissions to each team. These roles are specifically designed for Google Cloud Storage, simplifying access management and avoiding overly permissive configurations. Employing customer-supplied encryption keys (CSEK) provides the organization complete control over data encryption, satisfying the compliance need. CSEK ensures that Google does not have access to the keys, enhancing data

security. Enforcing TLS encryption protects data during transfer, preventing eavesdropping. Enabling Object Versioning allows for data recovery in case of accidental deletion or modification, while Cloud Audit Logs enable the organization to track all data access and file changes for auditing and compliance. Options A, B, and D, while addressing some concerns, don't comprehensively meet all requirements as effectively or securely as option C. Option A, using only server-side encryption, doesn't fulfill the requirement of customer-controlled keys. Option B relies on less manageable access control lists and doesn't use specific IAM roles for permissions. Option D proposes insufficient data access tracking and is more complex and less robust.

Authoritative Links:

IAM Roles for Cloud Storage: <https://cloud.google.com/storage/docs/access-control/iam-roles>

Customer-Supplied Encryption Keys (CSEK): <https://cloud.google.com/storage/docs/encryption/customer-supplied-keys>

Object Versioning: <https://cloud.google.com/storage/docs/object-versioning>

Cloud Audit Logs: <https://cloud.google.com/logging/docs/audit/>

Question: 290

CertyIQ

You are implementing communications restrictions for specific services in your Google Cloud organization. Your data analytics team works in a dedicated folder. You need to ensure that access to BigQuery is controlled for that folder and its projects. The data analytics team must be able to control the restrictions only at the folder level. What should you do?

- A. Create an organization-level access policy with a service perimeter to restrict BigQuery access. Assign the data analytics team the Access Context Manager Editor role on the access policy to allow the team to configure the access policy.
- B. Create a scoped policy on the folder with a service perimeter to restrict BigQuery access. Assign the data analytics team the Access Context Manager Editor role on the scoped policy to allow the team to configure the scoped policy.
- C. Define a hierarchical firewall policy on the folder to deny BigQuery access. Assign the data analytics team the Compute Organization Firewall Policy Admin role to allow the team to configure rules for the firewall policy.
- D. Enforce the Restrict Resource Service Usage organization policy constraint on the folder to restrict BigQuery access. Assign the data analytics team the Organization Policy Administrator role to allow the team to manage exclusions within the folder.

Answer: B

Explanation:

Here's a breakdown of why option B is the correct approach and why the others are not, focusing on Google Cloud's resource hierarchy, access control mechanisms, and service perimeters:

Why Option B is Correct:

Scoped Policy: Option B correctly uses a "scoped policy" (specifically, a service perimeter) applied directly at the folder level. This aligns with the requirement that restrictions should be controlled at the folder and project level, rather than organization-wide. Scoped policies allow for granular control, applying to only the designated resources and their children in the resource hierarchy.

Service Perimeter: A service perimeter within Access Context Manager provides boundary restrictions around resources, controlling access to services like BigQuery based on identity and context. This addresses the requirement of limiting BigQuery access.

Delegated Control: Assigning the data analytics team the "Access Context Manager Editor" role specifically on this scoped policy enables them to manage the access restrictions within their folder, fulfilling the requirement for the team to control the restrictions at the folder level. This aligns with the principle of least privilege.

Localized Administration: By assigning the Access Context Manager Editor role only at the folder level, the control over access policy for BigQuery is limited to that folder and the projects within it. This design promotes administrative efficiency by allowing teams to manage their access policies without affecting others.

Why Other Options are Incorrect:

Option A (Organization-Level Access Policy): While an organization-level policy could restrict BigQuery access, it would not allow the data analytics team to independently control restrictions for their specific folder, breaking the requirement of localized control. Access Context Manager Editor on organization-level policies grants broad permissions across the whole organization, which is not desirable for team-specific controls.

Option C (Hierarchical Firewall Policy): Hierarchical firewall policies primarily control network traffic, not service access like BigQuery. Firewall policies operate on the network layer and don't directly manage API access as required by the use case. The Compute Organization Firewall Policy Admin role is for managing network firewalls, not service access.

Option D (Restrict Resource Service Usage): The "Restrict Resource Service Usage" organization policy constraint is powerful but unsuitable for this scenario. It either allows or blocks specific services completely. While it can restrict BigQuery, delegating control to a specific team for folder-level configurations is not a core feature of the organization policy constraint. Furthermore, the Organization Policy Administrator role grants broad control, which contradicts the goal of localized team management.

Key Google Cloud Concepts:

Resource Hierarchy: Google Cloud organizes resources into an hierarchy of organization, folders, and projects. Policies can be applied at any of these levels.

Access Context Manager (ACM): This service allows you to define granular access control based on context, such as identity, device, and location, along with service perimeters that establish boundaries around resources.

Service Perimeter: A security boundary defined within Access Context Manager that limits access to Google Cloud resources based on specific parameters, thereby preventing data exfiltration.

Organization Policy: A service for defining central policies across a Google Cloud Organization.

IAM Roles: These roles define the level of access granted to principals for specific Google Cloud resources.

Authoritative Links:

Access Context Manager: <https://cloud.google.com/access-context-manager/docs>

Service Perimeters: <https://cloud.google.com/vpc-service-controls/docs/service-perimeters>

Google Cloud Resource Hierarchy: <https://cloud.google.com/resource-manager/docs/cloud-platform-resource-hierarchy>

Organization Policy: <https://cloud.google.com/resource-manager/docs/organization-policy/overview>

Question: 291

CertyIQ

Your organization is using a third-party identity and authentication provider to centrally manage users. You want to use this identity provider to grant access to the Google Cloud console without syncing identities to Google Cloud. Users should receive permissions based on attributes. What should you do?

- A. Configure the central identity provider as a workforce identity pool provider in Workforce Identity Federation. Create an attribute mapping by using the Common Expression Language (CEL).
- B. Configure a periodic synchronization of relevant users and groups with attributes to Cloud Identity. Activate single sign-on by using the Security Assertion Markup Language (SAML).
- C. Set up the Google Cloud Identity Platform. Configure an external authentication provider by using OpenID Connect and link user accounts based on attributes.

D. Activate external identities on the Identity-Aware Proxy. Use the Security Assertion Markup Language (SAML) to configure authentication based on attributes to the central authentication provider.

Answer: A

Explanation:

The correct answer is A. Workforce Identity Federation, specifically using workforce identity pools, is designed to allow external identities managed by third-party providers to access Google Cloud resources without requiring user synchronization to Google Cloud Identity. This is achieved by configuring the central identity provider as a workforce identity pool provider. The core benefit is the elimination of the need to create and manage identical user accounts within Google Cloud. Crucially, attribute-based access control (ABAC) is achieved using the Common Expression Language (CEL) to map user attributes from the external provider to Google Cloud permissions. CEL allows defining rules based on claims or attributes present in the identity token issued by the third-party provider, effectively translating them into specific Google Cloud roles and permissions on the fly. This ensures that users only gain access to the resources they need, based on their identity provider attributes. Option B is incorrect because it necessitates syncing user identities, which defeats the requirement to avoid synchronization. Option C involves setting up Google Cloud Identity Platform, implying local identity management, which contradicts the aim. Option D, utilizing IAP with external identities, doesn't address attribute-based permissions directly at the resource level as elegantly as Workforce Identity Federation. Therefore, Workforce Identity Federation offers the most direct and secure way to achieve the desired goal.

Further Research:

Google Cloud Workforce Identity Federation Documentation: <https://cloud.google.com/iam/docs/workforce-identity-federation>

Common Expression Language (CEL): <https://github.com/google/cel-spec>

Google Cloud IAM Overview: <https://cloud.google.com/iam/docs/overview>

Question: 292

CertyIQ

You are implementing a new web application on Google Cloud that will be accessed from your on-premises network. To provide protection from threats like malware, you must implement transport layer security (TLS) interception for incoming traffic to your application. What should you do?

- A. Configure Secure Web Proxy. Offload the TLS traffic in the load balancer, inspect the traffic, and forward the traffic to the web application.
- B. Configure an internal proxy load balancer. Offload the TLS traffic in the load balancer inspect, the traffic and forward the traffic to the web application.
- C. Configure a hierarchical firewall policy. Enable TLS interception by using Cloud Next Generation Firewall (NGFW) Enterprise.
- D. Configure a VPC firewall rule. Enable TLS interception by using Cloud Next Generation Firewall (NGFW) Enterprise.

Answer: A

Explanation:

Option A, configuring Secure Web Proxy, is the correct solution for implementing TLS interception for inbound traffic to your web application from your on-premises network. Secure Web Proxy is a Google Cloud service designed for this very purpose. It acts as an intermediary, decrypting the TLS traffic, inspecting it for threats like malware using its built-in capabilities, and then re-encrypting the traffic before forwarding it to the application. This provides a secure entry point to your application within the Google Cloud environment. The proxy operates at Layer 7, allowing for deep packet inspection and sophisticated filtering rules based on

various criteria, such as headers, URLs, and content. Options B, C, and D are not suited for this task. Option B describes an internal load balancer which focuses on load balancing not deep packet inspection. Option C and D involves hierarchical firewall policies and VPC firewall rules which do not provide TLS interception capabilities natively and do not have the same threat inspection functionality as a Secure Web Proxy. While NGFW can perform deep packet inspection, it's not directly the solution for traffic coming from your on-premises to a web application, Secure Web Proxy is. Secure Web Proxy integrates seamlessly with Google Cloud's load balancing services and provides a comprehensive solution for securing web traffic. By utilizing Secure Web Proxy, you ensure that traffic is both secure and reliably routed to your web application. This approach aligns with best practices for cloud security, focusing on proactive threat prevention and layered security.

Authoritative Links:

Google Cloud Secure Web Proxy: <https://cloud.google.com/secure-web-proxy>

Google Cloud Network Load Balancing: <https://cloud.google.com/load-balancing/docs/network>

Google Cloud Firewall Overview: <https://cloud.google.com/vpc/docs/firewall>

Cloud NGFW: <https://cloud.google.com/network-firewall/docs/ngfw/overview>

Question: 293

CertyIQ

Your organization has hired a small, temporary partner team for 18 months. The temporary team will work alongside your DevOps team to develop your organization's application that is hosted on Google Cloud. You must give the temporary partner team access to your application's resources on Google Cloud and ensure that partner employees lose access. If they are removed from their employer's organization. What should you do?

- A. Create a temporary username and password for the temporary partner team members. Auto-clean the usernames and passwords after the work engagement has ended.
- B. Create a workforce identity pool and federate the identity pool with the identity provider (IdP) of the temporary partner team.
- C. Implement just-in-time privileged access to Google Cloud for the temporary partner team.
- D. Add the identities of the temporary partner team members to your identity provider (IdP).

Answer: B

Explanation:

Option B, creating a workforce identity pool and federating with the partner's IdP, is the most suitable solution for managing temporary access for the partner team. Workforce Identity Federation allows external users to authenticate using their existing organizational identities, eliminating the need for creating and managing separate credentials. This approach adheres to the principle of least privilege by providing access only for the duration of their employment at the partner organization. When a partner employee leaves their organization, their access is automatically revoked through the partner's IdP, ensuring security and reducing administrative overhead. This approach avoids the risks associated with shared or temporary credentials that may be forgotten or linger beyond the engagement period, enhancing the security posture of the organization's Google Cloud environment. Option A, creating temporary usernames and passwords, requires manual management and is prone to security risks, particularly if the cleanup is not rigorously maintained. Option C, just-in-time access, focuses on granting permissions at the moment they are needed, but doesn't address the underlying issue of identity and its lifecycle. Option D, adding partner identities to your own IdP, isn't feasible and would mean managing external users in your directory which is complex and counterproductive.

Relevant links:

Google Cloud Workforce Identity Federation: <https://cloud.google.com/iam/docs/workforce-identity-federation>

Question: 294

CertyIQ

Your organization has an internet-facing application behind a load balancer. Your regulators require end-to-end encryption of user login credentials. You must implement this requirement. What should you do?

- A. Generate a symmetric key with Cloud KMS. Encrypt client-side user credentials by using the symmetric key.
- B. Concatenate the credential with a timestamp. Submit the timestamp and hashed value of credentials to the network.
- C. Deploy the TLS certificate at Google Cloud Global HTTPs Load Balancer, and submit the user credentials through HTTPs.
- D. Generate an asymmetric key with Cloud KMS. Encrypt client-side user credentials using the public key.

Answer: C

Explanation:

The correct answer is **C: Deploy the TLS certificate at Google Cloud Global HTTPs Load Balancer, and submit the user credentials through HTTPs.**

Here's why:

End-to-end encryption for user credentials, as mandated by regulations, requires protecting data in transit from the client to the application server. HTTPS, leveraging TLS (Transport Layer Security), achieves this. When you deploy a TLS certificate on the load balancer, it terminates the HTTPS connection there. This means that the user's browser encrypts the data, including their login credentials, before sending it across the internet, and the load balancer decrypts it before passing it on. The connection between the load balancer and the backend is often secured as well with TLS, or other means of secured communication. This configuration provides the necessary encryption from the user's browser to the load balancer and then onward to the application, thereby satisfying the regulatory requirement for end-to-end protection in transit.

Options A and D are incorrect because they focus on encrypting data at the client-side with KMS keys but would still send potentially vulnerable credentials in transit if not coupled with TLS. KMS is primarily designed for encryption at rest, and while it can be used for client-side encryption, this would not satisfy a simple end-to-end encryption requirement. Option B involves hashing, which protects passwords at rest, but isn't suited for transmission, nor does it satisfy an end-to-end encryption requirement; plus hashing credentials directly before transmission is extremely dangerous.

HTTPS with a properly configured TLS certificate is the most straightforward and widely accepted solution to the security mandate. It ensures confidentiality and integrity of the data during transmission.

Authoritative Links:

Google Cloud Load Balancing: <https://cloud.google.com/load-balancing>

TLS/SSL Overview: <https://www.cloudflare.com/learning/ssl/what-is-ssl/>

HTTPS Overview: <https://www.cloudflare.com/learning/ssl/what-is-https/>

Question: 295

CertyIQ

Your organization heavily utilizes serverless applications while prioritizing security best practices. You are responsible for enforcing image provenance and compliance with security standards before deployment. You leverage Cloud Build as your continuous integration and continuous deployment (CI/CD) tool for building container images. You must configure Binary Authorization to ensure that only images built by your Cloud Build pipeline are deployed and that the images pass security standard compliance checks. What should you do?

- A. Create a Binary Authorization attestor that uses a scanner to assess source code management repositories. Deploy images only if the attestor validates results against a security policy.
- B. Create a Binary Authorization attestor that utilizes a scanner to evaluate container image build processes. Define a policy that requires deployment of images only if this attestation is present.
- C. Create a Binary Authorization attestor that retrieves the Cloud Build build ID of the container image. Configure a policy to allow deployment only if there's a matching build ID attestation.
- D. Utilize a custom Security Health Analytics module to create a policy. Enforce the policy through Binary Authorization to prevent deployment of images that do not meet predefined security standards.

Answer: C

Explanation:

The correct answer is **C**. Here's why:

Binary Authorization is designed to ensure that only trusted container images are deployed. It achieves this through attestations, which are digital signatures confirming that an image has met specific criteria. In this scenario, the goal is to verify that images originate from the Cloud Build pipeline and have passed security compliance checks.

Option C directly addresses this requirement. By creating a Binary Authorization attestor that retrieves the Cloud Build build ID, and configuring a policy that demands matching attestations, you effectively guarantee that only images built by the authorized CI/CD pipeline can be deployed. The build ID acts as a unique, verifiable identifier, proving the image's origin. This approach implicitly ensures compliance as only images built via the established pipeline, which should have security checks integrated, are allowed.

Option A is incorrect because it focuses on scanning source code repositories, which does not provide assurance that the resulting container image was built and secured by the CI/CD pipeline. Option B is incorrect as scanning container image build process is not the purpose of Binary Authorization. Although security compliance checks are important, it needs to be integrated into the build process and attested to during deployment. Option D is not ideal because Security Health Analytics modules are designed to evaluate resources within a Google Cloud project and do not provide assurance about the integrity of the build pipeline of container images itself.

Therefore, the use of a Cloud Build build ID as the basis for Binary Authorization attestations is the most effective and secure method for fulfilling the requirements specified in the question. It ensures provenance, and it provides control over which images, coming from an authorized build process, can be deployed.

Authoritative Links:

Binary Authorization Overview: <https://cloud.google.com/binary-authorization/docs/overview>

Binary Authorization Concepts: <https://cloud.google.com/binary-authorization/docs/concepts>

Cloud Build Overview: <https://cloud.google.com/build/docs/overview>

Question: 296

CertyIQ

Your organization operates in a highly regulated industry and uses multiple Google Cloud services. You need to identify potential risks to regulatory compliance. Which situation introduces the greatest risk?

- A. The security team mandates the use of customer-managed encryption keys (CMEK) for all data classified as sensitive.
- B. Sensitive data is stored in a Cloud Storage bucket with the uniform bucket-level access setting enabled.
- C. The audit team needs access to Cloud Audit Logs related to managed services like BigQuery.
- D. Principals have broad IAM roles allowing the creation and management of Compute Engine VMs without a pre-defined hardening process.

Answer: D

Explanation:

The greatest risk to regulatory compliance stems from option D: "Principals have broad IAM roles allowing the creation and management of Compute Engine VMs without a pre-defined hardening process." This scenario introduces significant vulnerabilities because it bypasses crucial security controls mandated by most regulatory frameworks. Granting broad IAM permissions enables users to provision virtual machines without adhering to established security standards, potentially leading to misconfigurations, outdated software, and insecure operating systems. This lack of control makes it challenging to maintain a consistent security posture, rendering systems vulnerable to exploits and making compliance audits difficult. Option A, utilizing customer-managed encryption keys (CMEK), enhances data protection and aligns with many compliance standards, reducing risk. Option B, enabling uniform bucket-level access, simplifies access management, contributing to a more secure environment by reducing complexity. Option C, the audit team accessing Cloud Audit Logs, is vital for monitoring activity and demonstrating regulatory adherence. In contrast, option D directly contradicts the principle of least privilege and undermines standardized security processes. The absence of VM hardening creates a significantly larger attack surface and increases the potential for regulatory violations, like those related to data protection and system security.

Relevant Links:

IAM Best Practices: <https://cloud.google.com/iam/docs/best-practices-for-using-iam>

Hardening Compute Engine VMs: <https://cloud.google.com/compute/docs/security/hardening-your-instances>

Understanding Regulatory Compliance on Google Cloud: <https://cloud.google.com/security/compliance/>

Principle of Least Privilege: https://csrc.nist.gov/glossary/term/principle_of_least_privilege

Question: 297

CertyIQ

Your multinational organization is undergoing rapid expansion within Google Cloud. New teams and projects are added frequently. You are concerned about the potential for inconsistent security policy application and permission sprawl across the organization. You must enforce consistent standards while maintaining the autonomy of regional teams. You need to design a strategy to effectively manage IAM and organization policies at scale, ensuring security and administrative efficiency. What should you do?

- A. Create detailed organization-wide policies for common scenarios. Instruct teams to apply the policies carefully at the project and resource level as needed.
- B. Delegate the creation of organization policies to regional teams. Centrally review these policies for compliance before deployment.
- C. Define a small set of essential organization policies. Supplement these policies with a library of optional policy templates for teams to leverage as needed.
- D. Use a hierarchical structure of folders. Implement template-based organization policies that cascade down, allowing limited customization by regional teams.

Answer: D

Explanation:

The correct answer is **D. Use a hierarchical structure of folders. Implement template-based organization policies that cascade down, allowing limited customization by regional teams.** This approach addresses the core concerns of inconsistent security policies and permission sprawl while balancing central control with regional autonomy. Folders in Google Cloud provide a hierarchical structure that mirrors the organization's structure, allowing for policy inheritance. Implementing organization policies at higher levels (e.g., organization or folder level) and allowing them to cascade down ensures a baseline of security is applied across all projects and resources.

Template-based policies promote consistency and simplify administration. Regional teams can then customize or refine these policies at their respective folder level or project level, but only within the predefined limits of the template and without violating the security principles established at higher levels. This layered approach allows for local adaptation while maintaining overall control. Option A is problematic as manually applying detailed organization-wide policies is prone to errors and inconsistencies. Option B risks creating policy chaos if each region has full control without central oversight. Option C, while offering some flexibility, may still lead to inconsistencies due to the optional nature of most policies. Therefore, option D provides the most comprehensive solution for managing IAM and organization policies at scale. This combines the benefits of centralized control and decentralized autonomy, leading to greater administrative efficiency and consistency in the organization's security posture.

Authoritative Links for Further Research:

Google Cloud Resource Hierarchy: <https://cloud.google.com/resource-manager/docs/cloud-platform-resource-hierarchy>

Organization Policy Service: <https://cloud.google.com/resource-manager/docs/organization-policy/overview>
Creating and Managing Policies: <https://cloud.google.com/resource-manager/docs/organization-policy/creating-managing-policies>

Understanding Policy Inheritance: <https://cloud.google.com/resource-manager/docs/organization-policy/understanding-hierarchy>

Question: 298

CertyIQ

A security audit uncovered several inconsistencies in your project's Identity and Access Management (IAM) configuration. Some service accounts have overly permissive roles, and a few external collaborators have more access than necessary. You need to gain detailed visibility into changes to IAM policies, user activity, service account behavior, and access to sensitive projects. What should you do?

- A. Configure Google Cloud Functions to be triggered by changes to IAM policies. Analyze changes by using the policy simulator, send alerts upon risky modifications, and store event details.
- B. Enable the metrics explorer in Cloud Monitoring to follow the service account authentication events and build alerts linked on it.
- C. Use Cloud Audit Logs. Create log export sinks to send these logs to a security information and event management (SIEM) solution for correlation with other event sources.
- D. Deploy the OS Config Management agent to your VMs. Use OS Config Management to create patch management jobs and monitor system modifications.

Answer: C

Explanation:

The correct answer is **C. Use Cloud Audit Logs. Create log export sinks to send these logs to a security information and event management (SIEM) solution for correlation with other event sources.**

Here's why: Cloud Audit Logs provides a detailed record of actions performed within Google Cloud, including IAM policy modifications, user activity, and service account usage. These logs are crucial for security auditing and identifying suspicious behavior. By creating log export sinks, you can forward these audit logs to a SIEM system. A SIEM consolidates logs from various sources, enabling comprehensive security analysis, correlation of events, and proactive threat detection. This centralized approach allows you to gain a holistic view of security events and anomalies, satisfying the requirement for detailed visibility into IAM changes and access patterns. Google Cloud's documentation specifically highlights audit logs as the primary source for this type of security monitoring, making option C the most suitable solution. Options A, B, and D are less relevant. Cloud Functions (A) is not designed for primary log storage and analysis; Cloud Monitoring (B) is better for performance monitoring than detailed activity tracking; and OS Config Management (D) focuses on patching VMs, not IAM and access monitoring.

Supporting Links:

Cloud Audit Logs Overview: <https://cloud.google.com/logging/docs/audit>

Exporting Logs: <https://cloud.google.com/logging/docs/export>

Security Logging: <https://cloud.google.com/security/logging>

Question: 299

CertyIQ

You manage multiple internal-only applications that are hosted within different Google Cloud projects. You are deploying a new application that requires external internet access. To maintain security, you want to clearly separate this new application from internal systems. Your solution must have effective security isolation for the new externally-facing application. What should you do?

- A. Deploy the application within the same project as an internal application. Use a Shared VPC model to manage network configurations.
- B. Place the application in the same project as an existing internal application, and adjust firewall rules to allow external traffic.
- C. Create a VPC Service Controls perimeter, and place the new application's project within that perimeter.
- D. Create a new project for the application, and use VPC Network Peering to access necessary resources in the internal projects.

Answer: D

Explanation:

Here's a detailed justification for choosing option D as the best solution:

Option D, creating a new project for the externally-facing application and using VPC Network Peering, is the most secure and recommended approach. Creating a new project provides a strong isolation boundary. This inherently separates the new application's resources, IAM policies, and billing from internal systems, minimizing the blast radius of a potential security incident. VPC Network Peering allows the new application to securely access needed resources in internal projects without exposing the internal networks to the public internet. Each project maintains its own set of security controls, and peering establishes private connectivity over Google's backbone without traffic traversing the public internet.

Options A and B compromise security by placing the new application within existing internal projects. This violates the principle of least privilege and increases the attack surface because an incident in the new application could potentially impact internal systems. While Shared VPC can centralize network management (Option A), it does not provide the same isolation level as separate projects. Directly adjusting firewall rules to allow external traffic (Option B) is inherently risky and can lead to misconfigurations that expose internal resources. Option C, using VPC Service Controls, primarily focuses on data exfiltration and API usage control within a perimeter; it does not provide the same isolation and separation as distinct projects, which is the primary concern here. Thus, Option D provides the strongest security isolation, the requested separation, and adheres to best practices for cloud security.

Authoritative Links for Further Research:

Google Cloud Resource Organization: <https://cloud.google.com/resource-manager/docs/overview>

VPC Network Peering: <https://cloud.google.com/vpc/docs/vpc-peering>

Security Best Practices in Google Cloud: <https://cloud.google.com/security/>

Shared VPC: <https://cloud.google.com/vpc/docs/shared-vpc>

VPC Service Controls: <https://cloud.google.com/vpc-service-controls>

Question: 300

You work for an ecommerce company that stores sensitive customer data across multiple Google Cloud regions. The development team has built a new 3-tier application to process orders and must integrate the application into the production environment.

You must design the network architecture to ensure strong security boundaries and isolation for the new application, facilitate secure remote maintenance by authorized third-party vendors, and follow the principle of least privilege. What should you do?

- A. Create separate VPC networks for each tier. Use VPC peering between application tiers and other required VPCs. Provide vendors with SSH keys and root access only to the instances within the VPC for maintenance purposes.
- B. Create a single VPC network and create different subnets for each tier. Create a new Google project specifically for the third-party vendors and grant the network admin role to the vendors. Deploy a VPN appliance and rely on the vendors' configurations to secure third-party access.
- C. Create separate VPC networks for each tier. Use VPC peering between application tiers and other required VPCs. Enable Identity-Aware Proxy (IAP) for remote access to management resources, limiting access to authorized vendors.
- D. Create a single VPC network and create different subnets for each tier. Create a new Google project specifically for the third-party vendors. Grant the vendors ownership of that project and the ability to modify the Shared VPC configuration.

Answer: C

Explanation:

Option C is the correct choice because it best aligns with the principles of network security, least privilege, and secure remote access within a multi-tiered application deployment on Google Cloud. Creating separate VPC networks for each tier (e.g., web, application, data) establishes strong security boundaries. This segmentation limits the blast radius of potential security breaches, ensuring that a compromise in one tier does not automatically compromise others. VPC peering allows controlled communication between these isolated networks, enabling necessary traffic flow while maintaining separation. Furthermore, using Identity-Aware Proxy (IAP) for remote access is crucial. IAP provides secure, contextual access to management resources without exposing them directly to the internet. It centralizes authentication and authorization, ensuring only authorized vendors with appropriate identities can access the necessary resources. This method adheres to the principle of least privilege by granting access only to what is needed and avoids the risks associated with directly providing SSH keys and root access to vendor accounts. Option A is problematic because providing root access and SSH keys directly goes against the least privilege principle. Option B presents a flawed approach by granting excessive permissions and delegating network configurations to third parties. Option D is problematic as granting ownership and allowing modification of Shared VPC configurations to third-parties creates excessive access and introduces unnecessary security risk. Option C, therefore, offers a balanced approach to robust security with controlled, identity-based access for third-party vendors.

Supporting Concepts:

VPC Segmentation: Isolating workloads across different VPCs to minimize the impact of security incidents.

VPC Peering: Enabling controlled communication between VPC networks while keeping them logically separate.

Identity-Aware Proxy (IAP): Secure remote access control mechanism providing identity-based authorization.

Principle of Least Privilege: Granting only the minimum necessary permissions to users and services.

Authoritative Links:

VPC Networks: <https://cloud.google.com/vpc/docs/>

VPC Peering: <https://cloud.google.com/vpc/docs/vpc-peering>

Identity-Aware Proxy (IAP): <https://cloud.google.com/iap/docs/>

Principle of Least Privilege: https://en.wikipedia.org/wiki/Principle_of_least_privilege

Question: 301

CertyIQ

Your organization is implementing separation of duties in a Google Cloud project. A group of developers must deploy new code, but cannot have permission to change network firewall rules. What should you do?

- A. Assign the network administrator IAM role to all developers. Tell developers not to change firewall settings.
- B. Use Access Context Manager to create conditions that allow only authorized administrators to change firewall rules based on attributes such as IP address or device security posture.
- C. Create and assign two custom IAM roles. Assign the deployer role to control Compute Engine and deployment-related permissions. Assign the network administrator role to manage firewall permissions.
- D. Grant the editor IAM role to the developer group. Explicitly negate any firewall modification permissions by using IAM deny policies.

Answer: C

Explanation:

The correct answer is **C: Create and assign two custom IAM roles. Assign the deployer role to control Compute Engine and deployment-related permissions. Assign the network administrator role to manage firewall permissions.**

This option adheres to the principle of least privilege and implements separation of duties effectively. By creating custom IAM roles, you can precisely define the permissions each group requires. The "deployer" role would grant the necessary access for developers to deploy code, including actions on Compute Engine, Cloud Functions, or other deployment services. The "network administrator" role, on the other hand, would be specifically tailored for managing network configurations, including firewall rules. This separation ensures that developers cannot inadvertently or maliciously alter firewall settings, which are critical for security.

Option A is incorrect as assigning the network administrator role to developers violates the principle of least privilege. It gives them far more permissions than necessary, creating a significant security risk. Option B, while potentially useful in other contexts, is not the primary solution for separation of duties in this scenario. Access Context Manager (ACM) focuses on context-based access control, but here, we need role-based access control. Option D is also incorrect because using deny policies within IAM roles can be complex and difficult to manage, often leading to unintended access blocks. Custom roles offer a more straightforward and auditable approach. The principle of least privilege advocates for granting only the minimum permissions necessary for a user or group to perform their tasks. Separation of duties ensures that no single individual has complete control over a critical process, minimizing risks.

Further research:

Google Cloud IAM documentation: <https://cloud.google.com/iam/docs>

IAM best practices: <https://cloud.google.com/iam/docs/best-practices>

Understanding custom roles: https://cloud.google.com/iam/docs/understanding-roles#custom_roles

Principle of least privilege: https://en.wikipedia.org/wiki/Principle_of_least_privilege

Separation of duties: https://en.wikipedia.org/wiki/Separation_of_duties

Question: 302

CertyIQ

You manage a Google Cloud organization with many projects located in various regions around the world. The projects are protected by the same Access Context Manager access policy. You created a new folder that will host two projects that process protected health information (PHI) for US-based customers. The two projects will be

separately managed and require stricter protections. You are setting up the VPC Service Controls configuration for the new folder. You must ensure that only US-based personnel can access these projects and restrict Google Cloud API access to only BigQuery and Cloud Storage within these projects. What should you do?

- A. • Create a scoped access policy, add the new folder under “Select resources to include in the policy,” and assign an administrator under “Manage principals.”
 - For the service perimeter, specify the two new projects as “Resources to protect” in the service perimeter configuration.
 - Set “Restricted services” to “all services,” set “VPC accessible services” to “Selected services,” and specify only BigQuery and Cloud Storage under “Selected services.”
- B. • Enable Identity Aware Proxy in the new projects.
 - Create an Access Context Manager access level with an “IP Subnetworks” attribute condition set to the US-based corporate IP range.
 - Enable the “Restrict Resource Service Usage” organization policy at the new folder level with an “Allow” policy type and set both “storage.googleapis.com” and “bigquery.googleapis.com” under “Custom values.”
- C. • Edit the organization-level access policy and add the new folder under “Select resources to include in the policy.”
 - Specify the two new projects as “Resources to protect” in the service perimeter configuration.
 - Set “Restricted services” to “all services,” set “VPC accessible services” to “Selected services,” and specify only BigQuery and Cloud Storage.
 - Edit the existing access level to add a “Geographic locations” condition set to “US.”
- D. • Configure a Cloud Interconnect connection or a Virtual Private Network (VPN) between the on-premises environment and the Google Cloud organization.
 - Configure the VPC firewall policies within the new projects to only allow connections from the on-premises IP address range.
 - Enable the Restrict Resource Service Usage organization policy on the new folder with an “Allow” policy type, and set both “storage.googleapis.com” and “bigquery.googleapis.com” under “Custom values.”

Answer: C

Explanation:

Here's a detailed justification for why option C is the correct approach:

Option C correctly addresses all requirements by leveraging Access Context Manager and VPC Service Controls. First, it modifies the existing organization-level access policy, which is appropriate since the question states that the projects are already protected by an existing policy. It then includes the new folder within this organization-wide policy, ensuring the new projects adhere to the organization's broader security posture. It sets up a service perimeter, focusing on the two PHI-related projects as "Resources to protect," thus restricting access to only those resources. The service perimeter configuration sets "Restricted services" to "all services" and then uses "Selected services" to restrict access to only BigQuery and Cloud Storage APIs, meeting the requirement to limit Google Cloud API access. Crucially, it modifies the existing access level to add a "Geographic locations" condition limited to "US," ensuring only US-based personnel can access the projects. This is key for restricting access based on geographical location.

Options A and B are incorrect because they either fail to integrate with the existing organization-level access policy, or don't address all the necessary security requirements, and are therefore less comprehensive solutions. Option D is incorrect because while it uses networking controls to limit access by IP address, this approach is not as comprehensive or manageable as using Access Context Manager to enforce access by identity and location, and it doesn't properly restrict API access.

Key cloud security concepts used in option C include:

Access Context Manager: Centrally manages access policies based on attributes like user identity, IP address, and geographic location.

VPC Service Controls: Creates a security perimeter around Google Cloud resources to mitigate data exfiltration risks.

Service Perimeters: Sets boundaries that control which services can access protected resources.

Restricted Services: Limits which Google Cloud APIs can be accessed within a service perimeter.

Access Levels: Specifies the conditions that must be met for a user or application to gain access.

Authoritative Links for further research:

Access Context Manager Overview: Learn about how to use Access Context Manager for fine-grained access control.

VPC Service Controls Overview: Explore how VPC Service Controls can protect your cloud resources.

Access Levels Documentation: Understand how to define access levels based on attributes.

Service Perimeters Documentation: Learn to configure and manage service perimeters.

Question: 303

CertyIQ

There is a threat actor that is targeting organizations like yours. Attacks are always initiated from a known IP address range. You want to deny-list those IPs for your website, which is exposed to the internet through an Application Load Balancer. What should you do?

- A. Create a Cloud Armor policy with a deny-rule for the known IP address range. Attach the policy to the backend of the Application Load Balancer.
- B. Activate Identity-Aware Proxy for the backend of the Application Load Balancer. Create a firewall rule that only allows traffic from the proxy to the application.
- C. Create a log sink with a filter containing the known IP address range. Trigger an alert that detects when the Application Load Balancer is accessed from those IPs.
- D. Create a Cloud Firewall policy with a deny-rule for the known IP address range. Associate the firewall policy to the Virtual Private Cloud with the application backend.

Answer: A

Explanation:

The correct answer is **A. Create a Cloud Armor policy with a deny-rule for the known IP address range. Attach the policy to the backend of the Application Load Balancer.**

Here's why: Cloud Armor is a Web Application Firewall (WAF) service offered by Google Cloud. It's designed specifically to protect applications from various threats, including IP-based attacks, by inspecting incoming requests at the edge of Google's network. Creating a Cloud Armor policy with a deny rule for the known IP range directly blocks traffic originating from those IPs before it reaches the application backend, preventing malicious requests from being processed. This is the most efficient and targeted approach to block known bad IPs.

Option B is incorrect because Identity-Aware Proxy (IAP) is primarily for controlling access based on user identity, not IP addresses. While you could technically use it in conjunction with firewall rules to achieve similar results, it's not the most suitable tool for this scenario. Option C is also incorrect, as logging and alerting only notify you after the attack has occurred, not preventing it. This approach does not prevent the malicious traffic from reaching the backend. Option D is incorrect because Cloud Firewall rules operate at the VPC level and control traffic between network interfaces, not web requests at the application layer. It is not as effective as Cloud Armor at blocking IP traffic that is directed at the load balancer.

In summary, Cloud Armor provides a layer of protection at the network edge, which directly integrates with the Application Load Balancer and is built for the specific task of blocking traffic based on various criteria, including source IP addresses. This makes it the best tool for this specific use case, offering proactive and efficient threat mitigation.

Authoritative Links for further research:

Cloud Armor Overview: <https://cloud.google.com/armor/docs/overview>

Cloud Armor Policies: <https://cloud.google.com/armor/docs/configure/rules-policies>

Application Load Balancer: <https://cloud.google.com/load-balancing/docs/application-load-balancer>
Identity-Aware Proxy (IAP): <https://cloud.google.com/iap/docs/>
Cloud Firewall Overview: <https://cloud.google.com/firewall/docs/overview>

Question: 304

CertyIQ

You are managing a Google Cloud environment that is organized into folders that represent different teams. These teams need the flexibility to modify organization policies relevant to their work. You want to grant the teams the necessary permissions while upholding Google-recommended security practices and minimizing administrative complexity. What should you do?

- A. Create a custom IAM role with the organization policy administrator permission and grant the permission to each team's folder. Limit policy modifications based on folder names within the custom role's definition.
- B. Assign the organization policy administrator role to a central service account and provide teams with the credentials to use the service account when needed.
- C. Create an organization-level tag. Attach the tag to relevant folders. Use an IAM condition to restrict the organization policy administrator role to resources with that tag.
- D. Grant each team the organization policy administrator role at the organization level.

Answer: C

Explanation:

Here's a detailed justification for why option C is the correct approach:

Option C, utilizing organization-level tags combined with IAM conditions, aligns perfectly with the principle of least privilege and provides granular control over organization policy modifications. By creating an organization-level tag and applying it to team-specific folders, we establish a clear demarcation for policy management. Subsequently, we can use an IAM condition to restrict the Organization Policy Administrator role. The condition allows this powerful role to be effective only for folders bearing the designated tag, effectively delegating policy management to teams within their respective folders. This approach avoids granting overly broad organization-level permissions, a practice considered a high security risk. It also avoids creating and managing custom roles, reducing operational complexity (option A). Option B violates best practices by sharing a powerful service account across multiple teams, thus posing a security risk. Granting the Organization Policy Administrator at the organization level (option D) is a flagrant violation of least privilege, making it incredibly dangerous. IAM conditions provide a more refined alternative, restricting access based on attribute matching. This approach offers a balance between flexibility and security, aligning with Google's security best practices. **Authoritative Links:**

Google Cloud IAM Conditions: <https://cloud.google.com/iam/docs/conditions-overview>

Google Cloud Organization Policy: <https://cloud.google.com/resource-manager/docs/organization-policy/overview>

Google Cloud Resource Manager Tags: <https://cloud.google.com/resource-manager/docs/tags/tags-overview>

Google Cloud IAM Best Practices: <https://cloud.google.com/iam/docs/best-practices>

Question: 305

CertyIQ

Your organization is using Vertex AI Workbench Instances. You must ensure that newly deployed Instances are automatically kept up-to-date and that users cannot accidentally alter settings in the operating system. What should you do?

- A. Enforce the `disableRootAccess` and `requireAutoUpgradeSchedule` organization policies for newly deployed Instances.

- B.Enable the VM Manager and ensure the corresponding Google Compute Engine instances are added.
- C.Implement a firewall rule that prevents Secure Shell access to the corresponding Google Compute Engine instances by using tags.
- D.Assign the AI Notebooks Runner and AI Notebooks Viewer roles to the users of the AI Workbench Instances.

Answer: A

Explanation:

Option A, enforcing the `disableRootAccess` and `requireAutoUpgradeSchedule` organization policies, directly addresses the security and maintenance requirements. `disableRootAccess` prevents users from obtaining root privileges on the instances, limiting their ability to make unauthorized system changes. This aligns with the requirement to prevent accidental alteration of OS settings. `requireAutoUpgradeSchedule` ensures that the instances are automatically updated, fulfilling the need for up-to-date systems without manual intervention. Organization policies provide centralized, enforced controls over Google Cloud resources, ideal for ensuring consistent security posture. Option B, while enabling VM Manager is a good practice for patch management in general, it does not, by itself, prevent root access or enforce auto-upgrades for Vertex AI Workbench instances. Option C, implementing a firewall rule to block SSH, while enhancing security, would disrupt the normal operation of the Vertex AI Workbench, as SSH is commonly used for interactive use. Option D, assigning AI Notebooks roles, pertains to controlling access to the Vertex AI Workbench services, and not to the underlying instance's operating system security. Thus, Option A best meets both requirements of automatic updates and prevention of accidental setting changes.

Supporting Links:

Organization Policies: <https://cloud.google.com/resource-manager/docs/organization-policy/overview>

disableRootAccess Constraint: <https://cloud.google.com/resource-manager/docs/organization-policy/org-policy-constraints#compute-disableRootAccess>

requireAutoUpgradeSchedule Constraint: <https://cloud.google.com/resource-manager/docs/organization-policy/org-policy-constraints#compute-requireAutoUpgradeSchedule>

Vertex AI Workbench Organization Policy: <https://cloud.google.com/vertex-ai/docs/workbench/admin/set-org-policies>

Question: 306

CertyIQ

You must ensure that the keys used for at-rest encryption of your data are compliant with your organization's security controls. One security control mandates that keys get rotated every 90 days. You must implement an effective detection strategy to validate if keys are rotated as required. What should you do?

- A.Analyze the crypto key versions of the keys by using data from Cloud Asset Inventory. If an active key is older than 90 days, send an alert message through your incident notification channel.
- B.Assess the keys in the Cloud Key Management Service by implementing code in Cloud Run. If a key is not rotated after 90 days, raise a finding in Security Command Center.
- C.Define a metric that checks for timely key updates by using Cloud Logging. If a key is not rotated after 90 days, send an alert message through your incident notification channel.
- D.Identify keys that have not been rotated by using Security Health Analytics. If a key is not rotated after 90 days, a finding in Security Command Center is raised.

Answer: D

Explanation:

Here's a detailed justification for why option D is the correct approach, along with why the others are less suitable:

Why Option D is the Best Choice:

Option D leverages Security Health Analytics, a powerful tool within Security Command Center, designed for proactive vulnerability and misconfiguration detection. Security Health Analytics has built-in detectors specifically for identifying KMS key rotation issues. It continuously scans your cloud environment, comparing the current key rotation state against the defined policy. When a key hasn't been rotated within the expected 90-day timeframe, it automatically generates a finding within Security Command Center. This provides centralized visibility of non-compliant keys, enabling immediate action. This method is efficient because it's automated and doesn't require custom code development or the manual analysis of logs or asset inventories. This approach aligns perfectly with the objective of detecting key rotation non-compliance and provides an effective mechanism for remediation.

Why Other Options Are Less Suitable:

Option A (Cloud Asset Inventory): Cloud Asset Inventory is primarily for inventory management and asset metadata. While it can provide information about keys and their versions, it doesn't inherently have the logic for calculating the age of an active key and triggering alerts automatically. Creating this logic and alert system would require extra effort and code.

Option B (Cloud Run): Using Cloud Run for this task is overly complex. While you could write code to assess key rotation, it introduces operational overhead like managing the Cloud Run service. Furthermore, it lacks the integration with the centralized security reporting offered by Security Command Center.

Option C (Cloud Logging): Cloud Logging can capture key rotation events. However, using it directly for detecting non-rotation requires complex log analysis and the creation of custom metrics and alerts. It's not as efficient or seamless as the purpose-built Security Health Analytics detectors.

Key Concepts:

Security Command Center: A centralized security management service in Google Cloud Platform, providing threat detection, vulnerability scanning, and compliance monitoring.

Security Health Analytics: A component of Security Command Center that analyzes cloud configurations and resources for security misconfigurations and vulnerabilities.

Cloud Key Management Service (KMS): Google Cloud's service for managing cryptographic keys, including rotation.

Authoritative Links:

Security Health Analytics: <https://cloud.google.com/security-command-center/docs/concepts-security-health-analytics>

Security Command Center: <https://cloud.google.com/security-command-center/docs>

Cloud Key Management Service: <https://cloud.google.com/kms/docs>

In summary, leveraging Security Health Analytics is the most efficient and effective way to detect KMS key rotation non-compliance, as it's purpose-built for this type of security monitoring and seamlessly integrates with Security Command Center for centralized findings.

Question: 307

CertyIQ

Your organization is developing a sophisticated machine learning (ML) model to predict customer behavior for targeted marketing campaigns. The BigQuery dataset used for training includes sensitive personal information. You must design the security controls around the AI/ML pipeline. Data privacy must be maintained throughout the model's lifecycle and you must ensure that personal data is not used in the training process. Additionally, you must restrict access to the dataset to an authorized subset of people only. What should you do?

A. De-identify sensitive data before model training by using Cloud Data Loss Prevention (DLP) APIs. and implement strict Identity and Access Management (IAM) policies to control access to BigQuery.

B.Implement Identity-Aware Proxy to enforce context-aware access to BigQuery and models based on user identity and device.

C.Implement at-rest encryption by using customer-managed encryption keys (CMEK) for the pipeline. Implement strict Identity and Access Management (IAM) policies to control access to BigQuery.

D.Deploy the model on Confidential VMs for enhanced protection of data and code while in use. Implement strict Identity and Access Management (IAM) policies to control access to BigQuery.

Answer: A

Explanation:

Option A is the most appropriate solution because it directly addresses the core requirements: data privacy and access control. De-identifying sensitive data before model training using Cloud DLP APIs ensures that personal information is not directly used in the learning process, thus mitigating privacy risks. DLP offers techniques like masking, tokenization, and pseudonymization to transform data while preserving its utility for analysis. Concurrently, implementing strict IAM policies restricts access to the sensitive BigQuery dataset, ensuring that only authorized personnel can view or manipulate it. This dual approach tackles both data protection during processing and access management, providing a comprehensive security solution.

Option B, implementing Identity-Aware Proxy, is more focused on application-level access and doesn't address the fundamental requirement of de-identifying data. Option C, using CMEK, protects data at rest but does not prevent the model from learning sensitive information, nor does it de-identify the data before training. Similarly, Option D, deploying the model on Confidential VMs, offers in-use protection but lacks the crucial initial step of data sanitization.

Therefore, only Option A's approach of de-identifying data via Cloud DLP and using IAM for controlled access provides a comprehensive approach to securing the AI/ML pipeline and meeting the stated requirements effectively.

Relevant Links:

Cloud Data Loss Prevention (DLP): <https://cloud.google.com/dlp/docs>

Identity and Access Management (IAM): <https://cloud.google.com/iam/docs>

BigQuery Security Overview: <https://cloud.google.com/bigquery/docs/security-overview>

Question: 308

CertyIQ

Your organization wants to publish yearly reports of your website usage analytics. You must ensure that no data with personally identifiable information (PII) is published by using the Cloud Data Loss Prevention (Cloud DLP) API. Data integrity must be preserved. What should you do?

A.Detect all PII in storage by using the Cloud DLP API. Create a cloud function to delete the PII.

B.Discover and quarantine your PII data in your storage by using the Cloud DLP API.

C.Discover and transform PII data in your reports by using the Cloud DLP API.

D.Encrypt the PII from the report by using the Cloud DLP API.

Answer: C

Explanation:

The correct answer is **C. Discover and transform PII data in your reports by using the Cloud DLP API**. Here's why:

Option C directly addresses the requirement of preventing PII from being published while preserving data integrity. Cloud Data Loss Prevention (DLP) allows for the identification and transformation of sensitive data.

Transformation methods like masking, redaction, or tokenization allow you to de-identify PII without deleting it. This approach ensures the reports can still be used for analytics while protecting privacy.

Option A suggests deleting PII, which would not preserve data integrity. Deleting information removes crucial data points that contribute to analytics. Option B, which proposes quarantining PII, is also unsuitable for reporting. Quarantining data would make it inaccessible, hindering analytics. Option D, which suggests encrypting PII, does protect it, but it renders the report unusable for the intended analytics. The key here is that we want to maintain the data for analysis, just without identifying individuals. Option C uses the correct techniques to accomplish this.

Cloud DLP is designed to handle precisely this type of use case: identifying sensitive information, and then transforming it to maintain the utility of the data. This supports a balance between data security and business intelligence.

Authoritative Links:

Google Cloud DLP Documentation: <https://cloud.google.com/dlp/docs> - This link provides a comprehensive overview of the Cloud DLP service, including its functionalities and use cases.

Cloud DLP Transforms: <https://cloud.google.com/dlp/docs/transformations-concept> - This resource focuses specifically on the data transformation capabilities of Cloud DLP, crucial for understanding why Option C is correct.

Best Practices for Data Loss Prevention (DLP): <https://cloud.google.com/blog/products/gcp/best-practices-for-data-loss-prevention-dlp> - This blog post discusses broader best practices for using DLP solutions.

Question: 309

CertyIQ

Your development team is launching a new application. The new application has a microservices architecture on Compute Engine instances and serverless components, including Cloud Functions. This application will process financial transactions that require temporary, highly sensitive data in memory. You need to secure data in use during computations with a focus on minimizing the risk of unauthorized access to memory for this financial application. What should you do?

- A. Enable Confidential VM instances for Compute Engine, and ensure that relevant Cloud Functions can leverage hardware-based memory isolation.
- B. Use data masking and tokenization techniques on sensitive financial data fields throughout the application and the application's data processing workflows.
- C. Use the Cloud Data Loss Prevention (Cloud DLP) API to scan and mask sensitive data before feeding the data into any compute environment.
- D. Store all sensitive data during processing in Cloud Storage by using customer-managed encryption keys (CMEK), and set strict bucket-level permissions.

Answer: A

Explanation:

The correct answer is **A. Enable Confidential VM instances for Compute Engine, and ensure that relevant Cloud Functions can leverage hardware-based memory isolation.**

Here's why:

The primary requirement is to secure data **in use** during computations, specifically minimizing the risk of unauthorized memory access for sensitive financial data. Confidential VMs directly address this by utilizing hardware-based memory encryption, making data within the VM's memory inaccessible to unauthorized entities, including the hypervisor. This effectively mitigates risks like memory scraping or side-channel attacks. Similarly, while Cloud Functions don't directly offer Confidential Computing, leveraging hardware-based memory isolation (if available in the underlying infrastructure) ensures similar protection for the

serverless components handling sensitive data. Options B, C, and D, while important security practices, are not focused on securing data **in use within memory** which is the core ask here. Data masking/tokenization (B) primarily addresses data at rest or in transit, not while being actively processed in memory. Cloud DLP (C) helps find and protect sensitive data but doesn't provide real-time in-memory protection. Storing data with CMEK and strict permissions in Cloud Storage (D) protects data at rest, not during the actual computation. Confidential Computing technologies, as used in option A, specifically defend against threats targeting active memory, offering a robust solution for in-use data security. It is a direct and effective approach for the given scenario.

Supporting links:

Confidential Computing on Google Cloud: <https://cloud.google.com/security/confidential-computing>

Confidential VMs: <https://cloud.google.com/compute/confidential-vm/>

Confidential Computing on Cloud Functions:

<https://cloud.google.com/blog/products/serverless/announcing-confidential-computing-support-for-cloud-functions>

Question: 310

CertyIQ

You work for a financial organization in a highly regulated industry that is subject to active regulatory compliance. To meet compliance requirements, you need to continuously maintain a specific set of configurations, data residency, organizational policies, and personnel data access controls. What should you do?

- A. Apply an organizational policy constraint at the organization level to limit the location of new resource creation.
- B. Create an Assured Workloads folder for your required compliance program to apply defined controls and requirements.
- C. Go to the Compliance page in Security Command Center. View the report for your status against the required compliance standard. Triage violations to maintain compliance on a regular basis.
- D. Create a posture.yaml file with the required security compliance posture. Apply the posture with the gcloud scc postures create POSTURE_NAME --posture-from-file=posture.yaml command in Security Command Center Premium.

Answer: B

Explanation:

The correct answer is **B. Create an Assured Workloads folder for your required compliance program to apply defined controls and requirements.**

Assured Workloads is designed specifically to address the needs of organizations in highly regulated industries that require strict compliance with specific standards like FedRAMP, PCI DSS, or HIPAA. It provides a managed environment where pre-defined compliance controls are enforced consistently. Creating an Assured Workloads folder ensures that all resources within that folder adhere to the chosen compliance framework. This approach facilitates continuous compliance by automating the implementation and enforcement of security controls and configurations, as required by the regulatory standards. This centralized management simplifies audits and demonstrations of compliance.

Option A, while relevant for data residency, does not address the broader set of configurations, policies, and personnel access controls that the scenario demands. Option C focuses on reactive monitoring through Security Command Center, not proactive enforcement and provisioning of a compliant environment. Option D, utilizing postures in Security Command Center, addresses security posture, but doesn't provide the automated, end-to-end compliance management that Assured Workloads offers for regulated industries.

Assured Workloads is purpose-built for this scenario, allowing for the specification of the compliance regime

and managing all the resources in a way that adheres to that regime from creation, eliminating the risks of misconfiguration or manual setup errors. It provides a holistic, structured approach.

Further Research:

Google Cloud Assured Workloads Documentation: <https://cloud.google.com/assured-workloads/docs>
Overview of Assured Workloads: <https://cloud.google.com/blog/products/identity-security/assured-workloads-helps-organizations-in-highly-regulated-industries>

Question: 311

CertyIQ

Your organization is worried about recent news headlines regarding application vulnerabilities in production applications that have led to security breaches. You want to automatically scan your deployment pipeline for vulnerabilities and ensure only scanned and verified containers can run in the environment. What should you do?

- A. Use Kubernetes role-based access control (RBAC) as the source of truth for cluster access by granting “container.clusters.get” to limited users. Restrict deployment access by allowing these users to generate a kubeconfig file containing the configuration access to the GKE cluster.
- B. Use gcloud artifacts docker images describe LOCATION-docker.pkg.dev/PROJECT_ID/REPOSITORY/IMAGE_ID@sha256:HASH --show-package-vulnerability in your CI/CD pipeline, and trigger a pipeline failure for critical vulnerabilities.
- C. Enforce the use of Cloud Code for development so users receive real-time security feedback on vulnerable libraries and dependencies before they check in their code.
- D. Enable Binary Authorization and create attestations of scans.

Answer: D

Explanation:

The most effective solution is **D. Enable Binary Authorization and create attestations of scans**. Binary Authorization is a Google Cloud service that ensures only trusted container images are deployed. It works by requiring attestations, which are digital signatures, to be associated with container images before they can be run in a Kubernetes cluster (specifically, GKE).

By enabling Binary Authorization, you create a policy that mandates the presence of valid attestations. These attestations verify that the image has passed the necessary security checks, such as vulnerability scans. This ensures that only images that have been scanned and deemed safe can be deployed. When a deployment is attempted, Binary Authorization will check for the required attestation. If no valid attestation exists, deployment will be blocked, preventing the introduction of vulnerable containers into the environment.

Option A, focusing solely on RBAC, controls access to the cluster but doesn't address the core issue of verifying container image security. Option B, while useful for identifying vulnerabilities, doesn't inherently prevent vulnerable containers from being deployed; it just flags them. Option C, while beneficial for development, doesn't provide a direct enforcement mechanism in the production deployment pipeline.

Binary Authorization's strength lies in its enforcement capability at the point of deployment, integrating directly with the GKE cluster's runtime. This creates a security gate, preventing the deployment of unverified container images and providing a robust solution to the stated problem.

Authoritative Links:

Binary Authorization Documentation: <https://cloud.google.com/binary-authorization/docs>
Attestation Concepts: <https://cloud.google.com/binary-authorization/docs/attestation-concepts>

Question: 312

A team at your organization collects logs in an on-premises security information and event management system (SIEM). You must provide a subset of Google Cloud logs for the SIEM, and minimize the risk of data exposure in your cloud environment. What should you do?

- A. Create a new BigQuery dataset. Stream all logs to this dataset. Provide the on-premises SIEM system access to the data in BigQuery by using workload identity federation and let the SIEM team filter for the relevant log data.
- B. Define a log view for the relevant logs. Provide access to the log view to a principal from your on-premises identity provider by using workforce identity federation.
- C. Create a log sink for the relevant logs. Send the logs to Pub/Sub. Retrieve the logs from Pub/Sub and push the logs to the SIEM by using Dataflow.
- D. Filter for the relevant logs. Store the logs in a Cloud Storage bucket. Grant the service account access to the bucket. Provide the service account key to the SIEM team.

Answer: B**Explanation:**

Option B is the most secure and efficient solution for providing a subset of Google Cloud logs to an on-premises SIEM while minimizing data exposure. Log views allow for granular control over which logs are accessible. By creating a log view that filters for only the relevant logs, you avoid exposing the entire log repository to the SIEM. Workforce Identity Federation further enhances security by enabling authentication from your on-premises identity provider without the need for service account keys, reducing the risk of credential compromise. Option A exposes all logs to the SIEM via BigQuery, which doesn't meet the requirement of providing only a subset, and could expose sensitive data unnecessarily. Option C, while filtering logs, uses Pub/Sub, which adds complexity and costs for retrieving and pushing logs and doesn't directly address secure access control. Option D, using Cloud Storage and service account keys, increases the risk of key exposure, which is directly against the goal of minimized risk. Log views are specifically designed for this use case, offering a native solution for controlled access to specific log data. By using workforce identity federation, you eliminate the need for static credentials, thus improving the overall security posture. Choosing option B ensures compliance with security best practices, minimizing potential data exposure and managing access effectively through established identities. This option directly leverages cloud-native security features and promotes least privilege access.

Relevant Documentation:

Log views: <https://cloud.google.com/logging/docs/view/overview>

Workforce Identity Federation: <https://cloud.google.com/iam/docs/workforce-identity-federation>

Question: 313

Your Google Cloud organization is subdivided into three folders: production, development, and networking. Networking resources for the organization are centrally managed in the networking folder. You discovered that projects in the production folder are attaching to Shared VPCs that are outside of the networking folder which could become a data exfiltration risk. You must resolve the production folder issue without impacting the development folder. You need to use the most efficient and least disruptive approach. What should you do?

- A. Enable the Restrict Shared VPC Host Projects organization policy on the production folder. Create a custom rule and configure the policy type to Allow. In the Custom value section, enter `under:folders/networking`.
- B. Enable the Restrict Shared VPC Host Projects organization policy on the networking folder only. Create a new custom rule and configure the policy type to Allow. In the Custom value section, enter `under:organizations/123456739123`.
- C. Enable the Restrict Shared VPC Host Projects organization policy at the project level for each of the production projects. Create a custom rule and configure the policy type to Allow. In the Custom value section,

enter under:folders/networking.

D.Enable the Restrict Shared VPC Host Projects organization policy at the organization level. Create a custom rule and configure the policy type to Allow. In the Custom value section, enter under:folders/networking.

Answer: A

Explanation:

The correct answer is **A**. Here's a detailed justification:

The core issue is that production projects are inappropriately connecting to Shared VPCs outside the designated 'networking' folder, posing a security risk. We need to restrict this behavior in the production folder while leaving the development folder untouched, and do so efficiently and with minimal disruption.

Option A addresses this directly by enabling the "Restrict Shared VPC Host Projects" organization policy specifically on the **production folder**. This policy prevents resources within that folder from using Shared VPC networks located outside the allowed list. By configuring a custom rule with the "Allow" policy type and specifying folders/networking in the custom value, we effectively whitelist only Shared VPCs residing within the 'networking' folder, achieving the desired restriction for production projects. Crucially, this action doesn't affect the development folder as the policy is scoped to the production folder.

Option B is incorrect because applying the policy at the 'networking' folder would not prevent production projects from attaching to Shared VPCs outside of that folder, as that folder is not responsible for hosting the project resources in scope for the problem. The organization ID is also not the appropriate reference point.

Option C, enabling the policy at the project level, would be incredibly inefficient and challenging to maintain for a large number of production projects, making it less scalable and prone to human error. It is also disruptive in that the policy change could temporarily block resources.

Option D, applying the policy at the organization level, is too broad, it would impact all folders, including development, which contradicts the requirement to avoid impacting the development folder. The policy also uses a folder as an allow target when it should be an organization.

The principle of least privilege and scope dictates that the policy should be applied at the most specific level necessary to address the problem, which in this case is the 'production' folder. Option A provides the most efficient, targeted, and least disruptive solution.

Authoritative Links:

Organization policies: <https://cloud.google.com/resource-manager/docs/organization-policy/overview>

Restrict Shared VPC Host Projects: <https://cloud.google.com/resource-manager/docs/organization-policy/defining-constraints#constraints>

Shared VPC: <https://cloud.google.com/vpc/docs/shared-vpc>

Question: 314

CertyIQ

Your organization operates in a highly regulated environment and has a stringent set of compliance requirements for protecting customer data. You must encrypt data while in use to meet regulations. What should you do?

A.Enable the use of customer-supplied encryption keys (CSEK) keys in the Google Compute Engine VMs to give your organization maximum control over their VM disk encryption.

B.Establish a trusted execution environment with a Confidential VM.

C.Use a Shielded VM to ensure a secure boot with integrity monitoring for the application environment.

D.Use customer-managed encryption keys (CMEK) and Cloud KSM to enable your organization to control their keys for data encryption in Cloud SQL.

Answer: B

Explanation:

The correct answer is **B. Establish a trusted execution environment with a Confidential VM**. Here's why:

The core requirement is to encrypt data while in use. This is known as in-memory encryption, which traditional encryption methods, such as encryption at rest (CMEK, CSEK) and encryption in transit, do not address. Confidential VMs are designed specifically for this purpose. They leverage hardware-based Trusted Execution Environments (TEEs) like AMD SEV or Intel SGX, creating an isolated and protected space within the VM's memory. Data processed within the TEE is encrypted while being used, protecting it from other processes and the hypervisor.

Option A, using CSEK keys, only controls encryption at rest, meaning the data on disk. It doesn't protect the data while it's being actively processed in memory. Option C, Shielded VMs, focuses on boot integrity and protection against rootkits; they do not encrypt data in use. Option D, using CMEK with Cloud KMS for Cloud SQL, also only handles encryption at rest for database storage, not in-memory processing.

Confidential VMs provide a unique level of protection for sensitive data when it's being used by applications in a cloud environment. This is particularly critical for highly regulated industries with stringent compliance mandates relating to data-in-use protection. By encrypting the memory space, Confidential VMs significantly reduce the attack surface for sophisticated attackers who might try to access decrypted data in the memory of a virtual machine.

Authoritative Links:

Google Cloud Confidential Computing: <https://cloud.google.com/confidential-computing>

Confidential VM documentation: <https://cloud.google.com/compute/confidential-vm/docs>

Trusted Execution Environment: https://en.wikipedia.org/wiki/Trusted_execution_environment

Question: 315

CertyIQ

Your organization is building a real-time recommendation engine using ML models that process live user activity data stored in BigQuery and Cloud Storage. Each new model developed is saved to Artifact Registry. This new system deploys models to Google Kubernetes Engine, and uses Pub/Sub for message queues. Recent industry news have been reporting attacks exploiting ML model supply chains. You need to enhance the security in this serverless architecture, specifically against risks to the development and deployment pipeline. What should you do?

A.Enable container image vulnerability scanning during development and pre-deployment. Enforce Binary Authorization on images deployed from Artifact Registry to your continuous integration and continuous deployment (CVCD) pipeline.

B.Thoroughly sanitize all training data prior to model development to reduce risk of poisoning attacks. Use IAM for authorization, and apply role-based restrictions to code repositories and cloud services.

C.Limit external libraries and dependencies that are used for the ML models as much as possible. Continuously rotate encryption keys that are used to access the user data from BigQuery and Cloud Storage.

D.Develop strict firewall rules to limit external traffic to Cloud Run instances. Integrate intrusion detection systems (IDS) for real-time anomaly detection on Pub/Sub message flows.

Answer: A

Explanation:

The most effective approach to secure the ML model development and deployment pipeline against supply chain attacks, as described in the scenario, is option A. Enabling container image vulnerability scanning during development and pre-deployment is crucial for identifying and mitigating security weaknesses in the container images before they are deployed. This proactive measure helps prevent the introduction of

compromised software components. Enforcing Binary Authorization further enhances security by ensuring that only trusted, authorized container images from Artifact Registry are deployed through the CI/CD pipeline. This step verifies image integrity and prevents the deployment of tampered or unauthorized code, directly addressing supply chain risks. Options B, C, and D, while relevant to security, do not address the specific vulnerability of model supply chain attacks as directly as option A. Sanitizing training data (B) is important, but does not mitigate compromised images. Limiting external libraries (C) helps but lacks a comprehensive check for existing image vulnerabilities, while key rotation is a good security practice, it is tangential to supply chain security concerns. Firewall rules and IDS on the runtime environment (D) are essential defenses, but they do not prevent a malicious image from being deployed to begin with. The core of option A's strength is that it deals with the problem at the supply chain level, where an attack is likely to originate.

Supporting Concepts:

Container Image Vulnerability Scanning: This process scans container images for known security vulnerabilities, providing developers with information to fix issues before deployment.

Binary Authorization: A deployment-time security control that ensures only trusted container images are deployed to a GKE cluster by checking against predefined security policies.

Supply Chain Attacks: Attacks that target the development and distribution pipeline of software to inject malicious code and compromise systems.

Authoritative Links:

Google Cloud Documentation on Container Analysis: <https://cloud.google.com/container-analysis/docs>

Google Cloud Documentation on Binary Authorization: <https://cloud.google.com/binary-authorization/docs>

NIST Special Publication 800-161 Supply Chain Risk Management Practices for Federal Information Systems and Organizations: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-161.pdf>

Question: 316

CertyIQ

You want to set up a secure, internal network within Google Cloud for database servers. The servers must not have any direct communication with the public internet. What should you do?

- A. Assign a private IP address to each database server. Use a NAT gateway to provide internet connectivity to the database servers.
- B. Assign a static public IP address to each database server. Use firewall rules to restrict external access.
- C. Create a VPC with a private subnet. Assign a private IP address to each database server.
- D. Assign both a private IP address and a public IP address to each database server.

Answer: C

Explanation:

Option C, creating a VPC with a private subnet and assigning private IP addresses, is the correct solution for securing database servers within Google Cloud, preventing direct public internet access. A Virtual Private Cloud (VPC) acts as a logically isolated network within Google Cloud, offering control over network configuration. Private subnets within a VPC are specifically designed to house resources that should not be directly accessible from the internet. Assigning private IP addresses to the database servers ensures they are reachable only within the VPC, enhancing security. This approach adheres to the principle of least privilege and minimizes the attack surface by eliminating public exposure. Using private IP addresses negates the need for network address translation (NAT) for inbound internet traffic, further reducing complexity and potential vulnerabilities. By preventing direct internet connectivity, you protect the database servers from malicious activities originating from the public network, promoting a more robust and secure architecture.

Option A is incorrect as using a NAT gateway allows outbound internet connectivity, but doesn't prevent

inbound public access to the network. Option B is also incorrect as assigning public IP addresses, even with firewall rules, creates an unnecessary exposure and reliance on firewall configuration which is error prone. Option D is also incorrect for the same reason as B, that direct public IP assignments are an unnecessary exposure.

For further understanding:

Google Cloud VPC: <https://cloud.google.com/vpc/docs/overview>

Private IP Addresses: <https://cloud.google.com/vpc/docs/vpc>

Subnets: <https://cloud.google.com/vpc/docs/subnets>

Question: 317

CertyIQ

You work for a large organization that recently implemented a 100GB Cloud Interconnect connection between your Google Cloud and your on-premises edge router. While routinely checking the connectivity, you noticed that the connection is operational but there is an error message that indicates MACsec is operationally down. You need to resolve this error. What should you do?

- A. Ensure that the Cloud Interconnect connection supports MACsec.
- B. Ensure that the on-premises router is not down.
- C. Ensure that the active pre-shared key created for MACsec is not expired on both the on-premises and Google edge routers.
- D. Ensure that the active pre-shared key matches on both the on-premises and Google edge routers.

Answer: D

Explanation:

The correct answer is **D. Ensure that the active pre-shared key matches on both the on-premises and Google edge routers.**

Here's why: MACsec (Media Access Control Security) is a security protocol that provides point-to-point security for Ethernet links. It uses a pre-shared key (PSK) to establish secure communication between two devices. In the context of Cloud Interconnect, MACsec secures the physical connection between your on-premises edge router and Google's edge router. When MACsec is "operationally down," it means the security protocol is not functioning correctly, and a common cause is a mismatch in the pre-shared keys.

Option A is incorrect because the problem statement indicates the connection is operational, suggesting the link itself supports MACsec. Option B, while important generally, isn't the specific root cause for MACsec being down, as the connection is stated to be operational. Option C, while a good practice, isn't the primary reason for MACsec's operational down state; MACsec key rotations are generally handled through configuration and don't usually cause complete operational failure if the rotation itself is configured poorly. The issue stated implies the security protocol has failed initialization, not an expired key in rotation, hence the primary concern is the shared secret initialization failed. Option D addresses the most frequent cause of the "operationally down" status with MACsec on a Cloud Interconnect link. If the PSKs on both sides don't match exactly, MACsec won't initialize, leading to the reported error. Therefore, ensuring the keys are identical is the immediate troubleshooting step.

Authoritative Links:

Google Cloud Interconnect MACsec: <https://cloud.google.com/network-connectivity/docs/interconnect/how-to/configure-macsec> - This document explains MACsec on Google Cloud Interconnect, highlighting the requirement for matching PSKs.

IEEE 802.1AE (MACsec Standard): <https://standards.ieee.org/ieee/802/1AE/> - The official standard document for MACsec, offering deep technical details.

Question: 318

CertyIQ

Your organization must store highly sensitive data within Google Cloud. You need to design a solution that provides the strongest level of security and control. What should you do?

- A. Use Cloud Storage with customer-supplied encryption keys (CSEK), VPC Service Controls for network isolation, and Cloud DLP for data inspection.
- B. Use Cloud Storage with customer-managed encryption keys (CMEK), Cloud DLP for data classification, and Secret Manager for storing API access tokens.
- C. Use Cloud Storage with client-side encryption, Cloud KMS for key management, and Cloud HSM for cryptographic operations.
- D. Use Cloud Storage with server-side encryption, BigQuery with column-level encryption, and IAM roles for access control.

Answer: C

Explanation:

Option C is the most secure approach for storing highly sensitive data in Google Cloud. Client-side encryption, where data is encrypted before being sent to Cloud Storage, provides the strongest control over encryption keys, as they never leave the user's environment. This mitigates the risk of Google or other third parties accessing the unencrypted data. Cloud KMS for key management provides a secure, centralized way to manage cryptographic keys, including their generation, rotation, and access control. This ensures that keys are protected from unauthorized access and tampering. Using Cloud HSM for cryptographic operations adds an additional layer of security, as it performs cryptographic functions within a hardened, tamper-resistant hardware module. This protects keys from being compromised through software-based attacks.

Options A, B, and D offer less comprehensive security. While CSEK (Option A) provides some control over encryption keys, they are still managed within Google's infrastructure. CMEK (Option B) also relies on Google for key management infrastructure. Furthermore, neither CSEK nor CMEK, by themselves, prevent unauthorized access prior to being encrypted. Server-side encryption (Option D) uses Google-managed keys for encryption, providing the least control and security over encryption keys. While VPC Service Controls, Cloud DLP, and IAM are important security components, they do not address the specific need for strong end-to-end data encryption and control over the cryptographic process, which is best achieved through client-side encryption.

Authoritative Links:

Client-side encryption: <https://cloud.google.com/storage/docs/encryption/customer-supplied>

Cloud KMS: <https://cloud.google.com/kms/docs>

Cloud HSM: <https://cloud.google.com/hsm/docs>

Question: 319

CertyIQ

The InfoSec team has mandated that all new Cloud Run jobs and services in production must have Binary Authorization enabled. You need to enforce this requirement. What should you do?

- A. Configure an organization policy to require Binary Authorization enforcement on images deployed to Cloud Run.
- B. Configure a Security Health Analytics (SHA) custom rule that prevents the execution of Cloud Run jobs and services without Binary Authorization.
- C. Ensure the Cloud Run admin role is not assigned to developers.
- D. Configure a Binary Authorization custom policy that is not editable by developers and auto-attaches to all

Answer: A

Explanation:

Option A is the correct approach to enforce Binary Authorization for Cloud Run deployments. Google Cloud Organization Policies provide centralized control over your organization's resources. By configuring a policy that mandates Binary Authorization enforcement, you ensure that all Cloud Run services and jobs within the specified scope (e.g., projects, folders, or the entire organization) adhere to this security requirement. This policy acts as a gate, preventing deployments of container images that are not compliant with your Binary Authorization rules.

Option B, utilizing Security Health Analytics (SHA) custom rules, is primarily for detecting violations, not preventing them. SHA can alert you to non-compliant deployments, but it does not actively block the creation of Cloud Run jobs/services lacking Binary Authorization. Therefore, it's a reactive measure, not a proactive enforcement mechanism.

Option C, restricting Cloud Run admin roles for developers, while a good practice for least privilege, does not directly address the Binary Authorization mandate. Developers might still deploy non-compliant images if they have sufficient deployment permissions, even without full admin privileges. This measure focuses on access control, not on code integrity verification.

Option D, configuring a Binary Authorization custom policy, is a necessary part of the solution, but it does not automatically enforce that policy on all Cloud Run resources. You can create a policy, but you need an enforcement mechanism, which is where Organization Policy comes into play. Therefore, a custom policy by itself doesn't fulfill the requirement of enforcing the use of Binary Authorization for all Cloud Run workloads. The custom policy defines what is allowed, while the organization policy determines how it's applied.

In summary, organization policies offer the necessary control to universally enforce Binary Authorization for Cloud Run resources at the organization, folder, or project level. This provides proactive prevention, ensuring that only compliant images are deployed, rather than just detecting violations or limiting permissions.

Authoritative Links:

Google Cloud Organization Policy: <https://cloud.google.com/resource-manager/docs/organization-policy/overview>

Binary Authorization: <https://cloud.google.com/binary-authorization/docs>

Organization policy constraints: <https://cloud.google.com/resource-manager/docs/organization-policy/org-policy-constraints>

Question: 320

CertyIQ

You are developing an application that runs on a Compute Engine VM. The application needs to access data stored in Cloud Storage buckets in other Google Cloud projects. The required access to the buckets is variable. You need to provide access to these resources while following Google- recommended practices. What should you do?

- A. Limit the VMs access to the Cloud Storage buckets by setting the relevant access scope of the VM.
- B. Create IAM bindings for the VM's service account and the required buckets that allow appropriate access to the data stored in the buckets.
- C. Grant the VM's service account access to the required buckets by using domain-wide delegation.
- D. Create a group and assign IAM bindings to the group for each bucket that the application needs to access. Assign the VM's service account to the group.

Answer: B

Explanation:

The correct approach is **B. Create IAM bindings for the VM's service account and the required buckets that allow appropriate access to the data stored in the buckets.**

Here's why: Google Cloud recommends using service accounts for applications running on Compute Engine VMs to access other Google Cloud services. Each VM instance has an associated service account identity. Instead of directly granting access to the VM itself, we grant permissions to this service account. This aligns with the principle of least privilege, ensuring the application only has the necessary access. Option B directly applies IAM roles to the service account, which is the most secure and granular way to manage access permissions for a specific application on a VM. Option A, using access scopes, is a legacy method and not the recommended approach for fine-grained access control to individual resources like Cloud Storage buckets. Access scopes provide broader access based on service type, not specific resources. Option C, domain-wide delegation, is intended for API access on behalf of users within a domain, not for machine-to-machine communication which a VM represents. Option D, while leveraging groups, introduces an unnecessary layer of indirection. It complicates management and adds complexity compared to simply directly binding IAM roles to the service account. Direct IAM bindings on the service account is the most straightforward way to grant precisely the permissions the application needs on a per-bucket basis, making option B the most suitable choice for adhering to security best practices in Google Cloud.

Authoritative Links:

Service accounts: <https://cloud.google.com/iam/docs/service-accounts>

IAM roles: <https://cloud.google.com/iam/docs/understanding-roles>

Principle of least privilege: <https://cloud.google.com/security/principles/least-privilege>

Access scopes vs IAM: <https://cloud.google.com/compute/docs/access/service-accounts#scopes>

Question: 321

CertyIQ

Your organization strives to be a market leader in software innovation. You provided a large number of Google Cloud environments so developers can test the integration of Gemini in Vertex AI into their existing applications or create new projects. Your organization has 200 developers and a five-person security team. You must prevent and detect proper security policies across the Google Cloud environments. What should you do? (Choose two.)

- A. Apply organization policy constraints. Detect and monitor drifts by using Security Health Analytics.
- B. Publish internal policies and clear guidelines to securely develop applications.
- C. Use Cloud Logging to create log filters to detect misconfigurations. Trigger Cloud Run functions to remediate misconfigurations.
- D. Apply a predefined AI-recommended security posture template for Gemini in Vertex AI in Security Command Center Enterprise or Premium tiers.
- E. Implement the least privileged access Identity and Access Management roles to prevent misconfigurations.

Answer: AD

Explanation:

The correct answer is **A and D**. Let's break down why:

A. Apply organization policy constraints. Detect and monitor drifts by using Security Health Analytics.

Organization policies in Google Cloud allow you to centrally control resources across your entire organization, ensuring compliance and security standards. Applying constraints limits what actions users can take, reducing the risk of misconfigurations by developers. Security Health Analytics is a powerful tool within Security Command Center that continuously scans your Google Cloud environment for vulnerabilities and misconfigurations, identifying deviations from your established policies. This proactive monitoring enables you to catch drift and remediate issues before they become major problems. This combination provides a

strong foundation for preventative and detective security. <https://cloud.google.com/resource-manager/docs/organization-policy/overview>, <https://cloud.google.com/security-command-center/docs/concepts-security-health-analytics>

D. Apply a predefined AI-recommended security posture template for Gemini in Vertex AI in Security Command Center Enterprise or Premium tiers. Utilizing AI-recommended security posture templates specifically designed for Gemini in Vertex AI provides a starting point aligned with best practices. Security Command Center Enterprise and Premium tiers offer advanced features for AI-driven threat detection and compliance. These templates simplify complex configurations and ensure consistent security for the newly implemented AI tools, reducing the burden on the small security team. This proactive approach leverages Google's expertise to quickly secure Gemini usage. <https://cloud.google.com/security-command-center/docs/concepts-security-posture-management>

Why other options are less suitable:

B. Publish internal policies and clear guidelines to securely develop applications. While important, publishing policies alone is insufficient for ensuring compliance and preventing misconfigurations. It's reactive and relies on developers remembering and adhering to the policies. It doesn't automatically prevent or detect security issues like options A and D do.

C. Use Cloud Logging to create log filters to detect misconfigurations. Trigger Cloud Run functions to remediate misconfigurations. This approach is reactive and is a good practice for incident response but does not proactively prevent misconfigurations. Log filters and Cloud Run functions are good for remediation after something happens, whereas this question asks for prevention and detection.

E. Implement the least privileged access Identity and Access Management roles to prevent misconfigurations. While important, IAM is a foundational security practice, and this option does not focus on the new integration of Vertex AI. Option A already implies that least privileged access will be implemented through organization policies. This option alone is not enough.

Question: 322

CertyIQ

An organization is migrating from their current on-premises productivity software systems to G Suite. Some network security controls were in place that were mandated by a regulatory body in their region for their previous on-premises system. The organization's risk team wants to ensure that network security controls are maintained and effective in G Suite. A security architect supporting this migration has been asked to ensure that network security controls are in place as part of the new shared responsibility model between the organization and Google Cloud.

What solution would help meet the requirements?

- A. Ensure that firewall rules are in place to meet the required controls.
- B. Set up Cloud Armor to ensure that network security controls can be managed for G Suite.
- C. Network security is a built-in solution and Google's Cloud responsibility for SaaS products like G Suite.
- D. Set up an array of Virtual Private Cloud (VPC) networks to control network security as mandated by the relevant regulation.

Answer: C

Explanation:

The correct answer is C. Network security for SaaS products like G Suite is primarily Google's responsibility under the shared responsibility model. G Suite, being a Software as a Service (SaaS) offering, handles the underlying infrastructure and network security. Organizations utilizing G Suite are responsible for securing their data within the application, managing user access, and configuring features like data loss prevention (DLP). Options A, B, and D relate to infrastructure-as-a-service (IaaS) or platform-as-a-service (PaaS) scenarios where the customer has more control over networking. Firewall rules (A) and Cloud Armor (B) are typically used with virtual machines or web applications hosted within VPCs, and setting up VPC networks (D)

is irrelevant to G Suite's fundamental infrastructure. The risk team's need to maintain regulatory network security is already inherently met by Google's robust, compliant network infrastructure. The organization's focus should be on G Suite's security configurations and user practices, not on low-level network infrastructure. Therefore, acknowledging network security is a built-in element managed by Google is accurate and fulfills the shared responsibility model for a SaaS product.

<https://cloud.google.com/security/compliance/shared-responsibility>, <https://cloud.google.com/security/>

Question: 323

CertyIQ

Your company is using Cloud Dataproc for its Spark and Hadoop jobs. You want to be able to create, rotate, and destroy symmetric encryption keys used for the persistent disks used by Cloud Dataproc. Keys can be stored in the cloud.

What should you do?

- A. Use the Cloud Key Management Service to manage the data encryption key (DEK).
- B. Use the Cloud Key Management Service to manage the key encryption key (KEK).
- C. Use customer-supplied encryption keys to manage the data encryption key (DEK).
- D. Use customer-supplied encryption keys to manage the key encryption key (KEK).

Answer: B

Explanation:

Here's a detailed justification for why option B, "Use the Cloud Key Management Service to manage the key encryption key (KEK)," is the correct approach for managing encryption keys in Cloud Dataproc persistent disks, along with supporting explanations and links:

The core requirement is to create, rotate, and destroy symmetric encryption keys used for Cloud Dataproc persistent disks. These disks use encryption at rest to protect data. Google Cloud Platform (GCP) uses a two-layer encryption mechanism: data encryption keys (DEKs) and key encryption keys (KEKs). DEKs encrypt the actual data on the disk. KEKs encrypt the DEKs. This is commonly known as envelope encryption.

Option A suggests using Cloud KMS to manage the DEK. While feasible in some cases, it is not the recommended practice. Cloud KMS is designed to manage KEKs. This allows for centralized management and rotation of keys, which is vital for security.

Option C and D suggest using customer-supplied encryption keys (CSEK). While CSEK is an option, it does not align with the requirement of storing keys in the cloud. CSEK require you to manage the key on your own, outside of GCP.

Therefore, the most appropriate solution for centrally managing disk encryption keys while adhering to the requirement of in-cloud storage is to use Cloud KMS to manage the KEKs. This approach allows you to create, rotate, and destroy KEKs while ensuring your data is protected. By using KMS, the rotation, access controls, and auditing of these keys are simplified, enhancing your security posture. The system is designed to handle DEK creation and management behind the scenes when using KEKs via KMS. Therefore, you do not need to manage DEKs directly.

Here are some authoritative links for further research:

Cloud KMS Overview: <https://cloud.google.com/kms/docs/>

Cloud KMS Concepts: <https://cloud.google.com/kms/docs/concepts>

Cloud Dataproc Disk Encryption: <https://cloud.google.com/dataproc/docs/concepts/configuring-clusters/disk-encryption>

Envelope Encryption: <https://cloud.google.com/kms/docs/envelope-encryption>

In summary, using Cloud KMS to manage the KEKs for Cloud Dataproc disk encryption is the best practice solution because it provides centralized, secure, and manageable encryption key lifecycle management, meeting the requirements outlined in the prompt.

Question: 324

CertyIQ

A company allows every employee to use Google Cloud Platform. Each department has a Google Group, with all department members as group members. If a department member creates a new project, all members of that department should automatically have read-only access to all new project resources. Members of any other department should not have access to the project. You need to configure this behavior. What should you do to meet these requirements?

- A. Create a Folder per department under the Organization. For each department's Folder, assign the Project Viewer role to the Google Group related to that department.
- B. Create a Folder per department under the Organization. For each department's Folder, assign the Project Browser role to the Google Group related to that department.
- C. Create a Project per department under the Organization. For each department's Project, assign the Project Viewer role to the Google Group related to that department.
- D. Create a Project per department under the Organization. For each department's Project, assign the Project Browser role to the Google Group related to that department.

Answer: A

Explanation:

The correct answer is A. Here's why:

The requirement is to automatically grant read-only access to department members on newly created projects within their department. This necessitates a hierarchical structure for access control. Google Cloud's resource hierarchy allows policies to be inherited from higher levels (like Organization and Folders) to lower levels (like Projects).

Option A proposes creating a Folder for each department under the Organization. This is the appropriate level for access control grouping in this scenario. Assigning the 'Project Viewer' role to the department's Google Group at the Folder level means that any project created within that folder will inherit this permission. All members of the Google Group will automatically have read-only access to all resources within the new project. This fulfills the 'read-only access' requirement.

Option B is similar, but uses the 'Project Browser' role. This role is less powerful than 'Project Viewer' and does not necessarily grant access to view all resources within a project, thus not fulfilling the read-only requirement on all resources.

Options C and D are incorrect because they assign access roles on a per-project basis. This would be counter-productive since a new project is created by a department member and the members of the department should be granted access. This does not satisfy the requirement for automatic read-only access when new projects are created.

By leveraging Google Cloud's resource hierarchy and IAM role inheritance, Option A offers the most efficient and scalable solution. It ensures that permissions are automatically applied to all new projects within a department, while also preventing access from other departments.

Further research:

Google Cloud Resource Hierarchy: <https://cloud.google.com/resource-manager/docs/cloud-platform-resource-hierarchy>

Google Cloud IAM Roles: <https://cloud.google.com/iam/docs/understanding-roles>

Question: 325

CertyIQ

A customer's internal security team must manage its own encryption keys for encrypting data on Cloud Storage and decides to use customer-supplied encryption keys (CSEK).

How should the team complete this task?

- A. Upload the encryption key to a Cloud Storage bucket, and then upload the object to the same bucket.
- B. Use the gsutil command line tool to upload the object to Cloud Storage, and specify the location of the encryption key.
- C. Generate an encryption key in the Google Cloud Platform Console, and upload an object to Cloud Storage using the specified key.
- D. Encrypt the object, then use the gsutil command line tool or the Google Cloud Platform Console to upload the object to Cloud Storage.

Answer: B

Explanation:

The correct answer is **B**. Customer-Supplied Encryption Keys (CSEK) require the customer to manage the encryption keys, not Google. Option A is incorrect because storing the encryption key within Cloud Storage itself defeats the purpose of CSEK, which is to keep control of the key outside of Google's infrastructure. Option C is incorrect because CSEK keys are generated and managed by the customer, not within Google Cloud Platform. Option D is incorrect as CSEK requires the encryption process to happen on the server-side by Cloud Storage, where the service uses the provided key, rather than the client-side pre-encryption which is implied by the option.

Option B accurately reflects the correct method. The gsutil command-line tool allows users to specify the encryption key when uploading objects to Cloud Storage. This mechanism enables the customer to provide a unique key during the upload process, which Cloud Storage will then use for server-side encryption. The customer retains complete control over the key and its management, ensuring their data security is in their hands.

This process aligns with the principles of data security and control in cloud computing. CSEK provides an additional layer of protection, allowing the customer to meet their compliance or security needs. When using CSEK, it's crucial to remember that Google has no access to the encryption keys and is therefore not responsible for key management or data accessibility if the key is lost.

For further research, refer to the official Google Cloud documentation on Customer-Supplied Encryption Keys (CSEK):

[Using customer-supplied encryption keys](#)
[gsutil cp command documentation](#)

Question: 326

CertyIQ

While migrating your organization's infrastructure to GCP, a large number of users will need to access GCP Console. The Identity Management team already has a well-established way to manage your users and want to keep using your existing Active Directory or LDAP server along with the existing SSO password.

What should you do?

- A. Manually synchronize the data in Google domain with your existing Active Directory or LDAP server.
- B. Use Google Cloud Directory Sync to synchronize the data in Google domain with your existing Active

Directory or LDAP server.

C. Users sign in directly to the GCP Console using the credentials from your on-premises Kerberos compliant identity provider.

D. Users sign in using OpenID (OIDC) compatible IdP, receive an authentication token, then use that token to log in to the GCP Console.

Answer: B

Explanation:

The correct answer is **B. Use Google Cloud Directory Sync to synchronize the data in Google domain with your existing Active Directory or LDAP server.**

Here's why:

Google Cloud Directory Sync (GCDS) is a tool specifically designed to synchronize user and group data between on-premises directories (like Active Directory or LDAP) and Google Workspace/Cloud Identity. This allows organizations to leverage their existing identity management systems without requiring manual replication of users to the Google environment. Option B directly addresses the requirement of maintaining existing user management methods. GCDS ensures that changes in the on-premises directory are automatically reflected in Google, simplifying user management and maintaining consistency.

Option A (manual synchronization) is not scalable and prone to errors, making it unsuitable for large organizations. Option C (direct Kerberos sign-in) is not supported by Google Cloud Console for authentication. While Option D (OpenID with IdP) is a valid method for federated authentication, it doesn't handle the synchronization of users from the existing directory to Google. It only allows users authenticated by an external IdP to log in. GCDS is the most efficient and best practice method for synchronizing users and groups.

Key Concepts:

Directory Synchronization: Maintaining consistent user and group information across different directory services.

Google Cloud Directory Sync (GCDS): A Google-provided tool for automating directory synchronization with on-premises systems.

Federated Identity: Allowing users to authenticate through external identity providers (IdPs).

Single Sign-On (SSO): Enables users to access multiple applications with one set of credentials.

Authoritative Links:

Google Cloud Directory Sync: <https://support.google.com/a/answer/1069308?hl=en>

Best practices for synchronizing users with Cloud Identity:

<https://cloud.google.com/architecture/identity/best-practices-for-synchronizing-users-with-cloud-identity>

Cloud Identity: <https://cloud.google.com/identity>

Thank you

Thank you for being so interested in the premium exam material.
I'm glad to hear that you found it informative and helpful.

If you have any feedback or thoughts on the bumps, I would love to hear them.
Your insights can help me improve our writing and better understand our readers.

Best of Luck

You have worked hard to get to this point, and you are well-prepared for the exam
Keep your head up, stay positive, and go show that exam what you're made of!

Feedback

More Papers



Future is Secured
100% Pass Guarantee



24/7 Customer Support
Mail us - certyiqofficial@gmail.com



Free Updates
Lifetime Free Updates!

Total: **326 Questions**

Link: <https://certyiq.com/papers/google/professional-cloud-security-engineer>